

정책연구 2022-12

데이터 기반 보안 정책의 설계와 이행전략 연구

- 망분리 규제를 중심으로 -

A Study on the Design and Implementation Strategy of
Data-Driven Security Policies: Focusing on
Network Separation Regulation

최병삼 · 양현채 · 진설아 · 김가은 · 송명진

내 부 저 자

연구책임자
연구참여자

최병삼 | 과학기술정책연구원 연구위원
양현재 | 과학기술정책연구원 연구위원
진설아 | 과학기술정책연구원 선임연구원
김가은 | 과학기술정책연구원 선임연구원

외 부 저 자

송명진 | (전)과학기술정책연구원 부연구위원
(현)스타트업얼라이언스 리서치팀 리더

정책연구 2022-12

데이터 기반 보안 정책의 설계와 이행전략 연구: 망분리 규제를 중심으로

2022년 12월 24일 인쇄
2022년 12월 30일 발행

發行人 | 문미옥

發行處 | 과학기술정책연구원

세종특별자치시 시청대로 370

세종국책연구단지 과학·인프라동 5-7F

Tel: 044)287-2000 Fax: 044)287-2068

登 録 | 2003년 9월 8일 제2015-000014호

組版 및 印刷 | 미래미디어

Tel: 02)815-0407 Fax: 02)822-1269

ISBN 978-89-6112-849-0 93300

| 목 차 |

국문 요약	i
-------------	---

영문 요약	I
-------------	---

제1장 서론: 초연결, 디지털 전환, 그리고 망분리 규제	1
---------------------------------------	---

제1절 연구의 배경 및 필요성	1
------------------------	---

제2절 연구의 목적 및 주요 내용	5
--------------------------	---

제3절 연구의 방법 및 추진 체계	12
--------------------------	----

제2장 보안의 개요 및 최근 기술 동향	14
-----------------------------	----

제1절 보안의 개요	14
------------------	----

1. 보안 위협	14
----------------	----

2. 주요 보안 기술	18
-------------------	----

3. 최근 보안 패러다임	24
---------------------	----

제2절 최근 보안 기술 동향: 제로 트러스트 모델을 중심으로	25
---	----

1. 경계 보안 모델	25
-------------------	----

2. 제로 트러스트 모델	26
---------------------	----

제3장 국내 보안 정책의 현황과 문제점: 망분리 규제를 중심으로 ·	32
---------------------------------------	----

제1절 국내 보안 정책 현황	32
-----------------------	----

1. 국내 보안 환경의 특수성	32
------------------------	----

2. 국내 보안 정책의 최근 동향	38
--------------------------	----

제2절 망분리 규제의 개요 및 문제점	40
----------------------------	----

1. 망분리 규제의 개념	40
---------------------	----

2. 국내 망분리 규제의 경과	42
------------------------	----

3. 망분리 규제의 장점과 단점	44
제3절 보안 패러다임 전환의 필요성	53
1. 초연결 및 디지털 전환 시대의 도래	53
2. 해외 보안 정책 동향	56
3. 보안 패러다임 전환의 필요성	60

제4장 주요 산업별 보안 위협, 대응수단 및 정책 분석 62

제1절 금융	64
1. 금융 분야의 보안 위협	64
2. 금융 분야의 보안 수단 및 효과성 비교	68
3. 금융 분야의 국내외 망분리 규제 현황	71
4. 금융 분야의 보안 정책 제언	74
제2절 헬스케어	81
1. 헬스케어 분야의 보안 위협	81
2. 헬스케어 분야의 보안 수단 및 효과성 비교	83
3. 헬스케어 분야의 국내외 망분리 규제 현황	88
4. 헬스케어 분야의 보안 정책 제언	91
제3절 홈네트워크	95
1. 홈네트워크 분야의 보안 위협	95
2. 홈네트워크 분야의 보안 수단 및 효과성 비교	98
3. 홈네트워크 분야의 국내외 망분리 규제 현황	101
4. 홈네트워크 분야의 보안 정책 제언	103
제4절 자동차	109
1. 자동차 분야의 보안 위협	109
2. 자동차 분야의 보안 수단 및 효과성 비교	113
3. 자동차 분야의 국내외 망분리 규제 현황	116
4. 자동차 분야의 보안 정책 제언	118
제5절 소결	123

제5장 결론: 초연결 및 디지털 전환 시대의 보안 정책 126

제1절 추진과제 127

1. 망분리에 대한 개념 전환 및 규제 대상 조정 127

2. 제로 트러스트 모델의 시범적 도입 및 확산 129

3. 산업 및 기업 특성을 반영하여 보안 정책 차별화 131

제2절 선결과제 137

1. 중요도 중심의 데이터 분류 137

2. 정책 실효성 제고를 위한 사후 규제 강화 140

3. 전체 생태계 구성원의 인식의 전환 143

참고문헌 147

부록 1: 기타 분야의 망분리 규제 현황 153

부록 2: 금융/헬스케어/홈네트워크/자동차 보안 전문가

서면 질의서 162

Contents

Summary (in Korean)	i
----------------------------------	----------

Summary (in English)	1
-----------------------------------	----------

Chapter 1. Introduction: Hyper-Connectivity, Digital Transformation and Network Separation Regulation	1
--	----------

1. Background and Necessity of the Study	1
2. Purpose and Key Messages of the Study	5
3. Method and Process of the Study	12

Chapter 2. Overview of Security and Recent Technological Trend	14
---	-----------

1. Overview of Security	14
2. Recent Technological Trend: Focusing on Zero-Trust	25

Chapter 3. Current Status and Problems of Domestic Security Policy: Focusing on Network Separation Regulation	32
--	-----------

1. Status of Domestic Security Policy	32
2. Overview and Problems of Network Separation Regulation	40
3. Necessity of Transformation of Security Paradigm	53

Chapter 4. Analysis of Security Threats, Countermeasures, and Policies of Major Industries	62
---	-----------

1. Finance	64
2. Healthcare	81
3. Home Network	95
4. Automobile	109
5. Summary of the Analysis	123

Chapter 5. Conclusion: Security Policy in the Age of Hyper-Connectivity and Digital Transformation	126
1. Policy Tasks	127
2. Prerequisite Tasks	137
References	147
Appendix 1: Network Separation Regulation of Other Industries	153
Appendix 2: Questionnaire for Security Experts	162

| 표 목 차 |

〈표 1-1〉 보안에서 망분리와 감염병에서 지역 봉쇄의 유사성	4
〈표 1-2〉 망분리 규제 관련 기존 문헌의 특징과 본 연구의 차별성	11
〈표 2-1〉 사회공학적 공격의 주요 유형	17
〈표 2-2〉 제로 트러스트 모델의 장점과 단점	31
〈표 3-1〉 주요 정보통신 지표의 국내외 비교(2017)	32
〈표 3-2〉 국제정보화 지수별 우리나라 순위	33
〈표 3-3〉 김정은 시대 시기별 북한의 주요 사이버 공격 및 특징	36
〈표 3-4〉 국내 금융 보안 정책의 시대적 변화	38
〈표 3-5〉 망분리 정책의 경과	43
〈표 3-6〉 전 세계 정보보안(사이버보안) 시장 주요국 및 규모(2021)	47
〈표 3-7〉 국내 정보보안 산업 매출 현황(2020)	47
〈표 3-8〉 주요국의 정보보안 산업과 물리보안 산업 규모 비교	48
〈표 3-9〉 2008~2018년 주요 사이버 공격 사고 중 내부자로 인한 사례	50
〈표 3-10〉 정보보안의 3원칙(C.I.A.) 관점에서 본 망분리	51
〈표 3-11〉 망분리 환경에서의 보안 사고 사례	52
〈표 3-12〉 딜로이트가 제안하는 미래지향적인 규제의 방향성	61
〈표 4-1〉 서면 자문에 응답한 산업별 보안 전문가	62
〈표 4-2〉 산업별 보안 전문가 서면 질의서 문항	63
〈표 4-3〉 금융 분야의 보안 사고 유형 및 보안 대책	65
〈표 4-4〉 금융 분야의 보안 위협 사례	67
〈표 4-5〉 금융 분야 IT관련 법규 위반행위의 제재 대상	72
〈표 4-6〉 보건·의료 분야의 정보보호 관련 주요 법령	88
〈표 4-7〉 홈네트워크 설비의 구성요소	96
〈표 4-8〉 홈·가전 IoT 제품 유형별 주요 보안 위협	98
〈표 4-9〉 자동차 분야의 영역별 보안 위협 예시	109
〈표 4-10〉 자동차 분야의 영역별 보안 기술	114

〈표 4-11〉 자동차 분야의 국내외 망분리 규제 현황	118
〈표 4-12〉 금융 산업의 보안 위협, 대응수단 및 정책 요약	123
〈표 4-13〉 헬스케어 산업의 보안 위협, 대응수단 및 정책 요약	123
〈표 4-14〉 홈네트워크 산업의 보안 위협, 대응수단 및 정책 요약	124
〈표 4-15〉 자동차 산업의 보안 위협, 대응수단 및 정책 요약	125
〈표 5-1〉 금융보안원 ISMS-P 인증서 발급 현황	135
〈표 5-2〉 ISO/IEC 27001의 데이터 분류체계	138
〈표 5-3〉 영국 정부의 정보자산 등급 분류	139
〈표 5-4〉 중요도에 따른 데이터 분류 체계	140
〈표 5-5〉 징벌적 손해배상을 도입하고 있는 개인정보 관련 법률	141
〈표 5-6〉 규제 샌드박스의 구분	142

| 그 림 목 차 |

[그림 1-1] 보안의 3가지 목적(3원칙): 기밀성, 무결성, 가용성	7
[그림 1-2] 보안의 구성 요소: 보안의 대상 관점	8
[그림 1-3] 보안의 구성 요소: 보안의 수단 관점	9
[그림 1-4] 연구의 방법 및 추진 체계	13
[그림 2-1] 보안 공격의 유형	15
[그림 2-2] 보안 사고 발생의 핵심 원인	16
[그림 2-3] 보안 대책의 구성: 대상 및 수단	19
[그림 2-4] 다중 요소 인증(MFA)	21
[그림 2-5] 침입 탐지/방지 시스템(IDS/IPS)	22
[그림 2-6] 보안 정보 및 이벤트 관리(SIEM)	23
[그림 2-7] 보안 패러다임의 변화	24
[그림 2-8] 경계 기반 보안 모델 예시	26
[그림 2-9] 기존 네트워크와 제로 트러스트 네트워크의 비교	27
[그림 2-10] 제로 트러스트 모델의 개념	28
[그림 2-11] 제로 트러스트 모델의 원리	30
[그림 3-1] 딜로이트의 사이버 취약성 지수(Cyber Vulnerability Index)	34
[그림 3-2] 산업제어시스템(Industrial Control Systems)의 인터넷 연결성	35
[그림 3-3] 정책 영역별 정부 지출의 확대 필요성에 대한 국민의 인식	37
[그림 3-4] 「금융IT부문 자율보안체계 확립 방안」(2015.6)	39
[그림 3-5] 망분리의 개념	40
[그림 3-6] 물리적 망분리와 논리적 망분리의 비교	41
[그림 3-7] 마지노 선(Ligne Maginot)	49
[그림 3-8] 전 세계 스마트 기기의 증가 전망	53
[그림 3-9] 디지털 전환(4차 산업혁명)의 가치 창출 메커니즘	54
[그림 3-10] 미국 사이버보안및인프라보안국(CISA)이 권고하는 네트워크 분할	57
[그림 3-11] 해외 주요국의 망분리 규제 현황	58

[그림 3-12] 신기술 규제와 관련된 다양한 주체	60
[그림 4-1] 전자금융 서비스의 시스템 구성 및 주요 보안 요소	64
[그림 4-2] 보이스피싱 유형별 피해 현황(2019~2021)	67
[그림 4-3] 이상거래탐지시스템 구성의 예	69
[그림 4-4] 최근 10년 디지털 헬스케어 보안사고 사례	81
[그림 4-5] 디지털저작권관리(DRM) 솔루션의 구성	84
[그림 4-6] 블록체인의 의료정보시스템 예시	87
[그림 4-7] 헬스케어 분야의 법령 변화	88
[그림 4-8] ISMS-P의 인증대상	90
[그림 4-9] 보건복지부 데이터 중심병원 표준모델(안)(일부)	90
[그림 4-10] 자동차 분야 보안 위협 예시	110
[그림 4-11] 한국인터넷진흥원의 자율주행차 보안모델	121
[그림 5-1] 미래지향적 보안 정책을 위한 정책 제안	126
[그림 5-2] 데이터 기반 보안 정책의 방향성	127
[그림 5-3] 산업별 특성: 전산자원의 가용한 규모 및 지불의사(예시)	131
[그림 5-4] 망분리 및 제로 트러스트의 도입 가능성(예시)	132
[그림 5-5] 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 체계	135
[그림 5-6] 행정안전부의 정보·서비스 등급 분류	140
[그림 5-7] 미래지향적인 보안 정책을 위해 필요한 인식의 전환	144
[그림 5-8] 전체 보안 체계에서 망분리의 위치	144
[그림 5-9] 망분리 관련 이해관계자별 입장(예시)	145

| 요약 |

1. 서론: 초연결, 디지털 전환 그리고 망분리 규제

□ 초연결 및 디지털 전환의 시대에 망분리 규제가 적절한지, 향후 어떻게 보완되어야 하는지에 대한 본격적인 연구가 필요한 시점

- 현재 금융 산업에서 망분리 규제가 활발하게 논의되고 있고 규제가 완화되는 추세이나 향후 보안 사고가 발생하면 언제든지 다시 규제가 강화될 가능성이 상존
- 향후 금융, 헬스케어, 홈네트워크, 자동차 등 다양한 산업에서 연결과 데이터 분석에 기반한 혁신적인 서비스가 확대된다면 보안 위협에 대한 우려와 이를 사전에 차단하기 위해 망분리 규제를 도입하자는 주장도 지속적으로 등장할 전망
- 망분리 규제 이슈는 특정 산업의 비용 증가 차원을 넘어 국가 디지털 전환의 성패를 좌우하는 문제

□ 본 연구의 목적은 초연결 및 디지털 전환의 시대에 맞지 않는 망분리 규제의 보완 방안과 미래지향적인 보안 정책의 방향성을 제시하는 것

- “미래지향적인 정책”이란 미래에 등장할 신서비스의 구현을 가능하게 하는 보안 정책과 미래에 등장할 새로운 보안 기술을 적용할 수 있는 보안 정책을 의미

□ 본 연구의 연구문제

- Q. 금융, 헬스케어, 홈네트워크, 자동차 등 다양한 산업에 존재하거나 향후 도입될 수 있는 망분리 규제의 문제점은 무엇인가?
- Q. 망분리를 대체할 수 있는 대응수단은 무엇이고 보안 위협을 해결할 수 있는가?
- Q. 초연결 사회에 부합하는 보안 정책의 패러다임은 무엇이고, 이를 구현하기 위해 어떤 정책이 필요한가?

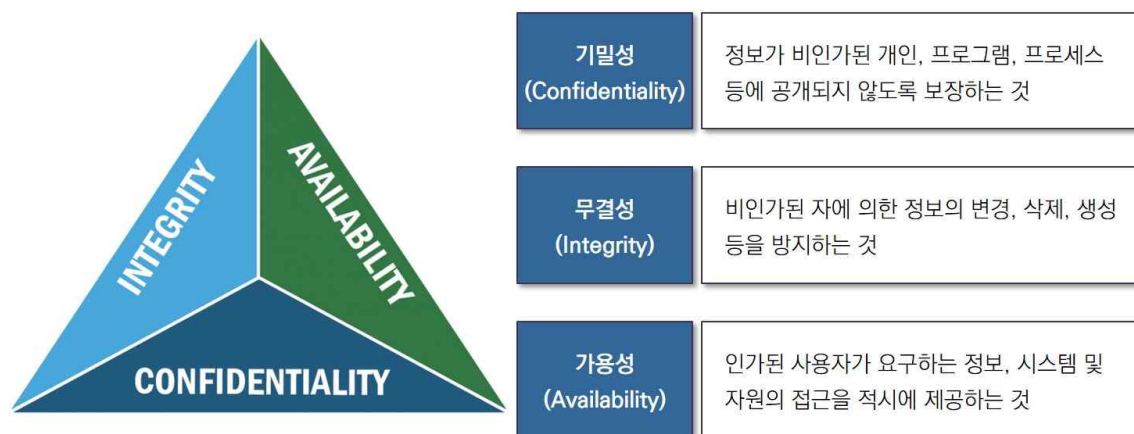
□ 기존 연구와 차별성

- 기존 연구도 망분리의 문제점을 지적하고 있지만 업계나 전문가뿐만 아니라 일반 국민까지 포함하는 다양한 관점에 대한 고려는 부족
 - 본 연구는 망분리도 완벽하지 않은 보안 수단이라는 점을 지적하고 망분리를 대체 또는 보완할 수 있는 다양한 보안 기술들을 소개함으로써 망분리 규제를 완화하는 것이 보안성을 낮춘다는 일반적인 인식에서 벗어날 필요가 있다고 주장
- 기존 연구는 망분리를 단순히 완화되어야 하는 대상으로 파악
 - 본 연구는 분야에 따라서 망분리가 실제로 필요하고 국방 시설, 국가 기간 인프라 등과 같이 오히려 강화되어야 하는 경우도 존재한다는 점을 제시
- 망분리 규제 등 보안 정책과 관련된 기존 논의가 분야마다 개별적으로 진행
 - 본 연구는 금융, 헬스케어, 홈네트워크, 자동차 등 망분리 규제가 시행되고 있고 시행될 가능성이 있는 주요 산업을 종합적으로 분석하고 대안을 모색하여 일관된 정책을 수립할 수 있는 틀을 제시

2. 보안의 개요 및 최근 기술 동향

- 보안은 “하드웨어, 소프트웨어, 네트워크, 데이터 등의 정보 시스템 자원을 비인가된 접근, 공개, 사용, 차단, 파괴 등으로부터 보호하여 기밀성, 무결성, 가용성을 보장하는 것”
 - 기밀성(Confidentiality)은 정보가 비인가된 개인, 프로그램, 프로세스 등에 공개되지 않도록 보장하는 것
 - 무결성(Integrity)은 비인가된 자에 의한 정보의 변경, 삭제, 생성을 방지하는 것
 - 가용성(Availability)은 인가된 사용자가 요구하는 정보, 시스템 및 자원의 접근을 적시에 제공하는 것

[그림 1] 보안의 3원칙(Confidentiality Integrity Availability Triad)



□ 보안 공격의 종류는 크게 가로채기, 위조/변조, 차단으로 구분

- 가로채기(Interception)는 공격자가 시스템 자원에 접근하여 데이터를 조회하는 것으로 보안의 기밀성을 훼손
- 위조/변조(fabrication)는 공격자가 데이터에 접근하여 불법적으로 변경, 전달하는 것으로 보안의 무결성을 훼손
- 차단(interruption)은 사용자가 시스템 자원에 접근/이용하는 것을 막는 것으로 보안의 가용성을 훼손

□ 최근 증가하고 있는 보안 공격 형태

- 지능형 지속 위협(Advanced Persistent Threat, APT): 특정 절차/기술을 반복적으로 사용하지 않고 새로 개발된 기술/전술을 사용하는 것으로 오랜 기간에 걸쳐 공격 대상이 눈치 채지 못하게 보안을 무력화시키고 정보를 유출
- 제로 데이 공격(Zero-day Attack): 아직 알려지지 않은 보안 취약점이나 대책이 마련되지 않은 취약점을 노린 해킹을 총칭하며, 여기서 “제로 데이”는 취약점이 발견된 날을 의미
- 사회공학적 공격(Social Engineering): 기술적인 방법이 아니라 사람을 속여

비밀 정보를 획득하는 기법으로 피싱(phishing), 파밍(pharming), 스미싱(smishing), 웨일링(whaling) 등

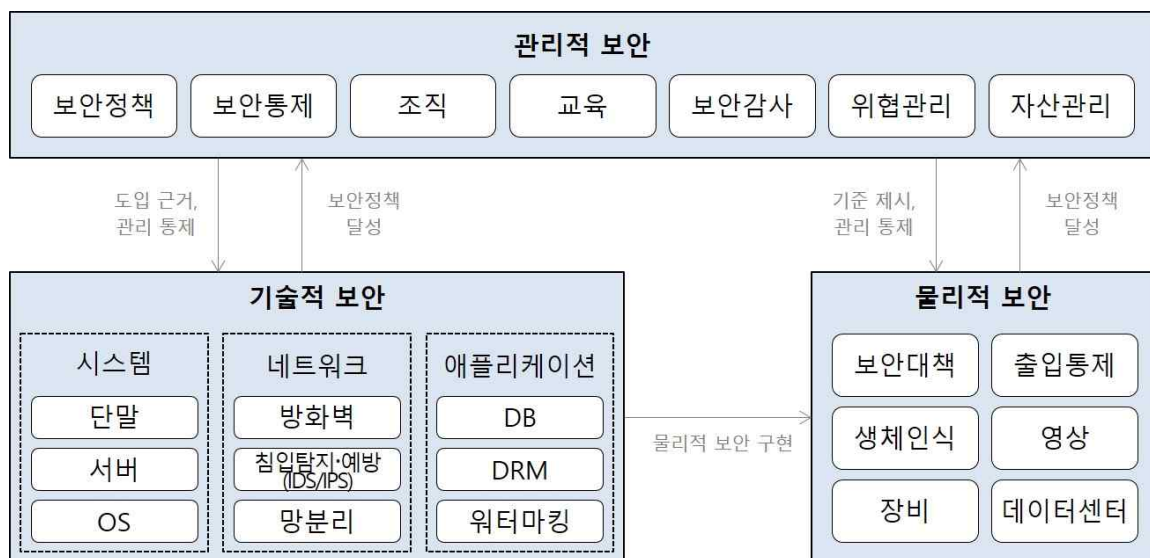
□ 최근 보안 위협의 특징

- ① 지능형 지속 위협(Advanced Persistent Threat: APT) 등과 같이 정형화되지 않은 공격이 많다는 점
- ② 조직의 내외부 구분 없이 어디서나 공격이 이루어진다는 점
- ③ 사회공학적 공격 등과 같이 사람을 통한 공격이 많다는 점

□ 보안 체계 및 보안 기술

- 보안 체계는 관리적 보안, 기술적 보안, 물리적 보안으로 구성

[그림 2] 보안 체계의 구성: 대상 및 수단



- 주요 보안 기술은 방화벽(firewall), 다중 요소 인증(MFA), 침입 탐지/방지 시스템 (IDS/IPS), 보안 정보 및 이벤트 관리(SIEM), 위협 탐지 및 대응(XDR) 등

□ 최근 보안 기술의 진화 방향

- (대상 범위) 기업 내 특정 경계면 → 기업 전반으로 확대
- (활용 수단) 하드웨어 장비 위주 → 다양한 종류의 데이터 분석, 인공지능 활용

□ 최근 새로운 보안 패러다임으로 제로 트러스트가 주목받고 있음

- 클라우드 서비스 확산, COVID-19 팬데믹 사태로 조직 내부가 아닌 외부 원격 근무 증가에 따라 전통적인 내부망과 외부망의 구분이 모호해지며 기존의 내 외부 네트워크 경계가 아닌, 새로운 신뢰 기반의 접근통제 모델이 필요해짐
- 제로 트러스트(Zero Trust)는 사용자가 정보 자원에 접근을 요청할 때 아무 것도 신뢰하지 않는다는 개념("never trust, always verify.")
 - 정보 자원의 물리적, 논리적인 위치와 상관 없이 모든 주체를 '신뢰할 수 없는 공격자'로 가정하고 정보 자원에 접근하려는 주체가 충분히 검증된 경우에 한하여 자원에 대한 접근 권한을 허가
 - 제로 트러스트는 하나의 관점 또는 패러다임이므로 구체적인 상황에 따라 제로 트러스트 원칙, 제로 트러스트 모델, 제로 트러스트 아키텍처, 제로 트러스트 네트워크 등과 같이 사용
- 제로 트러스트는 위협 대처능력, 효율적/효과적 보안 체계 등이 장점이나, 구축 시간 및 비용이 많이 소요되고, 고성능 컴퓨팅 자원이 필요하며 관리 난이도 및 부담이 증가한다는 것이 단점

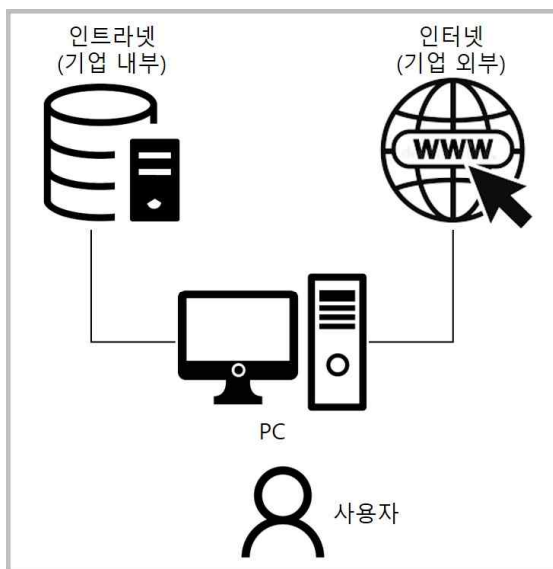
3. 국내 보안 정책의 현황과 문제점: 망분리 규제를 중심으로

- 망분리 규제란 기업에게 내부의 업무용 시스템과 인터넷 등 외부통신망을 분리하도록 의무화하는 것

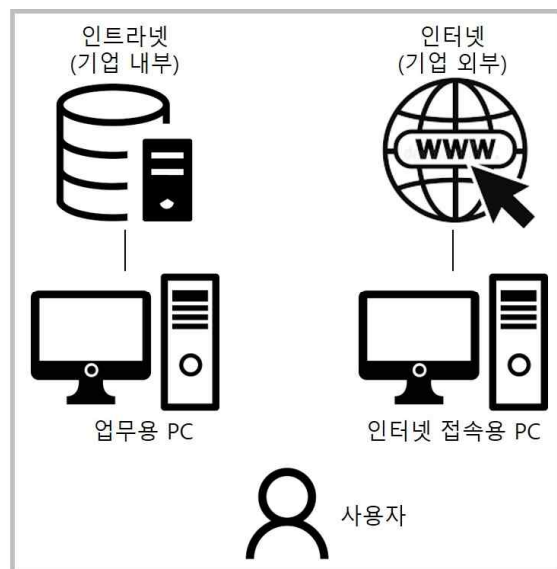
- 업무용 PC의 인터넷 연결을 차단하는 것이므로, 단순히 표현하면 직원 1인당 2대의 PC를 번갈아가며 사용해야 하는 상황
 - 보고자료 작성, 프로그래밍 등 업무를 수행할 때는 인터넷이 안 되는 업무용 PC를 사용하고, 외부에 이메일을 보내거나 뉴스 검색할 때는 사내 업무망에 연결이 안 되는 인터넷용 PC를 사용
 - 외부와 이메일로 업무용 자료를 공유할 때에는 업무용 PC와 인터넷용 PC 간에 보안USB로 자료를 전달

[그림 3] 망분리의 개념

(a) 망분리 규제 미적용



(b) 망분리 규제 적용



- 망분리는 세부적으로는 물리적 망분리와 논리적 망분리로 구분
 - 물리적 망분리는 기업 내부 업무용 PC와 외부 인터넷용 PC 간의 물리적인 연결이 완전하게 차단
 - 논리적 망분리는 기업 내부 업무용 PC가 외부 인터넷용 PC와 물리적으로는 연결은 되어 있지만 실제로 인터넷을 사용하려면 별도의 소프트웨어를 통해서만 가능

□ 망분리 규제의 장점과 단점

- (장점) 인터넷을 통한 위협 차단: 인터넷 접속을 사전에 차단하므로 기업 내부 시스템에 악성코드나 바이러스 유입 등과 같은 보안 사고가 발생할 가능성 감소
- (장점) 직관적이고 이해하기 용이: 인터넷을 차단하는 것이므로 복잡한 기술에 대한 지식 없이도 이해하기 쉬워서 보안 전문가가 아닌 정책 담당자나 일반 국민이 망분리를 선호하는 이유
- (단점) 기업 효율성 저하: PC, 소프트웨어, 네트워크 장비 등을 추가로 구매해야 하므로 기업의 투자비가 증가하고, 데이터, 분석·개발 도구, 오픈소스 등이 물리적으로 분리되어 있어서 소프트웨어 개발이 불편해지므로 업무의 생산성 저하
- (단점) 인력 유출 우려: 금융 등 망분리 규제의 적용을 받는 산업은 개발자 관점에서 매력도가 하락하여 우수한 인력의 유출이 발생
- (단점) 국내 보안산업 발전 저해: 기업이 각자 상황에 맞게 보안 투자를 하는 것이 아니라 망분리 규제 준수에 집중하게 되어 장기적으로 보안 투자가 감소
- (단점) 내부인 등 다양한 경로를 통한 위협에 취약: 망분리는 기업 시스템과 인터넷이라는 특정 경로에 치중하는 경계 보안 모델이므로 그 이외의 다른 경로에 대한 대비는 부족
 - 내부 시스템과 외부 인터넷 간 USB로 자료 교환하는 경로는 보안 위협에 노출
 - 최근 적외선, 초음파 통신 등을 활용한 해킹 기술이 개발되어 망분리 환경 하에서도 데이터 유출이 가능
 - 보안은 근본적으로 공격자와 방어자 사이의 기술적 싸움이므로 모니터링과 보안 수단의 정기적인 업데이트가 필요하나 망분리 하에서는 수작업이 불가피
 - 특히 내부로부터의 보안 위협에 취약: 최근 10년간 발생한 사이버 공격 중 대규모의 개인정보유출을 초래한 사건 상당수는 내부 직원, 외주 직원, 용역 직원, 외주 업체 직원 등 중요 정보에 접근이 허용된 신뢰된 사용자에 의해 발생

- (종합) 망분리는 직접적 경로를 통한 위협에 대해서는 기밀성과 무결성이 비교적 우수하지만 우회적 경로를 통한 위협에 대해서는 기밀성과 무결성이 미흡하고, 가용성 측면에서는 인가된 사용자가 요구하는 정보, 시스템, 자원 등의 접근을 적시에 제공하기 어려우므로 매우 미흡

〈표 1〉 정보보안의 3원칙(C.I.A.) 관점에서 본 망분리

	기밀성(Confidentiality) (정보가 비인가된 개인/ 프로그램/프로세스에 공개되지 않음을 보장)	무결성(Integrity) (비인가된 자에 의한 정보의 변경, 삭제, 생성 등을 방지)	가용성(Availability) (인가된 사용자가 요구하는 정보, 시스템, 자원 등의 접근을 적시에 제공)
직접적 경로 (인터넷 등)	비교적 우수 (완벽하지는 않음)	비교적 우수 (완벽하지는 않음)	매우 미흡
우회적 경로 (내부인 등)	미흡	미흡	매우 미흡

□ 해외 보안 정책 동향

- 미국, EU 등에서는 망분리를 보안 기법의 하나로 인정하고 있고 높은 보안 수준이 요구되는 자산에 권고하고 있으나 의무화하는 경우는 없으며, 망분리 도입 여부와 적용범위는 기관, 기업이 결정하는 것이 일반적
 - 미국 연방정부의 사이버보안및인프라보안국(CISA)은 정보기술(IT) 네트워크와 산업기술(OT) 네트워크, 그리고 보안수준이 높은 자산과 기타 자산에 대해 네트워크 분할(network segmentation)을 권고
 - 여기서 말하는 네트워크 분할은 전체 네트워크를 여러 개의 하위 네트워크로 구분하여 각각의 하위 네트워크에 대해 별도로 보안 관리를 하는 개념이므로 인터넷을 차단하는 국내 망분리와는 상이

- 미국, EU 등에서는 제로 트러스트로의 전환 정책을 적극적으로 추진
 - 바이든 대통령이 서명한 행정명령(Executive Order on Improving the Nation's Cybersecurity)에서는 연방 정부가 클라우드 서비스로의 전환을 가속화하기 위해 제로 트러스트(ZTA)를 도입해야 하며, 각 기관장은 이를 구축하기 위한 계획을 60일 이내에 수립하도록 명령

4. 주요 산업별 보안 위협, 대응수단 및 정책 분석

□ 산업별로 보안 위협 유형, 이를 대응하기 위한 보안 기술 현황 및 장단점, 국내외 망분리 규제 등 보안 정책 현황, 정책 제언 등을 종합적으로 파악

- 대상 산업은 현재 망분리 규제가 시행되고 있거나 향후 시행될 가능성이 있는 금융, 헬스케어, 홈네트워크, 자동차 등 4개를 선정
- 산업별로 심도있는 논의를 진행하기 위해 산업별 보안 전문가들을 대상으로 서면 자문을 실시
 - 각 산업의 보안 측면에서 대표적인 위협 요소는 무엇인가?
 - 위협 요소에 대응하기 위한 보안 수단과 보안 모델은 어떤 것들이 있는가?
 - 위협 요소에 대해 망분리와 다른 보안수단들은 효과적으로 대응할 수 있는가?
 - 국내·외 망분리 규제 현황과 전망은 어떠한가?
 - 반드시 망분리 규제가 필요한 부분이나 데이터가 있는가?
 - '영역 기반 보안 모델(망분리 등)'에서 '제로 트러스트 모델로 전환하는 것이 필요한가, 가능한가? 이를 위해 어떤 정책이 필요한가?

□ 각 산업별 문헌 조사, 전문가 자문, 연구팀 토의 결과를 종합

<표 2> 금융 산업의 보안 위협, 대응수단 및 정책

보안 위협	- (가로채기) 고객정보, 금융정보 유출, 다른 금융 범죄에 활용 - (위조/변조) 불법 금융 거래(자금 이체 등) - (차단) 분산 서비스 거부(Distributed Denial of Service: DDoS) 공격
대응 수단	- (보안 기술) 이상거래 탐지 시스템(Fraud Detection System, FDS) 등 다양한 기술 - (제로 트러스트) 중요 금융거래에 대해 도입 중
보안 규제	- (국내) 「전자금융감독규정」: 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 3. 내부통신망과 연결된 내부 업무용시스템은 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지 5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것 - (해외) 망분리는 권고사항, 강제하거나 의무화하고 있는 국가 없음, 가이드라인 제시
정책 제언	- 망분리 완화가 필요, 핵심 금융정보에 대해서는 망분리 유지 가능 - 자율적 보안체계 강조: 선제적 지침 배포, 사후 발생하는 보안사고에 대한 처벌/징계 - 제로 트러스트 도입을 위해 데이터 중요도 평가, 전환 과정의 문제에 대한 책임 경감
특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 큼(금융 IT 발달), 편차 존재(대기업 vs. 스타트업) - (전산자원 지불 의사) 타 분야 대비 높음(기업 의사결정), 편차 존재(대기업 vs. 스타트업)

<표 3> 헬스케어 산업의 보안 위협, 대응수단 및 정책

보안 위협	- (가로채기) 개인정보, 검진정보, 의료정보 등의 유출(예. 병원 데이터 제약사 유출) - (위조/변조) 처방전 위조 등(예. 항정신성의약품 처방) - (차단) 의료시스템 작동불능 등(예. 해외 병원의 수술장비 셧다운으로 환자 사망)
대응 수단	- (보안 기술) DRM(Digital Rights Management), DLP(Data Loss Prevention) 등 - (제로 트러스트) 헬스케어 적용 사례는 없는 것으로 파악됨
보안 규제	- (국내) 「전자의무기록의 관리·보존에 필요한 시설과 장비에 관한 기준」: 제7조(의료기관 외의 장소 관리·보존시 추가적인 조치) 전자의무기록 관리자가 의료기관 외의 장소에서 전자의무기록을 관리·보존하는 경우에는 규칙 제16조제1항제3호부터 제7호까지에 따른 시설과 장비에 대하여 별표에 따른 추가적인 조치를 하여야 한다.

	〈별표: 의료기관 외의 장소에 전자의무기록 보관시 필요한 추가적인 조치(일부 발췌)〉	
	구분	세부조치 내용
	네트워크 보안에 관한 시설과 장비	이중화된 네트워크의 구성 - 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립 네트워크 보호시스템 운영 - 침입차단시스템, 침입탐지시스템 등 인증된 정보보호시스템을 운영하여 내·외부 네트워크를 보호하여야 한다.
	- (해외) 명시적 망분리 규제 없음. 건강정보 보안 표준 설정(HIPPA Security Rule) 등	
정책 제언	- 망분리가 꼭 필요한 영역은 없다는 의견, 일부 의료장비(핵심 수술장비 등) 검토 가능 - 보건의료 데이터 활용 가이드라인 등과 같은 지침 제시가 바람직	
특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 크지 않음(헬스케어 IT 발달 미흡) - (전산자원 지불 의사) 타 분야 대비 높음(의료기관 결정), 편차 존재(대형 vs. 중소병원)	

<표 4> 홈네트워크 산업의 보안 위협, 대응수단 및 정책

보안 위협	- (가로채기) 홈캠 영상 유출 - (위조/변조) 홈캠 임의 촬영, 도어락 임의 개폐 등 - (차단) 원격제어기기, 원격검침기기, 감지기, 전자출입시스템, 차량출입시스템 등 마비
대응 수단	- (보안 기술) 가상사설통신망(VPN), 가상근거리통신망(VLAN), 암호화 등 - (제로 트러스트) 홈네트워크 적용 사례는 없는 것으로 파악됨
보안 규제	- (국내) 「지능형 홈네트워크 설비 설치 및 기술기준」: 14조의2(홈네트워크 보안) ① 단지서버와 세대별 홈게이트웨이 사이의 망은 전송되는 데이터의 노출, 탈취 등을 방지하기 위하여 물리적 방법으로 분리하거나, 소프트웨어를 이용한 가상사설통신망, 가상근거리통신망, 암호화기술 등을 활용하여 논리적 방법으로 분리하여 구성하여야 한다. - (해외) 국내와 같이 세대 간 분리를 의무화한 사례는 없는 것으로 파악됨
정책 제언	- 동일한 아파트 단지 내 공격 가능성을 고려할 때 제로 트러스트 모델의 도입 필요 - 홈네트워크 시스템의 특성을 파악하고 검증기반 보안 모델이 적절하게 적용될 수 있는지를 검증하는 연구와 시범적용 등이 선행될 필요

특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 작음(아파트 관리실이나 가정 내 설치) - (전산자원 지불 의사) 타 분야 대비 낮음(주로 개인 의사결정)
-----------	---

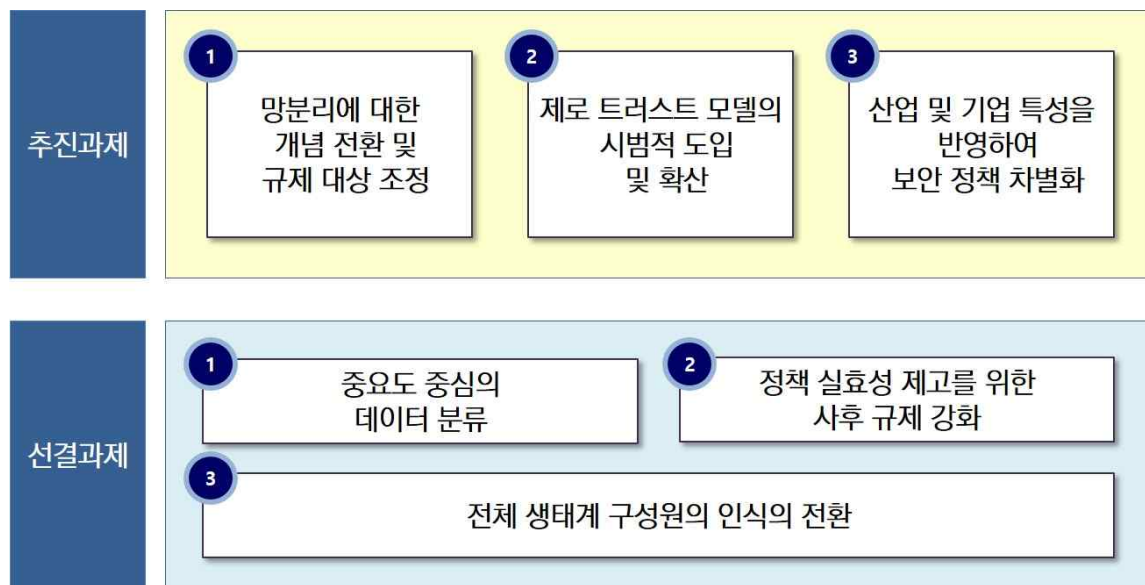
<표 5> 자동차 산업의 보안 위협, 대응수단 및 정책

보안 위협	- (가로채기) 차량 위치, 이동 경로 유출 - (위조/변조) 차량 강제 제어(가감속, 조향), 교통신호 강제 제어(예. 영화 “다이하드 4”) - (차단) 교통시스템 마비
대응 수단	- (보안 기술) 이동성, 실시간성으로 최신 보안 기술 활용 불가, 간단한 IDS 활용 수준 - (제로 트러스트) 차량 제어에는 활용 곤란, 인포테인먼트 시스템에는 향후 가능
보안 규제	- (국내) 제조사의 서비스에 대해 「개인정보의 기술적·관리적 보호조치 기준」: 제4조(접근통제) ⑥ 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상이거나 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억원 이상인 정보통신서비스 제공자등은 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등을 물리적 또는 논리적으로 망분리 하여야 한다. - (해외) 차량 제어 파트 보호를 위한 구조적 격리(isolation) 권고(망분리 아님)
정책 제언	- 망분리 도입이 어려울 전망이나, 교통신호인프라 등은 망분리 고려 가능 - 글로벌 시장을 고려하여 국내에만 해당되는 보안 규제는 지양할 필요
특징 또는 시사점	- (가용 전산자원 규모) 차량은 작음(모바일 기기), 제조사/교통시스템은 작지 않음 - (전산자원 지불 의사) 차량은 낮음(개인 의사결정), 제조사/교통시스템은 작지 않음

5. 결론: 초연결 및 디지털 전환 시대의 보안 정책

- 망분리와 제로 트러스트를 아우르는 데이터 기반 보안 정책을 위한 3가지 추진과제와 이것이 이행되기 위해 필요한 3가지 선결과제를 제시

[그림 4] 미래지향적 보안 정책을 위한 정책 제안



□ (추진과제 1) 망분리에 대한 개념 전환 및 규제 대상 조정

- 현행 물리적·논리적 망분리를 구조적 망분리를 포함하여 확장
 - 현재 국내에서 사용되고 있는 망분리의 개념은 물리적으로 또는 논리적으로 인터넷 연결을 끊는 것이므로 사실상 망차단
 - 보안의 기밀성, 무결성, 가용성을 높이기 위해 망분리의 개념을 현행 물리적·논리적 중심에서 구조적 망분리를 포함하여 확장
- 망분리의 규제 대상을 필수 기능 자산으로 한정
 - 물리적·논리적·구조적 망분리가 필요한 자산을 포지티브 방식으로 지정: 필수 기능(mission-critical) 자산 등

- 그 이외의 자산에 대해서는 망분리 여부를 기관의 자율적인 선택에 위임

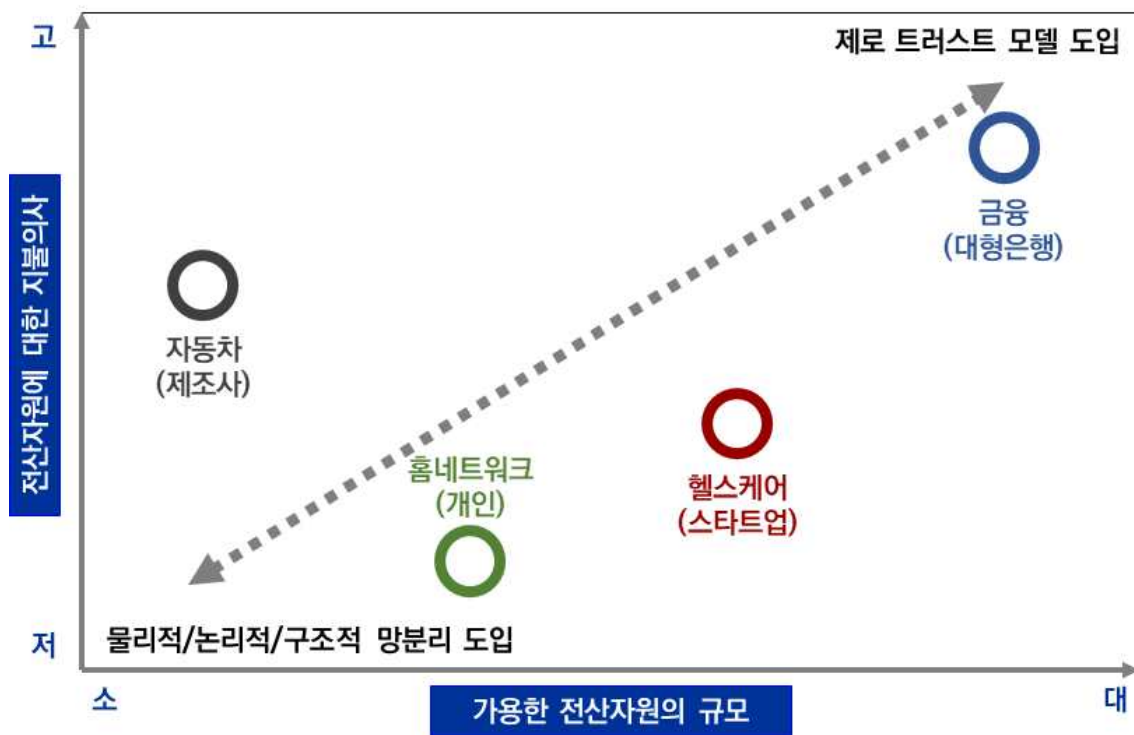
□ (추진과제 2) 제로 트러스트 모델의 시범적 도입 및 확산

- 망분리 규제의 대상은 필수 기능 자산으로 한정하는 대신 그 대안이라고 할 수 있는 제로 트러스트 모델의 도입을 적극적으로 고려
- 제로 트러스트 모델이 국내에서 활발하게 논의되고 있으나 아직 구체적으로 적용된 사례가 많지 않으므로 전면적인 도입보다는 점진적인 도입을 추진
 - 적용을 위해 데이터 등 모든 자산에 대한 중요도 분류, 자산에 접근하려는 모든 주체에 대한 식별 및 인증, 각 자산의 중요도에 따른 주체별 권한 부여가 필요
 - 단순히 자원 투자만으로 가능한 것이 아니라 기업의 업무방식 및 조직 구조, 문화의 큰 변화가 필요하므로 기존에 존재하는 시스템(legacy system)보다는 신규로 구축되는 시스템에 시도
 - 공공 부문에서 선행적으로 도입하여 성공 사례를 제시하는 것이 바람직:
(예) 스마트시티의 클라우드 기반 교통시스템에 대해 제로 트러스트 레퍼런스 모델을 개발하고 적용하여 성공사례를 제시함으로써 관련 기업으로 확산 촉진

□ (추진과제 3) 산업 및 기업 특성을 반영하여 보안 정책 차별화

- 가용한 전산자원의 규모, 전산자원에 대한 지불의사 등 산업별 특성을 반영하여 물리적/논리적/구조적 망분리 또는 제로 트러스트 도입 여부를 결정
 - 가용한 전산자원의 규모가 크고 전산자원에 대한 지불의사가 높을수록 제로 트러스트 모델의 도입이 용이, 그렇지 않을 경우 제로 트러스트 모델의 도입이 어려우므로 망분리 등 대안을 활용
- 기능의 중요도, 즉 일반 기능인지 필수 기능(mission-critical)인지 여부도 고려하여 물리적/논리적/구조적 망분리 또는 제로 트러스트 도입 가능성을 평가
 - 기능이 필수 기능에 가까울수록 물리적/논리적/구조적 망분리의 도입이 필수적

[그림 5] 산업별 특성: 전산자원의 가용한 규모 및 지불의사(예시)



[그림 6] 망분리 및 제로 트러스트의 도입 가능성(예시)



- 기업의 규모 또는 보안 수준에 따른 보안 정책 차별화
 - 매출액이나 사용자를 기준으로 하여 일정 수준 이하의 기업에 대해서는 정보 보안 규제의 적용을 제외하거나 유예하는 것도 가능
 - 정보 보안 수준이 높은 경우에는 망분리 등의 규제를 완화해주는 방안 고려

□ (선결과제 1) 사전적으로는 중요도 중심의 데이터 분류가 이루어질 필요

- 분류 단계의 수는 많을수록 데이터에 대한 세부적인 관리가 가능해지지만 분류 및 관리 비용도 증가하므로 국내외 데이터 분류체계에서는 주로 3~5단계로 구분
- 데이터 분류의 효과성과 구현가능성을 높이기 위해 전문성과 일관성을 고려하여 분류자를 선정

□ (선결과제 2) 사후적으로는 사고가 발생했을 때 처벌 수준을 높이는 등 사후규제 강화

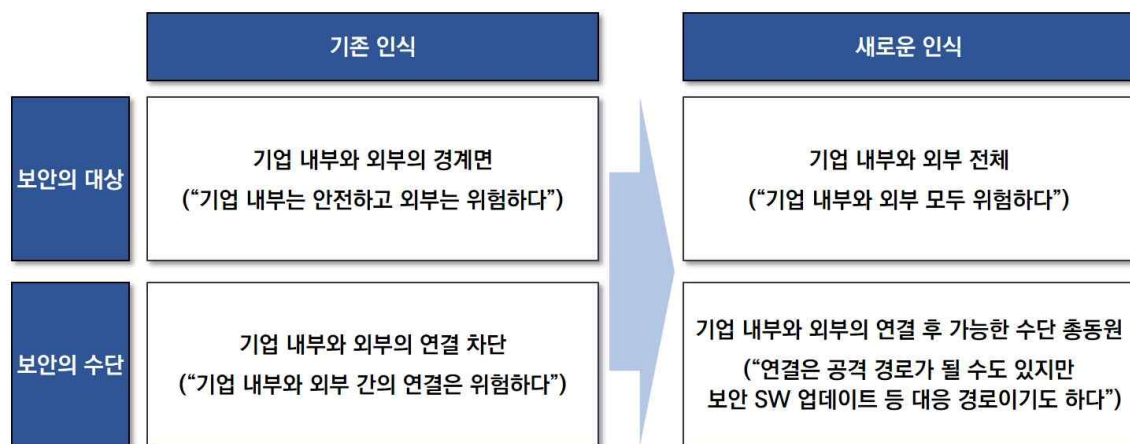
- 사후 규제가 제대로 작동하기 위해서는 징벌적 손해배상제를 적절히 활용할 필요
- 정보 보안 분야의 사후 규제가 효과적으로 작동하기 위해서는 향후 징벌적 손해 배상제를 손해액에 대한 배상 비율을 높이고, 데이터의 중요도에 따라, 기업의 고의 및 과실 여부에 따라 손해액 배상 비율을 차등 설정하는 방안이 필요

□ (선결과제 3) 장기적으로는 전체 생태계 구성원의 인식의 전환이 필요

- 보안의 범위를 기업 내부와 외부의 경계면에서 기업 전체로, 보안의 방식을 연결을 차단하는 것에서 기업 내부와 외부의 연결 후 가능한 수단을 총동원하는 것으로 확장하는 인식의 전환이 필요
 - 망분리는 보안의 영역을 기업 내부와 외부로 나누고 두 영역 간의 연결을 차단 하는 방식으로, 이는 내부는 안전하고 외부는 위험하다는 가정과 내부와 외부 간의 연결은 위험하다는 가정에 근거

- 그러나 현실에서 기업 내외부를 막론하고 보안 사고가 발생하고 있고 원격근무 확산으로 기업의 내외부 구분이 모호해지고 있음
- 데이터 네트워크를 통한 연결은 외부 위협이 침입할 수 있는 경로인 동시에 보안 수단이 업데이트 되는 경로

[그림 7] 미래지향적인 보안 정책을 위해 필요한 인식의 전환



- 보안 정책을 수립할 때 업계나 전문가뿐만 아니라 일반 국민까지 포함하는 다양한 관점을 고려하여 사회적 공감대를 형성하는 것이 중요
 - 망분리 규제에 대한 논의를 진행할 때 업계와 전문가의 관점에서는 투자비 증가, 생산성 저하, 인력 유출 등 망분리 규제의 문제점에만 주목하기 쉬움
 - 망분리 규제 변화의 필요성에 대한 전 사회적인 공감대를 얻기 위해서는 망분리 규제를 완화하는 것이 보안성을 낮춘다는 일반적인 인식에서 벗어날 필요

Summary

A Study on the Design and Implementation Strategy of Data-Driven Security Policies: Focusing on Network Separation Regulation

- **Project Leader: Byong-Sam Choi**
- **Participants: Hyeonchae Yang · Seol A Jin · Gaeun Kim · Myung Jin Song**

1. Introduction: Hyper-Connectivity, Digital Transformation and Network Separation Regulation

It is time for a full-fledged study on whether network separation regulations are appropriate and how they should be supplemented in the future in the era of hyper-connection and digital transformation. Currently, regulations on network separation are actively being discussed in the financial industry, and regulations are likely to be tightened again at any time if regulations are eased or security accidents occur in the future. In the future, if innovative services based on connection and data analysis are expanded in various industries such as finance, healthcare, home networks, and automobiles, concerns about security threats and calls for introducing network separation regulations to prevent them in advance will continue to emerge. Therefore, network separation regulation is a problem that determines the success or failure of national digital transformation beyond the cost increase of specific industries.

The purpose of this study is to present a supplementary plan for network separation regulations that do not fit the era of hyper-connection and digital transformation and the direction of future-oriented security policies. Here, "future-oriented policy" means a security policy that enables the implementation of new services that will emerge in the future and a security policy that can apply new security technologies that will emerge in the future.

The research problems of this study are as follows. What are the problems of network separation regulations that exist in various industries such as finance,

healthcare, home networks, and automobiles, or may be introduced in the future? What countermeasures can replace network separation and address security threats? What is the paradigm of security policies in line with a hyperconnected society, and what policies are needed to implement them?

This study is differentiated from existing studies in the following aspects. First, existing studies also point out the problem of network separation, but there is a lack of consideration for various perspectives that include not only the industry and experts but also the general public. This study points out that network separation is also an incomplete security tool and argues that easing network separation regulations by introducing various security technologies that can replace or supplement network separation needs to escape the general perception of lowering security. Second, existing studies identify network separation as an object that should be simply alleviated. This study suggests that network separation is actually necessary depending on the field and there are cases where it needs to be strengthened, such as defense facilities and national infrastructure. Third, existing discussions related to security policies such as network separation regulations have been conducted individually in each field. This study presents a framework for comprehensively analyzing major industries such as finance, healthcare, home networks, and automobiles that are in place and may be implemented, and seeking alternatives to establish consistent policies.

2. Overview of Security and Recent Technological Trend

Security is to ensure confidentiality, integrity, and availability by protecting information system resources such as hardware, software, networks, and data from unauthorized access, disclosure, use, blocking, and destruction. Confidentiality is to ensure that information is not disclosed to unauthorized individuals, programs, processes, etc., Integrity is to prevent information from being changed, deleted, and generated by unauthorized persons, and Availability is to provide timely access to information, systems, and resources required by authorized users.

The types of security attacks include intercept, forgery/modulation, and

blocking. Interception compromises the confidentiality of security by an attacker accessing system resources and inquiring data. Counterfeit/fabrication undermines the integrity of security by an attacker accessing, illegally changing, and delivering data. Interruption prevents users from accessing/using system resources, undermining the availability of security.

Recently, the increasing number of security attacks include intelligent persistent threats, zero-day attacks, and social engineering attacks. Advanced Persistent Threat (APT) is the use of newly developed technologies/tactics without repeated use of specific procedures/techniques, which over a long period of time neutralize security and leak information. Zero-day attack is a generic term for hacking aimed at unknown security vulnerabilities or vulnerabilities that have not been addressed, where "zero-day" means the date on which the vulnerability is found. Social engineering is not a technical method, but a technique for tricking people into acquiring confidential information, such as phishing, farming, smishing, and whaling.

The characteristics of recent security threats are that there are many unstructured attacks, such as Advanced Persistent Threat (APT), secondly, attacks anywhere regardless of the inside and outside of the organization, and thirdly, there are many attacks through people, such as social engineering attacks.

The security system consists of administrative, technical, and physical security. Major security technologies include firewall, multi-factor authentication (MFA), intrusion detection/prevention system (IDS/IPS), security information and event management (SIEM), threat detection and response (XDR). Recently, security technology has been evolving from a specific boundary within a company to the entire company, and the means of use is evolving to utilize various types of data analysis and artificial intelligence, not focusing only on hardware equipment.

Recently, Zero Trust is drawing attention as a new security paradigm. Due to the spread of cloud services and the COVID-19 pandemic, the distinction between traditional internal and external networks has become ambiguous, and a new trust-based access control model is needed, not existing internal and external network boundaries. Zero trust is the concept of trusting nothing when a user requests access to an information resource ("never trust, always verify").

Regardless of the physical and logical location of the information resource, all subjects are assumed to be 'untrusted attackers', and access to the resource is granted only if the subject trying to access the information resource is sufficiently verified. Zero Trust has advantages such as ability to cope with threats and efficient/effective security systems, but its disadvantages are that it takes a lot of time and money to deploy, requires high-performance computing resources, and increases management difficulty and burden.

3. Current Status and Problems of Domestic Security Policy: Focusing on Network Separation Regulation

Network separation regulations require companies to separate external communication networks such as the Internet from internal business systems. Since it blocks the Internet connection of business PCs, in simple terms, two PCs per employee must be used alternately. You should use a work PC that does not have the Internet when you write reporting data and programming, and use an Internet PC that does not have a connection to the in-house work network when sending e-mails or searching for news. When sharing business data with the outside by e-mail, the data is delivered through a secure USB between a business PC and an Internet PC.

Network separation is divided into physical network separation and logical network separation in detail. Physical network separation completely blocks the physical connection between a company's internal work PC and an external Internet PC, and logical network separation is a method in which a company's internal work PC is physically connected to an external Internet PC, but can only be used through separate software to actually use the Internet.

The advantage of network separation regulation is that, first, it can block threats through the Internet. Since Internet access is blocked in advance, the possibility of security accidents such as malicious code or virus inflow into the company's internal system can be reduced. Second, it is intuitive and easy to understand. Because it blocks the Internet, it is easy to understand without knowledge of complex technologies, which is why policymakers and the general

public, not security experts, prefer network separation.

First, the disadvantage of network separation regulation decreases corporate efficiency. Since additional PC, software, and network equipment must be purchased, corporate investment costs increase, and data, analysis and development tools, and open sources are physically separated, making software development inconvenient, reducing work productivity. Second, there is concern about the outflow of manpower. Industries subject to network separation regulations such as finance may experience an outflow of excellent manpower due to a decrease in attractiveness from the perspective of developers. Third, the development of the domestic security industry is hindered. Security investment may decrease in the long run as companies focus on compliance with network separation regulations rather than making security investments according to their circumstances. Fourth, it is vulnerable to threats through various channels such as insiders. Network separation is a boundary security model that focuses on a specific path such as the corporate system and the Internet, so preparation for other routes is insufficient. For example, the path to USB data exchange between the internal system and the external Internet is exposed to security threats. It is particularly vulnerable to security threats from within. Many of the cyberattacks that have occurred over the past decade have been caused by trusted users such as internal employees, outsourced employees, service employees, and outsourced company employees.

Taken together, network separation has relatively good confidentiality and integrity for threats through direct channels, but lacks confidentiality and integrity for threats through indirect channels. In terms of availability, it can be said that it is very insufficient because it is difficult to provide timely access to information, systems, and resources required by authorized users.

In the United States and the EU, network separation is recognized as one of the security techniques and recommends assets that require a high level of security, but it is not mandatory, and institutions and companies generally decide whether to introduce and apply network separation. The U.S. Federal Bureau of Cyber Security and Infrastructure Security (CISA) recommends network segmentation for IT networks, industrial technology (OT) networks, and

high-security assets and other assets. However, network division here is different from domestic network separation that blocks the Internet because it is the concept of separating the entire network into several sub-networks and separately managing security for each sub-network.

In addition, the United States and the EU are actively promoting policies to convert to zero trust. For example, the Executive Order on Implementing the Nation's Cybersecurity, signed by President Biden, requires the federal government to introduce a Zero Trust (ZTA) to accelerate the transition to cloud services, and each agency head orders a plan to build it within 60 days.

4. Analysis of Security Threats, Countermeasures, and Policies of Major Industries

This chapter comprehensively identifies the types of security threats by industry, the current status and strengths and weaknesses of security technologies to cope with them, the current status of security policies such as domestic and foreign network separation regulations, and policy suggestions. The target industries will select four: finance, healthcare, home networks, and automobiles, which are currently under network separation regulations or may be implemented in the future. In order to conduct in-depth discussions by industry, written advice was provided to security experts by industry.

5. Conclusion: Security Policy in the Age of Hyper-Connectivity and Digital Transformation

It presents three policy tasks for data-based security policies that encompass network separation and zero trust, and three prerequisites necessary for them to be implemented.

The first task is to change the concept of network separation and adjust the subject of regulation. The concept of network separation currently used in Korea is to physically or logically disconnect the Internet, so it can be said that it is actually network blocking. In order to increase the confidentiality, integrity, and

availability of security, the concept of network separation should be extended from the current physical and logical center to include structural network separation. In addition, the subject of regulation of network separation should be limited to essential functional assets. Mission-critical assets that require physical, logical, and structural network separation should be designated in a positive manner, but other assets should be left to the institution's autonomous choice of whether to separate the network.

The second task is the pilot introduction and spread of the zero-trust model. Instead of limiting the subject of the network separation regulation to essential functional assets, the introduction of a zero trust model, which can be said to be an alternative, should be actively considered. However, although the zero trust model is actively discussed in Korea, there are not many specific cases that have been applied yet, so it is desirable to push for gradual introduction rather than full introduction. The introduction of the Zero Trust requires classification of importance of all assets, identification and authentication of all entities that want to access assets, and authorization of each entity according to the importance of each asset, not just by investing in funds, but also by changing the company's work method, organizational structure, and culture. Therefore, it is preferable to try a newly constructed system rather than an existing legacy system. It is also possible to consider presenting success stories by introducing them in advance in the public sector. For example, a zero-trust reference model can be developed and applied to cloud-based transportation systems in smart cities to promote the spread to related companies by presenting success stories.

The third task is to differentiate security policies by reflecting industrial and corporate characteristics. The possibility of introducing physical/logical/structural network separation or zero-trust should be evaluated by considering the size of available computing resources and the importance of functions. In general, zero trust cannot be introduced if the size of available computing resources is below a certain level, and the closer the function is to the core function, the more essential it is to introduce physical/logical/structural network separation. It is necessary to decide whether to introduce physical/logical/structural network separation or zero trust by reflecting the characteristics of each industry, such as

the size of available computer resources and willingness to pay for computer resources. The larger the size of available computer resources and the higher the willingness to pay for computer resources, the easier it is to introduce a zero trust model, and the smaller the size of available computer resources and the lower the willingness to pay for computer resources, the more difficult it is to use alternatives such as network separation. In addition, security policies should be differentiated according to the size or security level of the enterprise. It is possible to exclude or suspend the application of information security regulations for companies below a certain level based on sales or users, and to ease regulations such as network separation if the information security level is high.

The first prerequisite needs to be data classification centered on importance in advance. The higher the number of classification steps, the more detailed management of the data becomes, but the cost of classification and management increases, so data classification systems at home and abroad are mainly divided into 3 to 5 stages. To increase the effectiveness and implementability of data classification, classifiers should be selected considering their expertise and consistency.

The second prerequisite is to strengthen post-regulation, such as raising the level of punishment when an accident occurs post-mortem. In order for post-regulation to work properly, it is necessary to appropriately utilize the punitive damages system. In order for post-regulation in the security field to work effectively, it is necessary to increase the compensation ratio for damages in the future and set the compensation ratio according to the importance of data and whether the company is intentional or negligent.

The third prerequisite is that in the long run, it is necessary to change the perception of all ecosystem members. There is a need for a shift in perception that extends the scope of security from the internal and external boundaries of the company to the entire company, from blocking the connection of security methods to mobilizing all possible means after connecting inside and outside the company. When establishing security policies, it is important to form a social consensus by considering various perspectives that include not only the industry or experts but also the general public.

| 제1장 | 서론: 초연결, 디지털 전환, 그리고 망분리 규제

제1절 연구의 배경 및 필요성

본 연구를 시작하게 된 계기는 금융 분야의 망분리 규제 논의였는데, 현재 시행 중인 망분리 규제가 금융 분야의 혁신, 특히 핀테크 산업의 발전을 저해할 우려가 있었기 때문이다. 망분리 규제란 간단하게 표현하면 기업에게 내부의 업무용 시스템과 인터넷 등 외부통신망을 분리하도록 의무화하는 것을 말한다. 즉, 업무용 PC의 인터넷 연결을 차단하는 것이다. 그래서 망분리 규제의 적용을 받는 금융회사 또는 전자금융업자의 경우 사용자가 기업 내부 시스템을 접속할 때와 인터넷을 접속할 때 각각 다른 PC를 사용해야 된다는 것을 의미한다.¹⁾ 업무용 PC와 인터넷 접속용 PC 간 데이터 공유가 필요할 경우 보안USB 등을 사용한다.

현행 법에서는 망분리에 대한 벌칙 및 과태료 규정을 두고 있다. 망분리를 하지 않았다는 사실만으로도 5천만원 이하의 과태료가 부과되고 만일 이로 인해 해킹 등이 발생할 경우 매출액 3/100의 과징금, 10년 이하의 징역이 부과될 수 있다(전자금융거래법 제49조, 제51조).

업계에서는 망분리 규제가 투자비 증가, 생산성 저하, 인력 유출 등을 초래하여 금융 산업의 발전을 저해한다고 주장해왔다(한국인터넷기업협회, 2022; 스타트업얼라이언스, 2020). 전문가들도 “핀테크 산업 경쟁력 강화를 위한 망분리 감독규정 개정 방안” 토론회(2019.8), “Remind 2019! 규제개혁 토론회”(2020.1), “디지털 뉴딜과 보안 패러다임” 컨퍼런스(2020.6), “망분리 규제가 핀테크 산업 개발환경에 미친 영향” 토론회(2021.9) 등을 통해 망분리 규제의 문제점을 지적했다.

업계와 전문가들이 제시하는 망분리 규제의 문제점은 첫째, 기업의 투자비 증가이다. 단순히 계산하더라도 업무용 PC와 인터넷 접속용 PC를 별도로 구매해야 하므

1) 망분리에는 물리적 망분리와 논리적 망분리가 있으며, 이 설명은 엄밀하게 말하면 ‘물리적 망분리’에 해당한다. 여기서는 문제의 핵심을 설명하기 위해 물리적 망분리 위주로 논의하고, 자세한 내용은 3장에서 설명하도록 한다.

로 PC, 소프트웨어 라이선스, 네트워크 장비 등의 비용이 추가로 발생한다. 업계 추산에 따르면 25인 기업의 경우 약 5억 원이 소요되고 기업 규모가 클수록 비용은 늘어난다(스타트업얼라이언스, 2020). 이는 모든 기업에게 부담이 될 수 있지만 특히 초기 스타트업에게는 진입장벽으로 작용할 수도 있다. 둘째, 소프트웨어 개발의 생산성 저하가 우려된다. 최근에는 소프트웨어를 개발할 때 오픈소스의 활용이 필수적인데 망분리 하에서는 데이터, 분석·개발 도구, 오픈소스 등이 물리적으로 분리되어 있어서 개발자들이 모든 소스코드에 대해 반입·반출 허가를 받아야 하는 등 업무 상 불편함을 감수해야 한다. ‘내부통신망과 연결된 내부 업무용시스템’이라는 모호한 범위는 업무 현장의 혼란을 가중시킨다. 이로 인해 업계에서는 개발자의 생산성이 약 50% 하락하여 더 많은 개발자가 필요하게 됨으로써 개발자 인건비가 약 30% 증가한다고 한다(스타트업얼라이언스, 2020). 이는 숫자화할 수 있는 비용 증가 이외에도 인터넷 기업과 금융 스타트업에게 중요한 개발 속도와 혁신에 부정적인 영향을 미친다. 셋째, 산업의 매력도가 하락하여 인력 유출이 우려된다. 망분리 환경에서의 개발 환경을 마련하는 일에 많은 시간을 투입하게 되어 본업인 개발에 집중하기 어렵기 때문에 개발자들이 금융 분야를 기피하거나 이탈하는 현상이 나타나고 있다. 이는 장기적으로 앞서 지적한 투자비 증가나 생산성 저하보다 더 심각하게 산업 발전에 부정적인 영향을 미칠 수 있다.

금융 분야의 망분리 규제와 관련된 업계 및 전문가들의 지적을 반영하여 금융위원회는 2022년 4월 「금융분야 클라우드 및 망분리 규제 개선방안」을 발표하였다(금융위원회 보도자료, 2022. 4. 15.). 망분리와 관련된 주요 내용은 그간 과도한 망분리 규제로 인해 디지털 신기술을 도입·활용하는 데 어려움이 있다는 의견을 반영하여 금융 분야의 디지털 전환을 안정적으로 뒷받침하기 위해 망분리 규제 개선을 추진하며, 일률적·획일적으로 적용되어온 망분리 규제를 개발·테스트 분야 등부터 단계적으로 완화한다는 것이다(금융위원회 보도자료, 2022. 4. 15.). 망분리 규제 완화의 범위나 속도가 적절한지에 대한 이견은 있을 수 있겠지만, 업계 및 전문가들의 의견을 상당 부분 반영한 결과라고 할 수 있다.

그렇다면 이번 개선방안을 통해 망분리 규제와 관련된 문제점은 완전히 해결된 것

일까? 본 연구에서는 두 가지 측면에서 향후 망분리 규제와 관련된 정책 이슈가 더욱 중요해질 것이라는 점을 강조하고자 한다.

첫째, 최근 망분리 규제가 완화되는 추세이나 향후 보안 사고가 발생하게 되면 언제든지 다시 규제가 강화될 가능성이 상존한다는 것이다. 망분리 규제는 2006년 정부와 공공 부문에 처음 도입되었지만 2011년 3.4 디도스(DDos) 공격, 2013년 3.20 사이버테러 등 대형 보안 사고가 발생할 때마다 금융 등 여러 분야로 적용이 확대되어 왔다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022). 보안 관점에서 우리나라의 특수성은 높은 유무선 인터넷 보급률에 비례하여 보안 위협도 높다는 점, 북한과 대치하고 있어서 국가안보에 대한 우려가 크다는 점, 2022년 10월 카카오톡 장애 사고에서 알 수 있듯이 국가적으로 중대한 사고가 발생했을 때 국민이 정부에게 책임을 묻거나 정부의 적극적인 역할을 기대한다는 점이라고 할 수 있는데, 이 모든 사항들이 정부가 망분리 규제를 유지하게 만드는 요인이 될 수 있다. 즉, 기업들의 지속적인 망분리 규제 완화 요구에도 불구하고 사회적으로 보안 위협에 대한 우려가 커지게 되면 정부는 직접적으로 효과가 있을 것으로 기대되는 망분리 규제를 고려하지 않을 수 없게 된다. 따라서 정부가 망분리 규제를 완화하는 것이 바람직한지, 어디까지 완화할 수 있는지에 대해 일관된 정책을 추진하기 위해서는 망분리 규제의 비용과 편익에 대한 종합적인 분석이 선행되어야 한다.

둘째, 모든 사물들이 연결되는 초연결(Hyper-Connectivity)이 진행되고 디지털 전환(Digital Transformation)이 가속화되는 추세에 비례하여 보안 위협도 커지고 있기 때문에 금융 분야 이외의 다양한 분야에 이미 망분리 규제가 존재하고 향후에도 도입될 수 있다는 것이다. 예를 들어, 헬스케어 분야에서는 의료데이터 보호를 위해 망분리 규제가 시행되고 있고(「전자의무기록의 관리·보존에 필요한 시설과 장비에 관한 기준」), 홈네트워크 분야의 경우 아파트 월패드 해킹 사고로 가정 내부 영상이 유출되어 사생활이 침해되는 사고가 여러 차례 발생함에 따라 2021년 12월 31일 「지능형 홈 네트워크 설비 설치 및 기술기준」 고시가 개정되어 2022년 7월 1일부터 시행되고 있다. 또한 자동차 분야도 커넥티드카, 자율주행차 등 네트워크 연결과 데이터 교환에 기반한 혁신 제품과 서비스의 보급이 확대될 경우 망분리 등 보안 정책에 대한 논의가

본격화될 것으로 전망된다. 따라서 각 산업별로 망분리 규제가 실제로 필요한 영역은 무엇인지, 보안 위협에 대응하는 대안은 무엇인지에 대한 선제적인 분석이 필요하다.

과거에는 망분리 규제가 긍정적인 역할을 한 것도 사실이지만, 보안 기술이 발전하고 기업의 역량이 높아졌다는 점을 고려한다면 새로운 형태의 규제를 모색할 필요가 있다. 보안 분야에서 망분리 규제는 외부 위협을 원천적으로 차단하기 위해 물리적인 분리를 선택한다는 점에서 코로나19 같은 감염병 상황의 지역 봉쇄에 비유될 수 있다. 지역 봉쇄를 다른 수단들이 마련되기 어려운 상황에서 단기적으로 활용할 수는 있지만 이것에만 의존하거나 장기적으로 지속할 수는 없다.

<표 1-1> 보안에서 망분리와 감염병에서 지역 봉쇄의 유사성

		대응 방식	
		연결 원천 차단	연결 후 대응
상황	보안	망분리	백신 등 보안 수단 개발, 시스템 점검 및 관리 등
	감염병 (COVID-19)	지역 봉쇄	진단키트·백신·치료제 개발, 방역 활동 등

자료: 저자 작성.

현재는 금융 산업에서 망분리 규제 논의가 활발하게 이루어지고 있고 완화되는 방향이지만, 향후 금융, 헬스케어, 홈네트워크, 자동차 등 다양한 산업에서 연결과 데이터 분석에 기반한 혁신적인 서비스가 확대될수록 보안 위협에 대한 우려도 지속적으로 커질 것이다. 이에 따라 보안 위협을 사전에 차단하기 위해 망분리 규제를 도입하는 주장도 계속 제기될 것이다. 따라서 망분리 규제 이슈는 특정 산업의 비용 증가 차원을 넘어 국가 디지털 전환의 성패를 좌우하는 문제이다. 초연결 및 디지털 전환의 시대에 망분리 규제가 적절한지, 향후 어떻게 보완되어야 하는지에 대한 본격적인 연구가 필요한 시점이다.

제2절 연구의 목적 및 주요 내용

□ 연구의 목적

본 연구의 목적은 초연결 및 디지털 전환의 시대에 맞지 않는 망분리 규제의 보완 방안, 더 나아가서 미래지향적인 보안 정책의 방향성을 제시하는 것이다. 여기서 “미래지향적인 정책”이라는 것은 미래에 등장할 신서비스의 구현을 가능하게 하는 보안 정책과 미래에 등장할 새로운 보안 기술을 적용할 수 있는 보안 정책을 의미한다. 이를 위해 다양한 산업에서 활용되고 있는 망분리 규제를 포함한 다양한 보안 수단에 대한 입체적이고 종합적인 분석을 수행하고자 한다.

본 연구의 연구문제는 다음과 같다. 금융, 헬스케어, 홈네트워크, 자동차 등 다양한 산업에 존재하거나 향후 도입될 수 있는 망분리 규제의 문제점은 무엇인가? 망분리를 대체할 수 있는 대응수단들은 무엇이고, 이는 보안 위협을 해결할 수 있는가? 초연결 및 디지털 전환 시대에 부합하는 미래지향적인 보안 패러다임은 무엇이고, 이를 구현하기 위해 어떤 정책이 필요한가?

□ 연구의 개요

본 연구의 핵심 메시지는 혁신과 규제 사이의 균형을 유지하는 미래지향적인 보안 규제를 수립하기 위해서는 인식의 전환이 필요하다는 것이다. 망분리는 보안의 영역을 기업 내부와 외부로 나누고 두 영역 간의 연결을 차단하는 방식이다. 그리고 이는 2가지 가정을 전제로 하고 있다. 첫 번째는 내부는 안전하고 외부는 위험하다는 것이고, 두 번째는 내부와 외부 간의 연결은 위험하다는 것이다. 그러나 현실에서 기업 내외부를 막론하고 보안 사고가 발생하고 있고 원격근무의 확산으로 기업 내외부의 구분이 모호해지는 상황에서는 기업 내부가 안전하다고 가정하는 것은 적절하지 않다. 또한 데이터 네트워크를 통한 연결은 외부 위협이 침입할 수 있는 경로이기도 하지만 보안 수단이 업데이트되는 경로이기도 하므로 연결을 차단하는 것만이 해결책이 될 수는 없다. 따라서 보안의 범위를 기업 내부와 외부의 경계면에서 기업 전체로, 보안의 방식을 연결을 차단하는 것에서 기업 내부와 외부의 연결 후 가능한 수단을 총동원

하는 것으로 확장하는 인식의 전환이 필요하다.

본 연구의 제목에 사용된 “데이터 기반 보안”이라는 표현에서 ‘데이터’는 두 가지 의미를 가진다. 첫째, 보안 대상으로서의 데이터이다. 연구의 주제가 데이터 보안, 즉 기관의 주요 자산인 데이터에 대한 보안이라는 것이다. 데이터의 중요도에 따라 규제를 차등화하는 등 데이터 관점에서 보안 정책을 수립해야 한다. 둘째, 보안 수단으로서의 데이터이다. 효과적인 보안을 위해서는 조직 내외부에서 창출되는 다양하고 방대한 데이터를 적극적으로 활용해야 한다는 것이다. 그리고 연구 제목의 “설계와 이행 전략”이라는 표현은 단순히 망분리 등 기존 정책의 문제점을 제시하는 것에 그치지 않고 정책 대안을 제안하고 이를 실행할 수 있는 방안을 제시한다는 의미이다.

□ 보안의 개념

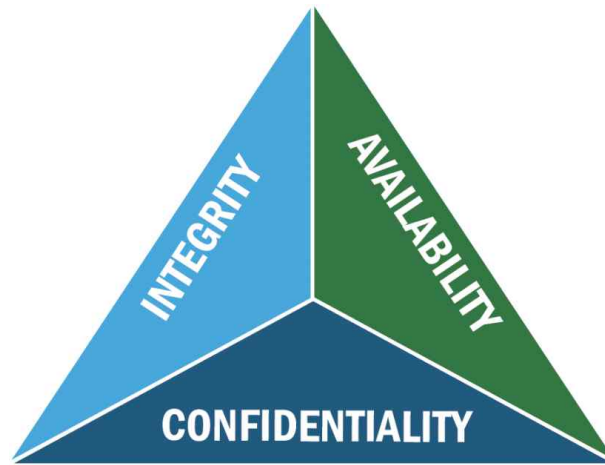
기존 문헌에는 보안과 관련하여 정보 보안, 데이터 보안, 컴퓨터 보안, 사이버 보안, 시스템 보안, 네트워크 보안 등 여러 가지 용어가 등장하는데, 본 연구의 논의를 효율적으로 진행하기 위해서는 이 용어들의 개념과 상호 관계를 정리할 필요가 있다.

미국 국립표준기술연구소(NIST)는 “정보 보안 개요(An Introduction to Information Security)” 보고서에서 정보 보안(information security)을 정보와 정보 시스템을 비인가된 접근, 사용, 공개, 차단, 수정, 파괴로부터 보호하여 기밀성, 무결성, 가용성을 보장하는 것(the protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to ensure confidentiality, integrity, and availability)이라고 정의한다(Nieles, Dempsey and Pillitteri, 2017). 여기서 기밀성(confidentiality)은 정보가 비인가된 개인, 프로그램, 프로세스 등에 공개되지 않도록 보장하는 것이고, 무결성(integrity)은 비인가된 자에 의한 정보의 변경, 삭제, 생성 등을 방지하는 것이며, 가용성(availability)은 인가된 사용자가 요구하는 정보, 시스템 및 자원의 접근을 적시에 제공하는 것이다(Nieles, Dempsey and Pillitteri, 2017; 삼성SDS 기술사회, 2019). 이를 보안의 3가지 목적 또는 3원칙이라고 부른다.

Stallings(2017)는 앞서 소개한 NIST의 보고서를 인용하면서 컴퓨터 보안

(computer security)을 “정보 시스템 자원의 무결성, 가용성, 기밀성을 보전하고자 하는 목표 달성을 위해 제공된 자동화된 정보 시스템 보호”라고 정의한다. 여기서 정보 시스템 자원이란 하드웨어, 소프트웨어, 펌웨어, 정보/데이터, 통신 네트워크 등을 모두 포함한다.

[그림 1-1] 보안의 3가지 목적(3원칙): 기밀성, 무결성, 가용성



Confidentiality	Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information
Integrity	Guarding against improper information modification or destruction and ensuring information non-repudiation and authenticity
Availability	Ensuring timely and reliable access to and use of information

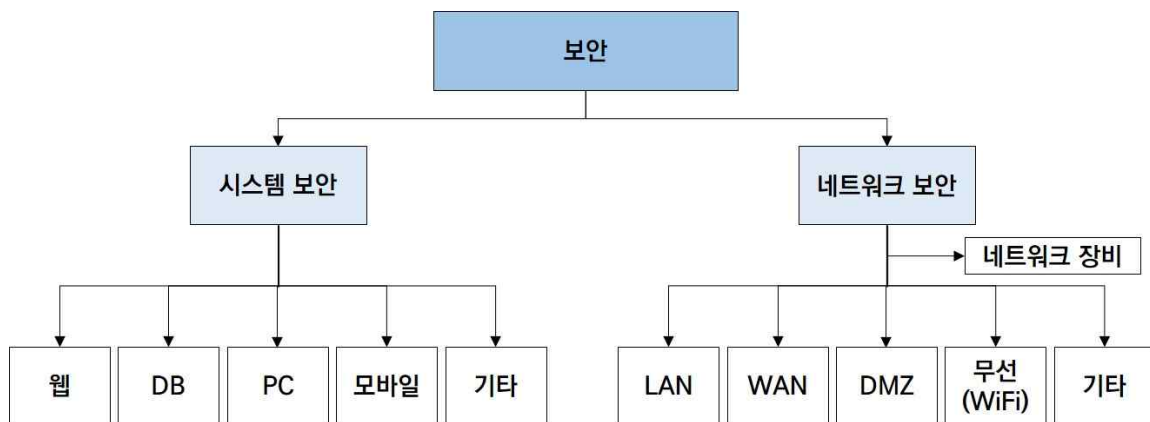
자료: <https://www.energy.gov/eere/femp/operational-technology-cybersecurity-energy-systems>
(검색일 2022. 10. 19.); Nieves, Dempsey and Pillitteri(2017), pp. 2~3.

한국정보통신기술협회(TTA)의 정보통신용어사전에서는 사이버 보안을 사이버 환경에서 네트워크 운영상의 위협으로부터 조직과 사용자 자산을 보호하기 위해 사용하는 기술적 수단, 보안 정책, 개념, 보안 안전 장치, 가이드라인, 위기 관리 방법, 보안 행동, 교육과 훈련, 모범 사례, 보안 보증, 그리고 보안 기술 등의 집합이며, 보안 목표는 가용성, 메시지 인증, 부인 방지를 포함한 무결성, 그리고 기밀성이라고 설명한다.²⁾ 삼성SDS 기술사회(2019)는 정보 보안을 정보의 수집·가공·저장·검색·송신·수신

중에 정보의 훼손, 변조, 유출 등을 방지하기 위한 관리적·기술적 수단을 강구하는 것으로 정의한다.

보안의 개념을 좀더 명확하게 살펴보기 위해 구성 요소를 살펴보면, 양대일(2021)은 보안을 시스템 보안과 네트워크 보안으로 구분한다. 시스템 보안은 권한이 없는, 허가받지 않은 사용자가 파일, 폴더, 장치 등을 사용하지 못하도록 제한하여 시스템을 보호하는 것이고, 네트워크 보안은 시스템 보안과 내용은 유사하지만 유선, 무선 네트워크에 대한 보안을 말한다(양대일, 2021). 즉, 보안을 시스템 보안과 네트워크 보안으로 구분하는 것은 보안의 대상 관점이라고 할 수 있다.

[그림 1-2] 보안의 구성 요소: 보안의 대상 관점

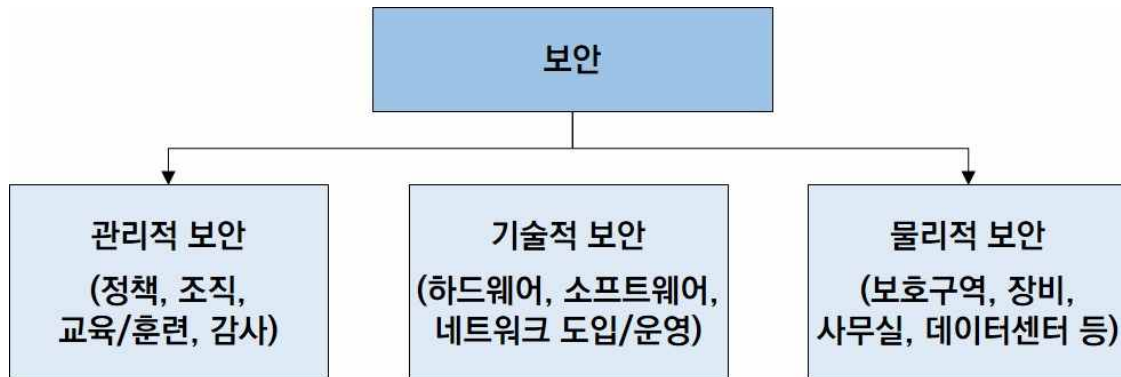


자료: 양대일(2021), p. 39.

삼성SDS 기술사회(2019)는 정보 보안의 관리 체계가 관리적 보안, 기술적 보안, 물리적 보안으로 구성되어 있다고 설명한다. 관리적 보안이란 한 기업, 조직의 보안정책과 보안조직을 구성하고 이를 기반으로 보안관리 운영 및 보안감사 등을 통해 지속적인 보안의 위협요소로부터 위협을 방지하고 취약 부분을 개선하는 것이며, 보안정책 및 조직체계, 인적 보안, 교육 및 훈련, 감사와 모니터링 등으로 구성된다(삼성SDS 기술사회, 2019). 기술적 보안은 보안정책을 기반으로 세부 보안 대상 영역의 보안을 이행하기 위한 하드웨어, 소프트웨어, 네트워크 등을 도입하고 운영하는 것이며, 네트

워크 보안, 시스템 보안, 애플리케이션 보안, 데이터베이스 보안, 디지털 콘텐츠 보안 등으로 구성된다(삼성SDS 기술사회, 2019). 물리적 보안이란, 특별한 보호가 필요한 주요 시설물과 장비 등의 자산에 대해 물리적 위협에 대한 안정성과 연속성을 보장하는 것이며, 물리적 보안대책(보호구역 등), 장비 보호, 사무실 보호, 데이터 센터 보안 등으로 구성된다(삼성SDS 기술사회, 2019). 즉 보안을 관리적 보안, 기술적 보안, 물리적 보안으로 구분하는 것은 보안의 수단 관점이라고 할 수 있다.

[그림 1-3] 보안의 구성 요소: 보안의 수단 관점



자료: 삼성SDS 기술사회(2019), pp. 25~26을 바탕으로 저자 정리.

이상의 논의를 종합하여, 본 연구에서는 보안을 “하드웨어, 소프트웨어, 네트워크, 데이터 등의 정보 시스템 자원을 비인가된 접근, 공개, 사용, 차단, 파괴 등으로부터 보호하여 기밀성, 무결성, 가용성을 보장하는 것”이라고 정의한다. 그리고 우리가 관심을 갖고 있는 보안이 건물 출입 등과 같은 현실 세상에서의 보안이 아니라 컴퓨터를 기반으로 한 사이버 세상에서의 보안이라는 차원에서 컴퓨터 보안, 사이버 보안 등도 같은 의미로 사용하기로 한다.³⁾ 보안의 대상은 시스템, 네트워크 등으로 구분되고, 보안의 수단은 관리적 보안, 기술적 보안, 물리적 보안으로 구성된다.

3) 정보 보안은 디지털, 아날로그 등 형식에 관계 없이 조직의 모든 데이터를 보호하는 것이고 사이버 보안은 디지털 데이터를 보호하는 것이라고 정의하여 사이버 보안이 정보 보안에 포함되는 것으로 정리하는 경우도 있다(예를 들어, <https://www.sap.com/korea/insights/what-is-cybersecurity.html>, 검색일 2022. 10. 20.). 단, 최근에는 아날로그 데이터의 비중이나 그에 대한 보안 위협이 크지 않다고 판단하여 본 연구에서는 정보 보안과 사이버 보안을 같은 개념으로 사용하고자 한다.

□ 기존 연구와 차별성

본 연구는 세 가지 측면에서 기존 연구와 차별성을 갖는다. 첫째, 기존 연구도 망분리의 문제점을 지적하고 있지만 업계나 전문가뿐만 아니라 일반 국민까지 포함하는 다양한 관점에 대한 고려는 부족하다. 그래서 망분리의 대안이 될 수 있는 다양한 보안 수단에 대한 소개나 보안에 대한 인식 전환에 대한 논의는 부족하다. 예를 들어, 스타트업얼라이언스(2020), 한국인터넷기업협회(2022), 이수환(2021)은 업계와 전문가의 관점에서 투자비 증가, 생산성 저하, 인력 유출 등 망분리 규제의 문제점을 지적하고 정보보호 수준이 우수한 기업에 망분리 규제를 완화하는 방안, 데이터를 중요도에 따라 분류하고 규제를 차등화하는 방안, 망분리 규제를 완화하되 보안성·위험성 심사, 보고 및 사후처벌을 강화하는 방안 등을 대안으로 제시한다. 그러나 효율성 제고와 함께 보안성 확보도 중요한 금융 산업의 상황과 보안 사고 발생 이후의 대처보다 예방을 중시하는 일반 국민과 정부 당국의 입장을 고려할 때 이 방안들이 망분리 규제의 확실한 대안이 될 수 있을지에 대해서는 충분한 고려가 필요하다. 본 연구에서는 망분리 규제 변화의 필요성에 대한 전 사회적인 공감대를 얻기 위해서는 망분리 규제를 완화하는 것이 보안성을 낮춘다는 일반적인 인식에서 벗어날 필요가 있다고 주장한다. 그래서 망분리도 완벽하지 않은 보안 수단이라는 점을 지적하고 망분리를 대체 또는 보완할 수 있는 다양한 보안 기술들을 소개한다.

둘째, 기존 연구는 망분리를 단순히 완화되어야 하는 대상으로 파악하고 있지만 분야에 따라서 망분리가 실제로 필요하고 오히려 강화되어야 하는 경우도 존재한다. 예를 들어 국가 안보와 직결되는 국방 시설, 국가 기간 인프라(원전 등)의 경우 연결의 편익보다 비용이 클 것으로 예상되므로 망분리 규제 완화에 신중해야 한다. 또한 망분리 규제의 필요성 논의와 별개로 현재 지방자치단체는 예산 부족을 이유로 망분리 규제를 준수하지 못하고 있는 상황은 개선이 필요하다. 본 연구에서는 망분리 규제가 필요한 영역과 필요하지 않는 영역을 구분함으로써 향후 보안 정책이 망분리에서 다른 수단으로 전환하는 것이 아니라 다양한 보안 수단을 포함하여 확장하는 것이며 필요한 영역에서는 망분리 규제를 오히려 강화할 수도 있다고 주장한다. 즉 망분리 규제와 관련하여 본 연구의 관점은 일방적인 규제 완화가 아니라 규제 강화와 완화를 포함

하는 규제 합리화이다.

셋째, 망분리 규제 등 보안 정책과 관련된 기존 논의는 분야마다 개별적으로 이루어지고 있다. 금융, 헬스케어, 홈네트워크, 자동차 등 각 분야별로 보안 위협은 무엇인지, 어떤 보안 수단이 있는지, 망분리가 필요한지 등이 논의된다. 하지만 일관된 정책을 수립하고 추진하기 위해서는 분야의 특수성도 고려해야 하지만 분야를 아우르는 공통의 원칙과 틀도 필요하다. 본 연구에서는 금융, 헬스케어, 홈네트워크, 자동차 등 망분리 규제가 시행되고 있고 시행될 가능성이 있는 주요 산업을 종합적으로 분석하고 대안을 모색하여 공통의 원칙과 틀을 제시한다.

<표 1-2> 망분리 규제 관련 기존 문헌의 특징과 본 연구의 차별성

구분	주요 문헌
기존 문헌의 특징	(1) 업계나 전문가뿐만 아니라 일반 국민까지 포함하는 다양한 관점에 대한 고려는 부족 (2) 망분리를 단순히 완화되어야 하는 대상으로 파악하여 규제 완화 관점에서 접근 (3) 망분리 규제와 관련된 논의가 분야별로 진행되어 공통의 원칙이나 틀 부족 [금융 분야] - 스타트업얼라이언스(2020), 「핀테크 기업의 망분리」, 이슈 미니 씨머리 vol 1. - 이수환(2021), 「디지털 금융혁신 관련 입법·정책과제 - 금융부문 망분리 규제 개선을 중심으로」, NARS 현안분석 제202호, 국회입법조사처 - 한국인터넷기업협회(2022), 『2021 인터넷산업규제 백서』. [헬스케어 분야] - 과학기술정보통신부·한국인터넷진흥원(2021.12a, b), 디지털 헬스케어 보안모델 PART I: 의료기기 / PART II: 서비스유형별 - 한국산업보안연구학회(2022), 『산업보안학』, 제2판, 박영사. [홈네트워크 분야] - 한국인터넷진흥원(2017), 『홈·가전 IoT 보안가이드』. - 한국산업보안연구학회(2022), 『산업보안학』, 제2판, 박영사. [자동차 분야] - 국토교통부·한국교통안전공단(2020. 12), 『자동차 사이버보안 가이드라인』. - 한국산업보안연구학회(2022), 『산업보안학』, 제2판, 박영사.
본 연구의 차별성	(1) 업계, 전문가, 일반 국민 등 다양한 관점을 고려하여 망분리 규제의 장단점을 평가하고 대안을 소개 (2) 망분리 규제를 단순히 완화되어야 하는 대상으로 파악하지 않고 망분리가 필요한 영역과 필요하지 않는 영역을 구분 (3) 망분리 규제가 시행되고 있고 시행될 가능성이 있는 주요 산업을 종합적으로 분석하고 대안을 모색하여 공통의 원칙과 틀을 제시

자료: 저자 작성.

제3절 연구의 방법 및 추진 체계

□ 연구 방법

본 연구에서 활용한 연구 방법은 문헌 조사와 전문가 자문이다. 연구팀은 문헌 조사를 통해 망분리 규제의 현황과 문제점, 업계 및 전문가가 제시하는 대안 등을 검토하였고, 보안 기술의 최근 동향, 국내 보안 정책의 문제점, 해외 보안 정책 사례 등을 조사하였으며 그 과정에서 보안 관련 국내 산·학·연 전문가들을 파악하였다. 그리고 연구의 방향성과 연구 문제, 분석 틀 등을 설계하였다.

전문가 자문은 1차와 2차에 걸쳐 진행되었다. 1차 전문가 자문은 국내 산·학·연 전문가들과의 대면 및 서면 인터뷰를 통해 진행되었고 연구팀이 설계한 연구의 방향성과 연구 문제, 분석 틀 등이 적절한지에 대해 의견을 수렴하였다. 그 결과 본 연구의 문제 의식과 가설이 적절함을 확인하였지만 산업별 분석이 필요하다는 점을 인식하게 되었다. 그래서 2차 전문가 자문은 금융, 헬스케어, 홈네트워크, 자동차 분야의 국내 산·학·연 전문가들을 대상으로 서면 심층 인터뷰와 화상회의를 병행하여 진행하였다. 이를 통해 각 산업별로 보안 위협의 유형, 이를 대응하기 위한 보안 기술 현황 및 장단점, 국내외 망분리 규제 등 보안 정책 현황, 분야별 보안 정책 제언 등을 종합적으로 파악하였다.

□ 연구의 추진 체계

본 연구의 추진체계는 다음과 같다. 먼저 제1장에서는 연구의 배경 및 필요성, 목적 및 주요 내용, 방법 및 추진 체계를 소개한다. 그 과정에서 보안 관련 개념, 본 연구의 핵심 메시지, 기존 연구와의 차별성을 서술한다. 초연결 및 디지털 전환의 시대에 망분리 규제를 고수하는 것은 안전하지도 효율적이지도 않고 미래지향적인 규제를 설계하기 위해서는 보안과 규제에 대한 인식의 전환이 필요함을 강조한다.

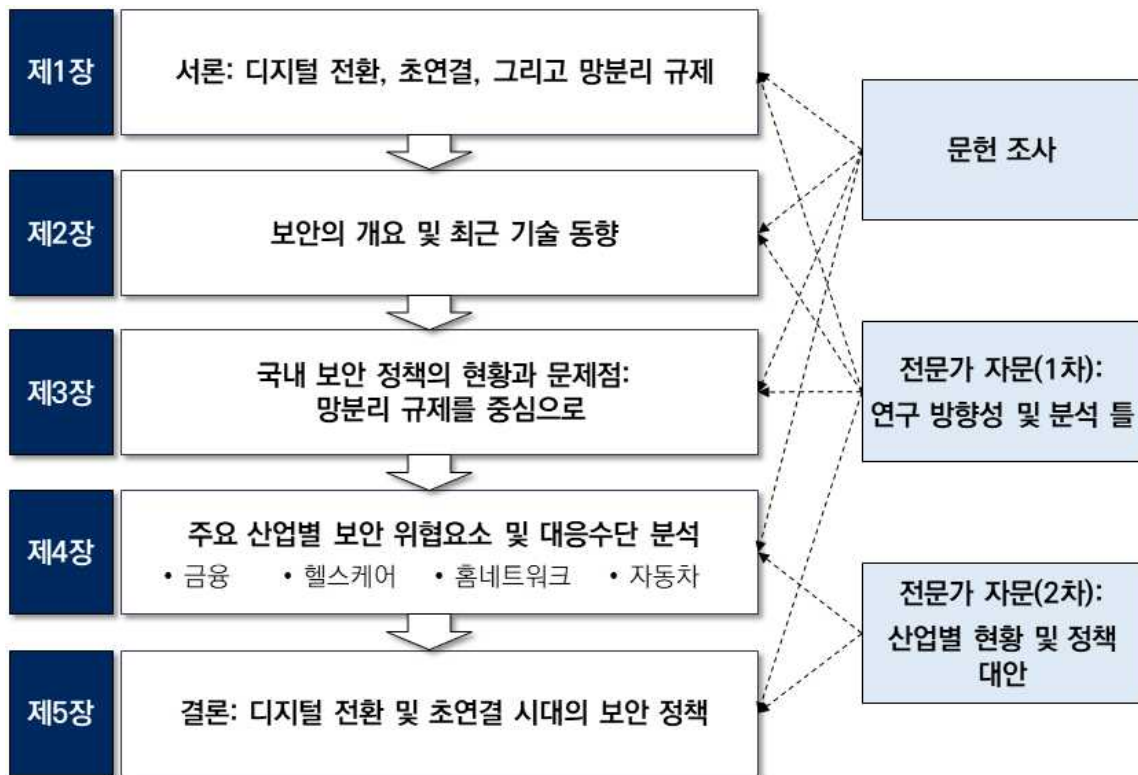
제2장에서는 이후 논의를 위한 기반을 제공하는 차원에서 보안 기술의 개요 및 최근 동향을 소개한다. 최근 개발 및 활용되고 있는 다양한 보안 기술과 보안 모델을 소개하고 특히 최근 국내외에서 각광받고 있는 제로 트러스트 모델(Zero Trust Model)에 대해 논의한다.

제3장에서는 현재 금융 분야를 중심으로 활발하게 논의되고 있는 망분리 규제의 현황과 문제점을 다룬다. 그리고 해외 정책과의 비교, 초연결 및 디지털 전환이라는 최근의 기술 환경 조망 등을 통해 보안 정책 패러다임의 전환 필요성을 제시한다.

제4장에서는 제2장과 제3장의 논의를 바탕으로 주요 산업별 위협요소 및 대응수단을 분석한다. 현재 망분리 규제가 시행되고 있거나 향후 시행될 가능성이 있는 금융, 헬스케어, 홈네트워크, 자동차 등 4개 산업을 선정하여 분야별 전문가 자문을 토대로 산업별 현황을 분석하고 정책 대안을 도출한다.

마지막으로 제5장에서는 제2장과 제3장의 논의와 제4장에서 도출한 산업별 대안을 종합하여 결론적으로 초연결 및 디지털 전환 시대의 보안 정책을 제시한다. 기존 망분리 정책의 문제점을 정리하고 그 대안과 이를 실행할 수 있는 방안을 제시한다.

[그림 1-4] 연구의 방법 및 추진 체계



자료: 저자 작성.

| 제2장 | 보안의 개요 및 최근 기술 동향

제1절 보안의 개요

1. 보안 위협

□ 보안 위협의 개념 및 유형

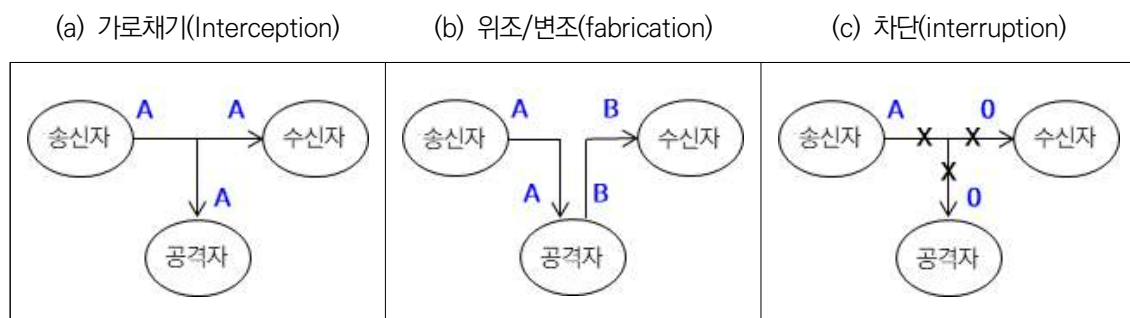
보안 위협(threat) 또는 공격(attack)은 기밀성, 무결성, 가용성 등 보안의 3가지 목적을 훼손하는 모든 행위를 포함하며, 가장 대표적인 유형 구분은 데이터의 변경 여부에 따라 소극적 공격과 적극적 공격으로 구분하는 것이다(삼성SDS 기술사회, 2019). 소극적 공격은 공격자(비인가자)가 데이터를 단순히 조회만 하고 변경하지 않는 것이고, 적극적 공격은 공격자가 데이터의 조회뿐만 아니라 변경까지 하는 것이며 소극적 공격에 비해 보안 위험도가 높다(삼성SDS 기술사회, 2019).

소극적 공격의 대표적인 사례는 도청(가로채기)이다. 도청(stealing) 또는 가로채기(interception)는 공격자가 시스템 자원에 접근하여 데이터를 조회하는 것이다. 송신자(source)가 수신자(destination)에게 보내려는 데이터는 그대로 전달되지만(예를 들어 보내려는 메시지를 A라고 한다면 “A → A”와 같이 표현할 수 있음), 그 데이터가 송신자가 원하지 않는 공격자에게도 전달되는 것이다. 가로채기는 보안의 기밀성(confidentiality)을 훼손하는 공격이다(삼성SDS 기술사회, 2019).

적극적 공격의 대표적인 사례는 위조/변조와 차단이다. 위조/변조(fabrication)는 공격자가 데이터에 접근한 후 이를 불법적으로 변경하여 전달하는 것이다. 수신자에게는 송신자가 전달하려는 것과 다른 데이터가 전달된다(예를 들어 보내려는 메시지와 다른 메시지를 B라고 한다면 “A → B”). 위조/변조는 보안의 무결성(integrity)을 훼손하는 공격이다(삼성SDS 기술사회, 2019). 차단(interruption)은 공격자가 인가 받은 사용자가 시스템 자원을 접근하고 이용하는 것을 막는 것이다. 따라서 송신자가 보내려는 데이터가 수신자에게 제대로 전달되지 않을 수도 있고(예를 들어 메시지를 보내거나 받지 못하는 것을 0이라고 한다면 “A → 0”), 송신자가 데이터를 보내는 것

자체가 어려울 수도 있다("0 → 0"). 공격자가 서버나 네트워크의 정상적인 서비스가 어렵도록 만드는 서비스 거부 공격(Denial of Service, DoS), 네트워크에 연결된 여러 대의 컴퓨터를 이용하여 서비스 거부 공격을 하는 분산 서비스 거부 공격(Distributed Denial of Service, DDos) 등이 차단에 해당된다. 차단(interruption)은 보안의 가용성(availability)을 훼손하는 공격이다(삼성SDS 기술사회, 2019).

[그림 2-1] 보안 공격의 유형



자료: 삼성SDS 기술사회(2019), pp. 36~37를 참고하여 저자 작성.

공격자는 5가지 유형으로 분류할 수 있고, 덜 위험한 공격자부터 더 위험한 공격자 순으로 정리하면 다음과 같다(Gilman and Barth, 2022). 첫째, 아마추어 공격자이다. 이들은 잘 알려진 취약점을 이용하여 특별한 공격 대상을 정하지 않고 간단한 공격을 한다. 둘째, 전문 공격자이다. 공격 대상을 정하고 그에 맞는 해킹 도구를 제작해 공격한다. 특정 대상에게 피싱 이메일을 보내는 해커가 이에 해당한다. 셋째, 내부 위협이다. 계약직, 일반 직원 등과 같이 적법한 시스템 사용자인데, 이들도 보안 위협이 될 수 있다. 넷째, 신뢰하는 내부자이다. 시스템을 관리할 수 있을 정도로 신뢰도가 높은 관리자가 이에 해당한다. 다섯째, 정부 주도 해커이다. 국내외 정부의 지원을 받아 일반 해커에 비해 풍부한 자원과 수준 높은 기술을 가지고 특정 대상을 공격한다.

국가정보원 외(2021)가 국내 주요 공공 및 민간 기관의 보안 담당자를 대상으로 실시한 조사에 따르면, 보안 사고의 주요 원인은 시스템, 제품 등 기술적인 요인보다 운영자, 외주업체, 이용자 등 인적인 요인이 더 높은 비중을 차지하는 것으로 나타났다(국가정보원 외, 2021).

[그림 2-2] 보안 사고 발생의 핵심 원인



자료: 국가정보원 외(2021), p. 236.

□ 최근 증가하고 있는 공격 형태

사회공학적 공격(social engineering)은 가로채기, 위조/변조, 차단 등과 같은 기술적인 방법이 아니라 사람을 속여서 데이터에 접근하는 공격 방식이다(삼성SDS 기술 사회, 2019). 사회공학적 공격은 도청(eavesdropping) 등과 같은 인간 기반 사회공학 기법과 피싱, 파밍, 스미싱, 웨일링 등과 같은 컴퓨터 기반 사회공학 기법으로 구분된다. 피싱(phishing)은 개인정보(private data)와 낚시(fishing)의 합성어로, 이메일이나 메시지를 사용해서 신뢰할 수 있는 사람 또는 기업이 보낸 메시지인 것처럼 가장하여 데이터를 불법적으로 얻는 공격이다. 파밍(Pharming)은 사용자가 자신의 웹 브라우저에서 정확한 웹 페이지 주소를 입력해도 가짜 웹 페이지에 접속하게 하여 개인정보를 훔치는 것이다. 스미싱(Smishing)은 문자(SMS)와 피싱(phishing)의 합성어로 문자메시지를 이용한 피싱이다. 신뢰할 수 있는 사람 또는 기업이 보낸 메시지로 가장하여 개인정보를 훔치는 것이다. 웨일링(Whaling)은 ‘고래잡이’라는 뜻으로 중요 데이터에 대한 접근 권한을 가진 CEO, CFO 등 기업 고위 경영진, 정치인 등을 대상으로 하는 공격이다.

<표 2-1> 사회공학적 공격의 주요 유형

구분	내 용
피싱 (phishing)	• '개인정보(Pprivate data)를 낚는다(Fishing)'라는 의미의 합성어 • 전화·문자·메신저·가짜사이트 등 전기통신수단을 이용하여 피해자를 기망·공갈함으로써 이용자의 개인정보나 금융정보를 빼낸 후, 금품을 갈취하는 사기 수법을 의미
보이스피싱	유선전화 발신번호를 수사기관 등으로 조작하여 해당기관을 사칭하면서 자금을 편취하거나 자녀납치, 사고빙자 등 이용자 환경의 약점을 노려 자금을 편취하는 수법
메신저 피싱	SNS, 모바일(또는 PC) 기반 메신저 등 신규인터넷 서비스의 친구추가 기능을 악용하여 친구나 지인의 계정으로 접속한 후 금전 차용 등을 요구 하는 수법
피싱사이트	불특정 다수에게 문자, 이메일 등을 보내 정상 홈페이지와 유사한 가짜 홈페이지로 접속을 유도하여 개인정보 및 금융정보를 편취하는 수법
파밍 (pharming)	• 피싱(Phishing)과 조작(Farming)의 합성어 • 악성프로그램에 감염된 PC를 조작하여 정상 사이트에 접속하더라도 가짜 사이트로 접속을 유도하여 금융거래정보를 빼낸 후 금전적인 피해를 입히는 사기 수법
스미싱 (smishing)	• 문자메시지(SMS)와 피싱(Phishing)의 합성어 • 스마트폰에 악성프로그램을 설치하여 피해자가 모르는 사이에 소액결제가 이루어지거나 개인정보 및 금융거래정보를 빼내가는 사기 수법
웨일링 (whaling)	• '고래잡이'라는 뜻 • 중요 데이터에 대한 접근 권한을 가진 CEO, CFO 등 기업 고위 경영진, 정치인 등을 대상으로 하는 공격

자료: 찾기쉬운 생활법령 정보, <https://www.easylaw.go.kr> (검색일 2022. 9. 1.)과 <https://www.boannews.com/media/view.asp?idx=67036> (검색일 2022. 9. 1.)의 내용을 저자 정리

최근 증가하고 있는 공격 형태 중 하나는 지능형 지속 위협(Advanced Persistent Threat, APT)이다. 이는 오랜 기간에 걸쳐 공격 대상이 눈치 채지 못하게 보안 서비스를 무력화하고 정보를 유출하는 방법이다(한군희, 2015). 특정 절차나 기술을 반복해서 사용하는 것이 아니라 새로 개발되는 기술이나 다양하게 진화하는 전술을 사용하는 공격을 말한다.⁴⁾ 분산 서비스 거부 공격(DDoS)처럼 단시간에 공격이 이루어지지 않고 수일부터 수년에 걸쳐 공격이 지속된다. 주로 개인 해커가 아니라 정부 주도 해커가 금전적이거나 정치적인 이유로 고도의 전문화된 기술을 활용해 공격한다.

제로 데이(Zero-day) 공격은 아직 알려지지 않은 보안 취약점이나 대책이 마련되

4) <https://brunch.co.kr/@ka3211/23> (검색일 2022. 10. 20.).

지 않은 취약점을 노린 해킹을 총칭한다.⁵⁾ 보안 취약점을 발견한 후 대개 몇 시간에서 며칠에 걸쳐 이를 보완하기 위한 보안 패치를 개발하게 되는데, 패치가 개발되는 기간 동안 혹은 취약점을 발견하지 못한 기간 동안 공격이 가해질 수 있다. 제로 데이 공격은 대응 방안이 마련되지 않아 데이터 탈취, 변조, 중단 등 다양한 방식으로 발전될 수 있어 큰 피해를 가져올 수 있다. 2021년 금융정보화추진협의회가 발표한 「금융정보화 추진 현황」에 따르면, 2020년 기준 금융회사의 전산시스템의 운영체제로 Linux가 41.9%로 가장 큰 비중을 차지하고, Windows(29.9%), Unix(18.3%)가 그 뒤를 이을 정도로 최근 금융기관이 오픈소스의 활용이 활발하다(금융정보화추진협의회, 2021). 그런데 이러한 오픈소스가 금융기관이 구축한 보안 시스템을 우회하는 데 주로 활용되고 있다.

최근 보안 위협의 특징을 정리하면 첫째, 지능형 지속 위협(APT) 등과 같이 정형화되지 않은 공격이 많다는 점, 둘째, 조직의 내외부 구분 없이 어디서나 공격이 이루어진다는 점, 셋째, 사회공학적 공격과 같이 사람을 통한 공격이 많다는 점이다.

2. 주요 보안 기술

제1장에서 소개한 바와 같이, 보안은 대상 관점에서 시스템 보안과 네트워크 보안으로 구분할 수도 있고(양대일, 2021), 시스템 보안에서 분리하여 애플리케이션 보안을 별도로 구분하기도 한다. 시스템 보안은 허가받지 않은 사용자가 파일, 폴더, 장치 등의 자원을 사용하지 못하도록 제한하여 시스템을 보호하는 것이고, 네트워크 보안은 유선, 무선 네트워크를 위협으로부터 보호하는 것이며, 애플리케이션 보안은 애플리케이션의 개발, 배포, 활용 등 수명주기 전체에 걸쳐 데이터, 코드 등이 도난당하거나 해킹당하는 것을 방지하는 것을 말한다.⁶⁾

또한, 정보 보안을 수단 관점에서 관리적 보안, 기술적 보안, 물리적 보안으로 구성되어 있다고 제1장에서 언급한 바 있다(삼성SDS 기술사회, 2019). 관리적 보안은 조직의 보안정책과 보안조직을 구성하고 이를 기반으로 보안관리 운영 및 보안감사 등

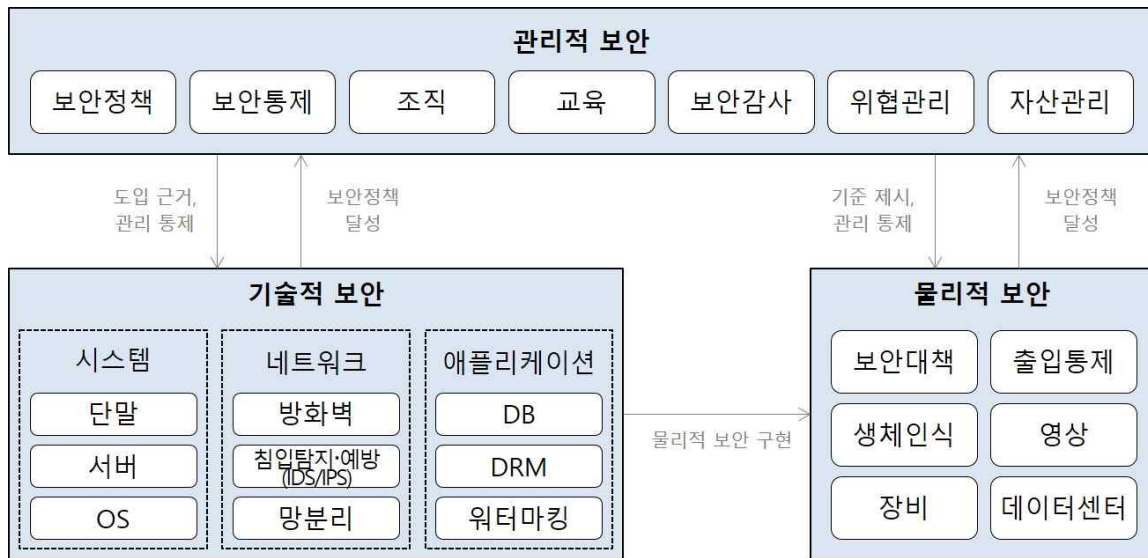
5) <https://www.akamai.com/ko/glossary/what-is-zero-day-attack> (검색일 2022. 10. 20.).

6) <https://www.microfocus.com/ko-kr/what-is/application-security> (검색일 2022. 10. 20.).

을 통해 지속적인 보안의 위협요소로부터 위협을 방지하고 취약 부분을 개선하는 것이고, 기술적 보안은 보안정책을 기반으로 세부 보안 대상 영역의 보안을 이행하기 위한 하드웨어, 소프트웨어, 네트워크 등을 도입하고 운영하는 것이며, 물리적 보안은 특별한 보호가 필요한 주요 시설물과 장비 등의 자산에 대해 물리적 위협에 대한 안정성과 영속성을 보장하는 것이다.

이상의 논의를 반영하고 구성 요소 간 관계를 표현하면 [그림 2-2]와 같다. 관리적 보안, 기술적 보안, 물리적 보안의 관계는 관리적 보안이 먼저 수립되고 이를 바탕으로 기술적 보안과 물리적 보안이 이루어지는 구조이다. 기술적 보안에는 시스템, 네트워크, 애플리케이션에 대한 보안 기술들이 포함된다.

[그림 2-3] 보안 대책의 구성: 대상 및 수단



자료: 강혁(2022), <https://anyflow.net/426> (검색일 2022. 9. 1.) 등을 바탕으로 저자 작성.

망분리 규제에 대한 심도 있는 논의를 진행하기 위해서는 이를 대체 또는 보완할 수 있는 보안 기술들에 대한 기본적인 이해가 선행되어야 한다. 다만 이미 많이 존재하고 있고 지금 현재도 지속적으로 개발되고 있는 수많은 보안 기술에 대한 상세한 설명은 본 연구의 범위를 벗어나므로 여기서는 이후 논의에서 언급할 몇 가지 기술에 대해 설명한다.

□ 방화벽(firewall)

방화벽은 외부 네트워크와 내부 네트워크 사이를 지나는 패킷을 미리 정한 규칙에 따라 모니터링하고 차단하거나 보내주는 기능을 하는 하드웨어나 소프트웨어를 말한다(양대일, 2021). 구체적으로는 접근 제어, 로그 기록, 인증 등의 기능을 수행한다. 패킷 필터링의 경우 외부에서 내부로 들어오는 패킷을 필터링하는 것(ingress filtering)과 내부에서 외부로 나가는 패킷을 필터링하는 것(egress filtering)으로 나누어진다(양대일, 2021). 방화벽은 보안 수준을 높이기 위한 일차적인 수단으로 사용되며, 외부의 위협으로부터 내부를 보호한다는 점에서 불길을 막는 방화벽과 비슷한 역할을 한다.

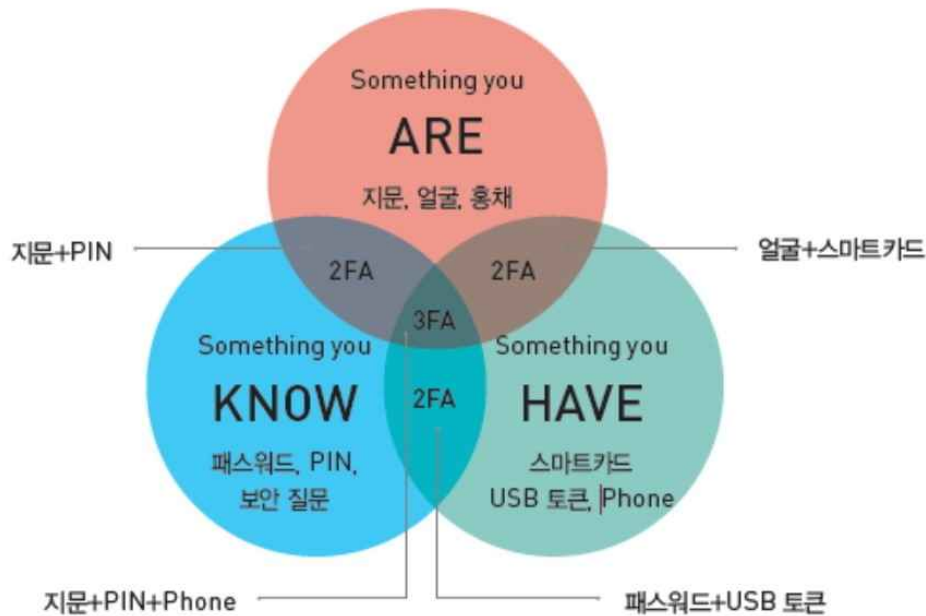
최근에는 기존 방화벽 기능에 애플리케이션 제어 기능을 부가한 차세대 방화벽(next generation firewall)도 활용되고 있다. 기존 방화벽은 IP정보와 포트정보만을 이용하여 제어하는데 애플리케이션 제어 기능은 애플리케이션별로 차단, 허용 등 제어를 할 수 있고 애플리케이션을 통해 유입되는 악성코드를 차단할 수도 있다(삼성 SDS 기술사회, 2019).

□ 다중 요소 인증(MFA)

인증(authentication)은 정보 시스템 접근 시 인가된 사용자를 증명하는 절차를 의미한다. 인증 수단에는 지식 기반(아이디, 패스워드 등) 인증, 소유 기반(출입증, OTP 등) 인증, 존재 기반(지문, 홍채 등 생체정보) 인증, 위치 기반(IP주소) 등으로 구분할 수 있다(양대일, 2021).

한 가지 인증 수단만 적용하여 인증을 수행하는 경우 단일 요소 인증(one factor authentication)이라고 하고 2개 이상의 인증 수단을 적용하여 인증을 수행하는 경우 다중 요소 인증(multi factor authentication, MFA)이라고 한다. 가령 금융 거래를 진행하는 경우 단순히 아이디와 패스워드 외에 보안 카드나 OTP(one time password)로 추가 인증을 하는 경우 다중 요소 인증을 적용한다고 할 수 있다. 중요 정보 시스템에 접근하는 경우 이용 주체 인증의 신뢰성을 높이기 위해서는 다중 요소 인증 기술을 적용하는 것이 바람직하다.

[그림 2-4] 다중 요소 인증(MFA)



자료: 소프트웨어정책연구소, <https://www.spri.kr/posts/view/18165?code=column> (검색일 2022. 10. 20.).

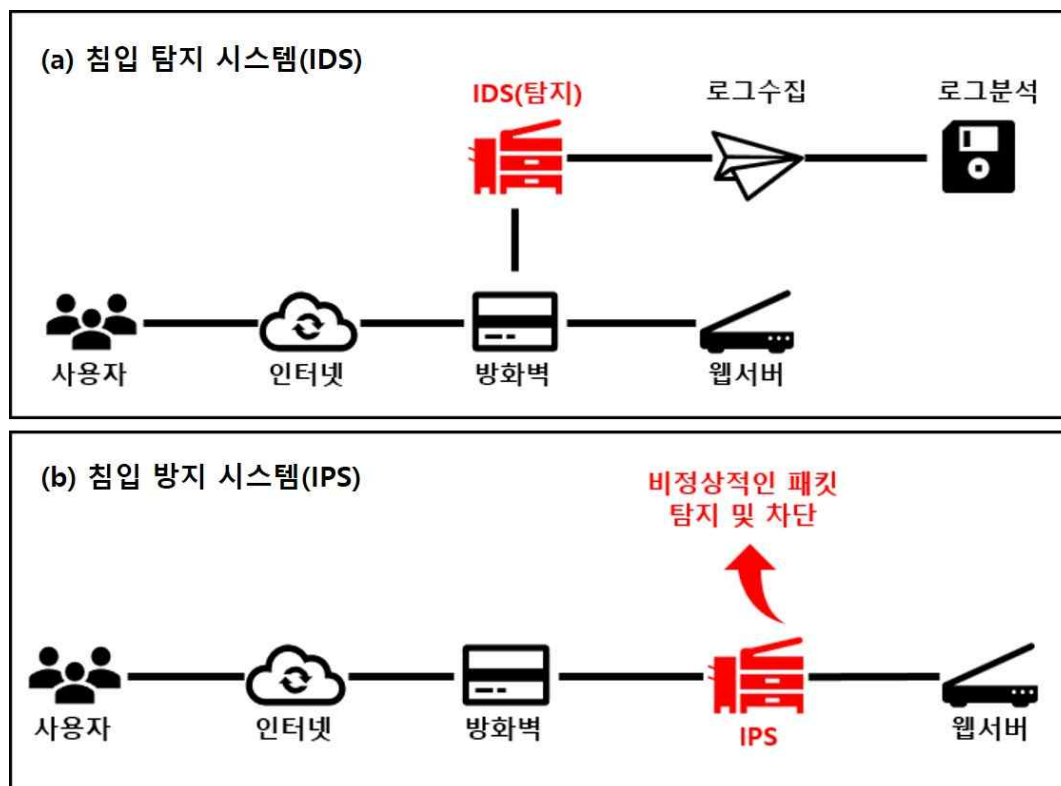
□ 침입 탐지/방지 시스템(IDS/IPS)

패킷의 헤더 정보만으로 패킷을 필터링하는 방화벽과 달리 침입 탐지 시스템(intrusion detection system, IDS)과 침입 방지 시스템(intrusion prevention system, IPS)은 데이터 영역에서 유해한 트래픽을 탐지 및 차단하기 위한 기술이다. 방화벽은 보안에서 가장 기본적인 수단이지만 차단할 수 있는 공격이 약 30% 정도 밖에 되지 않는다(양대일, 2021). 따라서 PC의 경우 백신을 설치하는데 기업 네트워크에서는 그 역할을 하는 것이 침입 탐지/방지 시스템(IDS/IPS)이다. 방화벽을 성문을 지키는 병사에 비유한다면, 침입 탐지/방지 시스템은 성 안을 순찰하는 병사에 비유할 수 있다(양대일, 2021).

침입 탐지 시스템(IDS)은 유해 트래픽의 탐지를 수행한다. 그 방법은 크게 오용 탐지와 이상 탐지로 나뉘어진다(양대일, 2021). 오용 탐지(misuse detection)는 이미 알려진 공격 패턴을 미리 입력해두었다가 이에 해당하는 패턴이 탐지되면 알려주는 것이다. 이상 탐지(anomaly detection)는 정상적이고 평균적인 상태를 기준으로 하여 상대적으로 급격한 변화를 일으키거나 확률이 낮은 사건이 발생하는 알려주는 것이다.

침입 방지 시스템(IPS)은 탐지와 차단 기능을 동일 장비에서 동시에 수행한다. 그래서 침입 방지 시스템은 침입 탐지 시스템과 방화벽의 조합으로 생각하면 된다(양대일, 2021). 즉 침입 탐지 기능을 수행하여 패킷을 검사 및 분석하여 정상적이지 않으면 방화벽 기능으로 패킷을 차단한다.

[그림 2-5] 침입 탐지/방지 시스템(IDS/IPS)



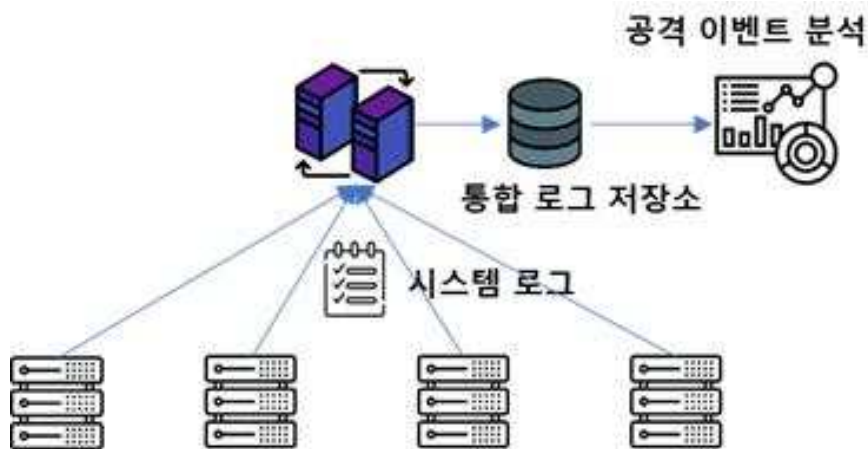
자료: <https://server-talk.tistory.com/289> (검색일 2022. 10. 20.).

□ 보안 정보 및 이벤트 관리(SIEM)

보안 정보 및 이벤트 관리(Security Information and Event Management, SIEM)는 네트워크 장비 및 보안 장비로부터 정보를 모으고 분석하여 위협을 탐지하는 기술이다. 보안 정보 및 이벤트 관리(SIEM)는 통합 로그 관리 시스템과 데이터 분석 시스템이 결합한 보안 기술이며 조직 내부에서 운영하는 다수의 서버, 네트워크 장비, 보안 시스템 등으로부터 로그를 수집하고 데이터 분석을 통해 악의적인 행위를 탐지하고 분류하는 기능을 제공한다(삼성SDS 기술사회, 2019).

과거에는 사후조치 위주의 보안 활동이었지만 점차적으로 보안 사고에 대한 징후를 사전에 탐지하고 예방 및 조치하기 위해 보안 정보 및 이벤트 관리(SIEM)의 중요성이 커지고 있다. 수많은 보안 로그 중에서 의미 있는 로그를 빠르게 분석하기 위해 빅데이터 플랫폼을 중심으로 구현되고 있다. 또한 인공지능을 이용한 분석 강화, 보안 취약점을 자동으로 탐색하고 대응하는 사이버 자가 면역 기술 등 새로운 기능이 지속적으로 개발되어 추가되고 있다.

[그림 2-6] 보안 정보 및 이벤트 관리(SIEM)



자료: 강혁(2022), p. 12.

□ 위협 탐지 및 대응(Detection and Response, XDR)

기존의 안티 바이러스의 경우 악성 코드의 고유한 특징을 패턴화한 시그니처 기반의 탐지 방식을 사용하고 있으나 위협 탐지 및 대응(XDR)은 행위 기반 탐지를 통해 사전에 정의된 특정 악성코드 뿐만 아니라 악의적인 행위를 수행하는 악성코드를 전반적으로 탐지하는 것이 가능하다(강혁, 2022). 악성코드로 판명된 정보가 있을 경우 해당 패턴을 XDR 엔진에 업데이트하고 모든 XDR 에이전트에 적용하므로 제로데이 공격과 같은 최초의 악성행위에 효과적으로 대응이 가능하다.

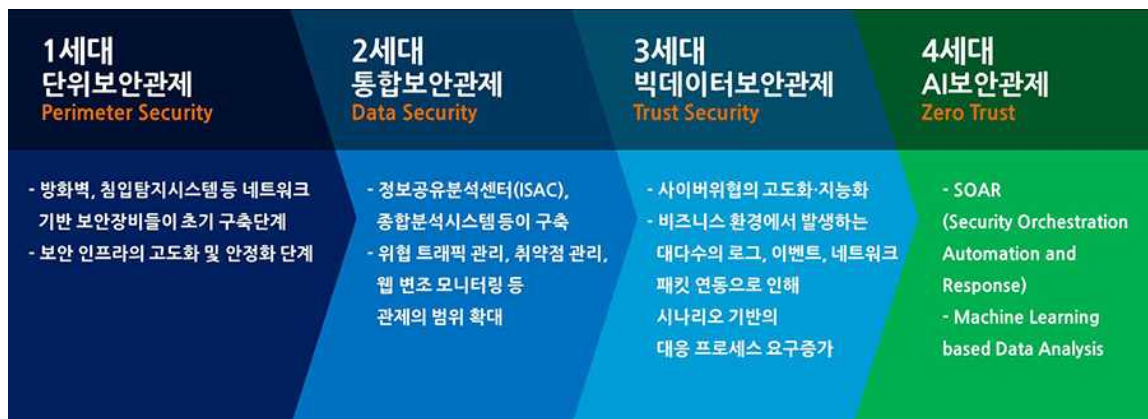
엔드포인트 탐지 및 대응(Endpoint Detection and Response, EDR)은 대표적인 XDR 솔루션이며 PC나 스마트폰, 태블릿 등의 엔드포인트 단말기에서 프로세스 생성, 레지스트리 변조, 외부 파일 다운로드 등 행위 정보를 수집하여 EDR 서버로 전송한다

(강혁, 2022). EDR 서버에서는 수집한 정보를 분석하여 사용자 단말기의 악성 프로세스 존재 여부를 판단한다.

3. 최근 보안 패러다임

보안 기업 이글루코퍼레이션에 따르면, 보안 관제는 보안 패러다임의 변화에 따라 단위보안 관제, 통합보안 관제, 빅데이터 보안 관제, 인공지능 보안 관제로 발전해 왔다(김미희, 2019. 7. 3.). 1세대 보안은 기업 내부와 외부를 분리하고 네트워크 보안 장비를 주로 활용하는 경계 보안(perimeter security)이고, 2세대 보안은 관제의 범위를 확대하여 기업 시스템 전반을 통합적으로 관리하는 통합 보안이며, 3세대 보안은 기업 내외부에서 발생하는 다양한 데이터를 활용하는 빅데이터 보안이다. 그리고 최근 4세대 보안은 인공지능 기술을 적극적으로 적용하고 있다.

[그림 2-7] 보안 패러다임의 변화



자료: 김미희(2019. 7. 3.), 「제로 트러스트(Zero Trust) 시대의 도래, 모든 것을 의심하고 조사하라」, 이글루, <https://www.igloo.co.kr/> (검색일 2022. 10. 27.).

최근 보안 패러다임은 과거에 비해 대상 범위는 기업 내 특정 경계면에서 기업 전반으로 확대되고, 그 수단은 하드웨어 장비뿐만 아니라 다양한 종류의 데이터와 인공지능 분석을 활용하는 방향으로 진화하고 있다고 볼 수 있다.

제2절 최근 보안 기술 동향: 제로 트러스트 모델을 중심으로

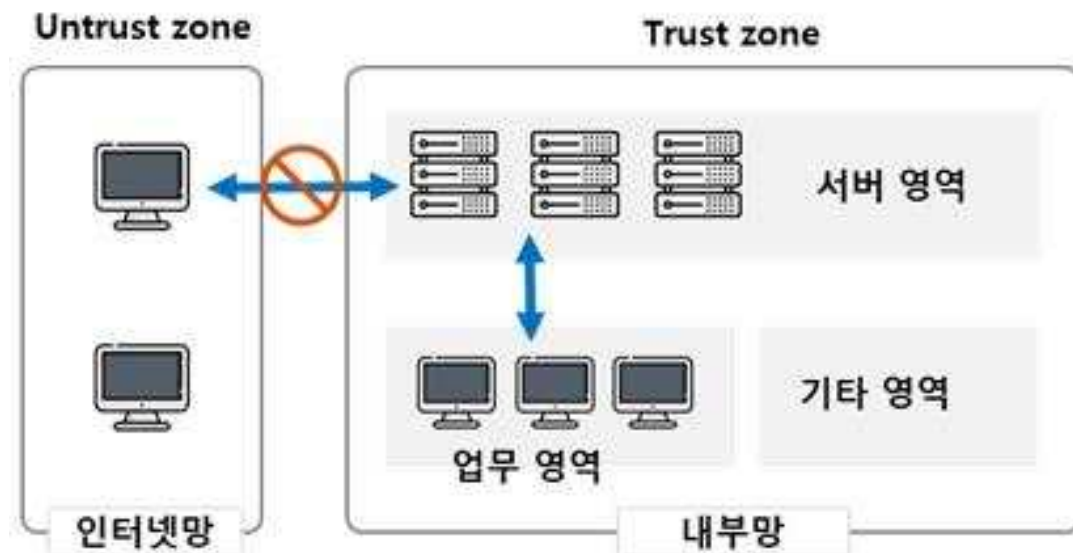
본 절에서는 최근 국내에서 관심을 모으고 있는 제로 트러스트 모델을 소개한다. 제로 트러스트 모델에 대한 관심이 높아지고 있고 이를 망분리 정책에 대한 대안으로 활용해야 한다는 주장이 제기된다. 제로 트러스트 모델의 특성을 명확하게 파악하기 위해 다른 종류의 접근 통제 모델인 경계 보안 모델을 먼저 소개한다. 참고로 망분리는 경계 보안 모델에 해당한다.

1. 경계 보안 모델

경계 기반 보안 모델은 조직에서 운영 중인 정보 시스템의 범위를 정의하고 해당 범위 내에 위치한 정보 시스템을 보호하는 모델이다. 조직의 보안 범위 내에 위치한 단말기 혹은 특정 네트워크 대역에서만 정보 시스템에 접근할 수 있으며, 인터넷 등 외부 네트워크에서는 정보 시스템에 접근할 수 없다. 망분리 조치는 이러한 경계 기반 보안 모델로부터 출발한 개념이다. [그림 2-6]과 같이 네트워크 대역을 기준으로 신뢰할 수 있는 영역(trust zone)과 신뢰할 수 없는 영역(untrust zone)을 구분하여 각 경계에서 접근 통제를 수행하는 것이 경계 기반 보안 모델의 기본 사상이다(강혁, 2022).

경계 기반 보안 모델은 외부로부터의 내부 정보시스템에 대한 보안 위협 차단에는 매우 효과적이지만 내부의 보안 위협에 대해서는 취약한 단점을 가지고 있기 때문에 내부자의 부정이나 침해 행위에 대해서는 별도의 보안 통제를 구현해야 한다. 또한 외부로부터의 접근을 원천적으로 허용하지 않기 때문에 스마트 워크나 재택 근무 등의 원격지 업무로 변화된 정보 기술 환경에 적용하기에는 여러 가지 한계를 보이고 있다.

[그림 2-8] 경계 기반 보안 모델 예시



자료: 강혁(2022), p. 3.

2. 제로 트러스트 모델

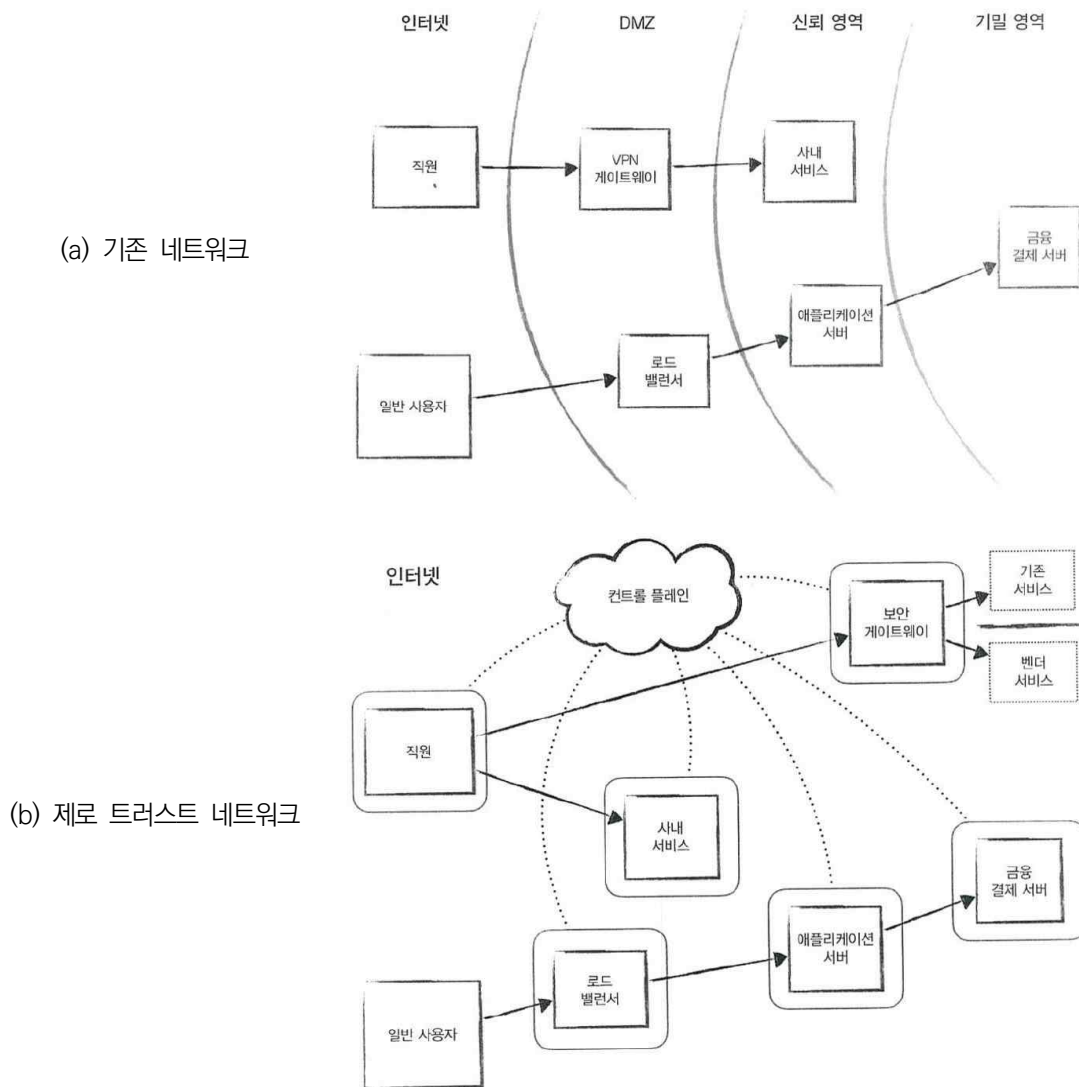
□ 제로 트러스트 모델의 개요

클라우드 서비스 확산, COVID-19 팬데믹 사태로 조직 내부가 아닌 외부 원격 근무 증가에 따라 전통적인 내부망과 외부망의 구분이 모호해지며 기존의 내 외부 네트워크 경계가 아닌, 새로운 신뢰 기반의 접근통제 모델이 주목받게 되었다. 이러한 신뢰 기반의 접근통제 모델 중 대표적인 것이 제로 트러스트 모델이다.

제로 트러스트 모델 또는 아키텍처(zero trust model/architecture)는 포레스터 리서치(Forrester Research)의 존 킨더버그(John Kindervag)가 2010년에 제안한 모델이다. 사용자가 정보 자원에 접근을 요청할 때 아무 것도 신뢰하지 않는다는 개념이다("never trust, always verify.")(이후기, 2022). 정보 자원의 물리적, 논리적인 위치와 상관 없이 모든 주체를 '신뢰할 수 없는 공격자'로 가정하고 정보 자원에 접근하려는 주체가 충분히 검증된 경우에 한하여 자원에 대한 접근 권한을 허가한다. 접근 권한을 할당받은 주체는 허가된 정보 자원에만 접근할 수 있고 그 외의 자원에는 접근할 수 없다. 즉 제로 트러스트는 사용자 접근 위치가 아니라 정보 시스템 접근 단말기

및 주체의 철저한 신원 검증과 최소 권한을 기반으로 하고 있으며 네트워크 경계가 없는 정보시스템 적용을 목적으로 한다. 이는 망분리 등 경계 보안 모델이 사용자의 접근 위치(내부)에 따라 권한을 부여하는 것과 대비된다.

[그림 2-9] 기존 네트워크와 제로 트러스트 네트워크의 비교



자료: Gilman, Evan, and Doub Barth(2022), p. 26, p. 28.

□ 제로 트러스트 모델의 7가지 기본 원칙

미국 국립표준기술연구소(NIST)는 2020년 제로 트러스트 아키텍처를 실현하기 위

한 7가지 기본 원칙(basic tenets)을 발표했다(Rose, S. et al., 2020).⁷⁾ 첫째, 모든 데이터 소스와 컴퓨팅 서비스는 자원이다(All data sources and computing services are considered resources)(Rose, S. et al., 2020). 여기서 자원이란 기업이 보호해야 하는 대상이라는 의미이다. 만약 개인이 소유한 기기도 기업의 자원에 접근할 수 있다면 자원으로 보호해야 한다. 둘째, 모든 통신은 네트워크 상의 위치에 관계없이 보안이 지켜져야 한다(All communication is secured regardless of network location)(Rose, S. et al., 2020). 즉, 기업이 소유한 네트워크를 통한 접속과 기업이 소유하지 않은 네트워크를 통한 접속은 동등한 수준의 보안 요구를 충족해야 한다.

[그림 2-10] 제로 트러스트 모델의 개념



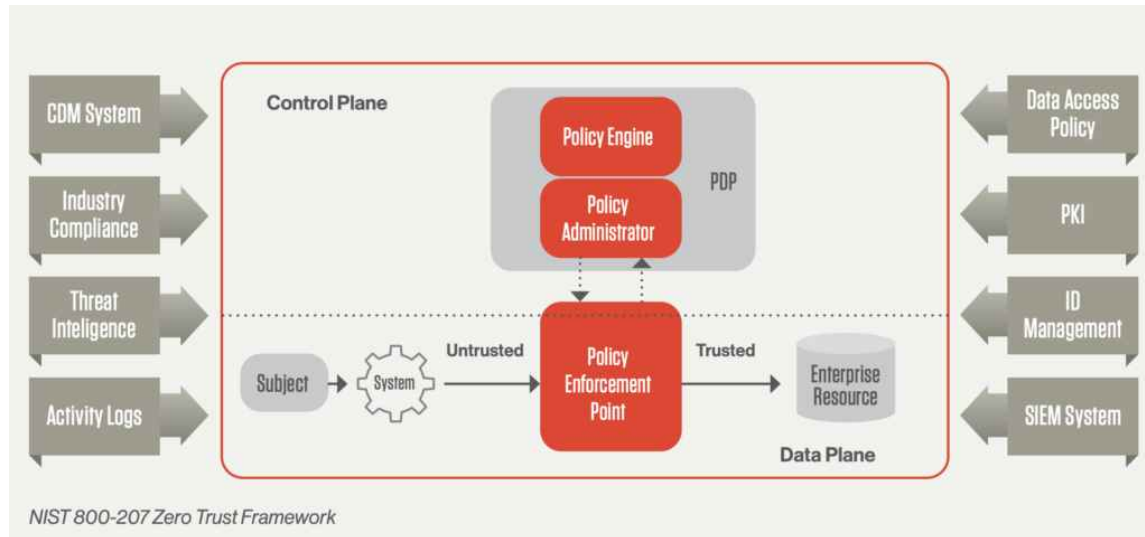
자료: <https://www.infusedinnovations.com/blog/secure-intelligent-workplace/pros-and-cons-of-the-zero-trust-model> (검색일 2022. 11. 5.).

7) <https://www.lgcns.com/blog/cns-tech/security/31896/> (검색일 2022. 10. 22.)

셋째, 기업의 개별 자원에 대한 접근은 세션마다 승인되어야 한다(Access to individual enterprise resources is granted on a per-session basis)(Rose, S. et al., 2020). 이전 세션에 대해 또는 기업의 다른 자원에 대한 접근이 승인되었다고 해당 자원에 대한 접근이 승인되어서는 안 된다. 넷째, 자원에 대한 접근은 고객 ID, 애플리케이션/서비스, 요청 자산 등의 상태를 따른 동적 정책에 의해 결정되어야 하고 다른 행태적, 환경적 특성을 고려할 수도 있다(Access to resources is determined by dynamic policy—including the observable state of client identity, application/service, and the requesting asset—and may include other behavioral and environmental attributes)(Rose, S. et al., 2020). 여기서 정책이란 조직이 지정한 특성에 기반한 접근 규칙의 집합이다. 예를 들어, 일반적인 사용 패턴에서 벗어난 행동이 관찰되면 접근은 허용되지 않아야 한다.

다섯째, 기업은 소유하거나 관련된 자산의 무결성과 보안 상태를 모니터링하고 측정해야 한다(The enterprise monitors and measures the integrity and security posture of all owned and associated assets)(Rose, S. et al., 2020). 어떤 자산도 원천적으로 신뢰하면 안 된다. 여섯째, 모든 자원에 대한 인증과 허가는 동적이고 접근이 허용되기 전에 엄격하게 적용한다(All resource authentication and authorization are dynamic and strictly enforced before access is allowed)(Rose, S. et al., 2020). 다요소 인증(MFA) 등의 수단을 통해 지속적으로 정보를 주고받으며 인증과 허가가 이루어져야 한다. 일곱 번째, 기업은 자산, 네트워크 인프라, 통신 등에 대한 가능한 많은 정보를 수집하고 이를 활용하여 보안을 개선해야 한다(The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to improve its security posture)(Rose, S. et al., 2020). 기업은 가능한 많은 정보를 통해 통찰을 얻고 이를 통해 새롭게 정책을 수립하고 실행해야 한다.

[그림 2-11] 제로 트러스트 모델의 원리



자료: <https://www.crowdstrike.com/cybersecurity-101/zero-trust-security/> (검색일 2022. 8. 16.)

□ 제로 트러스트 모델의 도입 추세

주요국에서는 제로 트러스트 모델의 도입을 적극적으로 추진하고 있다. 미국의 경우 제로 트러스트 모델 적용이 무척 활발하게 연구되고 있으며 미국국립표준기술연구소(NIST)에서 NIST.SP.800-207로 명명된 제로 트러스트 프레임워크 표준을 수립하여 공개하였다(Rose, S. et al., 2020). 조 바이든 미국 대통령은 2021년 5월 12일 사이버 보안 행정 명령(Executive Order, EO)을 통해 정부 기관들은 트러스트 아키텍처(zero-trust architectures)로 전환하고 다중 요소 인증(multi-factor authentication, MFA) 적용 및 전송 구간 암호화 구현을 180일 내에 가능하게 할 것을 발표하였다(White House, 2021. 5. 12.). 우리 정부도 2022년 2월 「정보보호 산업의 전략적 육성 방안」에서 “중요 기업 및 기반시설 보안을 개선하기 위해 제로 트러스트 보안정책 도입을 위한 기반 기술 확보 추진” 등의 정책을 발표한 바 있다(관계부처 합동, 2022. 2. 10.).

□ 제로 트러스트 모델의 장점과 단점

어떤 보안 모델과 마찬가지로 제로 트러스트 모델도 장점과 단점을 가진다. 장점은

기업의 전체 자원에 대해 보안 수준을 높일 수 있고 다양한 사용자에게 대해 안전하고 원활하게 서비스를 제공할 수 있다는 것이다. 단점은 처음에 제로 트러스트 모델을 시스템에 구현하는 데 상당한 시간과 투자가 필요하다는 것이다. 그리고 이를 운영하는 과정에서도 기기, 애플리케이션, 데이터 등의 자원과 다양한 유형의 사용자 그룹에 대해 모두 모니터링하고 인증하고 허가해야 하므로 관리의 난이도가 높아지고 부담도 커진다.

〈표 2-2〉 제로 트러스트 모델의 장점과 단점

구분	장점/단점	내용
장점	낮은 취약성 (Less vulnerability)	일단 구축이 되면, 기업을 안전하게 하며, 특히 다른 보안 모델에서 나타날 수 있는 내부 네트워크로부터의 위협에 대해 보안을 유지
	강력한 사용자 인식 및 접근 관리(Strong policies for user identification and access)	다요소 인증(MFA) 등을 통해 사용자 유형 및 작업 성격에 맞는 승인 및 허가가 가능
	스마트하고 안전한 데이터 관리 (Smart segmentation of data)	모든 데이터를 한꺼번에 관리하는 것이 아니라 데이터를 중요도에 따라 구분하여 관리하므로 중요한 데이터에 대한 위협이 저하
	효율적/효과적인 보안 체계 (Good security orchestration)	보안 상 허점이 발견되기 쉬워지고, 모든 보안 요소이 효율적이고 효과적으로 운영
단점	구축 시간 및 노력 (Time and effort to set up)	기존 시스템에서 새로운 시스템으로 이전하는 데 상당한 시간과 노력이 필요
	사용자 관리 부담 증가(Increased management of varied users)	임직원, 고객, 협력업체 등 다양한 사용자에게 대해 보안 정책을 수립하고 운영해야 하므로 부담이 증가
	관리해야 하는 기기 증가(More devices to manage)	모니터링하고 관리해야 하는 기기 및 네트워크의 종류와 수가 증가
	복잡한 애플리케이션 관리 (More complicated application management)	온프레미스(on-premise) 또는 클라우드 환경에서 다양한 플랫폼 위에서 작동되는 애플리케이션에 대한 관리 부담이 증가
	데이터 보안 난이도 증가 (More careful data security)	데이터가 저장되는 다양한 장소에 대해 보다 엄격한 보안이 이루어져야 하므로 관리 부담이 증가

자료: <https://www.infusedinnovations.com/blog/secure-intelligent-workplace/pros-and-cons-of-the-zero-trust-model> (검색일 2022. 11. 5.).

| 제3장 | 국내 보안 정책의 현황과 문제점: 망분리 규제를 중심으로

제1절 국내 보안 정책 현황

1. 국내 보안 환경의 특수성

□ 높은 연결성

보안 관점에서 우리나라의 가장 대표적인 특수성 중 하나는 네트워크 연결성, 즉 유무선 인터넷의 보급률과 활용도가 높다는 사실이다. 다음 표에서 알 수 있듯이 우리나라는 유무선 인터넷의 보급률과 활용도에서 세계 최고 수준에 올라 있다. 예를 들어, 인구 100명당 유선 브로드밴드 가입자 수에서 세계 평균은 13.6명이지만, 우리나라는 41.6명으로 거의 3배이며, 우리나라는 가입자 모두가 속도 10Mbps 이상의 고속 인터넷을 이용하고 있다(ITU, 2018).

<표 3-1> 주요 정보통신 지표의 국내외 비교(2017)

지표		우리나라	아시아태평양	세계
유선전화 가입자 수(인구 100명당)		52.7	9.5	13.0
휴대폰 가입자 수(인구 100명당)		124.9	104.0	103.6
유효 광대역 무선인터넷 가입자 수(인구 100명당)		112.8	60.3	61.9
3G 커버리지(전체 인구 대비 %)		99.9	91.3	87.9
LTE/WiMAX 커버리지(전체 인구 대비 %)		99.9	86.9	76.3
인터넷 이용자 비율(%)		95.1	44.3	48.6
컴퓨터 보유 가구 비율(%)		79.9	38.9	47.1
인터넷 연결 가구 비율(%)		99.9	49.0	54.7
인터넷 사용자당 해외 대역폭(kbit/s)		69.9	61.7	76.6
유선 브로드밴드 가입자 수(인구 100명당)		41.6	13.0	13.6
속도구간별 유선 브로드밴드 가입자 분포 (인구 100명당)	256kbps~2Mbps	-	2.4	4.2
	2Mbps~10Mbps	-	7.6	13.2
	10Mbps 이상	100.0	90.0	82.6

자료: ITU(2018), p. 93.

우리나라는 정보통신과 관련된 국가 단위의 경쟁력 지수에서도 상위권을 유지하고 있다. ICT 발전지수는 2017년 176개국 중에서 2위, 전자정부 발전지수는 2020년 193개국 중에서 2위, 온라인 참여지수는 2020년 193개국 중에서 1위, 네트워크 준비지수는 2020년 134개국 중에서 14위를 기록했다(국가정보원 외, 2021).

<표 3-2> 국제정보화 지수별 우리나라 순위

(단위: 위. 개국)

[작성기관] 지수명	지수 설명	우리나라 순위 (조사 대상 국가 수)													
		2007	2008	2009	2010	2011	2012	2013	2014	2015	2016	2017	2018	2019	2020
[ITU] ICT 발전지수	국가별 ICT에 대한 접근성, 이용도, 활용 역량 종합 평가	-	-	2 (159)	1 (159)	1 (152)	1 (155)	1 (157)	2 (166)	1 (167)	1 (175)	2 (176)	-	-	-
[UN] 전자정부 발전지수	국가별 ICT 주도의 발전을 위하여 전자정부를 이용하는 역량과 의지	-	6 (192)	-	1 (192)	-	1 (193)	-	1 (193)	-	3 (193)	-	3 (193)	-	2 (193)
[UN] 온라인 참여지수	국가별 온라인을 통한 시민의 공공정책 의사결정에 참여할 수 있는 수준	-	2 (192)	-	1 (192)	-	1 (193)	-	1 (193)	-	4 (193)	-	1 (193)	-	1 (193)
네트워크 준비지수	국가별 경제발전과 경쟁력 제고를 위하여 ICT를 활용하는 정도 측정	19 (122)	9 (127)	11 (134)	15 (133)	10 (138)	12 (142)	11 (144)	10 (148)	12 (143)	13 (139)	-	-	17 (121)	14 (134)

주: 1. ICT 발전지수: ITU, ICT Development Index.

2. 전자정부 발전지수, 온라인참여지수(격년제 발표): UN, United Nations E-Government Survey.

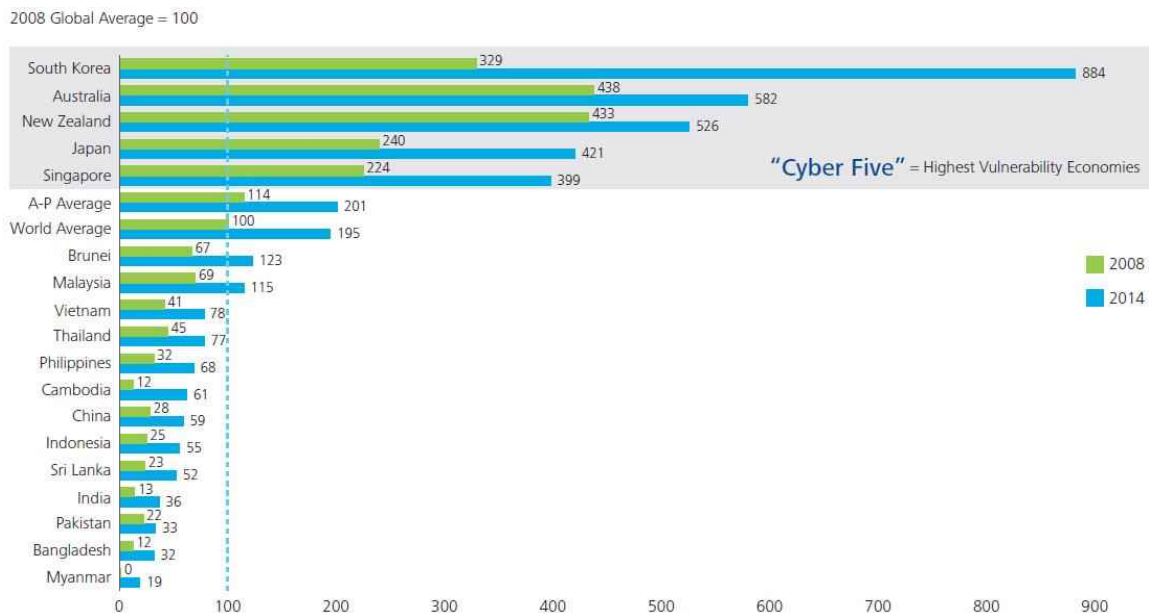
3. 네트워크 준비지수: Portulans Institute, Network Readiness Index.

자료: 국가정보원 외(2021), p. 69.

산업 및 사회 활동이 인터넷 기반으로 이루어진다는 것은 산업적으로나 사회적으로
는 바람직하지만 다른 한 편으로는 그만큼 외부의 침입에 노출될 수 있기 때문에 보안
적으로는 취약하다고 할 수 있다. 글로벌 컨설팅 업체인 딜로이트는 2016년 발간한
보고서에서 우리나라를 아시아태평양 지역에서 사이버 보안에 가장 취약한 국가라고
발표하였다(Deloitte, 2016). 딜로이트는 세계 각국의 휴대폰 가입자 수, 보안 서버
수, 유선 브로드밴드 가입자 수, 인터넷 사용량 등을 종합하여 ‘사이버 취약성 지수

(Cyber Vulnerability Index)’를 산출하였는데, 2008년 세계 평균이 100이라고 했을 때 우리나라는 2008년 329였고, 2014년 세계 평균이 195로 늘어난 데 비해 우리나라는 884로 증가했다(Deloitte, 2016). 우리나라에 이어 오스트레일리아, 뉴질랜드, 일본, 싱가포르도 사이버 보안이 취약한 국가들로 분류하였다.

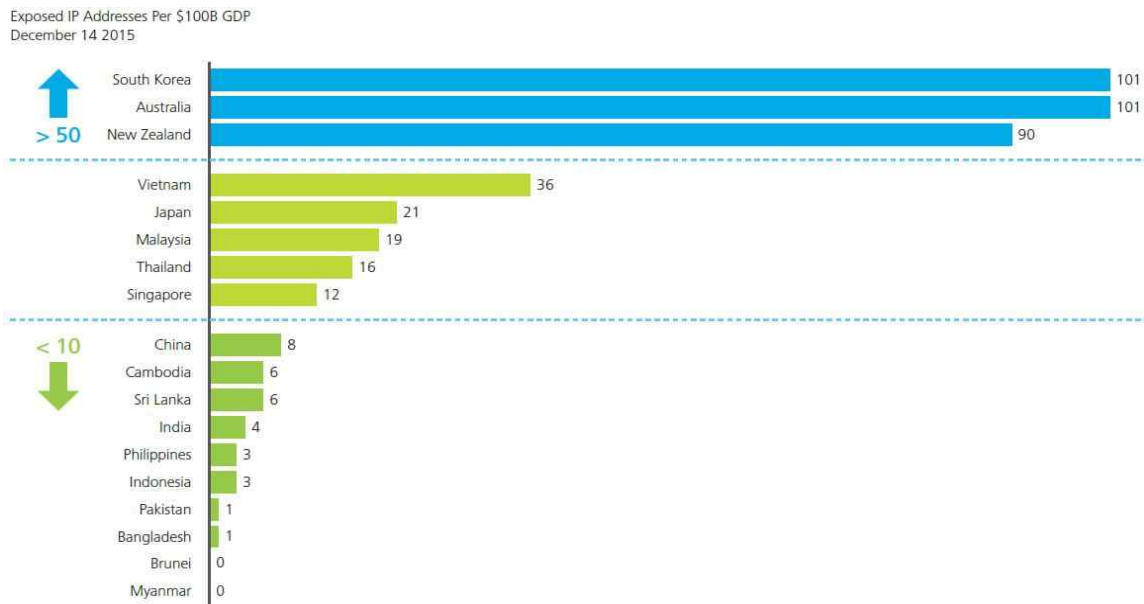
[그림 3-1] 딜로이트의 사이버 취약성 지수(Cyber Vulnerability Index)



자료: Deloitte(2016), p. 19.

또한 국가의 산업 인프라를 관리하는 정보시스템이 얼마나 인터넷에 연결되어 있는가에 대해서도 우리나라는 다른 아시아태평양 국가에 비해 월등히 높은 비율을 기록하고 있다. 예를 들어, 산업제어시스템(Industrial Control Systems)의 인터넷 연결성을 GDP로 표준화한 값을 국가별로 비교하면 우리나라(101)는 일본(21)에 비해 약 5배 높은 것으로 조사되었다(Deloitte, 2016).

[그림 3-2] 산업제어시스템(Industrial Control Systems)의 인터넷 연결성



주: GDP 1천억 달러당 산업용 IP주소의 수

자료: Deloitte(2016), p. 20.

여기서 한 가지 주의할 점은, 우리나라가 네트워크 연결성이 높아서 보안적으로 취약하다고 하는 것은 잠재적인 위협이 크다는 것을 의미할 뿐 실제로 보안 문제가 심각하게 발생하고 있다는 것은 아니라는 것이다. 실제로 우리나라는 ITU가 발표하는 세계사이버보안 지수(Global Cybersecurity Index)에서 전체 194개국 중에서 미국(100점, 1위), 영국(99.54점, 공동 2위), 사우디아라비아(99.54점, 공동 2위), 에스토니아(99.48점, 3위)에 이어 싱가포르, 스페인과 함께 공동 4위(98.52점)를 기록했다(ITU, 2021). 우리나라는 높은 네트워크 연결성으로 인해 잠재적인 보안 위협이 크지만 현재까지는 잘 관리되어 왔다고 할 수 있다.

□ 국가안보 상황

우리나라에서 보안 정책을 수립할 때 반드시 고려해야 하는 요인으로 북한과 대치하고 있는 상황을 빼놓을 수 없다. 다음 표에서 알 수 있듯이 최근까지도 북한은 자산 탈취와 군사·외교 기밀 확보와 같은 다양한 목적으로 세계 각국의 정부, 금융기관, 군사기관, 연구기관 등을 대상으로 광범위하게 사이버 공격을 진행하고 있다(김보미·오일석, 2021. 11).

<표 3-3> 김정은 시대 시기별 북한의 주요 사이버 공격 및 특징

시기	주요 사건	주요 사이버 공격 사례	특징
경제 핵무력 병진노선 (2013. 3.31 ~ 2018. 4.20)	핵실험 (2013.2.- 2017.9) 및 핵무력 완성 선언 (2017.11.29)	• 3.20, 6.25 DDos(2013) • 청와대 사칭 스마트폰 공격(2016.1) • 사이버사령부, 국방통합데이터센터 공격(2016.9) • 다음 이메일 해킹공격(2017.9) • 잠수함 기술 해킹(2016.4) • 소니픽처스(2014.11) • 한수원 해킹(2014.11~2015.4) • 워너크라이 랜섬웨어 2.0(2017.5) • 한국은행 서버 해킹 시도(2017.9)	사이버 무력행사 시기 (핵실험과 연계된 사이버 공격, 기반시설 마비를 통한 남한사회 교란, 국방 신기술 탈취, 미국에 대한 시위, 핵실험 재원 마련)
	포괄적 경제 제재 (2016. 3) 및 7차 당대회 (2016.5)	• 방글라데시 중앙은행 해킹(2016.2) • 국제금융기관 해킹(라자루스, 2016.10 ~2017.3) • 워너크라이 랜섬웨어 2.0(2017.5)	경제제재 회피 시기 (외화 획득(경제적 이득), 핵실험 재원 마련)
사회주의 경제건설 총력집중 (2018. 4.20 ~ 2021.1)	대화기 (평양-하노이 -판문점, 2018.2 ~2019.6)	• 통일부 대상 해킹 시도(2018,630건: 2019, 767건) • 국회 외통위, 정보위, 국방위 소속 의원 공격(2019.9) • 한글 취약점 이용 대북 전문가 공격 (2019.4)	대화탐색기 (남북대화 전략 파악)
	냉각기 (연락사무소 폭파, 2020.6~)	• 탈북, 외교안보 공격(2020.7)	남한과 미국의 대북전략 파악
	경제 개발 (2018~2020)	• 빗썸 가상화폐거래소 공격(2018.6) • 일본 가상화폐 코인체크 자산 탈취 공격(2018.1)	민생경제지원 공격기 (원산갈매(2018.3~ 2019.10), 평양종합병원 (2020.3~) 등 경제개발 외화벌이 공격)
	코로나19 이후 (2019.12~ 현재)	• 금융기관 공격(비글보이스 등, 2020. 2) • 가상화폐 거래소(2020.11), • 코로나 신기술 탈취 공격(신풍제약 등, 2020.12)	민생경제지원 공격 확산기 (외화획득으로 민생경제 지원, 코로나19 백신 및 치료제 기술 탈취 시도)
8차 당대회 이후 (2021.1. ~현재)	8차 당대회 (2021.1)	• 한국원자력연구원(2021.7) • 한국항공우주산업(2021.3 및 5) • 대우조선해양(2021.6) • 서울대병원(2021.6) • 한미정상회담 사이버 공격(2021.5전후) • 탈북, 조선노동당 8차 대회 분석 위장 이메일 해킹 공격(2021.2)	전방위 공격기 (신기술 탈취 공격, 민생경제지원 공격, 남북대화 탐색)

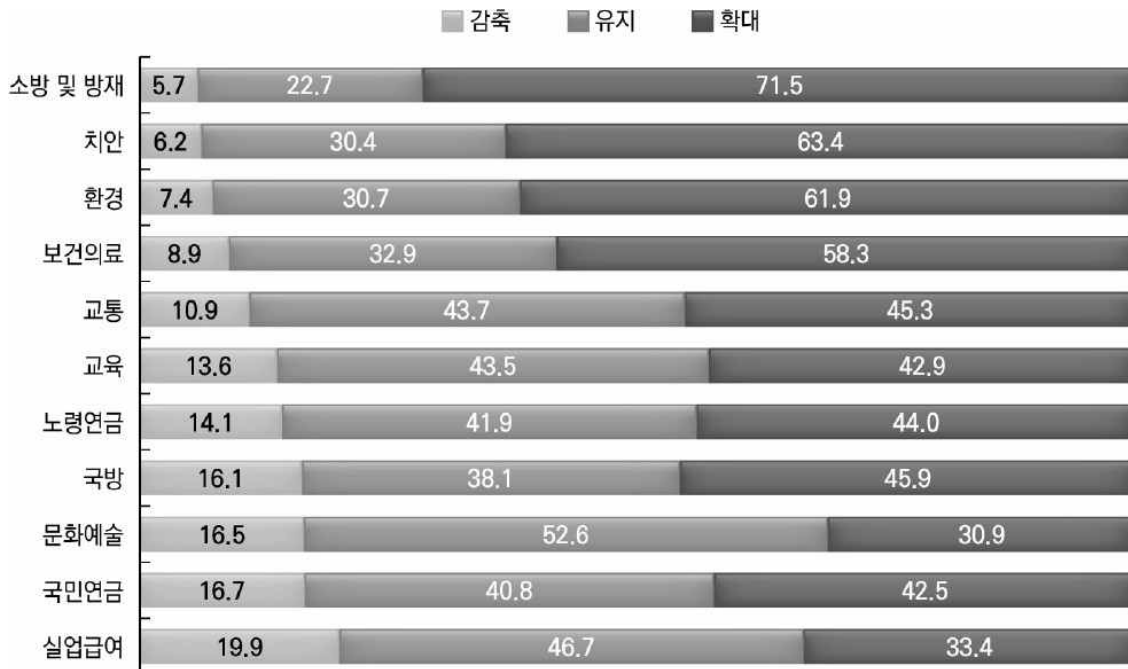
자료: 김보미·오일석(2021. 11), p. 13.

북한은 김정일 시대부터 사이버 공격 능력을 체계적으로 육성해왔고 김정은 집권 이후에도 핵, 미사일 등과 함께 중요한 전력 중 하나로 적극 활용하고 있다. 북한의 사이버 공격 인력은 2021년 현재 6,800여 명으로 2013년 3,000여 명에 비해 2배 이상 증가하였다(김보미·오일석, 2021. 11). 미국의 사이버 보안업체 크라우드스트라이크(CrowdStrike)는 2019년 북한의 사이버 공격 능력을 러시아에 이어 세계 2위로 평가하였다(김보미·오일석, 2021. 11).

□ 정부의 책임에 대한 국민의 인식 수준

국가적으로 중대한 사고가 발생했을 때 국민이 정부에게 책임을 묻거나 정부의 적극적인 역할을 기대한다는 점도 우리나라의 특수성으로 지적할 수 있다. 김상현(2019)에 따르면, 조사 대상의 과반수 이상이 소방·방재, 치안, 환경 등의 영역에서 정부 지출이 확대되어야 한다고 답변하였다(김상현, 2019). 즉, 국민들은 안전과 관련된 분야에서 정부가 적극적인 역할을 수행해야 한다고 생각하고 있다고 볼 수 있다.

[그림 3-3] 정책 영역별 정부 지출의 확대 필요성에 대한 국민의 인식



주: 1,500명 대상 조사, 단위 %

자료: 김상현(2019), p. 61.

2. 국내 보안 정책의 최근 동향

최근 핀테크 또는 테크핀 산업을 활성화시켜야 한다는 주장이 제기되면서 국내 보안 정책은 자율성과 유연성이 강조되고 있다. 아래의 표는 금융 분야에서 보안 정책의 시대적 변화를 정리한 것이다.

〈표 3-4〉 국내 금융 보안 정책의 시대적 변화

구분	내용
① 인프라 구축 시기 (2000~2010년)	- 2002년 세계 최초로 공인인증서를 전자금융거래에 적용 - 금융 정보공유·분석센터(ISAC) 설립 - 2005년 '전자거래 안전성 강화 종합대책' 발표: 금융권 보안프로그램 사용 등 - 2006년 금융보안의 기본 법규에 해당하는 「전자금융거래법」 제정
② 고도화 시기 (2011~2014년 상반기)	- 2011년 '금융회사 IT보안 강화 종합대책' 발표: 정보보호최고책임자 지정 의무화 - 2013년 '3.20 사이버테러' 후속 대책으로 '금융전산 보안강화 종합대책' 발표: 금융전산 망분리 및 이상금융거래탐지시스템(FDS) 구축 등 - 2014년 신용카드사 고객정보 유출사고가 발생하자, 관계부처 합동으로 '금융분야 개인정보유출 재발방지 종합대책'을 마련
③ 자율보안체계 정착 시기 (2014년 하반기 ~2017년)	- 2015년 'IT·금융융합 지원방안'(2015. 1.) 발표: 사전규제 최소화, 기술중립성 원칙 반영, 전자금융사고 책임부담 명확화 등 - '금융IT부문 자율보안체계 확립방안'(2015. 6.) 발표: 금융회사의 자율점검 강화, 이상금융거래정보 공유체계 구축, 금융보안원의 역할 부여 등
④ 디지털금융 혁신 시기 (2018년~현재)	- 2018년 '핀테크 혁신 활성화 방안'(2018. 3.)을 발표 - '금융권 클라우드 이용 확대 방안'(2018. 3.)을 발표 - '디지털금융 종합혁신방안'(2020. 7.)을 발표 - 2006년 제정된 「전자금융거래법」의 전면 개정을 추진

자료: 국가정보원 외(2021), pp. 119~120의 내용을 저자 정리.

금융위원회와 금융감독원은 2015년 6월 「금융IT부문 자율보안체계 확립 방안」을 통해 IT보안규제의 패러다임을 사전규제에서 사후규제로의 전환을 추진한다고 발표하였다(금융위원회·금융감독원, 2015. 6). 과거에는 사이버공격 방어 및 정보유출사고 방지 등 금융권 IT보안 강화를 위해 금융회사 및 전자금융업자에게 특정 보안·인증

기술의 사용 의무 등 보안 관련 규정을 항목별로 세세하게 규제해 왔으나 핀테크 산업 활성화를 위해 자율보안체계의 도입을 결정한 것이다.

「금융IT부문 자율보안체계 확립 방안」에서는 주요 추진과제로 자체 점검 및 책임 강화, IT보안 역량 향상, 민간 자율의 보안성 검토체계 구축, 감시체계 강화 등을 제시하였다(금융위원회·금융감독원, 2015. 6). 자율보안체계란 금융감독원에서 전담해오던 보안성심의가 폐지되고 금융보안이 전적으로 금융회사와 IT기업, 보안회사, 핀테크업체 등 민간 기업의 자율과 금융보안원·금융협회 등 민간기구의 의결에 맡겨진다는 것을 의미한다. 보안 관련 민간의 자체 점검 및 책임이 강화되고, 금융협회와 금융보안원 등 민간기구가 보안 체계 등을 구축하고, 금융당국은 관리·감독에 집중하는 형태로 금융보안이 관리되는 것이다.

[그림 3-4] 「금융IT부문 자율보안체계 확립 방안」(2015.6)



자료: 금융위원회·금융감독원(2015. 6), p. 3.

제2절 망분리 규제의 개요 및 문제점

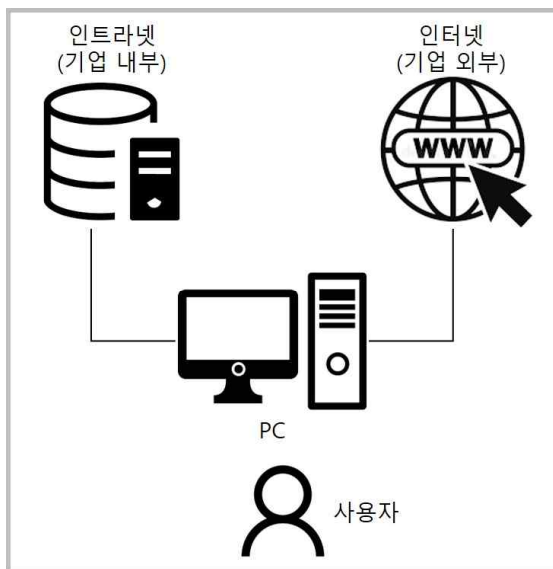
1. 망분리 규제의 개념

□ 망분리의 개념

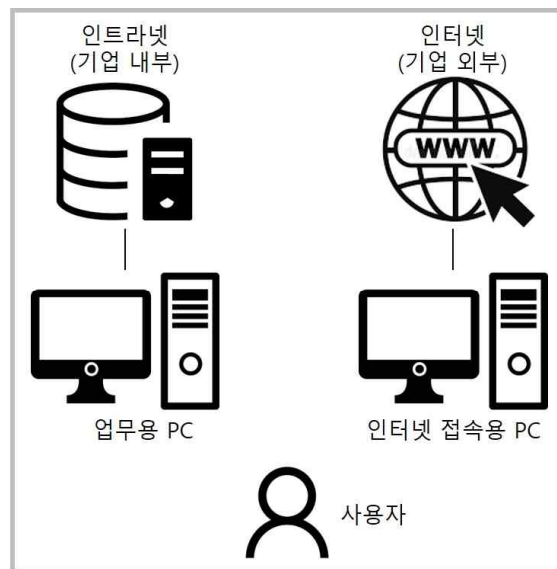
망분리 규제란 간단하게 표현하면 기업 내부의 업무용 시스템과 기업 외부의 인터넷을 분리하도록 의무화하는 것을 말한다. 즉, 기업에서 업무용으로 사용하고 있는 PC의 인터넷 연결을 차단하는 것이다. 따라서 직원 1인당 2대의 PC를 번갈아가며 사용해야 한다. 보고자료 작성, 프로그래밍 등 업무를 수행할 때는 인터넷이 안 되는 업무용 PC를 사용하고, 외부에 이메일을 보내거나 뉴스 검색할 때는 사내 업무망에 연결이 안 되는 인터넷용 PC를 사용한다. 그리고 외부와 이메일로 업무용 자료를 공유할 때에는 업무용 PC와 인터넷용 PC 간에 보안USB로 자료를 전달한다.

[그림 3-5] 망분리의 개념

(a) 망분리 규제 미적용



(b) 망분리 규제 적용



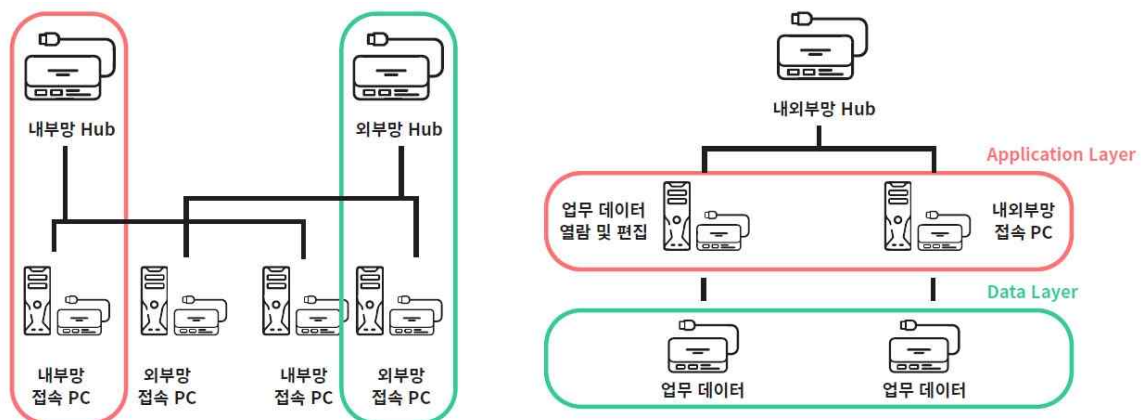
자료: <https://www.ciokorea.com/news/25647> (검색일 2022. 6. 20.)를 토대로 저자 작성.

망분리를 해야 하는 대상은 산업이나 관련 법마다 다르다. 금융 산업의 경우 ‘전자금융감독규정’에 따라 “내부통신망과 연결된 내부 업무용시스템”과 “인터넷(무선통신망 포함) 등 외부통신망”과 “분리·차단 및 접속 금지”해야 하고(전자금융감독규정 제15조), 개인정보를 다루는 인터넷 서비스 등의 산업에서는 “개인정보 보호법 시행령”에 따라 “개인정보처리시스템에 접속하는 개인정보취급자의 컴퓨터 등”을 “외부 인터넷망”과 “차단”해야 한다(개인정보 보호법 시행령 제48조의2). 가정용 CCTV 등과 같은 홈네트워크에서는 “지능형 홈네트워크 설비 설치 및 기술기준”에 따라 “단지서버”와 “세대별 홈게이트웨이”를 분리해야 한다(지능형 홈네트워크 설비 설치 및 기술기준 제14조의2).

□ 망분리의 유형: 물리적 망분리와 논리적 망분리

망분리에는 물리적 망분리와 논리적 망분리가 있으며, 앞선 설명은 엄밀하게 말하면 ‘물리적 망분리’에 해당한다. 즉, 물리적 망분리는 기업 내부 업무용 PC와 외부 인터넷용 PC가 네트워크의 물리적인 연결이 완전하게 차단되는 것을 말한다. 논리적 망분리는 기업 내부 업무용 PC가 외부 인터넷용 PC와 물리적으로는 연결은 되어 있지만 실제로 인터넷을 사용하려면 별도의 소프트웨어를 통해서만 가능한 것을 말한다(스타트업얼라이언스, 2020). 따라서 논리적 망분리에서는 직원이 업무 수행과 인터넷 접속을 위해 1인당 여러 대의 PC를 사용할 필요는 없다.

[그림 3-6] 물리적 망분리와 논리적 망분리의 비교



자료: 스타트업얼라이언스(2020), p. 32.

2. 국내 망분리 규제의 경과⁸⁾

국내에서 망분리 규제가 시행된 과정은 공공 부문에 도입된 2006~2010년, 민간 부문으로 확대된 2011~2016년, 규제 완화 요구에 따라 망분리 규제가 보완된 2016년 이후 등의 시기로 구분할 수 있다.

가. 공공부문 중심의 망분리 도입(2006~2010)

해킹과 정보유출의 위험도를 낮추는 방법으로 ‘망분리’를 먼저 도입한 것은 정부와 공공부문이다. 망분리 정책의 본격적인 시작점은 2006년이다. 2006년 5월 국가사이버안전전략 회의가 열리고, 6월 ‘해외발 국가기관 해킹 실태 및 대처방안’이라는 문서가 발표된다. 이 문서에서 최초로 국가기관 업무전산망과 인터넷 분리 방침이 언급되었다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022).

나. 민간, 금융으로의 망분리 확산(2011~2016)

정부 및 공공기관에 확산된 망분리 정책은 일정한 성과를 거두었으며, 2011년부터는 일련의 해킹사고를 계기로 민간부문으로 확산되기 시작한다. 2011년에는 3.4 DDoS라는 굵직한 사건이 터진다. 청와대, 국민은행 등 40개 기관이 공격받아 약 820여 대의 PC가 마비되고, 4월 12일 농협 전산망의 내부 서버가 파괴되고, 일주일간 금융거래가 마비되었다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022). 2013년에는 3.20 사이버테러가 일어나 KBS, YTN, MBC 등 언론사는 물론 NH농협은행, 신한은행, 제주은행 등 금융사가 커다란 손상을 입고 약 두 시간 동안 금융업무가 중단된다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022). 2012년 8월부터 정보통신망 이용촉진 및 정보보호 등에 관한 법률 시행령에 의해 개인정보취급자의 PC는 별도로 분리된 망을 사용하게 된다. 금융회사에도 망분리가 도입된다. 2013년 금융위는 7월 ‘금융전산보안강화종합대책’을 수립하고, ‘전자금융감독규정’을 개정한다. 금융회사 전산센터는 2014년, 은행의 본점과 영업점은 2015년, 보험, 카드, 증

8) 스타트업얼라이언스(2020), 한국인터넷기업협회(2022) 등을 종합하여 정리

권, 제2금융권은 2016년까지 망분리가 이루어지도록 했다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022).

다. 4차 산업혁명과 망분리 보완(2016~)

4차 산업혁명이 도래함에 따라 규제를 완화해야 한다는 업계의 요구를 수용하여 망분리 규제가 일부 보완되었다. 2016년 전자금융감독규정이 개정되어 논리적 망분리 허용, ‘비중요정보처리시스템’ 클라우드로 이관 가능 등의 내용이 담겼고, 2019년에는 ‘중요시스템’ 클라우드로 이관 가능 등의 내용이 추가되었다(스타트업얼라이언스, 2020; 한국인터넷기업협회, 2022).

<표 3-5> 망분리 정책의 경과

구분	내용
① 공공부문 중심의 망분리 도입 (2006~2010)	- 2006년 국가사이버안전전략회의, 망분리 최초 보고 - 2007년 망분리 시범사업(국무총리실, 통일부) - 2008년 정부부처 중심 1차 망분리 사업 - 2009년 기재부 업무망 해킹(4월), 7.7 DDoS, 국가사이버위기종합대책(9월) - 2010년 정부부처 중심 2차 망분리 사업
② 민간, 금융으로의 망분리 확산 (2011~2016)	- 2011년 3.4 DDoS(일주일간 금융거래 마비) - 2012년 정보통신망법 시행령 개정(개인정보 보유 PC 망 별도 분리) - 2013년 3.20 사이버테러(2시간 동안 금융업무 중단) - 2013년 금융전산 보안 강화 종합대책(7월), 전자금융감독규정개정(업무망/인터넷망 분리) - 2014년 금융회사 전산센터 망분리 완료 - 2015년 은행 본점, 영업점 망분리 완료 - 2016년 보험, 카드, 증권, 제2금융권 망분리 완료
③ 4차 산업혁명과 망분리 보완 (2016~)	- 2016년 전자금융감독규정 개정(영업점 PC 논리적망분리, ‘비중요정보처리시스템’ 클라우드로 이관 가능, 이 경우 물리적 망분리 예외 적용) - 2017년 ATM 이용자 정보 유출 - 2018년 금융위 ‘금융권 클라우드 확대 방안’ - 2019년 전자금융감독규정 개정(‘중요시스템’ 클라우드로 이관 가능)

자료: 스타트업얼라이언스(2020), p. 34.

3. 망분리 규제의 장점과 단점

□ (장점) 인터넷을 통한 위협 차단

망분리는 인터넷 접속을 사전에 차단하므로 기업 내부 시스템에 악성코드나 바이러스 유입 등과 같은 보안 사고가 발생할 가능성을 낮출 수 있다. 예를 들어, 2013년에 발생한 카르바나크 해킹 사고가 있다.⁹⁾ 국제 수사당국에 따르면 러시아와 우크라이나, 유럽, 중국 출신 범죄자들로 구성된 ‘카르바나크’라는 범죄 집단이 2013년부터 2년 동안 러시아, 우크라이나, 미국, 독일, 중국, 일본 등 30여개국 100여개 은행을 해킹했다고 한다. 정확한 피해 규모는 파악되지 않았지만 약 10억 달러로 추정된다. 이 사고로 국내 은행들은 피해를 입지 않은 것으로 알려져 있다.

따라서 인터넷 차단에서 초래되는 불편함에도 불구하고 그러한 망분리 구성을 불가피하게 선택해야 하는 경우도 있을 수 있다. 국가안보시설이나 주요기반시설 등 매우 중요한 시설의 경우에는 인터넷은 물론이고 어떠한 네트워크와도 완전히 차단된 폐쇄형 구조를 생각해 볼 수 있다(한국인터넷기업협회, 2022). 즉, 보호대상의 중요성이 매우 높다면 인터넷의 연결을 완전히 차단하는 불편은 감수해야 하는 것이다.

□ (장점) 직관적이고 이해하기 용이

망분리는 직접적인 보안 효과만큼이나 직관적이고 이해하기 쉽다는 점도 장점이라고 할 수 있다. 보안 전문가가 아닌 정책 담당자나 일반 국민이 망분리를 선호하는 이유라고 할 수 있다. 실제로 정부는 망분리 규제 이후 보안 사고가 많이 감소했다고 발표한 바 있다. 예를 들어 「4차 산업혁명 시대의 디지털금융 종합혁신방안: 전자금융 거래법령 등 개정방향」에서는 망분리 이후 금융권 보안사고가 지속적으로 감소했고, 2017년 전세계적인 랜섬웨어(악성코드 일종) 피해에도 국내 금융권 피해는 없었다고 지적하였다(금융위원회, 2020. 7).

9) <https://www.hani.co.kr/arti/international/globaleconomy/678737.html>; <https://zdnet.co.kr/view/?no=20150217095849> (검색일 2022. 7. 20.).

□ (단점) 기업 효율성 저하

망분리는 여러 가지 측면에서 기업의 효율성을 저하시킨다. 첫째, 기업의 투자비 증가이다. 단순히 계산하더라도 업무용 PC와 인터넷 접속용 PC를 별도로 구매해야 하므로 PC, 소프트웨어 라이선스, 네트워크 장비 등의 비용이 추가로 발생한다. 논리적 망분리의 경우 PC를 구매하는 비용은 줄어들지만 망연계 솔루션 구매 등으로 추가 비용이 발생한다. 업계 추산에 따르면 25인 기업의 경우 약 5억 원이 소요되고 기업 규모가 클수록 비용은 늘어난다(스타트업얼라이언스, 2020). 이는 모든 기업에게 부담이 될 수 있지만 특히 초기 스타트업에게는 진입장벽으로 작용할 수도 있다.

둘째, 업무의 생산성 저하가 우려된다. 최근에는 소프트웨어를 개발할 때 오픈소스의 활용이 필수적인데 망분리 하에서는 데이터, 분석·개발 도구, 오픈소스 등이 물리적으로 분리되어 있어서 개발자들이 모든 소스코드에 대해 반입·반출 허가를 받아야 하는 등 업무 상 불편함을 감수해야 한다. 또한 ‘내부통신망과 연결된 내부 업무용시스템’이라는 모호한 적용 범위는 업무 현장의 혼란을 가중시킨다. 이는 업무 증가 등의 형태로 눈에 보이지 않는 규제 준수 비용을 발생시킨다. 업계에서는 망분리로 인해 개발자의 생산성이 약 50% 하락하여 더 많은 개발자가 필요하게 됨으로써 개발자 인건비가 약 30% 증가한다고 한다(스타트업얼라이언스, 2020). 이는 숫자화할 수 있는 비용 증가 이외에도 인터넷 기업과 금융 스타트업에게 중요한 개발 속도와 혁신에 부정적인 영향을 미친다. 당국의 제재/처벌에 따른 기업 이미지 하락도 우려된다.

“최근 개발환경의 필수요소인 오픈소스, API 등 라이브러리 활용이 어렵습니다. github, stack over-flow 등 대표적인 오픈소스 개발자 커뮤니티에는 수십 조의 연구개발비로도 못 해내던 프로젝트의 소스코드가 무료로 개방되어 있습니다. 개발자는 이를 활용해 빠르고 유연하게 새로운 제품과 서비스를 만들고, 이를 이용한 결과물을 외부에 공개함으로써 다시 개발자 커뮤니티에 기여합니다. 망분리 환경으로 이렇게 자원 활용을 어렵게 하는 것은 스타트업의 주무기인 속도와 유연성을 빼앗는 것.” (스타트업얼라이언스, 2020),

□ (단점) 인력 유출 우려

산업의 매력도가 하락하여 인력 유출이 우려된다. 최근 스타트업에서는 개발자를 확보하는 것이 쉽지 않은 과제이다. 연구팀이 인터뷰한 기업 관계자들은 개발자들이 본업인 개발에 집중하지 못하고 망분리 환경에서의 개발 환경을 마련하는 일에 많은 시간을 투입할 수 밖에 없기 때문에 금융 분야를 기피하거나 이탈하는 현상이 나타나고 있다고 지적한다. 따라서 인력 유출은 장기적으로 앞서 지적인 투자비 증가나 생산성 저하보다 더 심각하게 산업 발전에 부정적인 영향을 미칠 수 있다.

“실력 좋은 개발자를 영입하려고 해도 망분리 규제 때문에 핀테크사에 오기를 꺼려함...개발자들이 말 그대로 '개발'을 하는 업무를 하는 데 시간을 쓰는 것이 아니라 망분리 환경을 만들고 적응하는 데 더 시간을 쓴다는 말이 나올 정도로, 단순히 개발 인원을 늘린다고 해결되는 문제가 아니라 전반적인 개발 환경에 부정적인 영향을 미침.” (핀테크 기업 임원) (아산나눔재단 등, 2020)

□ (단점) 국내 보안산업 발전 저해

보안 전문가들은 규제 중심의 보안이 국내 보안 수준을 하향 평준화시킨 주범이며 정보보안 시장 성장 한계의 원인이라고 지적한다.¹⁰⁾ 일반적으로 기업은 매출액의 일정 비율을 보안에 투자하게 되는데 망분리를 위한 비용이 발생하면 추가적인 보안 투자를 기피할 우려가 있다. 즉, 기업이 상황에 맞게 보안 투자를 하는 것이 아니라 망분리 규제 준수(compliance)에 집중하게 된다는 것이다. 보안 산업은 특히 공공 부문의 수주가 큰 비중을 차지하는데 공공, 금융 부문의 보안이 망분리로 규제되어 있기 때문에 정보보안 산업 시장이 확대되지 못하는 측면도 있다.

2021년 전 세계 정보보안 시장은 약 1.3억 달러(약 156조 원) 규모이며, 미국, 중국, 영국, 일본, 독일 등이 높은 비중을 차지한다(한국인터넷진흥원, 2022). 그에 비해 국내 정보보안 산업은 2020년 기준 3조 9천억 원 규모로 세계 시장의 약 2.5% 수준에 그치고 있다(과학기술정보통신부·한국정보보호산업협회, 2020). 정보보안 산업 내에

10) <https://www.joynews24.com/view/975645> (검색일 2022. 11. 9.)

서 망분리 관련 솔루션이 포함된 네트워크 보안 시스템 개발은 약 8,259억원의 매출을 보이며 국내 정보보안 시장의 21.1%를 차지하고 있다(과학기술정보통신부·한국정보보호산업협회, 2020).

<표 3-6> 전 세계 정보보안(사이버보안) 시장 주요국 및 규모(2021)

(단위: 백만 달러)

순위	국가	시장규모	비중(%)
전 세계		132,152	100
1	미국	54,108	40.9
2	중국	9,922	7.5
3	영국	8,641	6.5
4	일본	7,128	5.4
5	독일	6,571	5.0
5개국 합계		86,370	65.0

자료: 한국인터넷진흥원(2022), p. 9.

<표 3-7> 국내 정보보안 산업 매출 현황(2020)

(단위: 백만원)

정보보안 산업 중분류			매출 추이	비중(%)
전체	정보보안 시스템 개발 및 공급	네트워크 보안 시스템 개발	825,907	21.1
		시스템 보안 솔루션 개발	572,811	14.7
		정보유출 방지 시스템 개발	459,572	11.8
		암호/인증 시스템 개발	196,538	5.0
		보안관리 시스템 개발	343,050	8.8
	소계		2,397,878	61.4
	정보보안 관련 서비스		1,509,547	38.6
			3,907,425	100

자료: 과학기술정보통신부·한국정보보호산업협회(2020), pp. 25~26을 바탕으로 작성.

국내 정보보안 시장의 특징은 물리보안 영역과 비교하면 분명히 나타난다. 일반적으로 정보보호 산업은 크게 정보보안과 물리보안 산업으로 나뉜다. 정보보안은 컴퓨터 또는 네트워크 상 정보 유출·훼손 등을 방지하기 위한 보안으로 해킹/침입 탐지, 개인정보 유출 방지, 컴퓨터 포렌식 등이 해당되며, 물리보안은 재난재해, 범죄 등을 방지하기 위한 영상 감시, 바이오 인식, 무인전자경비 등을 의미한다(과학기술정보통신부·한국정보보호산업협회, 2020). 정보보안 선진시장인 미국, 일본, 영국 등은 정보보안 시장이 물리보안 시장의 약 2~3배의 규모를 보인다. 하지만 국내 시장은 2020년 기준 정보보안 시장이 3조 9천억 원, 물리보안 시장이 7조 9천억 원으로 물리보안 시장이 약 2배 더 크다. 이와 같이 다른 나라에 비해 국내 정보보안 산업 규모가 작은 이유는 망분리 규제의 영향이 클 것으로 판단된다.¹¹⁾

〈표 3-8〉 주요국의 정보보안 산업과 물리보안 산업 규모 비교

(단위: 십억 달러, 조 원)

국가	정보보안		물리보안
미국(십억 달러)	52.55	>	26.06
일본(십억 달러)	5.39	>	2.68
영국(십억 달러)	12.02	>	4.00
한국(조 원)	3.9	<	7.9

주: 미국·일본·영국 수치는 2018년 기준이며, 한국 수치는 2020년 기준

자료: 디지털데일리(2021. 3. 19.); 과학기술정보통신부·한국정보보호산업협회(2020), p. 25.

□ (단점) 내부인 등 다양한 경로를 통한 위협에 취약

앞서 설명한 대로 망분리는 인터넷 접속을 사전에 차단하여 직접적인 보안 효과를 가져다 주지만 다른 보안 수단과 마찬가지로 그것만으로 완벽한 보안을 보장하지는 않는다.

11) 디지털데일리(2021. 3. 19.), 'IT 강국의 민낯... 물리보안에 여전히 크게 밀리는 정보보안, 왜?', <https://www.ddaily.co.kr/news/article/?no=210943> (검색일 2022. 7. 20.).

망분리는 기업 시스템과 인터넷이라는 특정 경로에 치중하는 경계 보안 모델이므로 다른 경로에 대한 대비는 부족하다. 예를 들어 국내 핀테크 기업의 보안 담당자는 비유적으로 망분리는 뒷문 단속이기 때문에 서비스를 위한 앞문으로는 외부에서 충분히 공격 가능하다고 말한다. 1936년 프랑스가 2차 세계대전을 대비해 독일과의 국경에 쌓은 요새 ‘마지노 선(Ligne Maginot)’에 비유할 수 있다. 프랑스는 당시 마지노 선이 강력하다고 홍보하였지만, 정작 2차 세계대전이 발발하자 독일이 다른 나라로 우회하여 프랑스로 침고하는 바람에 무용지물이 되고 말았다. 또한, 특정 경계면에 치중하는 망분리는 최근 보안 환경 변화에도 맞지 않는다. 최근에는 기업에서 클라우드 시스템을 활용하는 경우도 많고 COVID-19으로 원격근무도 늘어나고 있어서 기업 내부 시스템과 외부 인터넷의 구분이 모호하다. 기업 내외부에서 점점 더 많은 기기들이 인터넷에 연결되고 있는 상황에서 특정 경계면만을 차단하는 것이 향후에도 효과를 발휘할지는 의문이다.

[그림 3-7] 마지노 선(Ligne Maginot)



자료: <https://www.le-lorrain.fr/blog/2015/09/23/la-ligne-maginot/> (검색일 2022. 11. 5.).

망분리는 특히 내부로부터의 보안 위협에 취약하다. 최근 10년간 발생한 사이버 공격 중 대규모의 개인정보유출을 초래한 사건 상당수는 내부 직원, 외주 직원, 용역 직원, 외주 업체 직원 등 상시적 또는 한시적인 권한으로 중요 정보에 접근이 허용된 신뢰된 사용자에게 의해 발생되었다(금융보안원, 2018). 그리고 이러한 보안 사고들은 공통적으로 그 피해 규모가 매우 컸으며 외부 사용자에게 의한 공격에 비해 피해 사실을 인지하는 데 더 많은 시일이 소요되었다는 특징을 보였다(김미희, 2019. 7. 3.).

〈표 3-9〉 2008~2018년 주요 사이버 공격 사고 중 내부자로 인한 사례

사고명	발생일	사고 개요
캐피탈사 홈페이지 고객정보 유출공격	2011.4	2011년 4월 A캐피탈사의 전직 직원이 퇴사 후, 재직 시 부여되었던 5개의 계정을 해커에게 전달, 해커는 금융회사의 서버와 통신하는 벤더사의 보조서버인 광고메일발송서버 및 정비내역조회서버에 정상 접속한 후 화면복사나 다운로드 방식으로 금융회사의 내부 서버에서 개인정보 약 175만 건 유출
카드사 개인정보 유출공격	2011.8	내부직원이 서버를 196회에 걸쳐 조회하여 47만 여건의 개인정보를 노트북에 복사 후 일부 유출하고, 텔레마케팅 업체에 개인정보를 전달
캐피탈사 개인정보 유출공격	2013.5	내부직원이 고객 8,000여명의 개인정보와 신용정보를 조회하고 유출, 회사 개인정보처리 시스템에 접속해 고객정보를 조회, 고객의 성명·휴대전화번호·회사명·신용등급 등이 담긴 정보를 별도 엑셀파일로 작성한 후 회사 프린터로 출력, SNS를 통해 문자 또는 조회화면 사진파일을 제3자에게 전달
은행 개인정보 유출공격	2013.12	은행 IT 전산센터 외주직원이 고객정보 10만3천 건을 USB에 저장해 제3자에게 전달하고 은행 대출담당 직원이 실적을 올리기 위해 고객정보 3만4천 건을 문서로 출력, 대출모집인에 전달
카드 3사 정보 유출공격	2014.1	국내 카드 3사의 고객 거래정보 약 1억400백만 건이 FDS 개발 용역직원을 통해 외부로 유출
보험사 고객정보 유출공격	2014.1	외주업체 직원 노트북으로 고객정보 35만 건 유출
빗썸	2017.6	빗썸 직원의 개인PC에서 고객 개인정보를 탈취 및 악용하여 인증정보를 알아내 70억원 상당의 가상통화를 부정 인출
코인레일	2018.6	거래소 직원PC 해킹 후, 가상통화 지갑을 탈취하여 350억원 상당의 가상통화를 부정 인출

자료: 금융보안원(2018), pp. 97~103에서 발췌.

망분리 하에서 물리적 또는 논리적 연결은 차단되었지만 실제로 내부 시스템과 외

부 인터넷은 USB 등을 통해 어떤 형태로든 자료가 교환될 수 밖에 없기 때문에 USB 오토런(Auto Run) 등을 통해 USB가 바이러스에 감염되었을 경우 대응 방법이 없다. 최근에는 USB를 RF 전송기로 활용하거나 CPU 전자기 신호를 이용하거나 HDD LED 표시등을 분석하거나 적외선 원격제어, 초음파 통신 등을 이용하는 등 망분리 환경 하에서의 해킹 기술도 발전되고 있다.¹²⁾

망분리 하에서는 새롭게 개발되는 보안 기술을 적용하기 어려우므로 보안이 취약해질 우려가 있다. 보안은 근본적으로 허점을 찾으려는 공격자와 이들을 막으려는 설계자나 관리자 사이의 기술적 싸움이므로 정기적으로, 더 나아가 항상 모니터링 해야 하는 것이 중요하다(Stallings, 2017). 일반적인 기업 시스템은 정기적으로 또는 새로운 보안 기술이 개발되거나 보안 위협이 우려될 때 보안 프로그램을 실시간으로 업데이트하지만 망분리 하에서는 불가능하다. 현장에서는 금융감독원 가이드에 따라 하루에 한번 수작업으로 업데이트를 하는 상황이라고 한다.

종합하면, 정보보안의 3원칙(C.I.A.) 관점에서 망분리는 직접적 경로를 통한 위협에 대해서는 기밀성과 무결성이 비교적 우수하지만 우회적 경로를 통한 위협에 대해서는 기밀성과 무결성이 미흡하다. 가용성 측면에서는 인가된 사용자가 요구하는 정보, 시스템, 자원 등의 접근을 적시에 제공하기 어려우므로 매우 미흡하다고 할 수 있다.

〈표 3-10〉 정보보안의 3원칙(C.I.A.) 관점에서 본 망분리

	기밀성(Confidentiality) (정보가 비인가된 개인/ 프로그램/프로세스에 공개되지 않음을 보장)	무결성(Integrity) (비인가된 자에 의한 정보의 변경, 삭제, 생성 등을 방지)	가용성(Availability) (인가된 사용자가 요구하는 정보, 시스템, 자원 등의 접근을 적시에 제공)
직접적 경로 (인터넷 등)	비교적 우수 (완벽하지는 않음)	비교적 우수 (완벽하지는 않음)	매우 미흡
우회적 경로 (내부인 등)	미흡	미흡	매우 미흡

자료: 저자 작성.

12) 보안뉴스(2018. 5. 19.), “[주말판] 보안의 궁극 망분리, 여태까지 나온 모든 공략법” <https://www.boannews.com/media/view.asp?idx=69597> (검색일 2022. 7. 20.).

이처럼 망분리는 인터넷을 사전에 차단하므로써 보안성이 높을 것으로 기대되지만 실제로는 보안 효과가 기대만큼 확실하다고 보기 어렵다. 실제로 망분리 환경에서도 보안 사고가 지속적으로 발생하고 있다.

〈표 3-11〉 망분리 환경에서의 보안 사고 사례

보안 사고	내용
이란 핵시설 보안 사고 (2010)	직원이 무심코 주운 USB를 들고 핵시설 안으로 들어가 안에 있던 악성코드가 제어시스템에 설치. 스텍스넷(Stuxnet)은 원전 제어시설을 감염시키고 원심분리기를 조작, 1천 개 이상 파괴
한국수력원자력 해킹 (2014)	해커는 메일에 악성코드가 포함된 한글파일을 첨부하고, 업무와 관련된 것처럼 메일 내용을 위장해 직원들이 이를 실행하도록 유도
인터파크 DB 유출 (2016)	담당자PC가 내/외부망에 연결이 가능하여 개인정보 DB에 접근가능, 해커는 스피어피싱으로 담당자PC에 악성코드 감염, DB서버에 접속하여 개인 정보 탈취 및 유출
국방부 해킹 (2016)	군 내부 백신 중계 서버가 내/외부망 동시 연결로 인해 해킹이 발생. 약 3,200대가 감염되고, 군사비밀을 포함한 일부 군사 정보가 유출됨. 북한 소행으로 추정

자료: 스타트업얼라이언스(2020), p. 33.

제3절 보안 패러다임 전환의 필요성

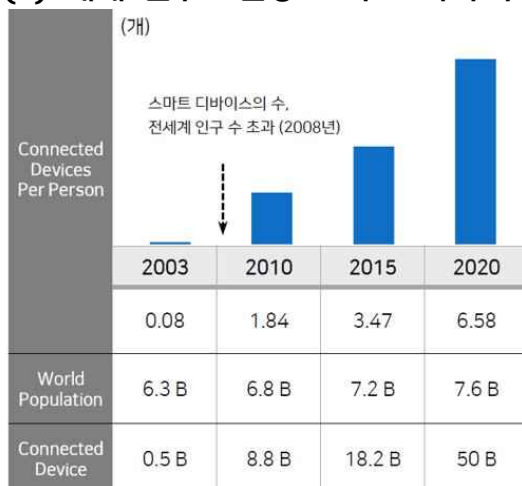
1. 초연결 및 디지털 전환 시대의 도래

□ 초연결과 디지털 전환의 개념

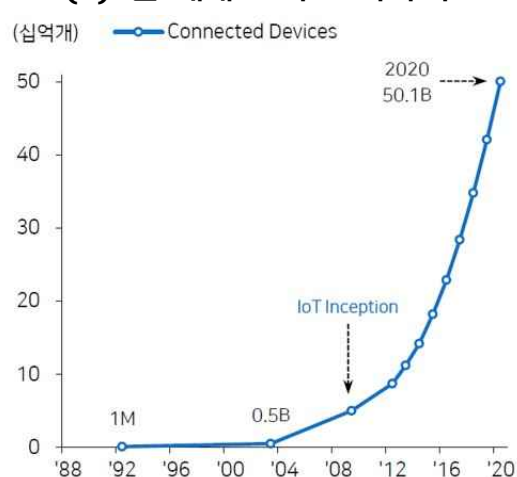
초연결(Hyperconnectivity)이란 사람-사람, 사람-기계, 기계-기계 간 연결이 급격하게 확대되고 그 연결의 방식도 다양화되는 것을 말한다. 우리 주변의 사물들이 연결되는 사물인터넷(Internet of things, IoT)에 이어 모든 사물이 연결되는 만물인터넷(Internet of Everything, IoE)이 비전으로 제시되고 있다. 스마트 기기의 수는 최근 급격하게 증가하고 있으며 향후에도 증가세는 지속될 전망이다. 전 세계 인구 1인당 스마트 기기 수는 2010년 1.8개에서 2020년에는 6.6개로 증가하였고 인구는 2010년 68억 명에서 2020년 76억 명으로 늘어나서 전 세계 스마트 기기 수는 2010년 88억 개에서 2020년 500억 개에 이르렀다(김준성, 2021). 이에 따라 기기 간 연결과 그로부터 발생하는 데이터의 양도 기하급수적으로 증가하고 있다. 또한 연결 매체도 음성, 텍스트, 이미지, 동영상 등으로, 연결 수단도 전화, 문자, 채팅, 이메일, 스트리밍 등으로 다양화되고 있다.

[그림 3-8] 전 세계 스마트 기기의 증가 전망

(a) 세계 인구 1인당 스마트 기기 수



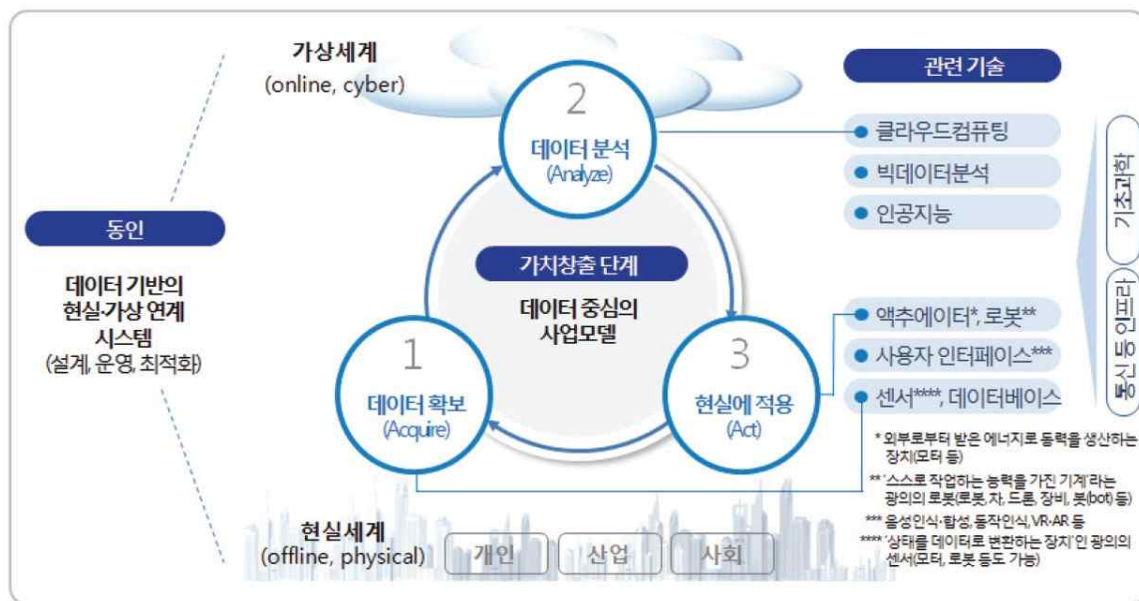
(b) 전 세계 스마트 기기 수



자료: 김준성(2021), p. 15.

전 세계적으로, 그리고 국가적으로 4차 산업혁명 및 디지털 전환을 전략적인 방향으로 제시하고 있다. 디지털 전환(digital transformation) 또는 4차 산업혁명은 현실 세계(physical world)에 있는 디지털 센서와 기기로부터 데이터를 확보하여 이를 클라우드 등의 가상세계(cyber world)에서 분석하고 그로부터 얻어진 통찰을 다시 현실 세계에 적용하는 것이다(최병삼·양희태·이제영, 2017). 따라서 센서, 기기, 네트워크 간의 연결은 디지털 전환을 위한 필수 조건이다. 더욱이 COVID-19로 인해 원격 근무와 화상회의, 원격 교육, 온라인 쇼핑, 배달 서비스, 원격 진료 등이 확대되면서 디지털 연결에 기반한 원격 경제 및 디지털 전환이 가속화되고 있다.

[그림 3-9] 디지털 전환(4차 산업혁명)의 가치 창출 메커니즘



자료: 최병삼·양희태·이제영(2017), p. 14.

□ 초연결 및 디지털 전환 시대의 보안 정책

일상 속 연결이 촘촘해지고 확장될수록 이는 사이버 공격의 대상이나 범위, 그리고 그 영향력 또한 치명적일 수 있음을 의미하기도 한다. 데이터 산업의 발전과 더불어 해킹사고는 끊이지 않고, 특히 충분한 준비 없이 맞이하게 된 팬데믹 상황 속에서 급작스러운 비대면 생활로의 전환은 보안에 위협적인 상황이다. 보안에 취약한 개인 기기

를 노리는 사이버 공격도 증가하고 있지만, 정교한 기술로 치밀하게 계획해 기업이나 정부를 대상으로 데이터 갈취, 서비스를 마비시키는 사이버 테러 위협 역시 늘어나고 있다. 대표적으로 2020년 발생한 솔라윈즈 (SolarWinds) 해킹 사례는 공급망 공격 기법으로, IT관리 솔루션의 정기 업데이트 과정에 악성코드를 심어 유포하여 미국 연방 정부와 마이크로소프트 등 우수 IT 기업의 많은 내부 정보가 침해된 사건이다.¹³⁾

중요한 것은, 이러한 사이버 위협이 있다고 해서 우리가 초연결 사회를 포기할 수는 없다는 점이다. 사이버 위협은 매 순간 직면하는 것이고, 앞으로도 계속될 것이다. 사이버 공격과 보안 산업의 관계는 창과 방패의 관계와 같다. 모든 창을 막아내는 방패가 존재하지 않듯이 모든 공격을 막아낼 수 있는 완벽한 보안 수단은 없다. 또한, 창이 날카로워지는 만큼 방패도 더 튼튼하게 발전하듯이 보안 산업이 더 발전하면 이를 공격하고자 하는 해킹 기술 역시 발달하게 된다. 따라서 계속되는 공격을 피해 연결을 단절하여 공격 받지 않는 방법을 취하기보다는 다양한 형태의 위협에 대응할 수 있도록 보안 기술을 고도화하고 보안 산업 및 생태계를 발전시키는 노력이 필요하다. 4차산업혁명위원회는 네트워크 및 데이터의 보호와 활용이 균형을 이루어야 함을 다음과 같이 강조한다(4차산업혁명위원회, 2019).

“사이버 보안이 담보되지 못한다면 4차 산업혁명과 관련된 모든 시도들은 사상누각이다. 5G 통신망 및 사물인터넷 기기들에 대한 신뢰성 확보 및 보안 내재화 (Security by Design), 외부 보안 전문인력의 집단지성 활용 및 공급망 보안 (Supply Chain Security) 등은 과거 어느 때보다 더욱 중요한 의미를 갖는다. 그럼에도 보안이 또 다른 규제가 되어서는 곤란하다. 대표적인 것이 ‘망 분리’와 같은 도메인 중심의 사이버 보안 정책이다. 이는 ‘모든 것이 네트워크에 연결되어 있고, 데이터는 활발하게 공유·활용되어야 한다’는 4차 산업혁명의 기본철학과 상충되며, 관련 산업 육성에도 걸림돌이 된다. 4차 산업혁명 시대, ‘보호’와 ‘활용’이라는 두 가지 딜레마 속에서 균형점을 찾을 때, 대한민국은 신뢰할 수 있는 초연결 국가로서의 위상을 갖게 될 것이다.” (4차산업혁명위원회, 2019)

13) <https://zdnet.co.kr/view/?no=20210122194956> (검색일 2022. 6. 30.)

2. 해외 보안 정책 동향

□ 망분리 관련 정책

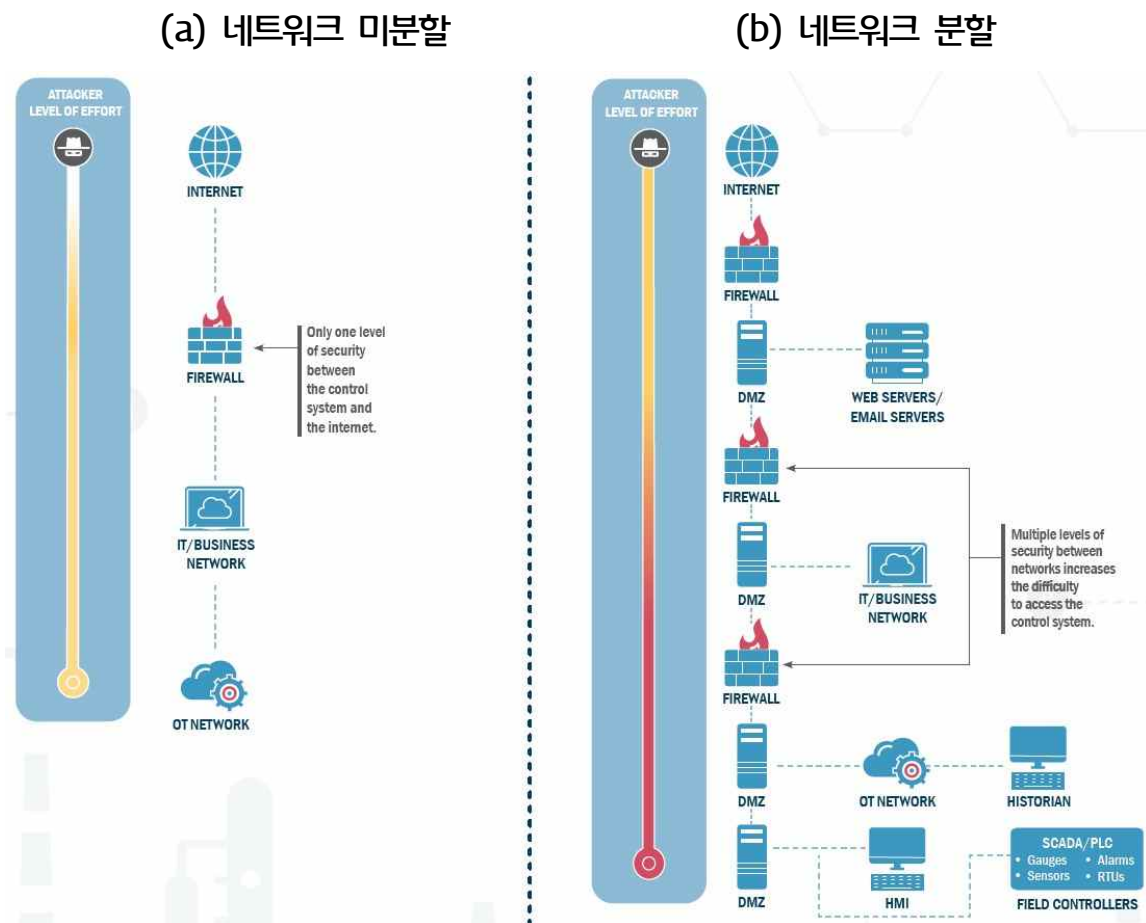
미국, EU 등 해외에서는 망분리¹⁴⁾를 보안 기법의 하나로 인정하고 있고 높은 보안 수준이 요구되는 자산에 권고하고 있으나 이를 의무화하지는 않고 있다. 망분리 도입 여부와 적용범위는 기관, 기업이 결정하는 것이 일반적이다.

미국에서 망분리를 언급한 주요 문건들을 살펴보면 다음과 같다. 미국 국립표준기술연구소(National Institute of Standards and Technology, NIST)은 국방 외 전 분야의 미 연방 정부의 정보시스템이 정보보안 관련 법규를 보다 효율적으로 지킬 수 있도록 돕는 것을 목적으로 정보보안 가이드라인을 발행했다(NIST, 2020. 9). 여기서 보안수단 중 하나로 정보시스템 요소 분리(isolation)를 제안하는데, 어떠한 정보시스템 요소를 어떠한 목적 혹은 기능에 의해 분리할지는 기관이 선택한다고 서술하고 있다(NIST, 2020. 9).

미국 연방정부의 사이버보안 담당 기관 사이버보안및인프라보안국(Cybersecurity and Infra-structure Security Agency, CISA)은 정보기술(information technology, IT) 네트워크와 산업기술(operation technology, OT) 네트워크, 그리고 보안수준이 높은 자산과 기타 자산에 대해 네트워크 분할(network segmentation)을 권고한다(CISA, 2022. 1). 그런데 중요한 것은 여기서 말하는 네트워크 분할은 [그림 3-10]과 같이 전체 네트워크를 여러 개의 하위 네트워크로 구분하여 각각의 하위 네트워크에 대해 별도로 보안 관리를 하는 개념이므로 인터넷을 차단하는 국내 망분리와는 다르다는 점이다. 또한 CISA는 네트워크 분할이 네트워크 보호를 위한 유일한 도구가 아니라는 점도 명시하고 있다.

14) 해외 문건에서는 망분리를 상황에 따라 “air gap”, “segmentation”, “segregation”, “zoning” 등으로 표현한다. 여기서 “air gap”은 배관에서 오염수 역류로부터 수질을 보호하기 위해 설치되는 공간을 비유하여 붙여진 이름이다([https://en.wikipedia.org/wiki/Air_gap_\(networking\)](https://en.wikipedia.org/wiki/Air_gap_(networking)), 검색일 2022. 6. 30.).

[그림 3-10] 미국 사이버보안및인프라보안국(CISA)이 권고하는 네트워크 분할



자료: CISA(2022. 1), p. 1.

금융 분야의 경우 은행규제기관으로 구성된 연방금융기관 검사협의회(Federal Financial Institutions Examination Council)는 2016년 정보보안(Information Security)이라는 문건을 발간하였는데(Federal Financial Institutions Examination Council, 2016), 이 문건의 목적은 기업과 감사역이 정보시스템의 보안 수준을 측정하는 데 필요한 요소를 제시하고, 정보보안 프로그램의 전반적인 리스크 관리 수준의 적합도를 측정할 수 있게 도와주는 것이다(스타트업얼라이언스, 2020). 여기서 자산의 중요도에 따라 네트워크를 나누는 것(zoning)을 권고하고 있는데, 이는 매우 중요한 정보에 대해서는 망을 나누거나 접근을 제한할 수 있다는 일반적인 원칙을 제시한 것이라고 볼 수 있고, 인터넷을 차단하는 망분리를 제안한 것은 아니라고 할 수 있다.

유럽연합(EU)은 망분리 규제를 의무화하지 않으며 일반개인정보보호법(General Data Protection Regulation, GDPR)을 기준으로 개인정보 보호 및 관리를 규제하고 있다. 일반개인정보보호법은 2016년 제정되어 2018년부터 시행되고 있다. 개인정보 보호 및 관리 의무를 위반한 경우 최대 2천만 유로 또는 전년도 매출액의 최대 4%까지 과징금을 부과한다(아산나눔재단 등, 2020). 예를 들어, 2018년 영국항공이 사이버 공격을 당해 약 50만 명의 고객 개인정보(이름, 우편주소, 이메일주소, 신용카드 정보 등)가 유출된 사건이 있었는데, 영국 정보위원회는 GDPR 위반을 근거로 영국항공에게 약 2,700억 원의 과징금을 부과한 바 있다(아산나눔재단 등, 2020).

이처럼 전자금융감독규정의 망분리와 같은 수준의 규제는 전세계적으로 우리나라가 유일하다(아산나눔재단 등, 2020). 해외에서도 일반적으로 망을 몇 개의 구역(zone)으로 적절하게 분리하는 것은 일반화되어 있다. 하지만 전자금융감독규정의 망분리는 국가정보기관이나 국방기관 수준의 폐쇄망에 해당되므로 해외에서 민간 부문에 적용한 유사한 사례를 찾을 수 없다. 해외에서는 기업에게 보안 방법을 자율적으로 맡기고 대신 사고 발생 시 강력한 책임을 묻는 자율 규제 및 사후 규제 방식을 적용하고 있다.

[그림 3-11] 해외 주요국의 망분리 규제 현황

국가	아시아				북미		유럽
	 한국	 중국	 일본	 호주	 미국	 캐나다	 EU
망분리 규제 현황	✓	✗	✗	✗	✗	✗	✗
관련 주체/규정	· 금융위원회 전자금융 감독규정	· 산업정보 기술부	· 사이버보안 전략본부	· 사이버보안 센터	· 연방금융기관 검사협의회	· 사이버보안 센터	· 유럽네트워크 정보보호원
내용	· 금융회사 및 핀테크 기업 대상 물리적/ 논리적 망분리 의무화	· 보안 위한 기술적인 조치를 취할 것을 규정 · 망분리에 대한 언급 없음	· 보안을 자율적으로 지킬 것을 규정함 · 망분리에 대한 언급 없음	· 강제성 없는 권고로, 망분리를 하나의 수단으로 제시	· 의무화하지 않고 일반적 원칙만 제시	· 강제성 없는 권고로, 망분리를 하나의 수단으로 제시	· 강제성 없는 권고로, 망분리를 하나의 수단으로 제시

자료: 한국인터넷기업협회(2022), p. 139.

□ 제로 트러스트 관련 정책

미국은 공공 부문에서 제로 트러스트 아키텍처(Zero Trust Architecture, ZTA)의 도입을 촉구하는 행정명령을 발표하는 등 제로 트러스트로의 전환 정책을 적극적으로 추진하고 있다. 바이든 대통령이 서명한 행정명령(Executive Order on Improving the Nation's Cybersecurity)에서는 연방 정부는 클라우드 서비스로의 전환을 가속화하기 위해 모범사례인 제로 트러스트(ZTA)를 도입해야 하며, 각 기관장은 이를 구축하기 위한 계획을 60일 이내에 수립하도록 명령하고 있다(White House, 2021. 5. 12.). 특히, 미국 사이버보안및인프라 보안국(CISA)의 신속한 전환을 촉구하고 미국 표준기술연구소(NIST)에서 제시하는 도입 프로세스에 따라 제로 트러스트 아키텍처 구축 계획을 장·단기적으로 수립할 것을 제시한다. 참고로, 미국 표준기술연구소(NIST)에서 제시하는 제로 트러스트 아키텍처 도입 프로세스는 ① 기업의 행위자 파악, ② 기업이 소유한 자산 파악, ③ 주요 프로세스 식별 및 프로세스 실행과 관련된 위험 평가, ④ ZTA 적용 후보를 위한 정책 수립, ⑤ 후보 솔루션 파악, ⑥ 초기 구축 및 모니터링, ⑦ 적용 확대이다(Rose, S. et al., 2020).

“미국 정부의 제로 트러스트 사이버보안 원칙 지향(Moving the U.S. Government Towards Zero Trust Cybersecurity Principles)”이라는 문건에서는 행정명령에 따라 행정부 부서 및 기관에서 60일 내에 수립한 구축 계획을 2024년 말까지 완료하도록 명령한다(White House, 2022. 1. 26.). 또한 2024년 말까지의 예산 추정치를 예산관리국(OMB, Office of Management and Budget)에 제출해야 한다. 미국 국가안보국(NSA)의 네트워크 인프라 보안 가이드(Network Infrastructure Security Guidance)에서는 서두에서 다양한 영역의 네트워크 보안에 있어 제로 트러스트 보안 모델의 원칙이 필수적으로 달성되어야 한다는 점을 강조한다(NSA, 2022. 6).

유럽연합(EU)은 “사이버 보안법(Cybersecurity Act)”을 2019년 6월부터 시행하며 유럽 전역의 사이버 보안을 강화하고 있다.¹⁵⁾ ‘제로 트러스트’ 관련해서는 유럽연합 차원에서 추진하지는 않고 도입을 권고하는 수준이다.

15) <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-act> (검색일 2022. 6. 30.).

3. 보안 패러다임 전환의 필요성

글로벌 업체인 딜로이트는 다양한 신기술이 등장함에 따라 신기술 규제와 관련하여 다양한 문제점이 발생하고 있다고 지적한다(Ennis, H. et al., 2019). 예를 들어 정부 부처, 기업, 공공 연구소 등 다양한 주체가 있으며 이들은 보안성을 중시하거나 경제성을 중시하는 등 서로 다른 입장을 나타낼 수 있다.

[그림 3-12] 신기술 규제와 관련된 다양한 주체

	Security focus	Market focus
Regulators	Departments of State, Homeland Security, Defense, and Justice	Departments of Commerce and Treasury, trade representatives, consumer and safety regulators, etc.
Builders	Traditional military industrial base	
	Government labs, federally funded R&D centers, etc.	Other industries, academia, and other technology producers

자료: Ennis, H. et al.(2019), p. 8.

딜로이트는 미래지향적인 규제의 방향성으로 결과 기반 규제(Outcome-based regulation), 영역별 차이를 고려하는 규제(Risk-weighted regulation), 규제 샌드박스(Regulatory sandboxes), 적응형 규제(Adaptive regulation), 협력적 규제(Collaborative regulation)를 제시한다(Ennis, H. et al., 2019). 이를 망분리 관점에서 해석한다면, 망분리라고 하는 사전적인 규제를 모든 영역에 대해 적용하는 것은 새로운 기술이 등장하는 추세에 맞지 않으므로 이를 영역별 차이를 고려하여 유연하게 적용해야 한다고 볼 수 있다.

<표 3-12> 딜로이트가 제안하는 미래지향적인 규제의 방향성

방향성	내용
결과 기반 규제 (Outcome-based regulation)	형태가 아니라 결과와 성과에 초점을 두는 규제
영역별 차이를 고려하는 규제 (Risk-weighted regulation)	모든 상황에 맞는 규제(one-size-fits-all)가 아니라 데이터에 기반하여 영역별로 접근하는 규제
규제 샌드박스 (Regulatory sandboxes)	새로운 기술에 대해 시범적으로 도입하고 검증
적응형 규제 (Adaptive regulation)	규제하고 잊는 방식(regulate and forget)이 아니라 상황에 대응하여 반복적으로 규제를 수정 보완
협력적 규제 (Collaborative regulation)	전체 생태계에 포함된 다양한 주체들을 아우르며 국가적, 세계적으로 규제를 조율

자료: Ennis, H. et al.(2019), p. 11.를 기반으로 저자 정리

국내에서도 망분리 등 영역 기반에서 제로 트러스트 등 인증 기반으로 보안 패러다임 전환이 필요하다는 전문가들의 주장이 최근 제기되고 있다.

“글로벌 보안 시장은 제로 트러스트 네트워크 액세스(ZTNA)를 향하고 있다. 전통적인 영역 기반 보안 정책으로 설계된 국내 공공·금융기관의 망분리 정책은 근본적인 변화가 필요하다.” (이동범 한국정보보호산업협회(KISIA) 회장)¹⁶⁾

“망분리 도입만으로 보안이 완벽해진다는 식의 접근은 위험하다...망분리를 완벽한 해법으로 제안하기보다 다요소 인증을 기반한 ‘제로 트러스트’를 강조한다...디지털 전환에 따라 주요 데이터들이 클라우드 환경에 적용되고 있는 현재 환경에서 하나만으로 보안을 규정하기는 힘들다...완벽한 해결책을 찾기는 어려운 상황이기 때문에 망분리, 홈네트워크에 대한 보안 가시성 등 각각을 하나의 보안 옵션으로 보고 여러 기술을 복합적으로 적용해 제로 트러스트를 통해 데이터를 식별해나가는 과정이 필요” (심상규 펜타시큐리티 CTO)¹⁷⁾

16) <https://www.datanet.co.kr/news/articleView.html?idxno=144256> (검색일 2022. 11. 5.).

17) <http://www.engjournal.co.kr/news/articleView.html?idxno=1738> (검색일 2022. 11. 5.).

| 제4장 | 주요 산업별 보안 위협, 대응수단 및 정책 분석

본 장에서는 주요 산업을 대상으로 제2장에서 소개한 보안 위협 및 기술, 제3장에서 논의했던 국내 보안 정책의 현황과 문제점을 구체적으로 살펴보도록 한다. 대상 산업은 현재 망분리 규제가 시행되고 있거나 향후 시행될 가능성이 있는 금융, 헬스케어, 홈네트워크, 자동차 등 4개를 선정하였다.

산업별로 심도있는 논의를 진행하기 위해 산업별 보안 전문가들을 대상으로 서면 자문을 실시하였다. 이를 위해 문헌 조사 등을 통해 각 산업별로 보안 이론 및 실무, 기술 및 정책에 대해 종합적인 의견을 제공해줄 수 있는 전문가들을 산업별로 3~4명씩 총 13명의 전문가를 선정하였다.

〈표 4-1〉 서면 자문에 응답한 산업별 보안 전문가

연번	구 분	소 속	보고서 본문 표기
1	금융	금융서비스 기업 정보보안 및 개인정보보호 책임자	금융 보안 전문가 1
2		금융서비스 기업 정보보호 최고책임자(CISO)	금융 보안 전문가 2
3		대학 정보보호학과 교수(핀테크 보안 전문가)	금융 보안 전문가 3
4		대학 정보보호학과 교수(금융 보안정책 전문가)	금융 보안 전문가 4
5	헬스케어	헬스케어 기업 기술 총괄 책임자	헬스케어 보안 전문가 1
6		헬스케어 기업 기술연구소 소장	헬스케어 보안 전문가 2
7		헬스케어 기업 기술연구소 소장	헬스케어 보안 전문가 3
8	홈네트워크	보안 솔루션 기업 대표	홈네트워크 보안 전문가 1
9		대학 컴퓨터공학과 교수(보안 위협 전문가)	홈네트워크 보안 전문가 2
10		인터넷·정보보호 전문기관 연구원(홈네트워크 전문가)	홈네트워크 보안 전문가 3
11	자동차	자동차 보안 솔루션 기업 대표	자동차 보안 전문가 1
12		대학 정보통신공학부 교수(자동차 보안 전문가)	자동차 보안 전문가 2
13		인터넷·정보보호 전문기관 연구원(자율주행차 전문가)	자동차 보안 전문가 3

자료: 저자 작성.

다양한 이해관계 및 관점을 파악할 수 있도록 핀테크 스타트업 정보보호 최고책임자(Chief Information Security Officer, CISO), 보안 솔루션 기업 대표, 대학 정보보호학과 교수, 정보보안 관련 공공연구기관 연구원 등 다양한 경력을 보유한 산·학·연 전문가들을 섭외하였다.

전문가 자문은 다음과 같은 방식으로 진행되었다. 먼저, 연구팀이 보안 관련 문헌을 리뷰한 후 보안 위협, 대응 수단, 보안 규제, 정책 제언 등의 문항으로 구성된 서면 질의서를 작성하였다. 전문가들이 본 과제의 문제의식과 현재까지의 진행상황을 이해하고 답변할 수 있도록 전문가들에게 서면 질의서와 과제 소개자료를 함께 제공하였다. 다음으로, 산업별 보안 전문가들이 과제 소개자료를 참고하여 서면 질의서에 의견을 작성하였다. 마지막으로, 연구팀이 산업별 보안 전문가들이 보내온 자문 결과를 취합하고 검토하였으며, 필요한 경우 해당 전문가와 온라인 회의를 통해 추가 토의를 진행하였다.

〈표 4-2〉 산업별 보안 전문가 서면 질의서 문항

구분	문항
보안 위협	Q1. 금융/헬스케어/홈네트워크/자동차 분야의 보안 측면에서 대표적인 위협 요소(가로채기, 변조, 흐름 차단, 위조 삽입 등)는 무엇인가?
대응 수단	Q2. 위의 위협 요소에 대응하기 위한 보안 수단(망분리, SIEM, 블록체인 등)과 보안 모델(제로 트러스트 등)은 어떤 것들이 있는가? Q3. 위의 각 위협 요소에 대해 망분리와 다른 보안수단들은 효과적으로 대응할 수 있는가? (장단점 비교)
보안 규제	Q4. 금융/헬스케어/홈네트워크/자동차 산업에서의 국내·외 망분리 규제 현황과 전망은 어떠한가?
정책 제언	Q5. 금융/헬스케어/홈네트워크/자동차 산업에서 반드시 망분리 규제가 필요한 부분이나 데이터가 있는가? (예를 들어, 원전, 군사시설 등) Q6. 금융/헬스케어/홈네트워크/자동차 산업에서 '영역 기반 보안 모델(망분리 등)'에서 '제로 트러스트 모델로 전환하는 것이 필요한가, 그리고 가능한가? Q7. 금융/헬스케어/홈네트워크/자동차 산업에서 '제로 트러스트(Zero Trust)'로 전환하기 위해 어떤 정책이 필요하고 어떤 제도적 문제가 해결되어야 하는가?

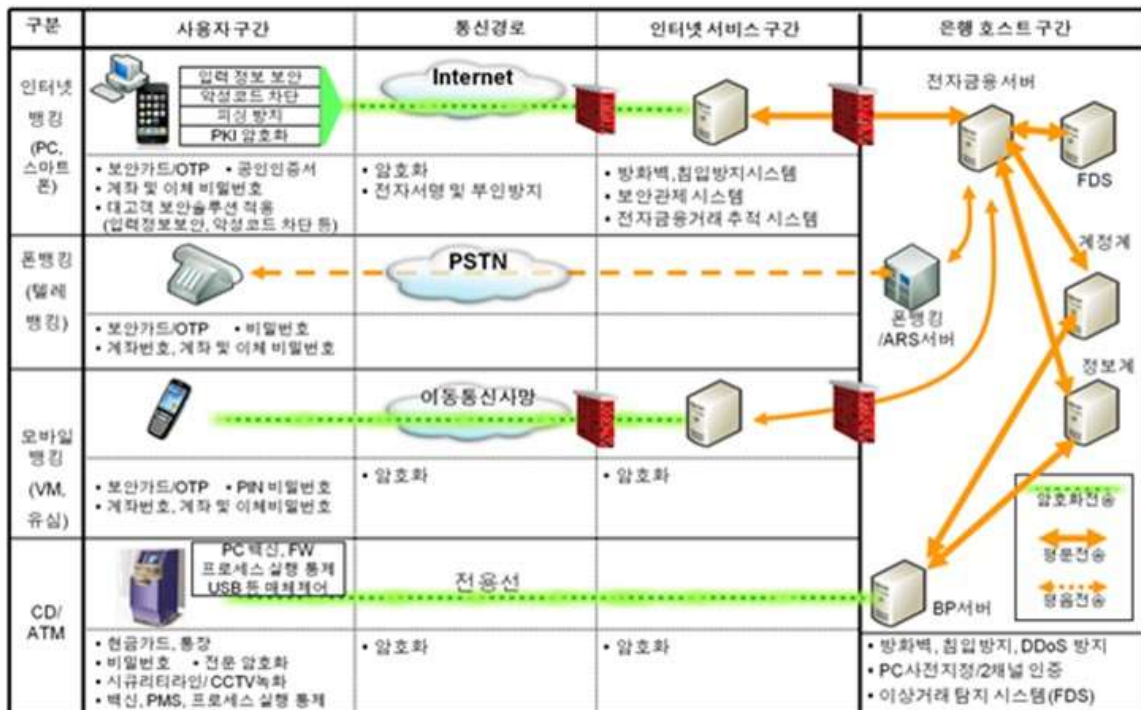
자료: 저자 작성.

제1절 금융

1. 금융 분야의 보안 위협

금융 분야에서는 인터넷, 서버, PC, 스마트폰, 현금자동입출금기(ATM) 등 정보통신기술이 활발하게 이용되고 있다. 따라서 랜섬웨어, 서비스 거부, 가로채기, 변조, 악성코드 유입, 오픈소스 취약점 공격 등 다양한 형태의 보안 위협이 존재한다. 최근에는 오픈뱅킹이 본격적으로 도입되면서 보안 위협도 증가할 것으로 예상된다. 폐쇄적으로 운영되던 금융결제 인프라가 개방되고 모든 금융거래가 하나의 앱(app)에 집중됨에 따라 이용 편리성이 제고되고 마이데이터 서비스 산업의 발전이 기대되지만, 앱이 해킹될 경우 연계된 모든 은행이 피해를 입을 수 있어서 사고 발생 시 피해 규모가 과거보다 커질 수 있다. 김인석 외(2015)는 금융 서비스 시스템의 구성과 금융 분야에서 발생하는 다양한 사고 유형과 주요 보안 대책을 종합적으로 소개한다.

[그림 4-1] 전자금융 서비스의 시스템 구성 및 주요 보안 요소



자료: 김인석 외(2015), p. 143.

<표 4-3> 금융 분야의 보안 사고 유형 및 보안 대책

구분	사고 유형	주요 보안 대책
외부에서 내부로의 비인가 접속	외부 해커가 인터넷을 통해 은행 내부 서버로 접속하여 시스템 해킹을 통해 내부 정보 유출 또는 위/변조, 시스템 장애 유발 등	• 모의해킹, 취약점 점검, 소스코드 보안, 형상관리 • 방화벽, IPS, DDoS 차단, DB침해접속 탐지 시스템 등 네트워크 보안시스템 구축 • 보안 관제(ESM)
내부에서 내부로의 비인가 접속	내부 단말에서 내부 서버로 비인가 접속하여 내부 정보 유출, 위변조, 장애 유발 등	• 관리적 보안, 서버/DB 시스템 보안, 비밀번호 암호화, 내부정보 유출 방지 • 비인가 외부인 출입 통제 • 망분리(내부 업무망과 사용자 망간 분리, 인터넷 접속망분리)
고객 전송 구간 해킹	고객 PC와 인터넷뱅킹 서버 간 거래 전문 유출, 위/변조 등	• PKI 암호화, 전문 위/변조 방지 • E2E 암호화
사용자 환경의 정보 유출/변조	사용자의 비밀번호, 공인인증서 등 인증 정보 유출 후 불법 접속 및 불법 자금 이체 사고 발생 : 고객 PC 해킹, 메모리 해킹, 피싱/파밍/스미싱 등	• 사용자용 보안프로그램: 키보드보안, 백신/해킹방지, 피싱/파밍/스미싱 방지 등 • 거래 인증: 보안카드/OTP • 공인인증서 보안: HSM, S/W 보안토큰, 스마트폰/USM 저장 • 2채널 인증(SMS/ARS, 모바일 앱 인증 등) • 입금계좌 사전 지정, 이체 한도 제한, 출금 지연 • 전자금융사기방지시스템(FDS)
제휴 중계 업체 침해 사고	인터넷뱅킹 제휴업체에서 고객 정보 유출, 불법 자금 이체 사고 발생 등	• 전자금융거래법: 은행의 사고 책임 강화 및 은행에서 제휴업체에 대한 점검 의무화 • 제휴업체에서 거래 정보 조회 및 저장 제한 • 제휴업체 자체 내부정보 유출 통제 체계 구축 • 인터넷뱅킹 거래 전문의 E2E 암호화 등

자료: 김인석 외(2015), p. 143.

다수의 전문가들은 금융 분야의 대표적인 위협 요소로 지능형 지속 위협(APT)을 언급했다. 또한 오픈소스 취약점 공격, 사회공학적 공격 등에 대해서도 그 심각성을 지적하였다.

“정교한 악성코드를 서버, PC에 감염시켜 사전에 정의된 악성 행위를 하거나 외부 커맨드 서버와의 통신을 통해 개인신용정보 탈취, 거래 중단 등의 시도하는 공격임. 실제 인터파크, SK커뮤니케이션즈 해킹 사고 등 큰 피해를 입은 케이스가 계속 나

타나고 있음.” (금융 보안 전문가 1)

“금융회사에 대한 APT 공격은 비인가 보안프로그램 설치, 패치되지 않은 운영체제와 같은 보안 취약점을 노리지만 그보다 사회공학적 기법이 많은 비중을 차지하고 있다. 장기적인 공격 목표를 세우고 임직원 정보를 사전에 파악하고 협력업체나 아웃소싱 정보를 통해 보유한 취약점을 수집하여 정교하고 지능적인 해킹 툴을 사용하여 치밀하게 공격을 수행한다. 실제 이러한 APT 공격으로 금융회사의 임직원 정보는 물론 고객정보, 금융거래정보, 신용정보 등이 지속적으로 유출되어 2차, 3차 피해로 이어지고 있다.” (금융 보안 전문가 3)

“오픈소스의 취약점을 통한 공격으로 수많은 오픈소스들이 사용되고 있으며 특히 제로 데이와 같은 경우 영향도가 높고 오픈되는 즉시 많은 공격 시도가 유입되고 있음.” (금융 보안 전문가 1)

“사회공학적 공격은 최종적으로 고객 개인정보를 목표로 하고 있으며, 수많은 피싱 시도와 차단 사례를 보안시스템 로그를 통해 확인할 수 있다. 피싱 공격은 랜섬웨어 감염과 고객 개인정보 유출사고의 출발점이 될 수 있다.” (금융 보안 전문가 2)

“이용자의 신원을 도용하거나 계정 정보를 탈취해 허위 거래를 발생시키거나 금전적인 탈취를 시도하는 공격은 기술적, 사회공학적 등 다양한 방식으로 진화하고 있음. 금전적인 이득이라는 직접적인 동기가 있고 보안에 대한 이해도가 낮은 이용자를 타겟으로 하는 경우가 많음.” (금융 보안 전문가 1)

최근 현황을 보면, 금융회사 전산시스템의 운영체제 비율이 2020년 기준 리눅스(Linux) 41.9%, 윈도우(Windows) 29.9%, 유닉스(Unix) 18.3% 등으로 나타나 금융기관의 오픈소스 활용이 활발하다는 사실을 알 수 있다(금융정보화추진협의회, 2021). 그런데 오픈소스의 경우 금융기관이 구축한 보안 시스템을 우회하는 데 주로 활용되고 있다. 또한 최근 피싱(phishing), 파밍(pharming), 스미싱(smishing) 등 개인정보를 불법으로 취득하는 다양한 사기 수법이 많이 발생하고 있다. 금융감독원 발표에

따르면, 2021년 보이스피싱으로 인한 피해금액은 총 1,682억 원이었으며, 전년 대비 671억원 감소했으나 60대 이상의 고령자의 피해가 증가하고, 사회적 관심사인 코로나19와 관련한 신종 사기 수법이 성행했다(금융감독원 보도자료, 2022. 4. 20.).

[그림 4-2] 보이스피싱 유형별 피해 현황(2019~2021)



자료: 금융감독원 보도자료(2022. 4. 20), p. 2.

<표 4-4> 금융 분야의 보안 위협 사례

보안위협	내 용	사 례
APT 공격	오랜 기간에 걸쳐 공격 대상이 눈치 채지 못하게 보안 서비스를 무력화, 정보를 유출하는 방법	2013년 3.20 사이버 대란으로 신한은행, 제주은행, 농협은행의 전산망이 마비(스타트업얼라이언스, 2020)
오픈소스 취약점 공격	아직 알려지지 않은 보안 취약점이나 대책이 마련되지 않은 취약점을 노린 해킹	2021년 발견된 자바 프로그램 개발에 사용되는 라이브러리 log4j의 보안 취약점 이슈 발생¹⁸⁾
전기 통신 수단을 이용한 금융사기	피싱, 파밍, 스미싱 등 사회공학적인 기법으로 개인정보를 불법으로 취득하는 다양한 사기 수법	2014년 카드 3사에서 유출된 1억 건의 개인정보가 예금을 인출하거나 보이스 피싱에 이용¹⁹⁾

자료: 전문가 의견을 취합하여 저자 작성.

18) <https://www.lgcns.com/blog/cns-tech/security/22605/> (검색일 2022. 6. 30.).

19) <https://www.joongang.co.kr/article/23871180#home> (검색일 2022. 6. 30.).

2. 금융 분야의 보안 수단 및 효과성 비교

금융 분야에서는 앞서 논의된 APT 공격, 오픈소스 취약점 공격, 사회공학적 공격과 분산 서비스 거부(Distributed Denial of Service: DDoS) 공격, 중간 가로채기 공격 등에 대응하기 위해 다양한 보안 수단이 개발되어 적용되고 있다. 금융 분야 전문가들은 대표적인 보안 수단 및 모델로 망분리, 이상거래 탐지 시스템(Fraud Detection System: FDS), 제로 트러스트 아키텍처를 언급했다.

□ 망분리

망분리는 금융권의 대표적인 보안 수단으로 꼽힌다. 지능화되는 APT 공격에 대한 대응으로 금융 당국은 2013년 3.20 사이버 대란 이후 「금융전산 망분리 가이드라인」을 배포하고 「전자금융감독규정」을 개정하여 망분리를 단계적으로 의무화한 바 있다(스타트업얼라이언스, 2020).

“금융회사에 대한 APT 공격으로 인한 피해가 급증하자 금융감독 당국은 망분리 규제 이행을 의무화 하였으며 금융회사는 물론 제2, 제3 금융권에서도 망분리를 순차적으로 도입하였다.” (금융 보안 전문가 3)

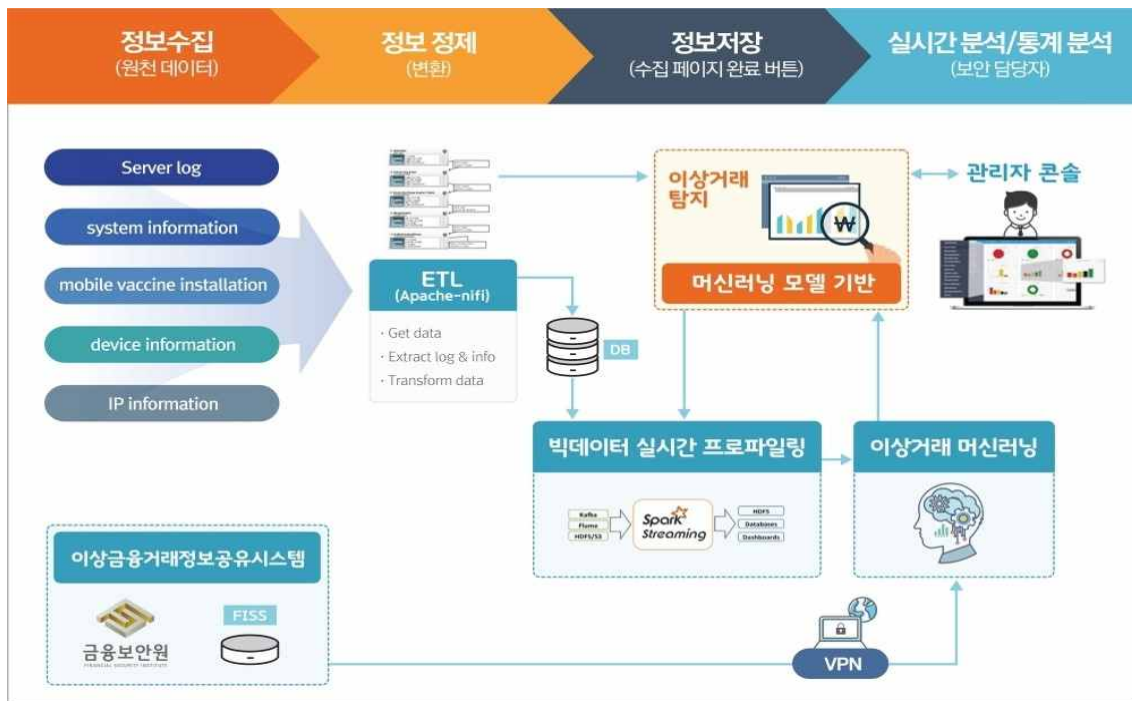
“내부 서버 및 이를 접근하는 PC가 인터넷과 연결되지 않도록 하는 망분리를 통해 악성코드 유입 가능성을 줄이고 내부 서버 및 PC가 외부 공격(커맨드) 서버와 통신을 차단해 원격제어, 데이터 유출 등을 차단하고 있음.” (금융 보안 전문가 1)

□ 이상거래 탐지 시스템(Fraud Detection System, FDS)

이상거래 탐지 시스템(FDS)은 이용자 혹은 기업의 금전적 손실, 정보 유출 등 이상 행위를 통해 발생될 수 있는 악의적인 행위들을 탐지하고 차단하기 위해 고안된 시스템이다(한승우, 2015). 이 시스템은 거래활동을 모니터링하고 다양한 분석 방법을 조합하여 이상 거래 패턴을 파악함으로써 금융 사고에 대한 사전 혹은 사후 대응을 지원할 수 있다. 최근에는 중요 정보를 처리함에 있어 이상행위 모니터링을 강화하기 위해

인공지능이나 딥러닝과 같은 알고리즘을 사용하고 있으며, 이로 인해 이상행위에 대한 신속한 대응, 자동화된 탐지결과 도출을 기대할 수 있게 되었다.

[그림 4-3] 이상거래탐지시스템 구성의 예



자료: 김경애(2018. 8. 13.), 「YH데이터베이스, 액티브X 대체하는 이상징후탐지로 보안 업그레이드」, 보안뉴스, <http://m.boannews.com/html/detail.html?idx=72118> (검색일 2022. 7. 30.).

“메신저/보이스 피싱 또는 파밍을 예방하기 위해 금융권에서는 악성 앱 탐지기술과 이상거래탐지시스템(FDS)을 구축하여 일괄 대응체계 확보에 나서고 있다.” (금융 보안 전문가 3)

“자동화는 보안정책이 실수 없이 적용될 수 있도록 도와주며, 보안전문가들이 보다 심도있는 분석업무에 집중할 수 있는 환경을 만들어 준다.” (금융 보안 전문가 2)

□ 제로 트러스트(Zero Trust) 모델

오픈소스 취약점이나 APT 공격이 진화하면서 대응 전략도 발전하고 있는데, 최근 가장 주목을 받는 모델로 전문가들은 제로 트러스트를 꼽았다. 기존 보안 기법이 악성

행위인지 여부가 확실하지 않은 회색 영역을 줄여가는 데 중점을 두었다면, 제로 트러스트 모델에서는 흑백 또는 회색의 개념을 없애고 모든 것을 믿을 수 없다고 전제하여 확실히 믿을 수 있는 것만을 허용하는 방식이다.

“오픈소스 취약점, APT 등으로 실제 시스템 침해 공격이나 발생하는 경우 공격의 시작점이나 시도되는 포인트가 외부가 아닌 내부의 신뢰할 수 있는 시스템, PC인 경우를 대비해 제로 트러스트 원칙에 따라 개인신용정보, 중요 거래 시스템은 추가적인 네트워크 인증, 인증서 인증, 물리보안키 등의 다중인증(Multi-Factor Authentication: MFA)을 적용함.” (금융 보안 전문가 1)

□ 보안수단 및 보안모델의 장단점

망분리가 랜섬웨어, APT 공격 등에 대한 확실한 방어 수단인가에 대해서는 전문가들의 의견이 엇갈렸다. 일부 전문가는 망분리가 인터넷을 통한 외부 공격에 확실한 내부 방어 체계를 구축하고 있다고 평가했다. 하지만 망분리가 적용되더라도 APT 공격 가능성은 여전히 존재하며, 공격자가 금융권의 망분리 구조를 이해하고 인터넷의 연결 없이 내부로만 침투하여 활동할 수 있다면 APT 공격이 가능하다는 의견도 제기되었다. 오픈소스 취약점 공격에는 신속한 패치 및 업데이트가 중요하나 망분리로 인해 외부 서버와 직접 통신이 어려워 오히려 대응이 늦어질 수 있는 점도 한계로 지목되었다.

“망 분리는 인터넷을 통한 외부로부터의 공격을 차단하기 위한 수단으로 중요 서버에 접속되어 있는 모든 PC는 인터넷과 차단되어 있어 최고의 차단 체계라고 판단된다.” (금융 보안 전문가 4)

“금융회사는 직원들이 기존 내부망과 인터넷망을 동시에 사용하면서 보안이 취약하고 다양한 침해사고에 무방비로 피해를 입은 사례가 있었지만 망분리를 적용하면서 내부 보안이 강화되고 금융보안사고도 감소하는 효과가 나타났다.” (금융 보안 전문가 3)

“망을 분리하더라도 업무상 목적으로 다양한 파일들이 망연계 솔루션 등을 통해 내

부로 반입되고 있으며 반입되는 파일도 패턴을 기반으로 한 백신 솔루션을 통해 점검하고 있기 때문에 새로운 유형의 APT 악성코드는 탐지할 수 없어 APT 공격 가능성이 계속 존재할 수밖에 없음.” (금융 보안 전문가 1)

만약 APT 혹은 오픈소스 취약점 공격이 성공한 상황에서도 외부로 정보 유출을 시도하거나 외부의 서버와 통신을 하는 경우 망분리가 이를 차단하는 효과를 발휘할 수 있다는 의견도 있었다.

3. 금융 분야의 국내외 망분리 규제 현황

□ 국내 망분리 규제 현황

금융 분야의 망분리는 인터넷 망과 내부 통신망의 분리 즉, 외부에서 내부로 유입되는 모든 프로그램, 데이터, 메일 등을 기본적으로 차단함으로써 내부 시스템을 보호하려는 것이다. 금융 분야의 망분리 정책은 금융회사와 전자금융업자 그리고 핀테크 기업에 적용된다. 망분리의 근거는 「개인정보보호법」과 「전자금융 감독 규정」이 있다. 「개인정보보호법」 제31조에 개인정보 보호책임자의 지정과 역할을 규명하였고, 「전자금융 감독 규정」 제15조 제1항 제3호, 제5호에서 망분리를 언급하고 있다.

〈전자금융감독규정〉

제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운영하여야 한다.

3. 내부통신망과 연결된 내부 업무용시스템은 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지

5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것

망분리가 적절하게 이루어지지 않으면 금융감독원 검사 시 지적을 받고 담당자는 징계를 받게 된다. 사고로 연결될 경우 담당자는 물론 관리자, 임원도 징계를 받는다.

〈표 4-5〉 금융 분야 IT관련 법규 위반행위의 제재 대상

유형		내 용
IT사고 중 다음 유형에 해당하는 사고가 발생한 경우	유형1	(전산자료 또는 프로그램을 조작하여 발생한 중대한 사고: 「전자금융거래법」제21조 위반) 금융회사 임직원이 고의로 전산자료 또는 프로그램을 조작하여 발생한 사고로 금융기관 또는 금융거래자에게 손실을 초래하는 등 사회적 물의를 일으키는 경우
	유형2	(접근매체 위변조 등에 의한 금전사고: 「전자금융거래법」 제9조 위반) 접근매체의 위조, 변조 및 도용으로 발생한 사고, 계약체결 또는 거래지시의 전자적전송이나 처리과정에서 발생한 금전적 사고(단, 금융회사의 부주의에 의하여 발생한 사고에 한함)
	유형3	(전산시스템 재해복구 지연: 「전자금융감독규정」제23조제9항 위반)금융회사 핵심업무를 지원하는 전산시스템이 재해복구목표시간을 초과하여 중단된 경우
	유형4	(해킹에 의한 고객정보 유출: 「전자금융감독규정」제4절 위반) 해킹 등으로 인하여 고객정보가 유출된 경우
IT사고가 발생하지 않은 경우	유형5	(「전자금융거래법」제21조 위반) IT관련 법규 위반으로 사고발생 위험이 현저히 높은 경우
기타	유형6	(「전자금융감독규정」제13조제1항 제11호 및 제4항 위반) 정보처리시스템 가동기록을 보존하지 않았거나 기록을 삭제·훼손한 경우

주: 「전자금융거래법」, 「전자금융감독규정」 및 동 규정 시행세칙을 위반한 행위를 의미

자료: 「금융기관 검사 및 제재에 관한 규정 시행세칙」, 별표 3 금융업종별·위반유형별 제재양정기준(신설 2011.12.28., 개정 2014.7.23., 2016.2.29., 2020.5.13.)

전문가들은 망분리 규제에서 지정하는 범위가 광범위하여 클라우드, 오픈소스라는 인터넷 기반의 업무 환경과 지능화되고 있는 악성코드의 진화를 고려할 때 단순히 외부망과 내부망을 차단하는 모델은 규제의 효과성이 약해지고 있다고 지적한다.

“망분리 대상을 내부 업무용 시스템, 정보처리시스템과 이를 접근하는 단말기 등으로 규정하고 있어 사실상 모든 시스템이라고 볼 수 있을 만큼 광범위하게 인터넷 차단을 요구하고 있음.” (금융 보안 전문가 1)

“최근 정부는 클라우드와 망분리 규제를 완화하는 정책을 발표하였지만 여전히 대체 수단을 요구하거나 연구개발 목적이라는 조건을 달고 있다. 이러한 정부 주도의 정보보호 정책은 보안시장과 금융업계 모두에게 시대착오적인 발상이고 규제 일변도의 금융보안 정책은 금융회사의 디지털 전환에 걸림돌이 되고 있다.” (금융 보안 전문가 3)

또한 금융 부분에 보안 사고가 있을 때마다 관련 보안규정의 개정이 잇따라 진행된 결과 현재 보안규정은 해석이 난해할 정도로 복잡해졌다는 점을 지적하였다.

“국내 금융회사에서 보안사고가 발생할 때마다 정부는 보안기술을 강제하고 감독규정에 규제를 추가하는 일이 반복됨에 따라 지금의 전자금융감독규정은 방대하고 난해하여 업계와 시장에서 해석하기도 쉽지 않다.” (금융 보안 전문가 3)

□ 해외 망분리 규제 현황과 전망

전문가들은 공통적으로 망분리는 권고사항일 뿐 이를 강제하거나 의무화하고 있는 국가는 해외 어디에도 없다는 의견을 제시하였다. 해외 보안 정책은 기본적으로 자율성에 중심을 두고 있으며 기업마다 인프라와 환경이 다르기 때문에 이에 적합한 보안 모델 또한 달라질 수밖에 없다는 점을 인식하고 있기 때문이다. 망분리가 보안 수단 중 하나로서 금융회사가 자율적으로 도입하면 되는 사항임을 강조했다.

“국제 보안 컨퍼런스 중 가장 큰 행사인 RSA에서도 국내와 유사한 망분리 모델을 적용한 사례나 연구 발표가 전무함. 또한, ISO, PCI-DSS, SOC 등 주요 정보보호, 내부통제 등의 국제표준에서도 이러한 요구를 하고 있지 않기 때문에 해외에서 이에 대한 규제가 도입될 가능성은 없다고 보임.” (금융 보안 전문가 1)

“미국 사이버보안및인프라보안국(CISA)도 높은 보안수준이 요구되는 자산 식별 후 네트워크 분할을 권고 (네트워크 분할이 네트워크 보호 측면의 유일한 도구는 아님을 명시)” (금융 보안 전문가 4)

개인정보를 상대적으로 강하게 보호하는 유럽에서도 망분리 규제를 의무화하지 않고 있고 일반개인정보보호법(GDPR)을 기준으로 개인정보를 보호 및 관리하며, 이를 위반한 경우 사후적 규제로 과징금을 부과하는 형태로 추진하고 있다. 이밖에 중국, 일본, 호주와 같은 국가에서도 보안에 관한 기술적인 조치는 권고사항일 뿐 망분리에 대한 별도의 언급 없이 자율적인 조치로 진행되고 있다.

“내부망과 외부망 분리보다는 정보자산을 기밀성, 중요도에 따라 분류하고 네트워크 보안과 접근 권한 통제도 자율적으로 권고하고 있다.” (금융 보안 전문가 3)

4. 금융 분야의 보안 정책 제언

가. 금융 분야에서 망분리 규제가 반드시 필요한 부분

□ 데이터 관점: 개인정보

금융 기업이 보유한 개인신용정보와 금융 정보는 유출될 경우 입을 피해를 고려하면 보호의 우선순위가 가장 높다. 일부 전문가는 개인신용정보는 외부 인터넷뿐만 아니라 연결이 불필요한 내부 네트워크와도 분리되는 즉, 폐쇄된 네트워크가 전제되어야 함을 지적했다. 한편, 데이터의 활용성을 향상시키기 위해 개인식별 정보를 제거하거나 가명 처리한 금융 정보의 경우는 우선순위를 상대적으로 낮게 설정할 수 있다.

“데이터 관점에서는 금융 분야에서 외부 유출이 되지 않도록 보호해야 할 가장 우선 순위가 높은 데이터는 개인신용정보보호임.” (금융 보안 전문가 1)

“고객원장 데이터는 망분리보다는 폐쇄된 네트워크에 위치하고 이중 방화벽으로 통제하면서 서비스와 복제를 병행하여야 한다.” (금융 보안 전문가 3)

□ 보안시스템 관점: 운영 서버

금융회사의 보안 서버는 크게 운영 서버(Real Server)와 개발 및 테스트 서버로 분류할 수 있다. 금융 서비스와 직접적으로 관련이 있는 정보는 운영 서버에서 처리되고,

개발 및 테스트 서버에서는 각종 소스 프로그램, 실행 프로그램, 단위 시험 등이 수행된다. 전문가들은 현재와 같이 서버 유형의 구분 없이 망분리가 적용되는 것은 업무 효율성이 저하될 우려가 있으므로 망분리는 운영 서버에만 적용되고, 개발 및 테스트 서버, 사내 인트라넷을 이용하는 PC는 적용에 예외로 두는 것이 타당하다고 말한다.

“만약에 부분적인 망분리를 적용한다면 운영 서버를 중심으로 한 부문이 대상이 될 것이다.” (금융 보안 전문가 4)

나. 향후 지향해야 할 보안수단과 보안모델의 방향

금융회사가 보유하고 있는 예금, 고객정보 및 금융정보는 유출되거나 시스템이 마비될 경우 개인은 물론 국가적으로 큰 혼란을 야기할 수 있다. 더욱이 최근 코로나 사태로 인해 다양한 비대면 사이버공격이 발생하고 있는데, 의료기관, 정부, 보건소 등을 사칭한 악성코드 감염 시도와 랜섬웨어 공격이 금융회사를 대상으로 빈번하게 발생하고 있다. 따라서 금융회사에 대해서는 높은 수준의 보안이 요구되며, 보안 정책을 수립할 때 다음과 같은 방향을 고려해야 할 것이다.

□ 범위를 최소화하여 망분리 유지

다수의 전문가들이 현재의 망분리를 유지하되 최소화할 것을 권고했다. 지금과 같이 단순히 내부와 내부를 구분하는 이분법적인 논리가 아닌 클라우드 환경 여부, 네트워크 구조, 업무 방식, 정보 자산의 중요도 등에 따라 하나의 네트워크 보안 통제 모델로서 유연하게 망분리를 적용하는 것이 적절하다는 의견이었다. 더욱이 망분리가 적용되는 영역을 설정함에 있어 제로 트러스트 원칙에 따라 망을 세분화할 수 있음을 제시했다. 이렇듯 외부와 빈번하게 통신이 필요한 환경과 폐쇄적인 환경을 분리해야 APT 공격과 같은 정교한 공격을 무효화할 수 있다.

“랜섬웨어 공격, APT 공격 등 다른 대응 방법이 없는 상황에서 물리적/논리적 망분리의 계속 사용이 필요하다. 다만, 재택 근무가 확대되고 있고 모든 PC에 대하여

적용하는 등 업무의 효율성이 저해하는 부문이 많으므로 핵심적인 서버를 보호하는 형태로 완화된 망분리가 바람직하다고 판단한다.” (금융 보안 전문가 4)

“망분리는 네트워크 보안 모델의 하나이며 클라우드 환경에서는 가상 네트워크(VPC)를 통해 저비용으로 큰 효과를 볼 수 있는 방식이기도 함. 망분리가 진화하는 공격 수법과 환경에서도 보안 모델로 계속 효과성을 갖기 위해서는 범위를 최소화 해서 예외 상황도 최소화해야 함.” (금융 보안 전문가 1)

“제로 트러스트 원칙에 따라 망을 세분화하여 나눈다면 더욱 효과적일 수 있음(서비스/컴포넌트별로 가상 네트워크를 설정해 통신을 차단하는 마이크로 아키텍처 등)” (금융 보안 전문가 1)

□ 자율적 네트워크 보안체계 마련

전문가들은 우리나라 금융회사의 정보보호 수준이 높아졌고 독자적인 보안환경 구축과 운영 능력이 확보되었으므로 금융 기관의 자율적인 네트워크 보안체계 구축이 필요하다고 말한다. 더 이상 금융보안이라는 명목으로 보안기술과 보안규제를 확산해 나갈 필요가 없으며, 국가나 금융 당국이 일률적으로 통제하는 방식보다는 예견되는 보안사고에 대비하는 자율적 보안능력을 향상시키고 선제적인 지침을 배포하여 사후 발생하는 보안사고에 대한 처벌과 징계만으로도 충분하다는 것이다.

“금융보안은 국가나 당국이 통제하는 방식보다는 예견되는 보안사고에 대비하는 자율적 보안능력을 향상시키고 선제적인 지침을 배포하는 방식으로 진행될 것이다.” (금융 보안 전문가 3)

“해외 주요국은 보안정책이나 규제를 획일화하지 않으며 가이드라인을 통해 금융회사들이 자발적 참여나 자율적 운용을 권하는 수준임.” (금융 보안 전문가 3)

□ 제로 트러스트(Zero Trust) 도입을 위한 환경 조성

제로 트러스트는 APT, 오픈소스 취약점, 공급망 공격 등과 같이 예측·통제할 수 없는 상황의 발생을 염두에 두고 이에 대비하기 위해 정보 자산과 시스템, 사용자 계정, 보안카드, 일회용비밀번호생성기(One Time Password, OTP) 등 다양한 인증수단 도입, 프로세스에 다단계 인증, 최소한의 권한 부여, 마이크로 아키텍처 구성 등을 통해 실질적인 피해를 예방할 수 있도록 한다.

이를 위해 정보 자산에 대한 중요도 평가를 실시하여 위협 요소를 상시 모니터링하고 미흡한 상황을 보완하는 종합적인 보안 프로세스 구축이 요구된다. 다만, 모든 시스템과 자산 접근에 제로 트러스트 원칙에 따라 강력한 통제를 적용하기는 제반 비용이 많이 들기 때문에 데이터 중요도와 환경에 기초한 리스크 평가를 통해 적절한 통제수단을 차등화하는 보안모델이 적절하다.

“제로 트러스트 환경을 도입하기 이전에 금융회사 내부의 모든 접속자를 대상으로 전산자산에 대한 접근, 승인, 수집, 감사 등 일련의 원칙과 프로세스를 마련하여 신뢰할 수 있는 여건을 갖추어야 한다.” (금융 보안 전문가 3)

다. 영역 기반에서 검증 기반 보안 모델로 전환 가능성

대부분의 전문가들이 높은 효율성과 안정성, 전세계적인 추세 등을 고려했을 때 검증 기반 보안 모델로의 변화가 타당하다고 평가했다. 금융 분야에 망분리 규제가 완화되고 새로운 비즈니스가 개발되면서 제로 트러스트와 같은 새로운 개념의 보안 모델이 필요한 시기이다. 일부 금융기업에서는 제로 트러스트 모델을 이미 적용하고 있다.

“PC에 안티바이러스를 설치하여 회사가 제공한 것에 한하여 접속을 허용한다든지, 액티브 디렉토리(Active Directory: AD)에 등록된 계정만 접속을 허가하고 설정된 권한 범위에서만 시스템을 접근할 수 있도록 한다든지, 인증 시 비밀번호 이외에 보안카드나 OTP, 생체 인증 등 MFA 체계를 구축하는 등 많은 형태로 제로 트러스트 모델을 활용하고 있다.” (금융 보안 전문가 4)

그러나 전문가들은 엄밀한 의미에서 영역 기반 보안 모델에서 검증 기반 보안 모델로 전환하는 것이라기보다는 검증 기반 보안 모델이 망분리 같은 영역 기반 보안 모델을 포함하여 발전하는 것이라고 지적한다.

“광범위한 경계선에만 의존하는 것이 아니라 내부에서의 접근과 요청이 정당한지 데이터 중요도, 인터페이스 방식, 요청자에 따라 검증할 수 있도록 전환을 해야 함.” (금융 보안 전문가 1)

“제로 트러스트 모델은 기존 보안 모델에 비하여 보다 강화된 인증과 검증을 도입하는 것이라고 할 수 있다. 다만, 정보보안의 목표는 단일한 보안기술과 패러다임의 적용을 통해서 달성 가능한 것이 아님을 전제로 해야 한다.” (금융 보안 전문가 2)

금융 분야에 제로 트러스트가 도입되면, 방화벽이나 내부망의 경계가 사라지고 언제 어디서든 다양한 디바이스를 통해 금융회사의 네트워크와 애플리케이션에 안전하고 일관된 방법으로 접근할 수 있게 될 것이다. 금융 기업이 제로 트러스트를 도입하기 위해서는 우선 각 기관 내부에서 작동하는 보안솔루션, 보안디바이스, 보안서비스, 보안프로세스 등을 종합적으로 파악하고, 모의해킹 등을 활용하여 보안 취약점을 진단한 후 독자적으로 제로 트러스트 아키텍처를 구축할 필요가 있다. 기존 방식이 임직원 사용자의 네트워크 이용이 중심이었다면, 향후에는 데이터 사용을 중심으로 접근하여 인증과 접근 권한이 동시에 제어되는 방식으로 아키텍처를 구축하여야 할 것이다. 또한 기존의 불필요한 보안정책이나 지침은 폐기하고 형식적인 보안업무도 제거하면서 변화해가는 금융전산망에 알맞도록 새로운 보안정책과 ID 통합을 통해 리소스 액세스 규칙을 새롭게 설정하는 작업을 병행하여야 한다.

또한 다수의 전문가들이 제로 트러스트의 실현은 점진적으로 이루어지는 것이 타당하다는 것에 의견을 모았다. 현재 금융 회사는 영역 기반 모델을 중심으로 보안정책을 운용하고 있으므로 기존의 보안 모델을 제로 트러스트 모델로 일시에 바꾸는 것은 변화의 실패에 대한 위험성, 비용, 시간, 전문 인력, 직원들의 공감대 형성 부족 등에서 부담을 초래할 수 있기 때문이다. 따라서 영역 기반 보안 모델이 필요한 부분과 검증

기반 보안 모델이 필요한 부분을 분리하고, 당분간 이 두 모델이 공존하는 하이브리드 보안 체계를 운용하게 될 것이다. 그리고 검증 기반 보안 모델에 대한 안전성과 효과성이 입증된 이후 보안 체계 전체를 제로 트러스트 방식으로 전환할 수 있을 것이다.

“보호 범위와 방어 대상이 다르기 때문에 전체를 전환하는 것은 망분리 이전에 발생되었던 위협이 재현될 것이므로 권고하지 않으며, 망분리와 같은 영역 기반 보안 모델과 검증 기반 보안 모델을 혼합하여 적용하는 방안이 가장 현실적이고 효과적으로 판단된다.” (금융 보안 전문가 4)

라. 검증 기반 보안 모델로 전환하기 위한 정책

□ 자율적 추진 유도

이제까지의 금융 분야 보안 정책은 정부 또는 금융 감독 당국이 주도해 왔고 어느 정도의 안정성을 확보했다고 평가할 수 있다. 하지만 모든 전문가들이 동의하는 바와 같이 향후의 금융 정책은 금융회사가 자율적으로 추진할 수 있도록 변화하는 것이 바람직하다. 또한 제로 트러스트는 하나의 원칙이며 구체적인 구현 방식은 각 기업이 처한 상황에 따라 달라질 것이기 때문에 지금처럼 규제화하기도 어렵다. 특정한 보안 방식을 구체적으로 요구하는 정책보다는 기업마다 적합한 방식을 찾아 보안에 충분히 투자할 수 있도록 동기를 부여하는 정책이 요구된다.

일례로 특정 보안 기술이나 통제를 구현했는지 체크하는 일괄적인 방식의 평가에서 기업의 보안 역량과 리소스에 따른 보안 모델의 차이와 수준의 편차를 고려하여 보안 모델을 수립할 수 있도록 독려하는 방식의 평가로 전환하는 것이 필요하다. 정부나 금융 당국이 기업으로 하여금 주기적으로 수행한 환경 리스크 평가를 기초로 보안 효과성을 입증하도록 하고, 리스크 평가가 제로 트러스트 원칙에 따라 수행되도록 한다면 자연스럽게 보안 모델이 전환될 수 있을 것이다. 또한 현재 일정 규모 이상의 정보통신 기업이 의무적으로 받고 있는 정보보호 관리체계(Information Security Management System, ISMS)와 같은 인증도 활용해 볼 수 있을 것이다.

“각 기업이 개별적인 환경과 상황에 맞게 보안 모델을 수립할 수 있도록 하기 위해 특정 기술이나 모델을 규제화하지 않고 일정 규모 이상의 보안 조직, 예산을 집행하도록 하고 보안사고 발생 시 페널티를 부여하는 방향으로 규제가 변화할 필요가 있음” (금융 보안 전문가 1)

□ 전환 과정에서 발생하는 문제에 대한 책임부담 경감

전문가들은 기업의 입장에서 신규 시스템의 도입이나 전환을 꺼리는 이유 중 하나가 업무 수행과정에서 발생된 결과에 책임을 지우는 관행 때문이라고 지적했다. 시스템 장애나 사고 발생 시 담당자는 물론 관리자, CEO 등에 과중한 처벌이 부과된다는 것이다. 실제로 금융회사는 사고 발생 시 부과되는 처벌로 인하여 규정에 명시된 사항 이외에는 자발적으로 정보보호에 대한 연구를 충분히 하고 있지 않을 뿐만 아니라 책임 회피를 위해 공동의 가이드 작성 요구, 유사한 방법의 보안 수단 사용 등 자율성과 거리가 먼 방식으로 보안 체계를 운용하고 있다. 제로 트러스트는 아직 활용된 사례가 많지 않아 전환 과정에서 시행착오가 발생할 수밖에 없다. 따라서 고의나 중대한 과실이 아닐 경우 발생한 사고에 대해 적용하고 있는 각종 징계조항이 삭제 또는 개정되지 않는다면 새로운 보안 모델로의 전환은 이루어지지 않을 것이다.

“고의나 중대한 과실이 아닐 경우 업무 수행 과정에서 발생하는 결과에 대하여 별도로 책임을 묻지 않는 정책이 필요하다.” (금융 보안 전문가 4)

□ 인력 육성 및 내부 가이드라인 마련

금융 당국과 기업은 특정 보안기술이나 보안모델의 도입이 만능이 아니라는 인식을 가질 필요가 있다. 즉, 내부 보안전문가를 육성하여 위험평가능력을 개발하고 이에 기반한 위험통제 프로세스의 정립과 개선이 필수적이다. 기업 내부에서는 정보보호 거버넌스를 구축하는 차원에서 정보보호최고책임자와 정보보호위원회 같은 의사결정 기구를 통해 기존의 보안정책을 새롭게 개편하고 제로 트러스트 가이드라인을 마련 및 배포하여야 한다.

제2절 헬스케어

1. 헬스케어 분야의 보안 위협

헬스케어 분야의 데이터는 단순히 개인정보를 넘어서 진료기록, 질병 등의 민감 정보를 포함하며 진단, 치료 등에 활용되고 있다. 그렇기 때문에 데이터 보안 위협은 단순한 개인정보 유출을 넘어 생명에 영향을 주는 위협이 될 수도 있다. 디지털 헬스케어 보안사고는 [그림 4-4]와 같이 최근 지속적으로 발생하고 있는데, 의료장비 또는 시스템이 해킹된 사례도 다수 발생하였다.

[그림 4-4] 최근 10년 디지털 헬스케어 보안사고 사례



자료: 과학기술정보통신부·한국인터넷진흥원(2021. 12b), p. 4.

헬스케어 산업에서의 보안 위협은 크게 3가지로 나누어 살펴볼 수 있다. 개인정보 유출, 개인정보 위변조, 시스템 해킹으로 인한 셧다운이다.

첫째, 개인정보 유출의 경우 개인정보는 바이러스, APT(Advanced Persistent Threat) 공격 등 다양한 경로로 유출될 수 있다. 병원은 현재 망분리가 강제는 아니지만 망분리 환경을 구축하고 있는 추세이며 의료법을 중심으로 각종 보안 규정을 준수

해 데이터 유출이나 위변조가 없도록 통제하고 있다. 하지만, 병원 관계자 또는 환자 개인을 통해 데이터가 유출될 수 있다. 다른 산업과 마찬가지로 개인의 로컬 단말기(핸드폰, 컴퓨터 등)를 통해 해킹을 시도하는 경우가 있고, 모바일 앱으로 건강검진 정보를 제공하는 경우처럼 개인에게 정보를 전달하는 과정에서 가로채기로 정보를 탈취해가는 가능성도 있다. 실제 사례로는 2021년 6월 악성코드 감염을 통해 서울대병원의 환자정보가 유출된 사고가 있었는데, 생년월일, 성별과 같은 인적사항의 개인정보 일부와 신체적 정보(병원등록번호, 진료과, 진단명, 검사일 등의 의료정보) 일부가 유출되었다.²⁰⁾ 2018년과 2019년 고려대 안암병원, 가톨릭대 서울성모병원 등의 대학병원에서 개인정보가 사람을 통해 제약사로 유출된 사례도 있었다.²¹⁾

“헬스케어 산업은 개인의 사생활을 침해할 수 있는 개인정보와 민감정보를 다루고 있고, 환자들의 데이터 자체가 회사와 기관의 자산이다. 데이터가 유출될 경우에는 피해 규모가 상당하며, 특히 대체 불가능한 데이터(유전체, 지문 등)의 경우에는 더 막대하다.” (헬스케어 보안 전문가 1)

둘째, 개인정보 위변조의 경우 의료정보 중에서 진단, 치료정보 등에 개입하여 위변조하는 문제가 있다. 병원에서 진단을 받고 약 처방 또는 치료를 하는 단계에서 데이터가 위변조되면 잘못된 진단과 치료를 받게 되어 생명이 위협받을 수 있다. 또한 최근 환자가 위조처방전을 약국에 제출하고 향정신성의약품을 처방받다가 경찰에 위조범으로 신고된 사례처럼 처방전을 악용하는 경우도 발생할 수 있다.²²⁾

셋째, 시스템 해킹으로 인한 셧다운이다. 의료정보시스템, 헬스케어 기기 등이 해킹을 당하게 되면 개인정보 유출뿐 아니라 오작동, 작동불능 등의 상황이 된다. 예를 들어 국내 의료기관에서 사용 중인 PACS(Picture Archiving and Communication System, 의료영상저장 및 전송시스템)에서 서버가 공격을 받은 사고가 있었다.²³⁾

20) 서울신문(2022. 7. 13.), 「서울대병원 개인정보 추가 유출…생년월일·검사결과 줄줄이」,

<https://www.seoul.co.kr/news/newsView.php?id=20220713500188> (검색일 2022. 9. 22.).

21) 청년의사(2022. 2. 25.), 「내 정보가 제약사에? '환자 개인정보 유출'에 머리 숙인 대학병원들」,

<https://www.docdocdoc.co.kr/news/articleView.html?idxno=2020167> (검색일 2022. 9. 22.).

22) 데일리팜(2022. 7. 23.), 「향정 위조처방전에 속은 약국 6곳, 행정처분 없을 듯」,

<http://www.dailypharm.com/Users/News/NewsView.html?ID=290303> (검색일 2022. 9. 22.).

PACS는 환자의 의료영상을 디지털로 관리, 전송하는 시스템으로 의료기관에서 환자의 영상을 판독하는 데 활용된다. 만약 PACS가 해킹을 당해 서버가 마비되거나 잘못된 영상을 보여주게 된다면, 환자의 생명에 직접적인 영향을 끼치게 되는 것이다. 실제로 2020년 독일 뒤셀도르프 대학병원에서는 여성 중환자가 수술을 받을 예정이었는데, 랜섬웨어 공격으로 병원의 서버가 모두 암호화되어 수술 진행이 불가하여 사망한 사고가 있었다.²⁴⁾ 2022년 8월에도 프랑스 남부에 위치한 CHSF(Center Hospitalier sud Francilien) 병원에서 랜섬웨어 공격을 받아 병원의 응급 수술 및 서비스가 모두 중단되었다.²⁵⁾

“웨어러블 기기, 병원 기기 뿐 아니라 인공 장기(심장 등) 혹은 이동 가능한 인슐린 주사기 등을 활용하는 의료 네트워크에서 데이터 흐름이 차단되면 수정, 전달 등의 업데이트가 불가하고 오작동을 일으켜 결국에는 건강에 심각한 문제가 발생할 것입니다. 예를 들어서 심장은 1분에 80번 이상 뛰면 안 되기 때문에 75번으로 세팅해 놔는데 위조된 정보가 가서 90번 뛰게 하면 신체에 이상이 생기고 환자가 직접적인 피해를 받게 될 것입니다.” (헬스케어 보안 전문가 3)

2. 헬스케어 분야의 보안 수단 및 효과성 비교

헬스케어 보안 전문가 자문 결과와 관련 문헌을 종합하면, 개인정보 유출, 개인정보 위변조, 시스템 해킹으로 인한 셧다운 등의 위협에 대응하기 위한 보안 수단은 내부 인프라 측면과 서비스 제공 측면으로 구분할 수 있다. 내부 인프라 측면의 보안 수단에는 디지털저작권관리, 데이터유출방지, 패치관리솔루션, 망분리 등이 있고, 서비스 제공 측면의 보안 수단에는 블록체인, 접근제어목록 등이 있다.

23) 보안뉴스(2022. 7. 4.), 「[긴급] 국내 병원 환자 의료영상 관리 시스템 'PACS' 노린 공격 발견」, <https://m.boannews.com/html/detail.html?idx=108000> (검색일 2022. 9. 22.).

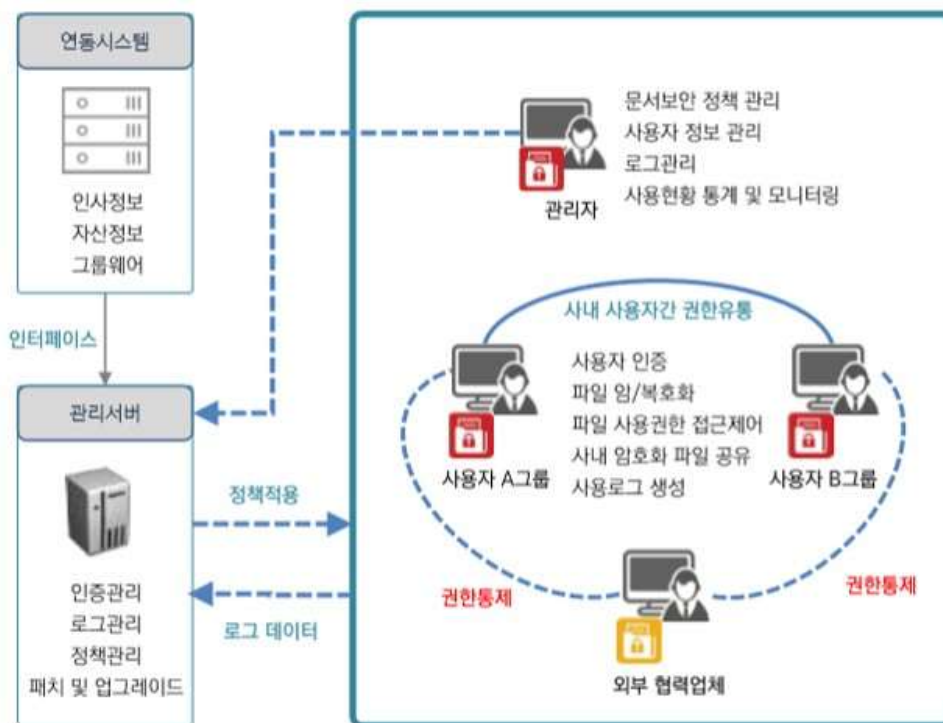
24) 동아사이언스(2020. 9. 18.), 「랜섬웨어 공격으로 독일 병원에서 여성 환자 숨져」, <https://www.dongascience.com/news.php?idx=39930> (검색일 2022. 9. 22.).

25) CCTV NEWS(2022. 8. 24.), 「프랑스 대형 병원, 랜섬웨어 공격 받아 전산 마비돼」, <https://www.cctvnews.co.kr/news/articleView.html?idxno=233260> (검색일 2022. 9. 23.).

□ 내부 인프라 측면의 보안 수단

디지털저작권관리(Digital Rights Management, DRM)는 허가된 사용자만이 디지털콘텐츠에 접근할 수 있도록 만드는 제한 기술과 디지털콘텐츠가 무분별하게 복제될 수 없도록 하는 보안 기술을 의미한다.²⁶⁾ 콘텐츠의 불법복제를 방지하는 기술, 사용료 부과를 통한 유통 및 관리를 지원하는 서비스, 기업 내 문서보안과 저작권을 관리하는 기술 등을 포함한다. 예를 들어 DRM 솔루션을 도입한 한국의학연구소에서는 정보 사용자가 권한에 맞는 문서만 볼 수 있도록 하고 접속 기록을 서버에 남겨 환자 정보에 대한 무분별한 접근을 차단하고 추후 문제 발생 시 책임 소재를 명확히 하도록 하였다.²⁷⁾

[그림 4-5] 디지털저작권관리(DRM) 솔루션의 구성



자료: SK설더스(2021), p. 104.

26) 네이버 지식백과 DRM [Digital Rights Management], <https://terms.naver.com/entry.naver?docId=3571052&cid=59088&categoryId=59096> (검색일 2022. 9. 28.)

27) 청년의사(2012. 4. 13.), "병의원도 DRM 도입으로 개인정보보호법 해결 가능", <http://www.docdocdoc.co.kr/news/articleView.html?idxno=112749> (검색일 2022. 9. 28.)

데이터유출방지(Data Loss Prevention, DLP)는 데이터가 메신저, 웹메일, USB 등의 다양한 경로로 유출되는 것을 기록하고 방지하는 기술을 의미한다. 사전 통제 기능을 하며 기록을 남기기 때문에 사후 유출 경로를 파악하는 데도 활용된다.²⁸⁾

“DLP는 엔드포인트 DLP와 네트워크 DLP 등 2가지 모드가 있습니다. 엔드포인트 DLP는 PC에서 이메일, 웹브라우저 등 데이터가 외부로 유출될 때 탐지하여 관리자에게 알려주는 역할을 합니다. 네트워크 DLP는 네트워크 상에서 외부 유출 상황이 발생하면 관리자에게 알려주는 것입니다. 관리자가 최종 판단하는 것이고, 관리자의 액션에 따라 책임을 물을 수도 있습니다.” (헬스케어 보안 전문가 3)

패치관리솔루션(patch management system, PMS)은 PC에 보안 패치를 원격으로 자동 설치 및 관리한다. 패치관리솔루션은 악성코드와 외부 위협에 대응하기 위해 업데이트를 일괄 수행하며, 취약한 운영체제를 보완하여 안전한 기기 관리 및 물리적 보호를 가능하게 한다(과학기술정보통신부·한국인터넷진흥원, 2021. 12a; SK실터스, 2021). 최근 헬스케어 산업의 중대한 보안 위협으로 ‘미패치 IoT 기기’가 지적되고 있기 때문에²⁹⁾ 향후 패치관리솔루션의 역할이 더욱 중요해질 것이다.

망분리는 외부망과 내부망을 물리적, 논리적으로 분리함으로써 접근을 원천 차단한다는 점에서 데이터 유출이나 랜섬웨어 같은 위협에 대응하는 가장 안전한 수단일 수도 있다. 하지만, 재택근무, 원격근무 등의 업무환경 변화로 외부에서 데이터를 활용해야 하는 경우 보안 위협이 발생하고 망분리를 구축하는 데 비용과 시간의 비효율이 따른다.

“규제를 따르기 위해서 솔루션 도입과 비용(PC 별도 구매)이 발생할 수밖에 없으며, 규제를 지키고 유지하기 위한 비용 부담, 업무 지연이 상당합니다. 데이터가 서로 연결되지 않으므로 융복합적인 개발이 불가능하다는 단점이 있습니다. 망분리가 잘 유지되면 유의미하지만 휴먼에러(논리적 망분리의 설정 오류 등)와 여러 망을

28) 위키백과, 데이터 유출 방지, <https://bit.ly/3Rfc5il> (검색일 2022. 9. 27.).

29) ITWorld(2022. 2. 3.), 「헬스케어 산업의 가장 큰 보안 위협은 ‘미패치 IoT 기기’」, <https://www.itworld.co.kr/news/224024> (검색일 2022. 9. 28.).

유지할 때 가지고 있는 한계가 분명합니다.” (헬스케어 보안 전문가 1)

“망분리가 해킹 방지를 위한 가장 좋은 대안으로 간주되고 있으나, 망분리 시 실제 업무의 불편함으로 인해서 사용자들이 보안에 취약한 도구들(카카오톡, 개인 이메일 등)을 이용해 외부와 자료를 공유하는 등 부작용이 많이 발생하고 있습니다. 또한, 분리된 이중 망간 전송통제를 시스템적으로 구현하기도 하나 전송자료에 대한 영향도 검토, 사유 확인 등 적절한 승인체계 및 통제관리인력 확보가 선행되지 않는다면 망간 전송통제는 무의미(단순 요청 건 승인 처리)하며, 이에 따른 정보 유출은 망분리의 문제점인데 현재 전혀 고려되지 않습니다.” (헬스케어 보안 전문가 2)

□ 서비스 제공 측면의 보안 수단

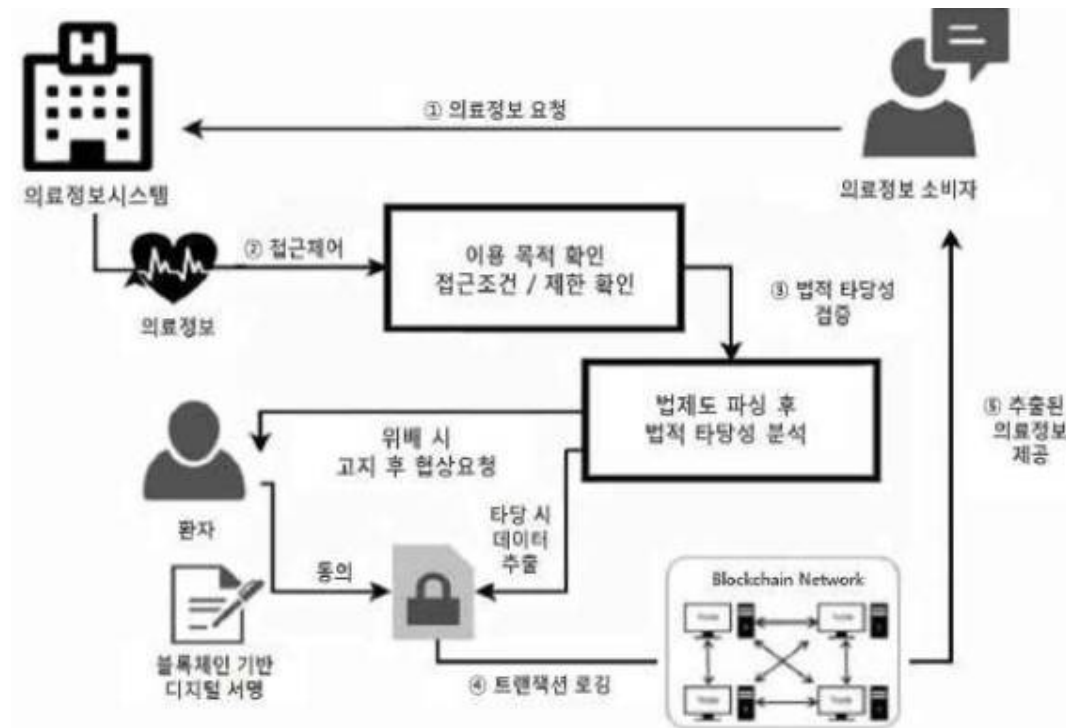
블록체인(BlockChain)은 데이터 무결성(Data Integrity)을 검증하며, 디지털 헬스케어가 부상하면서 데이터가 위조변조될 가능성을 차단하고 원본성을 증명하는 데 활용되고 있다. 헬스케어 분야에서는 의료 정보의 위변조 위협을 방지하여 보안성 강화, 본인의 정보를 암호화하여 저장 및 활용하기 때문에 정보 주권 강화, 어느 기관에서든 해당 정보를 활용할 수 있기 때문에 정보 교류 활성화, 더 나아가 정보 활용 확대 및 의료의 질 향상 등의 효과를 기대할 수 있다(한국보건산업진흥원, 2018). 구글, IBM, 메디블록, 휴먼스케이프, 교보생명, 레몬헬스케어 등 국내외 기업들이 헬스케어 분야에서 블록체인을 활용하고 있다.

하지만 일부 전문가는 블록체인이 위변조 방지에 일부 효용 가치가 있지만 이는 현존하는 진본확인기술로도 충분히 가능하다는 견해도 제시한다. 또한 블록체인도 보안 위협에 완벽하게 대응하지 못하는 등 여러 가지 문제점이 있다고 지적한다.

“블록체인의 경우 Private chain이 아닌 이상 개인정보 유출의 위험이 높고, 또한 on-chain node에 저장되는 개인정보는 법적으로 암호화해야 하며, 의료데이터의 경우 데이터 크기로 인하여 off-chain의 외부 저장소를 이용하여 chain의 node에는 해당 장소 주소의 hash값만을 가지는 등의 명확한 기술적 한계가 있습니다. 또한 chain의 데이터는 현재 국정원 가이드라인에서 요구하는 데이터 삭제(문서의

경우 파쇄 및 소각, 저장장치의 경우 물리적 파괴 혹은 디가우징)가 불가능하다는 문제점도 있죠.” (헬스케어 보안 전문가 2)

[그림 4-6] 블록체인의 의료정보시스템 예시



자료: 한국보건산업진흥원(2018), p. 6.

환자의 의료정보가 불법적으로 유통될 수 있는 문제점을 해결하기 위해 헬스케어 서비스에서는 의료진의 접근 권한에 주목하고 있으며(정운수, 2016), 접근 권한과 관련된 보안수단의 대표적인 예로는 접근제어목록(access control list, ACL)이 있다. 이는 개체나 개체 속성에 적용되어 있는 허가 목록을 말한다. 이 목록은 누가 또는 무엇이 객체 접근 허가를 받는지, 어떠한 작업이 객체에 수행되도록 허가를 받을지를 지정한다. 예를 들어, XYZ 파일에 대한 ACL 위의 항목(Alice, delete)은 Alice에게 XYZ 파일을 삭제할 허가 권한을 제공한다.³⁰⁾

30) 위키백과, 접근 제어 목록, https://ko.wikipedia.org/wiki/%EC%A0%91%EA%B7%BC_%EC%A0%9C%EC%96%B4_%EB%AA%A9%EB%A1%9D (검색일 2022. 9. 27.).

3. 헬스케어 분야의 국내외 망분리 규제 현황

□ 국내 망분리 규제 현황

헬스케어 분야는 개인정보를 취급하며, 의료 장비에서도 환자의 정보를 취급하고 있어서 개인정보보호법, 의료법, 국민건강보험법, 산업안전보건법, 정보통신기반 보호법 등의 법과 관련이 있다.

〈표 4-6〉 보건·의료 분야의 정보보호 관련 주요 법령

구분	보건·의료 해당 내용	
컴플라이언스 개인정보보호	• 의료법 • 국민건강보험법	• 산업안전보건법 • 정보통신기반 보호법 • 개인정보보호법
대상	• 의료기관(「의료법」 제3조 제2항에 따른 의원급 의료기관, 조산원, 병원급 의료기관)	

자료: SK설더스(2021), p. 11의 표에서 보건·의료 부분만 발췌.

2016년에는 정보통신망법에서 상급종합병원을 대상으로 ISMS인증 의무화를 도입하였고, 2018년에는 전자의무기록시스템(EMR) 관련 보관 기준을 발표하는 등 관련 법령이 지속적으로 제·개정되고 있다(SK설더스, 2021).

[그림 4-7] 헬스케어 분야의 법령 변화



자료: SK설더스(2021), p. 18.

헬스케어 분야의 망분리 규제는 전자의무기록(Electronic Medical Record, EMR)의 관리·보존에 대해 의무를 부과한다.

〈전자의무기록의 관리·보존에 필요한 시설과 장비에 관한 기준〉

제7조(의료기관 외의 장소 관리·보존시 추가적인 조치) 전자의무기록 관리자가 의료기관 외의 장소에서 전자의무기록을 관리·보존하는 경우에는 규칙 제16조제1항 제3호부터 제7호까지에 따른 시설과 장비에 대하여 별표에 따른 추가적인 조치를 하여야 한다.

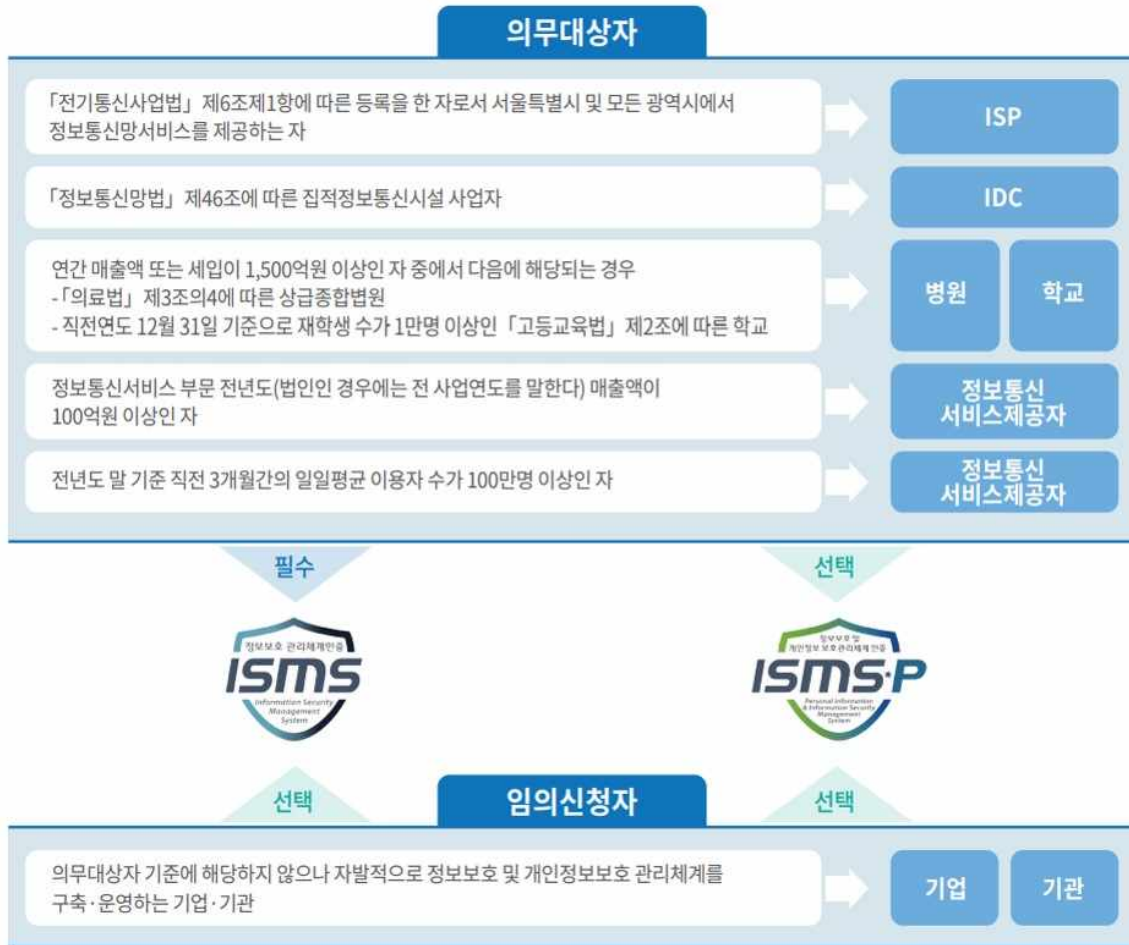
〈별표〉 의료기관 외의 장소에 전자의무기록 보관시 필요한 추가적인 조치(일부 발췌)

구분		세부조치 내용
네트워크 보안에 관한 시설과 장비	이중화된 네트워크의 구성	- 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립
	네트워크 보호시스템 운영	- 침입차단시스템, 침입탐지시스템 등 인증된 정보보호시스템을 운영하여 내·외부 네트워크를 보호하여야 한다.

“헬스케어 데이터를 별도로 두고 열람하게 되어 있는데 보호와 활용이 균형을 맞춰야 되는데 보호에 방점이 있다.” (헬스케어 보안 전문가 3)

또한, ISMS(정보보호 관리체계) 인증 및 ISMS-P(정보보호 및 개인정보보호 관리체계) 인증을 받기 위해서는 망분리를 해야 되는 경우가 있다. 병원의 경우 연간 매출액 또는 세액이 1,500억 이상이고 「의료법」 제3조의 4에 따른 상급종합병원에 해당하는 경우이다(과학기술정보통신부·개인정보위원회·한국인터넷진흥원, 2021. 7). 의료 분야에 인증 범위 예시에 따르면 EMR과 같은 의료 정보 시스템과 원격의료시스템, 홈페이지가 해당된다.

[그림 4-8] ISMS-P의 인증대상



자료: 과학기술정보통신부·개인정보위원회·한국인터넷진흥원(2021. 7), p. 24.

[그림 4-9] 보건복지부 데이터 중심병원 표준모델(안)(일부)



* 해당 문건에서 의견수렴용 자료로, 확정되지 않은 사업계획임을 밝힌 바 있음.

자료: 보건복지부 데이터·AI팀(2020. 5), p. 3.

“현재 정책적으로 의료데이터 중심병원사업, 정보통신 서비스 제공자 규제 등 통해 대형병원 위주로 망분리에 대한 요구를 받고 있는 상황이다.” (헬스케어 보안 전문가 2)

□ 해외 망분리 규제 현황

해외에서는 명시적으로 망분리를 요구하고 있는 정책은 없다. 망분리와 같은 아키텍처적인 사항은 강제하지 않고 권고하여 기업 상황에 맞는 보안을 유지할 수 있도록 하고 사후적으로 문제가 생겼을 경우 처벌을 하는 방식이다.

미국에서는 개인정보보호와 전자형식으로 보유 또는 전송되는 특정 건강 정보를 보호하기 위해 국가 보안 표준을 설정하는 내용인 ‘HIPAA Security Rule’이 있다.³¹⁾ HIPAA에서는 ‘해당 기관’에서 행정적, 물리적, 기술적 보호 장치를 마련할 것을 권고한다. 그 외에도 미국 보건복지부(US Department of Health and Human Services, HHS)에서 미국 국립표준기술연구소(National Institute of Standards and Technology, NIST)에서 발표한 사이버안전 프레임워크(Cybersecurity Framework)에 기반하여 가이드라인을 발표하였다.³²⁾ 사이버 보안 위협사항(예: 랜섬웨어, 디도스 등)이 감지되면 대응하는 절차에 대한 내용이다.

4. 헬스케어 분야의 보안 정책 제언

가. 헬스케어 분야에서 망분리 규제가 반드시 필요한 부분

헬스케어 보안 전문가들은 망분리가 단시간에 효과를 낼 수 있는 보안 수단이지만 이를 도입하려면 시간과 비용이 많이 소요되며, 망분리를 한다고 해서 외부의 위협을 완벽히 차단하기 어렵다고 말한다. 보안체계는 물리적, 관리적, 기술적 보안 요소가 있는데 전반적인 보안체계가 강화되어야 위협에 효과적으로 대응할 수 있다는 것이다.

31) <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html> (검색일 2022. 6. 30.).

32) <https://aspr.hhs.gov/cip/hph-cybersecurity-framework-implementation-guide/Pages/Introduction.aspx> (검색일 2022. 6. 30.).

즉 보안 수단은 한 가지로 수렴할 수 없으며 기업의 비즈니스 모델과 부합하게 적절한 보안 수단을 설정하는 자율성을 주고 데이터를 보호 및 강화시키는 방안 마련이 필요하다고 주장한다.

“망분리가 꼭 필요한 영역은 없습니다. 망분리를 하고 그 외의 수단으로 기밀정보를 취급하는 일이 빈번해지면 부작용이 생깁니다. 세상에 완벽한 ‘기술’은 없으며 보안은 기술적 보안, 물리적 보안, 관리적 보안 이 3가지가 모두 적용되어야 합니다. 모든 보안 사고는 기술적 보안의 기술적 문제보다는 사소한 관리적 보안, 물리적 보안으로 생기는 경우가 대부분입니다.” (헬스케어 보안 전문가 2)

나. 영역 기반에서 검증 기반 보안 모델로 전환 가능성

제로 트러스트(Zero Trust) 모델은 해외에 솔루션 기업들이 일부 있으나 아직 헬스케어 산업에서 적용한 사례는 많지 않은 것으로 보인다. 제로 트러스트를 우리가 지향해야 할 보안 모델로 보는 것에 대해 전문가들은 제로 트러스트가 가지는 장점도 물론 있지만 이 역시 보안의 완벽한 대응 모델이 아님을 강조하고 다른 대응 방안을 함께 활용되어야 한다고 말한다.

“제로 트러스트 모델은 망분리 같은 아키텍처적인 것을 강제하지 않고 권고하여 기업의 상황에 맞는 보안을 유지할 수 있도록 한다고 생각한다. 제로 트러스트는 블랙리스트 위주의 보안 방식보다는 화이트리스트 방식이라고 볼 수 있다. 망분리가 가지고 있는 한계가 분명히 있어서 제로 트러스트 모델로 전환하는 것도 중요하지만 실제 사용하는 사용자들의 불편함을 최소화하는 것이 중요하다. 제로 트러스트도 사회공학적 해킹을 포함한 APT 공격을 방어하기에는 쉽지 않다.” (헬스케어 보안 전문가 1)

“제로 트러스트는 새로운 것이 아니고 기존 보안관리 체계에 중간 단계마다 기존의 신뢰결과를 무시하고 재검증하는 절차가 추가된 것뿐이며, 이를 위한 자동화 또는 관리인력 추가 등 내부적인 합의가 필요하다. 실제로 보안 사고는 기술적 보안이

아닌 인적 보안 혹은 물리적 보안에서 발생하는 경우가 대부분이라는 것을 고려하여 대안을 마련해야 한다.” (헬스케어 보안 전문가 2)

“제로 트러스트는 결국에는 멀티팩터 인증 수단만 도입해서 되는 게 아니다. 멀티팩터를 통해 인증 레벨을 설정하고 데이터의 위험 평가를 하고, 취약점 평가를 거쳐서 권한을 부여하게 될 텐데, 이를 하는 과정에서 시간과 비용이 많이 발생한다. 제로 트러스트를 한다고 해서 다른 DRM, DLP 등의 보안수단을 사용하지 않게 되지는 않을 것이다.” (헬스케어 보안 전문가 3)

다. 검증 기반 보안 모델로 전환하기 위한 정책

제로 트러스트 모델로 전환하기 위해서 정부와 의료기관, 기업은 우선적으로 특정 보안기술의 도입이 만능이 아니라는 인식을 가질 필요가 있다. 즉, 내부 보안전문가를 육성하여 위험평가능력을 개발하고, 이에 기반을 둔 위험통제 프로세스의 정립과 개선이 필수적이다. 기업 내부에서는 정보보호 거버넌스를 구축하는 차원에서 정보보호 최고책임자와 정보보호위원회 같은 의사결정 기구를 통해 기존의 보안정책을 새롭게 개편해야 한다.

시스템, 네트워크, 애플리케이션 등의 기술적 보안과 물리적 보안을 갖추어도 이의 전반을 관리하는 조직, 교육 등의 관리적 보안이 제대로 이루어지지 않는다면 완벽한 보안모델이 될 수 없다. 전문가들은 공통적으로 헬스케어 산업의 기업, 병원 등 기관별 상황과 비즈니스 상황에 맞춰 적절한 보안 수단을 가지고 자율적 보안 체계를 구성하는 것이 바람직한 방향이라는 의견을 제시하였다.

제로 트러스트 모델로의 전환을 촉진하기 위해 제로 트러스트 가이드라인을 마련하고 배포하는 것도 고려할 수 있다. 다만, 가이드라인을 배포하는 것에 대해서는 그것이 산업에 미칠 영향력을 고려해야 된다는 의견도 있었다. 기업의 가이드라인이 강제성은 없지만, 업계의 기준으로 작용하여 기업들이 이를 따라가고자 하는 움직임이 있기 때문이다. 따라서 가이드라인이 기업의 규모나 투자 여력을 고려하여 기업 상황에 맞는 보안 투자를 유도하는 방향으로 제시되어야 할 것이다.

“제로 트러스트를 위한 지원 사업들은 안내가 필요하며 실제 의료계에서도 IT 관련 직종에서도, 관심이 없으면 제로 트러스트가 무엇인지도 모를 수 있음. 정책을 ‘규제’ 보다는 ‘권고’ 정도로 진행하고, 보건의료 데이터 활용 가이드라인과 같이 보안 가이드라인들을 제시해주고, 주기적으로 질문 혹은 유권해석이 나오는 사례들을 FAQ 형식으로 공유가 필요함” (헬스케어 보안 전문가 1)

“산업 발전을 고려한다면 현재는 망분리 때문에 수동으로 직접 사람이 해당 자리에 서만 작업을 하고 그대로 두고 나와야 하는데 데이터의 영향평가를 통해 데이터를 분류해서 권한을 나눠주고 접근 제어를 통제하면 될 것 같음. 그리고 업계에서는 정부 가이드라인 준수를 출발점으로 보고 있어서 강제성은 없겠지만 발간되는 순간 지키려고 많이 참고하는 편임” (헬스케어 보안 전문가 3)

제3절 홈네트워크

1. 홈네트워크 분야의 보안 위협

홈네트워크의 정의를 살펴보면, 국토교통부, 산업통상자원부, 과학기술정보통신부 고시인 「지능형 홈 네트워크 설비 설치 및 기술기준(이하 기술기준)」에서 정의한 홈네트워크는 ‘주택의 성능과 주거의 질 향상을 위하여 세대 또는 주택단지 내 지능형 정보통신 및 가전기기 등의 상호 연계를 통하여 통합된 주거서비스를 제공하는 설비’이다. 즉, 홈네트워크는 각 세대별로 마련한 스마트 가전·기기의 개념을 넘어 주택단지 내에서 입주민에게 편리한 서비스를 제공하고 효율적이고 지능적인 단지 관리를 위한 시스템을 의미한다.

홈네트워크는 홈네트워크망, 홈네트워크장비, 홈네트워크 사용기기로 구성된다. 홈네트워크망은 홈네트워크장비 및 홈네트워크 사용기기를 ‘연결하는 것’을 말하며, 홈네트워크장비는 홈네트워크망을 통해 ‘접속하는 장치’를 의미한다. 홈네트워크 사용기기는 홈네트워크망에 ‘접속하여 사용하는 여러 장비’를 말한다.³³⁾ 각 구성요소 및 세부 구성요소는 다음의 <표 4-7>과 같다.

전문가들이 언급한 홈네트워크 분야의 주요 보안 위협은 가로채기와 위·변조로 인한 침입과 유출, 타인에 의한 제어로 정리될 수 있다. 무선 환경 기반의 홈네트워크 시스템에서 가장 대표적인 위협은 악성코드 삽입, 암호화되지 않은 망, 인증정보 위조 등의 방법으로 네트워크망에 침입하여 월패드로 전달되는 각종 제어명령을 가로채고 다른 세대의 월패드를 제어하는 것이다. 요즘은 스마트폰에 설치된 앱을 통해서도 홈네트워크 기기 및 시스템에 접속할 수 있기 때문에 이를 통해 침입하는 경우도 발생한다. 그리고 악의적인 의도를 가지고 침입하는 내부 인가자의 소행은 세대별 망분리 방법으로도 막을 수 없는 보안 위협이다. 특히 단지 내부가 인트라넷 개념의 단일 유선망으로 형성되는 홈네트워크는 이러한 내·외부 공격에 노출되기 쉽고 위험성도 크다.

33) 지능형 홈네트워크 설비 설치 및 기술기준(2021. 12. 31. 일부개정) 제3조.

<표 4-7> 홈네트워크 설비의 구성요소

구성요소	세부 구성요소	설명
홈네트워크망	홈네트워크장비 및 홈네트워크사용기기를 연결하는 것	
	단지망	집중구내통신실에서 세대까지를 연결하는 망
	세대망	전유부분(각 세대내)을 연결하는 망
홈네트워크 장비	홈네트워크망을 통해 접속하는 장치	
	홈게이트웨이	전유부분에 설치되어 세대내에서 사용되는 홈네트워크 사용기기들을 유무선 네트워크로 연결하고 세대망과 단지망 혹은 통신사의 기간망을 상호 접속하는 장치
	세대단말기	세대 및 공용부의 다양한 설비의 기능 및 성능을 제어하고 확인할 수 있는 기기로 사용자 인터페이스를 제공하는 장치
	단지네트워크장비	세대내 홈게이트웨이와 단지서버간의 통신 및 보안을 수행하는 장비로서, 백본(back-bone), 방화벽(Fire Wall), 워크그룹스위치 등 단지망을 구성하는 장비
	단지서버	홈네트워크 설비를 총괄적으로 관리하며, 이로 부터 발생하는 각종 데이터의 저장·관리·서비스를 제공하는 장비
홈네트워크 사용기기	홈네트워크 망에 접속하여 사용하는 다음과 같은 장비	
	원격제어기기	주택내부 및 외부에서 가스, 조명, 전기 및 난방, 출입 등을 원격으로 제어할 수 있는 기기
	원격검침시스템	주택내부 및 외부에서 전력, 가스, 난방, 온수, 수도 등의 사용량 정보를 원격으로 검침하는 시스템
	감지기	화재, 가스누설, 주거침입 등 세대 내의 상황을 감지하는데 필요한 기기
	전자출입시스템	비밀번호나 출입카드 등 전자매체를 활용하여 주동출입 및 지하주차장 출입을 관리하는 시스템
	차량출입시스템	단지에 출입하는 차량의 등록여부를 확인하고 출입을 관리하는 시스템
	무인택배시스템	물품배송자와 입주자간 직접대면 없이 택배화물, 등기우편물 등 배달물품을 주고받을 수 있는 시스템
	그 밖에 영상정보처리기기, 전자경비시스템 등 홈네트워크 망에 접속하여 설치되는 시스템 또는 장비	

자료: 「지능형 홈네트워크 설비 설치 및 기술기준」(2021. 12. 31. 일부개정) 제3조.

이러한 위협은 홈네트워크 시스템에 연결된 세대별 홈네트워크 기기에도 동일하게 적용되어 세대 내 다양한 스마트 가전 및 기기들에서 사용하는 센서정보, 카메라 영상 정보 등에 대해서도 가로채기 및 위·변조가 행해질 수 있다. 이 외에 허술한 비밀번호 설정 및 관리로 인해 침입이 일어나기도 한다. 전문가들은 사용자가 단말기를 구매한 후에 처음 설정한 비밀번호를 변경하지 않는 허점을 이용하여 불법 침입 또는 해킹이 이루어지기도 하는데, 이러한 방법을 일반인들이 온라인 상에서도 쉽게 찾을 수 있다는 점을 지적하였다.

“구글 검색엔진 또는 유튜브에서 해킹에 필요한 내용이나 특정 기기 모델 등을 검색 시 해킹의 방법들을 자세히 설명하고, 홈 IoT 장비들의 초기 ID/PW 등을 쉽게 찾을 수 있다. 이러한 방법 적용 시, 누구나 손쉽게 해킹 및 불법 접속이 가능하다.”
(홈네트워크 보안 전문가 1)

한국인터넷진흥원에서 발간한 『홈·가전 IoT 보안가이드』에서 정리한 홈·가전 IoT 제품 유형별 주요 보안 위협은 다음의 <표 4-8>과 같다(한국인터넷진흥원, 2017). 주택단지 단위로 운영되는 홈네트워크와 적용 범위의 차이는 있지만 본 가이드라인에서 주요 보안위협 원인으로 언급된 접근통제 부재, 물리적 보안 취약점, 강도가 약한 비밀번호, 인증 메커니즘 부재 등은 앞에서 전문가들이 언급한 홈네트워크 분야의 주요 위협과 유사한 상황을 의미한다. 그 중에서 ‘전송데이터 보호 부재’는 만약 가로채기 및 유출이 이루어졌어도 탈취된 정보 및 데이터가 암호화되어 식별할 수 없거나 변조하여 활용될 수 없도록 하는 방안이 부재한 것을 의미한다.

현재 홈네트워크의 핵심 제어·관리 장치인 월패드와 보안 취약성으로 인해 발생된 피해에 대해 어떤 주체(예. 주택 건설사, 월패드 제조업체, 보안 솔루션 업체 등)가 책임을 져야 한다는 규정은 없는 것으로 보인다. 보안관련 사고가 발생하면 직접적인 사고 발생의 원인이 누구에게 있는지를 피해자가 입증해야 한다. 사고 발생 이전 점점 단계에서 기술기준을 준수하지 않았거나 기준 위반사례에 해당하는 단지에 대해서는 해당 지자체를 통해 관계법령에 따라 사업주체 또는 관리주체에게 조치를 요구하고 준수 여부에 대한 추가조사를 요청해야 한다.

<표 4-8> 홈·가전 IoT 제품 유형별 주요 보안 위협

유형	주요 제품	주요 보안위협	주요 보안위협 원인
멀티미디어 제품	스마트TV, 스마트 냉장고 등	- PC 환경에서의 모든 악용 행위 - 카메라/마이크 내장 시 사생활 침해	- 인증 메커니즘 부재 - 강도가 약한 비밀번호 - 펌웨어 업데이트 취약점 - 물리적 보안 취약점
생활가전 제품	청소기, 인공지능 로봇 등	- 알려진 운영체제 취약점 및 인터넷 기반 해킹 위협 - 로봇청소기에 내장된 카메라를 통해 사용자 집 모니터링	- 인증 메커니즘 부재 - 펌웨어 업데이트 취약점 - 물리적 보안 취약점
네트워크 제품	홈캠, 네트워크 카메라 등	- 사진 및 동영상을 공격자의 서버 및 이메일로 전송 - 네트워크에 연결된 홈캠 등을 원격으로 제어하여 임의 촬영 등 사생활 침해	- 접근통제 부재 - 전송데이터 보호 부재 - 물리적 보안 취약점
제어 제품	디지털 도어락, 가스밸브 등	- 제어기능 탈취로 도어락의 임의 개폐	- 인증 메커니즘 부재 - 강도가 약한 비밀번호 - 접근통제 부재 - 물리적 보안 취약점
	모바일 앱(웹) 등	- 앱 소스코드 노출로 IoT 제품 제어기능 탈취	- 인증정보 평문 저장 - 전송데이터 보호 부재
센서 제품	온/습도 센서 등	- 잘못된 또는 변조된 온·습도 정보 전송	- 전송데이터 보호 부재 - 데이터 무결성 부재 - 물리적 보안 취약점

자료: 한국인터넷진흥원(2017), p. 13.

2. 홈네트워크 분야의 보안 수단 및 효과성 비교

전문가들은 홈네트워크의 보안 위협에 대응하기 위해서는 다양한 보안 기술들이 상호보완적인 구조를 이루어 적용되어야 한다는 데에 의견을 모았다.

“가로채기 위협에 대한 효과적인 보안 수단은 데이터 혹은 VPN의 암호화이며, 인증 정보의 위조 공격에는 전송데이터의 무결성 확보가 효과적인 대응이라고 할 수 있다. 하지만 이는 예시일 뿐, 전반적인 위협에 대응하기 위해서는 실제 위협뿐 아니라 발생 가능한 위협까지도 분석되어야 한다. 따라서 하나의 보안수단은 어느 위협에는

효율적이지만 다른 위협에는 비효율적일 수 있다.” (홈네트워크 보안 전문가 2)

“상호보완적인 보안 기술들을 설치 환경에 맞춰 융합·최적화하는 것이 관건. 보안 방식은 상호보완적인 것이며, 보안 솔루션 기술이란 하나의 기술로 모든 보안을 커버한다는 것은 불가능.” (홈네트워크 보안 전문가 1)

전문가들은 네트워크 보안, 인증 보안, 데이터 보안 등 3가지 수단이 복합적으로 적용되어야 한다고 강조했다.³⁴⁾ 첫째, 네트워크 보안은 네트워크를 탈취·변형·우회하여 데이터와 시스템을 교란시키는 것을 막기 위한 수단으로, 망분리는 네트워크 보안 중 하나의 수단이다. 홈네트워크 분야에서 적용되는 네트워크 망분리 기술은 가상사설통신망(Virtual Private Network, VPN), 가상근거리통신망(Virtual Local Area Network, VLAN), 홈게이트웨이를 이용한 망분리 등으로 나뉜다. 가상사설통신망(VPN)은 일반 인터넷망과 같은 공중망을 사설망처럼 이용해 접근이 어려운 별도의 가상 네트워크를 구성하는 방식이며, 가상근거리통신망(VLAN)은 물리적 배선에 상관없이 데이터가 전달되는 범위를 임의로 나눌 수 있는 논리적 망분리 기술이다. 홈게이트웨이를 이용한 망분리는 세대망이 시작되는 세대 단자함에 하드웨어(HW) 형태의 홈게이트웨이를 설치하여 망분리를 구현하는 방식으로 이 안에 VPN, VLAN 기능이 포함되어 있다.

최근에 많이 적용되고 있는 네트워크 망분리 수단은 VPN에 웹 브라우저와 서버 간의 통신에서 정보를 암호화하는 SSL(Secure Sockets Layer) 보안 프로토콜을 적용³⁵⁾한 SSL VPN이다. 원격지에서 인터넷으로 내부 시스템 자원을 안전하게 사용할 수 있어 재택근무 시스템에 많이 적용되고 있다. 이는 원격으로 설치, 유지·보수, 관리가 가능해 사용하기가 편리하고 구축 및 관리 비용이 적게 든다는 장점이 있다. 하지만 통신상의 암호화를 뚫고 침입한 경우에는 데이터 유출이 불가피하다.

둘째, 인증 보안은 크게 사용자 인증 방식과 기기 인증 방식으로 나뉜다. 사용자 인증은 ID/PW 입력 방식이, 기기 인증은 OTP(One Time Password)가 대표적이다.

34) 3가지 보안수단의 설명은 홈네트워크 보안 전문가1의 설명을 바탕으로 작성

35) 네이버 지식백과 IT 용어사전, <https://bit.ly/3r6kbiD> (검색일 2022. 9. 26.)

하지만 전문가들이 권장하는 방식인 다중 요소 인증(Multi-Factor Authentication, MFA) 방법은 패스워드와 같이 해당 이용자가 '알고' 있는 요소, 하드웨어 토큰과 같이 해당 이용자가 '갖고' 있는 요소, 생체인식 정보와 같이 해당 이용자의 '고유' 요소 등에서 최소 2개 이상을 함께 사용하여 인증하는 방식이다.³⁶⁾

마지막으로 데이터 보안은 네트워크 보안과 인증 보안을 뚫고 데이터가 유출되어도 암호화를 통해 공격자에 의한 내용 식별과 활용이 불가능하도록 만드는 방법이다. 대표적인 방법으로 유무선 통신구간의 서버와 클라이언트 바로 앞단에 암호화를 제공하는 E2E(End to End) 구간 암호화 기술, 서버에 저장된 데이터를 암호화하여 저장하는 데이터 암호화 기술 등이 있다.

최근에는 VPN, 문서 암호화(DRM) 등의 정보보호 시스템과 암호가 주 기능인 제품 유형(예. 메일/구간/디스크·파일 암호화, 하드웨어 구간 보안 토큰, 기타 암호화)에 국가·공공기관 도입기준의 검증이 완료된 암호모듈 탑재를 필수로 요구하고 있다. KCMVP(Korea Cryptographic Module Validation Program) 인증 제도는 국제 기준인 CMVP를 한국에 맞게 적용한 암호모듈 검증제도이다(이용석·이정훈, 2019). KCMVP 인증은 「사이버안보 업무규정」 제9조와 「전자정부 시행령」 제69조 등에 따라 국가정보통신망에서 소통·저장되는 비밀이 아닌 업무자료를 보호하기 위해 국가·공공기관에서 도입하는 암호모듈의 안전성과 구현 적합성을 검증하는 제도이다. 발전소 등의 공공 인프라부터 적용되기 시작하여 향후 정보통신망을 이용하는 모든 기기 및 서비스에 적용될 것으로 전망되고 있다. 홈네트워크 기술기준에서도 정보보안 인증 기기 사용을 권고하고 있기 때문에 홈네트워크 보안에도 KCMVP 인증이 점점 도입되고 있는 추세이다.

전문가들은 위의 3가지 보안수단이 각 상황과 위협 유형에 맞게 최적의 보안 솔루션을 만들어낼 수 있도록 융합되어 적용되는 것이 홈네트워크 보안의 기본이라고 설명하였다. 하지만 보안의 효과성만을 기준으로 보안 수단이 적용될 수 없는 현장의 문제점 또한 지적하였다. 전국의 공동주택(아파트 등)은 수많은 브랜드만큼이나 다양한 설치 환경이 존재하므로 공동주택의 설치 환경 또는 건설사·홈네트워크 업체의 이

36) 네이버 지식백과 IT 용어사전, <https://bit.ly/3UCDsWH> (검색일 2022. 9. 26.)

해관계나 요구사항에 따라 적용할 수 있는 수단이 달라지는 점을 언급하였다.

“공동주택에 보안솔루션을 구축하기 위해서는 건설사 및 그 건설사와 계약한 홈네트워크 업체의 승인(계약)을 득해야 하고, 계약 체결 이후 홈네트워크 시스템과 보안시스템을 통합시키는 작업(개발)을 거쳐야 한다. 필요에 따라서는 별도의 개발이 필요하며 단기간에 호환시키기는 쉽지 않다.” (홈네트워크 보안 전문가 1)

3. 홈네트워크 분야의 국내외 망분리 규제 현황

□ 국내 망분리 규제 현황

홈네트워크 분야의 망분리 규제는 2021년 12월 개정되어 2022년 7월부터 시행된 「지능형 홈 네트워크 설비 설치 및 기술기준」에 규정되어 있다. 시행일인 2022년 7월 1일 이후 주택 건설 사업을 승인받아 시공을 시작하는 새 아파트부터 적용된다.

〈지능형 홈네트워크 설비 설치 및 기술기준〉

14조의2(홈네트워크 보안) ① 단지서버와 세대별 홈게이트웨이 사이의 망은 전송되는 데이터의 노출, 탈취 등을 방지하기 위하여 물리적 방법으로 분리하거나, 소프트웨어를 이용한 가상사설통신망, 가상근거리통신망, 암호화기술 등을 활용하여 논리적 방법으로 분리하여 구성하여야 한다.

현재 발표된 규제 내용은 내·외부 시스템을 물리적으로 분리해야 하는 금융 분야의 규제 수준이 아니라, 한 세대가 해킹되더라도 그 피해가 다른 세대까지 영향을 미치지 않도록 하기 위해 물리적·논리적 망분리 중 하나를 요구하는 세대 간 망분리이다. 이를 위해 아파트 단지 서버에서부터 각 세대 간의 네트워크를 물리적 방법으로 분리하거나 소프트웨어를 이용한 가상사설통신망(VPN), 가상근거리통신망(VLAN), 암호화 기술 등을 활용하여 논리적 방법으로 분리하여 구성하도록 하고 있다.

전문가들은 홈네트워크 분야의 망분리 규제가 향후 구체화될 필요가 있으며, 이 때 고려해야 할 사항들을 제시하였다. 참고로 향후 개정된 기술기준에서 요구하는 망분리 포함 보안 관련 세부내용이 담긴 ‘홈네트워크 보안 가이드라인’이 발표될 예정이다.

“현재 구축되어 있는 홈네트워크 시스템은 제조사에 따라 다양한 방식으로 설치·시공되어 있어 유지보수나 교체 공사 시 상호연동성 확보가 쉽지 않아 불편함이 있다. 금번 고시에 따르면 세대 간 분리를 물리적·논리적으로 구현하도록 하고 있는데, 논리적 구현 방법인 VLAN, VPN, 암호화 방식 등을 적용하는 데 있어 기술적인 의견 차가 있다. 이에 대해서는 전문가 검토를 통해 기술적 합의를 이뤄가고 있다.” (홈네트워크 보안 전문가 3)

“홈네트워크가 실제로 설치 및 운영되는 건설 현장에 맞는, 합리적이고 효율적인 규제 프로세스가 구축되어야 한다. 예를 들어, 설계-공사-준공 검사 시 평가 점점 방식은 무엇이며, 누구에 의해 평가될 것이며, 평가 결과에 따른 인증제도는 어떤 식으로 구성되는지 등과 관련하여 기존 건설과 건축의 업무 프로세스에 부합하는 효율적인 가이드라인이 제작되어야 한다. 참고로 완공 시 준공검사는 통상 감리사에 의해 진행되는데, 지금의 감리사들은 정보통신 및 보안 영역에 대한 지식이 전무하며 비전문가 집단으로 구성되어 있어 평가의 능력이 없다.” (홈네트워크 보안 전문가 1)

□ 해외 망분리 규제 현황 및 전망

서면 자문에 참여한 홈네트워크 보안 전문가들은 모두 해외는 망분리를 규제로 의무화하지 않고 있으며, 위반 및 사고발생에 관한 책임을 강화함으로써 기업 스스로 보안을 강화할 것을 유도하고 있다고 설명하였다. 전문가들은 이러한 기조의 흐름 상 향후에도 홈네트워크 분야에 망분리 규제는 적용되지 않을 것이라는 데에 의견을 모았다.

“해외는 망분리뿐만 아니라, 어떤 특정 기술을 반드시 쓰도록 하는 규제 자체를 하지 않으며, 규제를 할 것이라고도 예상되지 않습니다. 다만, 개인정보를 보호해야

하는 원칙을 강조하고, 조치가 미흡하여 사고가 발행하였을 경우에 무거운 책임을 묻는 쪽으로 더욱더 강화되고 있습니다.” (홈네트워크 보안 전문가 1)

“해외의 경우 망분리를 규제하지 않고 위반에 대한 처벌을 강화함으로써 기업들 스스로 개인정보보호법을 준수하도록 유도하는 방향으로 진행이 될 것으로 예상되며, 점차 위반에 대한 처벌 수위가 높아질 것으로 전망됩니다. 망분리 규제를 의무화하지 않는 해외의 경우에는 오히려 다양한 보안취약 요인에 탄력적으로 대응할 수 있도록 함으로써 업무의 효율성과 공격기법에 적합한 대응이 가능하다고 판단됩니다. 또한 향후 대응 기술의 발전과 더불어 공격기법도 함께 진화하기 때문에 이에 대해서도 망분리 규제를 의무화하지 않는 것이 옳다고 생각하고 있습니다.” (홈네트워크 보안 전문가 2)

“해외에서는 망분리를 하나의 수단으로 권고하고 있어, 홈네트워크 분야에서도 국내와 같이 세대간 분리를 의무화한 사례는 아직 확인되지 않았다. 이와 같은 환경에서 해외에서는 홈네트워크 분야에 대해서도 세대 간 데이터 보호를 위한 자율적인 보안 강화 및 적용을 권고할 것으로 예상된다.” (홈네트워크 보안 전문가 3)

4. 홈네트워크 분야의 보안 정책 제언

가. 홈네트워크 분야에서 망분리 규제가 반드시 필요한 부분

홈네트워크 분야에서 망분리 규제가 반드시 필요한 부분은 어디인지를 묻는 질문에 전문가들은 구체적으로 보안이 필요한 영역 혹은 데이터를 제시하기보다는 개인 사생활 관련 부분에 대한 독립성과 기밀성 확보가 중요하다는 의견을 주었다.

“홈네트워크에서 망분리의 가장 큰 목적은 가구 간의 접근을 차단함으로써 데이터 또는 정보의 독립성을 유지하는 것이라 할 수 있겠습니다. 따라서 개인 사생활 침해 및 개인정보 뿐만 아니라 공격자에게 악용될 수 있는 데이터라면 모두가 망분리의 대상이 될 수 있습니다.” (홈네트워크 보안 전문가 2)

“2021년 11월 월패드 해킹으로 인해 아파트 사생활 노출이 이슈가 되었던 것처럼 홈네트워크에서 가장 중요한 요소는 아파트 사생활 보호이다.” (홈네트워크 보안 전문가 3)

나. 향후 지향해야 할 보안수단과 보안모델의 방향

일부 전문가는 현재 드러난 홈네트워크의 주요 보안 위협에 대한 피해를 최소화하는 데에는 세대별 망분리가 효과적인 방안이라고 언급하였다.

“홈네트워크 분야에서는 검증 기반 보안 모델로 전환하기보다는 영역 기반 보안모델인 망분리를 적용하는 것이 현재로서는 효율성이 높다고 생각합니다. 홈네트워크 내 정보들은 높은 보안성을 요구하는 정보를 다루지는 않지만, 홈네트워크 내 IoT 기기들은 공유가 아닌 개개인의 것으로 독립성이 보장되어야 한다고 봅니다. 현재 아파트와 같은 집단 공동 주거지 형태에서는 홈네트워크의 독립성 보장을 위해 영역 기반 보안모델인 망분리 방법이 가장 효과적인 방법이 될 수 있다고 봅니다.” (홈네트워크 보안 전문가 2)

하지만 세대별 망분리는 해킹 피해가 일어나도 그것이 확산되지 않도록 하는 기본적인 피해방지 조치에 불과하기 때문에 이를 넘어서 사고 발생을 막을 수 있는 시스템을 구축하고, 만약 사고 발생 후에도 사생활 정보가 담긴 데이터로 인한 피해가 발생하지 않도록 하는 방안이 필요하다고 하였다.

“현재 세대별 망분리 방안의 논리가 해킹되더라도 피해를 최소화하자는 것이라면 앞으로 지향해야 할 방향은 해킹 사고 발생을 막을 수 있는 수준의 솔루션을 구성하고, 설사 해킹되더라도 피해가 발생하지 않도록 하는 것이다. (기술기준에서 정한) 가상화 망분리 기술은 무한대에 가까운 인터넷 환경에서 특정 개인의 IP 주소를 가상화하여 주소를 은닉하는 데 유용하기 때문에 인터넷 통신망에 적용하기에는 효율성이 우수하나, 아파트나 다수의 공동주택에 설치 운용되는 단일 유선네트워크 망에는 그 효과가 지극히 미미하다 할 수 있다. 불순 의도를 가진 내·외부의 해커는

단지 내의 유선망에 쉽게 물리적으로 접속 가능하고, 그 유선망을 통해 전송되는 데이터를 해킹할 수 있기 때문이다.” (홈네트워크 보안 전문가 1)

또한 향후 홈네트워크 분야가 발전하면서 생길 다양한 위협에 신속하게 대응하기 위한 보안관계 구축이 선제적으로 추진될 필요성도 언급되었다. 이를 통해 점진적으로 검증 기반 보안 모델의 도입이 가능할 것으로 전망하나, 특정 보안 수단과 모델을 모든 상황에 적용하는 것이 아니라 그 위협을 막을 수 있는 최적의 솔루션을 만들기 위해 보안 수단뿐만 아니라 보안 모델도 적절히 혼합되어 사용되어야 한다는 의견을 주었다.

“현재 발견된 보안 위협은 홈네트워크망의 분리 적용판으로도 크게 제거될 수 있으나, 향후 홈네트워크의 발전과 더불어 다양한 침입과 사고를 예방하고 신속하게 대응할 수 있는 보안관계(SIEM 등) 도입부터 시작하여 향후 비인가 접근을 근본적으로 차단할 수 있는 제로 트러스트 기반 홈네트워크 보안모델 적용까지 성숙해 나갈 것으로 전망된다.” (홈네트워크 보안 전문가 3)

“향후 보안모델로 제로 트러스트 액세스를 지향하는 모델의 구현이 필요할 것으로 보입니다. 단, 이것 또한 극히 제한된 공격 기법에 대한 대응 방안일 뿐 내부자 및 악성코드, 네트워크 공유 등의 공격에 대해서는 망분리 및 SIEM이 함께 필요하게 됩니다. 따라서 어떤 수단, 어떤 모델이 우수한지를 따지기보다는 네트워크 환경과 취급 데이터, 위협 요인들에 따라 혼합된 수단과 모델이 적용될 수 있어야 한다고 봅니다.” (홈네트워크 보안 전문가 2)

다. 영역 기반에서 검증 기반 보안 모델로 전환 가능성

홈네트워크는 세대·단지 내 IoT 장비에 대해 여러 명의 가족 구성원 혹은 공동주택 관리인이 내부의 월패드 및 제어기기, 외부 스마트폰 등을 통해 접근하고 제어명령을 내릴 수 있다. 향후 홈네트워크에 연결될 기기는 더욱 많아질 전망이며, 이에 따라 수집·관리 대상인 데이터도 양이 많아지고 종류도 다양해질 것이다. 따라서 중요도에 따라 접근 권한과 그룹을 나누는 시스템이 반드시 필요하다.

이와 같이 다양한 IoT 기기와 연결되며 내·외부의 접근을 모두 허용하고 다양한 사용자가 시스템을 함께 제어할 수 있는 홈네트워크의 특성을 고려했을 때 내·외부, 이용자·기기를 모두 신뢰하지 않고 의심하는 제로 트러스트(검증기반 보안 모델)의 기본 철학이 효과적으로 작용할 수 있다는 쪽으로 전문가들의 의견이 모아졌다. 하지만 궁극적으로 하나의 보안모델로 대응하려는 생각은 지양해야 함을 강조하였다.

“다양한 IoT 기기와 외부에서의 접근 허용, 사용자 구분 등으로 대표되는 홈네트워크의 구성요소는 제로 트러스트의 철학과 일맥상통함. 홈네트워크의 내·외부 관리는 정상적인 접근 외에도 비정상적인 디바이스와 공격자가 함께 접근할 수 있으므로 기본적으로 아무도 신뢰하지 않는 모델인 제로 트러스트를 적용하는 것이 홈네트워크 보안의 이상적인 구성일 수 있음” (홈네트워크 보안 전문가 3)

“실제 사생활 침해, 보안 사고의 위험은 인터넷망을 통해 외부로부터 접근해 오는 공격보다 동일한 아파트 단지 내에 거주하는 불순한 의도를 가진 특정 입주민에 의해 자행될 가능성이 크다고 할 수 있다. 실제로 그러한 사례들이 존재한다. 따라서 공동주택(아파트) 외부에 보안 울타리가 존재 한다고 해도 내부에서 벌어질 수 있는 각종 보안 사고를 고려하여 ‘제로 트러스트 보안 모델’ 적용이 필요하며, 가능하다.” (홈네트워크 보안 전문가 1)

하지만 현재 적용 중인 세대별 망분리(영역 기반 보안 모델)가 효과를 나타내는 부분이 존재하며, 검증 기반 보안 모델이 홈네트워크의 어느 영역에서 최적의 보안 효과를 낼 수 있을지에 대한 사례 및 연구가 없다는 점을 지적하였다. 따라서 단기간 내에 보안 모델 전환은 어려우며, 현재의 세대별 망분리를 기반으로 점차적인 결합 및 전환이 이루어질 것으로 전망하였다.

“현 홈네트워크의 송수신 데이터와 망의 환경 등에 따라 망분리가 효율적으로 작용할 수 있는 부분은 망분리 방식을 함께 적용하고, 그렇지 않은 점에 대해서 검증 기반 보안 모델로 전환하는 방법이 불가피하리라고 판단됩니다. 그리고 점차 망분리와 검증 기반 보안 모델의 문제점들을 모두 개선할 수 있는 방법을 찾을 때까지

함께 병행해서 사용될 것으로 전망됩니다.” (홈네트워크 보안 전문가 2)

“국내 홈네트워크는 향후 몇 년간은 세대 간 분리 기술이 적용될 것으로 예상된다. 따라서 제로 트러스트를 홈네트워크에 도입 및 적용하기 위해서는 기존 기반 위에 적용하게 될 가능성이 높다. 따라서 현재 홈네트워크에 적용 중인 세대 간 분리를 제로 트러스트 기반 모델로 설계하고 전환 계획을 마련해야 할 것이다.” (홈네트워크 보안 전문가 3)

라. 검증 기반 보안 모델로 전환하기 위한 정책

□ 검증 기반 보안 모델의 적합성 검증

검증 기반 보안 모델의 홈네트워크 적용 방안뿐만 아니라 이제 발전 초기 단계인 홈네트워크 시스템 및 관련 데이터의 중요도 분류 등에 관한 연구 및 기준 마련도 이제 시작 단계에 불과하다. 따라서 전문가들은 홈네트워크 시스템의 특성을 파악하고 검증 기반 보안 모델이 적절하게 적용될 수 있는지를 검증하는 연구와 시범 적용 등이 선행되어야 한다고 지적했다.

“홈네트워크에 대해 어떤 보안모델을 적용할지를 결정하기 위해 데이터, 기기, 서비스에 대한 분류와 효율성 분석이 선행되고, 이에 따라 적용될 수 있는 절차가 마련되어야 할 것입니다. 홈네트워크 내에서도 접근성이 빈번한 것과 그렇지 않은 기기 또는 서비스가 있을 것이며, 취급 및 생성 데이터 또한 개인정보 또는 개인정보를 유추 가능하거나 연관도가 높은 데이터를 포함하는지 여부에 따라서도 보안등급 및 정책이 바뀔 수 있습니다.” (홈네트워크 보안 전문가 2)

“기존 제도를 대체할 수 있는 제로 트러스트가 홈네트워크에 적합한 보안모델임을 증명하는 연구와 시범적용 등이 선행되고 사회적 합의가 있게 된다면 제로 트러스트를 기반으로 한 제도가 마련될 수 있을 것이다.” (홈네트워크 보안 전문가 3)

□ 사용자 편의성 및 비용 고려

전문가들은 반복적으로 검증을 요구하는 검증 기반 보안 모델의 특성이 사용자의 편의성을 저하시킬 수 있는 점을 우려하였다. 보안은 오히려 잘못 이용되거나 허술하게 관리되면 취약성이 더욱 높아지기 때문에 추후 적용 단계에서는 사용자가 큰 부담 없이 서비스를 이용할 수 있도록 단점이 보완된 기술 및 솔루션이 필요하다고 지적했다. 또한 검증 기반 보안 모델의 실제 도입 시 발생할 추가 비용 및 절차에 관해서도 입주민을 비롯한 구성원들의 사회적 합의가 필요하다는 의견을 주었다.

“홈네트워크 시스템에 검증 기반 보안모델을 적용하는 것을 가정했을 때 입주민, 아파트 관리자, 보안 담당자 등의 내·외부인들은 먼저 홈네트워크 관련 기기 및 서비스 사용 전 정해진 인증 절차를 거쳐 적법한 사용자임을 인증해야 한다. 검증기반 보안 모델이 사용자 인증에 있어 보안성은 높지만 사용자들의 시간과 노력을 아껴주는 편의성도 중요하다. 보안기술 적용에 있어 가장 큰 허들은 사용자들의 불편함이다. 적용 절차가 복잡하거나 적용에 있어 시간이 오래 걸린다면 편의성과 경제성을 가장 우선시하는 대부분의 사람들은 보안기술 사용을 멀리하게 될 것이다. 결론적으로 인증 절차의 적용에 있어 절차와 시간을 최소화할 수 있는 인증 기술이 적용되어야 한다.” (홈네트워크 보안 전문가 1)

“검증 기반 보안의 경우 사용자에게 대한 검증과정이 반복적이고 복잡하며, 내부자에 의한 공격과 한번 허용된 악의적인 인가자의 경우에는 찾아내기가 어려운 점들이 발생할 수 있습니다. 그리고 기기 사용(특정 시간·행위·이벤트 등)에 대한 검증이 반복되거나 이 과정에서 오류가 발생하는 등 서비스의 지속성을 저해할 수 있는 단점들도 있어 이에 대한 신중한 결정이 필요하다고 판단됩니다.” (홈네트워크 보안 전문가 2)

“홈네트워크 도입 시 보안은 입주민들의 관리비 상승과 연결되어 있어 사회적 합의와 공감대가 이루어지고 합리적인 비용의 제로 트러스트 적용모델이 개발되어야 할 것이다.” (홈네트워크 보안 전문가 3)

제4절 자동차

1. 자동차 분야의 보안 위협

자동차 분야에서 현재 발생하고 있거나 미래에 발생할 수 있는 보안 위협을 파악하기 위해서는 먼저 자동차의 최근 변화 양상을 살펴볼 필요가 있다. 자동차는 발명된 이후 100년 이상 엔진, 트랜스미션, 브레이크 등 기계 장치로 구성된 독립된 기기 또는 폐쇄된 시스템이었지만 전기전자 부품의 비중이 커지고 외부와 통신 네트워크(V2X, vehicle to everything)를 통해 데이터를 주고받게 되면서 스마트카, 커넥티드카로 진화하고 있다. 그래서 최근에는 자동차를 ‘바퀴 달린 컴퓨터(computer on wheels)’라고 부르기도 한다.

자동차와 관련된 보안 이슈를 살펴보기 위해 자동차 내부, 교통 인프라, 이들 간의 통신 네트워크로 구분해 볼 수 있다.³⁷⁾ 자동차 분야의 대표적인 보안 위협에는 자동차 강제 제어, 교통 인프라 강제 제어, 개인/차량 데이터 유출 등이 있다. 이들은 각각 자동차 내부, 교통 인프라, 이들 간의 통신망에서 발생할 수 있는 보안 위협이다.

〈표 4-9〉 자동차 분야의 영역별 보안 위협 예시

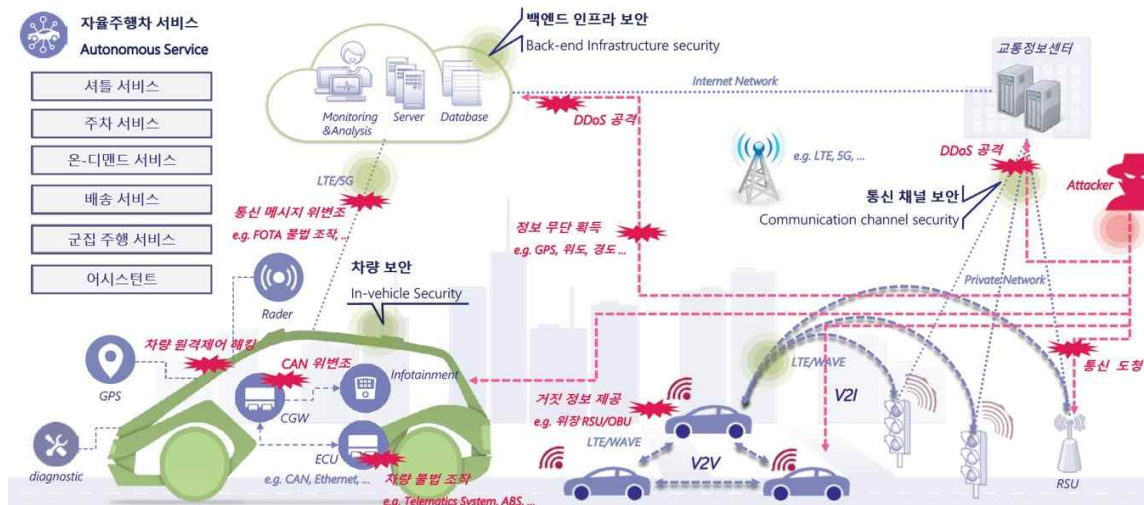
영역		보안 위협
자동차 내부 (차량)		펌웨어 변조, 차량 원격제어 해킹, CAN 위변조, 차량 불법 조작, 서비스거부(DoS)
통신 네트워크 (V2X, vehicle to everything)	차량 - 차량 (V2V, vehicle to vehicle)	통신도청, 통신메시지 위변조, 정보 무단 획득, 거짓 정보 제공, 부인
	차량 - 교통 인프라 (V2I, vehicle to infrastructure)	
교통 인프라		정보 유출, 권한 상승, 서비스 거부(DoS)

자료: 전문가 자문 내용을 취합하여 정리.

37) 본 연구에서는 자동차 분야의 보안 이슈를 논의할 때 독립된 기기로서의 자동차가 아니라 통신 네트워크, 교통 인프라 등 기기와 연결된 전체 시스템을 대상으로 한다.

운전자의 의도와 다르게 자동차를 출발, 조향, 정지시키거나 운전자에게 잘못된 교통 신호를 제공하는 것(예를 들어, 적색 신호등을 녹색 신호등으로 변경)은 운전자 및 보행자의 생명, 차량에 직접적으로 피해를 줄 수 있기 때문에 가장 심각한 위협이라고 할 수 있다. 개인/차량 데이터 유출은 프라이버시 침해를 가져올 뿐만 아니라 다른 범죄 행위에 악용될 우려가 있기 때문에 이또한 중요한 위협이라고 할 수 있다. 이하에서 각각에 대해 좀더 구체적으로 살펴보자.

[그림 4-10] 자동차 분야 보안 위협 예시



자료: 과학기술정보통신부·한국인터넷진흥원(2020. 12), p. 10.

□ 자동차 강제 제어

자동차 강제 제어는 외부인이 차문의 개폐와 출발, 조향, 정지 등 차량의 동작을 자동차 소유자 또는 운전자의 의지와 다르게 수행하는 것을 말한다. 이는 교통사고 발생으로 인한 운전자 및 보행자 사망·상해, 차량 파손, 차량 도난 등으로 이어질 수 있다.³⁸⁾ 사실 차문 개폐는 오래 전부터 간단한 장비만으로 가능하다고 알려져 있기 때문에 새롭게 등장하는 위협이라고 할 수는 없지만 차량 앱을 통하거나 원격으로 이루어질 경우 그 가능성은 더 커질 수 있다. 조향 등 차량 동작은 운전자의 생명에 직결

38) 최근 미국에서 한국 차를 대상으로 하는 절도 범죄가 늘어나고 있어서 이에 대한 대응이 필요한 상황이다 (<https://www.mk.co.kr/news/world/view/2022/08/726193/>, 검색일 2022. 9. 26.).

되는 문제이므로 특히 중대한 위협이라고 할 수 있다. 예를 들어, 운전자가 핸들을 돌리면 회전각도를 관련 장치로 전송하는데 이를 무시하거나 다른 값을 전송하면 차가 원하지 않는 방향으로 이동하게 된다. 자동차선유지시스템(ALKS, Automated Lane Keeping System)이 차선을 인식하여 차량을 조향할 때 카메라와 레이더 등으로부터 수신되는 정보를 변조하여 차선을 무시하도록 조작한다면 차가 다른 차선을 침범하여 사고를 발생시킬 수 있다.

자동차를 외부인이 강제로 제어할 수 있는 것은 대부분의 자동차가 내부 데이터 통신 네트워크에 보안 기능이 취약한 과거 프로토콜을 그대로 사용하고 있기 때문이다.

“자동차 내부 네트워크는 CAN (Controller Area Network), CAN FD (CAN Flexible Data-rate), LIN (Local Interconnect Network), MOST (Media Oriented System Transport), FlexRay, Ethernet 등과 같은 네트워크 프로토콜을 사용하여 통신을 수행하는데, 가장 대표적으로 사용되는 것이 CAN임. CAN은 버스형 구조(bus topology)를 가지며 프로토콜이 제공하는 보안기능이 전혀 없고 통신 시 송신측에서 네트워크로 메시지를 브로드캐스팅함. 따라서 네트워크에 참여하고 있는 모든 노드가 해당 데이터를 수신할 수 있기 때문에 공격자는 와이어를 연결하는 것만으로도 데이터를 수신할 수 있음. 마찬가지로 데이터 프레임의 구조만 알 수 있으면 언제든지 데이터를 송신할 수 있음.” (자동차 보안 전문가1)

자동차 강제 제어의 대표적인 실제 사례는 2015년 크라이슬러 지프 그랜드 체로키이다.³⁹⁾ IT미디어 와이어드가 두 명의 프로해커와 함께 자동차를 해킹해 원격 제어하는 영상을 유튜브에 공개했다. 텔레매틱스 서비스인 ‘유커넥트’를 통해 자동차 펌웨어를 조작해 스티어링 휠과 브레이크, 엔진 등 차의 기능을 제어하는 데 성공하였다. 이로 인해 크라이슬러는 지프 그랜드 체로키 140만 대를 리콜 조치하였다. 2016년에는 테슬라 앱에 대한 해킹도 시연된 바 있다. 테슬라 앱이 설치된 안드로이드 스마트폰에 악성 앱을 설치하고 이를 통해 앱 데이터를 탈취하여 차량을 추적하고 개폐 및 운전이 가능하다는 사실이 공개되었다.

39) <http://www.cartvnews.com/news/articleView.html?idxno=204588> (검색일 2022. 9. 26.)

□ 교통 인프라 강제 제어

교통 인프라를 원격으로 제어하는 것은 다양한 서비스 제공을 가능하게 한다. 예를 들어 제주도에서는 2020년 말 주요 도로 약 300km 구간에 차세대 교통 시스템(C-ITS, Cooperative-Intelligent Transport System)이 구축되었다.⁴⁰⁾ 이를 통해 주행 중인 운전자에게 실시간으로 주변 교통상황이나 노면·기상 정보를 제공하고 낙하물, 교통사고 등의 위험 경고도 알려준다. ‘긴급차량 우선신호 서비스’는 구급차 등 긴급 차량의 위치를 추적하여 신호등을 제어함으로써 차량이 교차로 등에서 신호등에 걸리지 않도록 ‘녹색’ 신호를 유지해 준다.⁴¹⁾

하지만 교통 인프라의 원격 제어는 보안 위협의 발생가능성도 수반한다. 교통 인프라도 넓게 보면 하나의 ICT 시스템이므로 일반적인 ICT 시스템에서 발생할 수 있는 서비스거부(DoS, Denial of Service) 공격, 데이터 유출, 데이터 위변조 등의 위협이 동일하게 존재한다. 따라서 공격자가 교통 인프라를 해킹하게 된다면 도로의 신호 체계를 원하는 대로 조작할 수 있다. 영화 「다이하드4」에서는 이를 실감나게 묘사하고 있다. 테러집단이 신호등을 조작해 모두 모두 파란색으로 바꾸자 모든 차들이 교차로에서 멈추지 않아서 사고가 발생하고 교통이 마비되고 만다.

□ 개인/차량 데이터 유출

차량과 교통 인프라 간의 통신 채널이나 차량 내 내비게이션 시스템이 해킹되면 차량의 위치, 이동 경로 등의 정보가 유출될 수 있다. 이는 개인의 프라이버시 침해이므로 그 자체로도 위험하지만 폭행 등 다른 범죄 행위에 악용될 우려가 있으므로 심각한 위협이라고 할 수 있다.

GPS추적기는 누구나 쉽게 구입할 수 있고 최근 애플이 블루투스 추적기 에어태그(AirTag)를 출시하여 차량의 위치를 추적하는 것은 지금도 가능하다. 하지만 만약 원격으로 데이터에 대한 접근이 가능해진다면 개인정보 유출은 더욱 빈번해지고 그 피해도 늘어날 것으로 예상된다.

40) <https://www.koit.co.kr/news/articleView.html?idxno=81068> (검색일 2022. 9. 26.)

41) 관련 유튜브 영상(<https://www.youtube.com/watch?v=wPOU1goqfEA>) (검색일 2022. 9. 26.)

2. 자동차 분야의 보안 수단 및 효과성 비교

보안 관점에서 보는 자동차 분야의 특징은 첫째, 차량 내 전자장비들은 간단한 칩에 소프트웨어가 탑재된 형태의 임베디드(embedded) 시스템이므로 PC나 서버에 비해 연산 능력이 뛰어나지 않다. 따라서 임베디드 시스템에 맞는 보안 기술이 필요하다. 둘째, 차량 내부 통신의 경우 실시간성이 중요하기 때문에 복잡한 보안 기술을 적용하기 어렵다. 즉 약 10ms마다 메시지를 전송하는 등 고속의 데이터 통신이 필요한 상황에서 메시지마다 인증과 권한을 부여하는 것은 사실상 불가능하다.

이와 같은 특징으로 인해 자동차 분야에서는 상대적으로 복잡한 보안 기술을 활용하기 어렵다. 즉 금융 등 다른 분야에서 일반적으로 활용되는 보안 기술들, 즉 IDS (Intrusion Detection System), SIEM (Security information and event management), XDR (Extended Detection and Response) 등이 자동차에는 적용되기 어렵다. 다만 최근에는 아주 간단한 형태의 IDS가 장착되기 시작하는 추세이다. 또한 차량 내 인포테인먼트 시스템 등은 점차 연산 능력이 커지고 있기 때문에 향후에는 일반적인 보안 기술이 활용될 가능성이 있다. 교통 인프라의 경우 일반적인 ICT 시스템과 유사하므로 다양한 보안 기술이 적용될 수 있고 일부는 더욱 고도화된 보안 기술(V2X SCMS 등)이 필요하기도 한다.

자동차 분야에서 활용되고 있는 주요 보안 기술들을 보안 위협별로 구분하여 제시하면 다음 표와 같다. 예를 들어 보안 부팅(Secure Boot)은 자동차의 전자제어장치 ECU (Electronic Control Unit)가 동작할 때 무결성을 점검하는 것이고, 보안 플래시(Secure Flash)는 ECU에 펌웨어(firmware)를 설치할 때 인가된 제조사의 소프트웨어인지를 확인하는 것이다.

<표 4-10> 자동차 분야의 영역별 보안 기술

영역	보안 위협	보안 기술
자동차 내부 (차량)	펌웨어 변조	HPSE(HSM), Secure Boot, Secure Debug, Secure Diagnosis, Secure Flash, Secure Software Update
	차량 원격제어 해킹	Secure Access, Secure Diagnosis, IDS, SecOC
	CAN 위변조	IDS, SecOC, Secure Software Update
	차량 불법 조작	Secure Access, Secure Diagnosis
	서비스거부(DoS)	IDS
통신 네트워크 (V2X, vehicle to everything)	통신도청	IPSec, TLS/DTLS, WAVE 통신 보안 기술(SCMS)
	통신메시지 위변조	
	정보 무단 획득	
	거짓 정보 제공	
	부인	
교통 인프라	정보 유출	Firewall(WAF, UTM, NGFW), DataBase Encryption, Access Control, Endpoint Detection & Response
	권한 상승	Access Control
	서비스 거부(DoS)	Firewall(WAF, UTM, NGFW)

자료: 과학기술정보통신부·한국인터넷진흥원(2020. 12), p. 12.

자동차 분야에서는 이와 같은 보안 기술을 적용하는 것과 병행하여 구조적인 격리(isolation) 기법을 활용하고 있다. 하나의 프로세서가 내부 네트워크와 외부 네트워크를 모두 담당할 경우 보안 문제가 발생할 수 있으므로 내부 네트워크와 외부 네트워크를 담당하는 프로세서를 별도로 구성하거나 두 영역 사이에 가상의 완충 공간을 두어 외부 공격에 대응하는 것이다. 구조적인 격리는 영역이 구분되어 있을 뿐 구분된 영역들 간에 연결이 되어 있어서 데이터 통신이 가능하다는 점에서 연결 자체를 끊는 망분리와 다르다.

“근래의 자동차는 커넥티드 서비스 등을 위하여 외부와 다양하게 자주 연결됨. 차량의 각 ECU들은 성능이 그리 뛰어나지 않기 때문에 attack surface를 줄이기 위하여 외부 네트워크 인터페이스들을 한 곳에서 관리하는 추세이며 이런 장치를 CCU

(Central Communication Unit)라고 함. 그리고 CCU는 차량 내부 네트워크 전체를 관장하는 CGW (Central GateWay)는 근래의 domain-centralized E/E architecture에서 각 도메인 간의 메시지를 중계하는 역할을 수행함. 이 때 CGW는 일종의 망분리가 필요함. 대개의 CGW는 MCU (microcontroller)와 AP (Application processor) 두 개의 칩셋을 가지는데, MCU는 차량 내부 네트워크를 관장하고, AP는 User interface나 외부 통신을 관장함. 즉, CCU는 AP와 연결됨. 법이나 규제는 없지만, 대부분의 자동차 제조사는 자체의 보안 사양(Security specification)을 통해 외부 통신과 내부 통신을 분리하도록 강제하고 있음. 두 개의 칩셋으로 각 네트워크를 분리하고, 두 칩셋은 SPI (Serial Peripheral Interface)로 연결함. 그리고 CCU 또는 AP에서 IDS, FW 및 접근제어를 수행하여 안전한 통신을 보장함” (자동차 보안 전문가 1)

“구조적인 격리의 또 다른 사례는 차량 인포테인먼트 시스템임. 여기에는 리눅스, 안드로이드 등과 같은 운영체제가 많이 사용되는데 사용자가 별도의 소프트웨어를 설치할 수 있으며, 이는 공격자가 멀웨어를 설치할 수도 있다는 것을 의미함. 따라서 사용자가 앱을 설치할 수 있는 구간을 하이퍼바이저(hypervisor)라고 하는 가상의 공간 또는 가상 머신을 만들고, 이를 통해 중요한 소프트웨어 및 차량 내부와 연결되는 부분을 통제할 수 있고 혹시 악성 앱이 설치되더라도 시스템의 다른 부분으로 전파되지 않도록 함” (자동차 보안 전문가 1)

자동차 분야의 보안 기술들이 자동차 분야의 보안 위협에 현재 효과적으로 대응하고 있는지 또는 미래에 효과적으로 대응할 수 있을지에 대해 자동차 보안 전문가들의 공통적인 의견은 어떠한 하나의 기술로 모든 위협을 완전하게 대응하는 것은 불가능하다는 것이다. 또한 새로운 공격 방법이 계속 나타나고 있기 때문에 현재의 보안 수단이 100% 보안을 보장하지도 않는다. 보안 기술도 지속적으로 발전해 나가야 한다. 기술적인 보안 기술 적용 이외에도 관리적인 보안 활동과 보안성에 대한 검증이 필요하다.

3. 자동차 분야의 국내외 망분리 규제 현황

□ 국내 망분리 규제 현황

국내의 경우 자동차 차량에 대한 망분리 규제는 별도로 없다. 자동차는 글로벌한 산업이므로 자동차 보안 규제를 국내 자동차 업체에만 적용할 수는 없고 이를 위해서는 국제적인 논의가 필요하다. 다만, 국토교통부의 「자동차 사이버보안 가이드라인」은 네트워크 분리를 우회하여 제어권 확보에 대한 보안 위협에 대해서 모범 사례를 따라야 한다고 제시하고 있다(국토교통부·한국교통안전공단, 2020. 12). 그리고 국내 자동차 제조사의 서비스⁴²⁾에 대해서는 「개인정보의 기술적·관리적 보호조치 기준」에서 ‘정보통신서비스 제공자’로서 망분리를 하도록 요구하고 있다.

〈개인정보의 기술적·관리적 보호조치 기준〉

제4조(접근통제)

⑥ 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상이거나 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억원 이상인 정보통신서비스 제공자등은 개인정보 처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등을 물리적 또는 논리적으로 망분리 하여야 한다.

자동차 관련 통신 네트워크와 교통 인프라의 경우 주요정보통신기반시설에 해당되고 운영주체가 공공기관이므로 「주요정보통신기반시설 보호지침」과 「국가 정보보안 기본지침」의 적용을 받아 망분리 규제를 준수해야 한다.

42) 스마트폰에서 자동차 앱을 구동하면 자동차 제조사로 연결되어 원격으로 조정을 하게 되는데 이 부분에서 개인정보 관련 법령의 적용을 받는다.

〈주요정보통신기반시설 보호지침〉

제26조(제어시스템 보안관리) ① 관리기관의 장은 주요정보통신기반시설 중 제어시스템의 보호를 위하여 제어시스템이 포함된 정보통신망을 폐쇄망으로 운영하여야 한다. 다만, 업무시스템 등과의 연결이 불가피할 경우 해당 구간에 일방향통신 장비 설치 등 제어시스템을 내부 업무망 등과 분리·운영하여야 한다.

〈국가 정보보안 기본지침〉

제40조(내부망·인터넷망 분리) ① 각급기관의 장은 내부망과 기관 인터넷망을 분리·운영하여야 한다.

□ 해외 망분리 규제 현황

다른 분야와 마찬가지로 해외의 경우 망분리 규제는 존재하지 않는다. 다만, 미국 도로교통안전국(NHTSA)의 자동차 사이버보안 권고⁴³⁾에서는 자동차의 주행과 안전에 해당하는 필수적인(mission-critical) 영역을 외부 공격으로부터 보호하기 위한 목적에서 차량 아키텍처 설계간 격리(isolation)를 권고하고 있으나, 망분리 자체가 언급된 것은 아니다. 자동차의 아키텍처는 제조사 고유의 영역이므로 이에 대한 별도의 규제는 존재하지 않는다.

유럽 네트워크정보보호원(ENISA)에서도 자동차 기술적 보안 항목으로 컴포넌트의 분리를 권고하고 있다. 유럽의 자동차사이버보안법규에서도 망분리를 명시한 항목은 없다. 다만 제조사의 사이버보안관리시스템(CSMS)의 인증을 요구하고 있으며 인증받은 제조사의 차종별로 인증기관에서 보안적용 평가를 심사결과 제출을 통해 차량 형식 승인(VTA)을 발급한다. 또한, 세계적으로 자동차의 개발단계에서 폐기까지 전 주기(life-cycle)에서의 보안을 보장하기 위해 ISO21434가 개발되었다.

43) NHTSA (2022.9), Cybersecurity Best Practices for the Safety of Modern Vehicles.

<표 4-11> 자동차 분야의 국내외 망분리 규제 현황

영역	국내	해외
자동차 차량	- 자동차 차량에 대한 망분리 규제는 없음 - 자동차 제조사에 대한 망분리 규제 존재 (개인정보의 기술적·관리적 보호조치 기준)	- 없음 (미국 도로교통안전국(NHTSA)은 격리 권고, 유럽은 제조사의 사이버보안관리시스템(CSMS) 인증 요구, 차량 형식 승인(VTA) 발급)
통신 네트워크	- 없음	- 없음
교통 인프라	- 교통 인프라 운영 주체에 대한 망분리 규제 존재(주요정보통신기반시설 보호지침, 국가 정보보안 기본지침)	- 없음

자료: 전문가 자문 내용을 취합하여 정리.

4. 자동차 분야의 보안 정책 제언

가. 자동차 분야에서 망분리 규제가 반드시 필요한 부분

첫째, 자동차 분야는 영역별로 요구되는 보안 수준 및 적용가능한 보안 수단이 다르기 때문에 영역 기반 모델이 적용되어야 하는 부분이 여전히 존재한다. 예를 들어, 연산 능력의 한계와 실시간 데이터 통신의 필요성이 존재하는 주행과 안전에 해당하는 필수적인(mission-critical) 차량 내부 네트워크와 점차 연산 능력이 커지고 실시간성이 상대적으로 낮은 외부 네트워크에 대한 구분이 필요하고, 개인 소유의 자동차 차량과 공공 소유의 교통 인프라에 대한 구분도 필요하다. 이처럼 영역별로 차별화된 접근이 필요하다. 현재 차량 내부 네트워크에 대해서는 구조적인 격리가 권고되고 있고 자동차 제조사들이 자발적으로 이를 채택하고 있으므로 향후에도 이와 같은 기조가 유지되는 것이 바람직하다. 공공 소유의 교통 인프라에 대해서는 현재 망분리 규제가 적용되는 부분에 대해서 실제로 망분리가 보안에 더 효과적인지, 다양한 보안 수단을 종합적으로 활용하는 것이 더 효과적인지에 대한 검토가 필요하다. 예를 들어, 자율주행 데이터셋 공유 등 외부와의 통신 시스템을 제외한 차량 모니터링, 제어 등 운영 시스템에 대해서는 향후에도 망분리가 필요할 수 있다. 또한 현재 보안 관리가

체계적으로 이루어지지 못하고 있는 도로 CCTV 등에 대해 필요한 부분에 대해 망분리를 적용할 수도 있다.

“차량 자체에 대한 망분리는 전자식제어장치 내 프로세스의 한계 때문에 어려운 상황이나 차량과 통신하는 차량 제조사의 백엔드 인프라의 경우 망분리가 필요함. 차량 제조사의 텔레메틱스나 5G 등을 이용하여 통신하는 백엔드인프라의 경우 차량을 원격에서 제어하거나 OTA를 통해 차량 내부 제어기에 접근이 가능하기 때문에 인프라의 보안사고가 사람이 운전하는 차량으로 확대되어 인명사고가 발생할 수 있기에 망분리가 필요함. 도로교통체계와 연계되어 자율협력주행을 제공하는 교통센터와 같은 백엔드 인프라의 경우에도 제조사의 백엔드 인프라와 동일한 보안사고가 발생할 수 있기 때문에 망분리에 대한 권고가 필요함.” (자동차 보안 전문가 3)

자동차와 자동차, 자동차와 교통 인프라 간의 통신 네트워크에 대해서는 아직 망분리 규제가 적용되고 있지 않지만 향후 보안 사고가 발생하거나 보안 위협이 구체화될 경우 규제가 도입될 가능성을 배제할 수 없다. 이 경우에도 스마트 서비스의 제공을 포기해서라도 연결을 끊고 망분리를 하는 것이 보안에 더 효과적인지, 연결 후 무선소프트웨어업데이트(OTA, over the air)를 통해 보안 기술을 업데이트하는 것이 더 효과적인지에 대한 비교가 필요하다.

나. 영역 기반에서 검증 기반 보안 모델로 전환 가능성

자동차 분야에서 망분리 같은 영역 기반 모델에서 제로 트러스트 같은 검증 기반 모델로 보안 정책을 확장하기 위해서는 주의할 사항들이 있다. 첫째, 제로 트러스트 등 검증 기반 모델이 논의는 활발하게 되고 있으나 구체적으로 적용된 사례가 많지 않으므로 전면적인 도입보다는 점진적인 도입을 추진하는 것이 바람직하다. 제로 트러스트 모델을 도입하기 위해서는 자산(데이터 등)에 접근하려는 모든 주체에 대한 식별 및 인증, 모든 자산에 대한 중요도 분류를 바탕으로 주체별 권한 부여가 이루어져야 한다. 따라서 엄밀한 의미의 제로 트러스트 모델은 아직 구현되지 않았고 구현하기

위한 비용이나 시간도 막대하다. 이는 단순히 자원 투자만으로 가능한 것이 아니라 기업의 업무방식 및 조직 구조, 문화의 큰 변화를 필요로 한다. 따라서 기존에 존재하는 시스템(legacy system)보다는 신규로 구축되는 시스템에 적용을 시도해 보는 것이 바람직하다. 원천적으로 제로 트러스트 모델을 적용하기 어려운 영역도 있다. 차량 내부 네트워크의 경우 제한된 컴퓨팅 능력 및 실시간성 (real-time) 제공의 필요성으로 인하여 여러 위치에서 인증을 수행하는 것이 쉽지 않다. 따라서, 제로 트러스트 모델로 전환하는 것이 현재로서는 어려울 수 있다. 향후 차량에 고성능 컴퓨팅 시스템이 장착될 경우 제로 트러스트 모델의 적용을 검토해 볼 수 있다.

둘째, 영역 기반 모델이든, 검증 기반 모델이든 어느 하나의 보안 모델을 너무 신뢰하거나 기술적인 측면에만 지나치게 의존하는 것을 경계해야 한다. 효과적인 보안은 물리적 보안, 기술적 보안, 관리적 보안이 모두 제대로 이루어졌을 때 가능하며, 기술적인 측면 못지않게 인적 측면의 중요성을 강조하지 않을 수 없다. 망분리든, 제로 트러스트 모델이든 어떤 인력이 구현하고 운영하느냐에 따라 그 성과가 큰 차이를 보이기 때문이다.

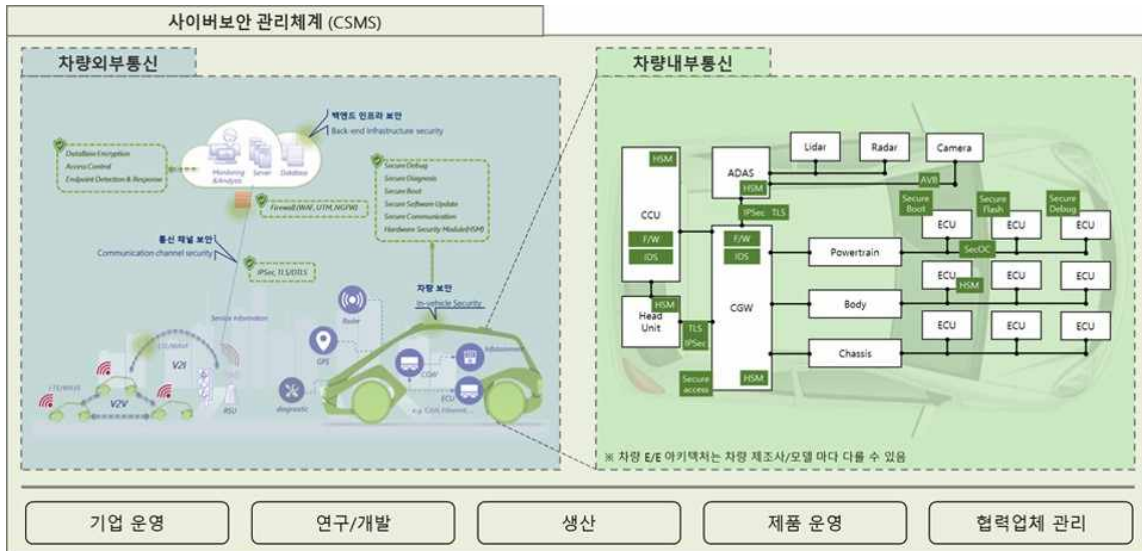
다. 검증 기반 보안 모델로 전환하기 위한 정책

자동차 분야에서 망분리 같은 영역 기반 모델에 지나치게 의존하지 않고 제로 트러스트 같은 검증 기반 모델을 포함하는 보다 유연한 보안 정책으로 이행하기 위해서는 다양한 정책 과제를 추진해야 한다.

첫째, 기업이 바람직한 보안 수단 또는 모델을 자율적으로 도입하도록 하는 대표적인 정책 중 하나인 가이드라인 제시를 고려할 수 있다. 가이드라인의 좋은 사례는 자율주행차에 대해 한국인터넷진흥원이 보안모델을 개발하여 배포한 것이다.⁴⁴⁾

44) 자율주행차 보안모델에서는 자율주행차 및 서비스, 제조사의 관리작기술적·물리적 보안강화 방안을 제시하였음.

[그림 4-11] 한국인터넷진흥원의 자율주행차 보안모델



자료: 과학기술정보통신부·한국인터넷진흥원(2021. 12c), p. 11.

제로 트러스트 같은 최근의 기술 패러다임을 포함하는 자동차 보안 가이드라인 관련하여 주의할 점은 아직 실제 구현된 사례가 부족하여 업계의 공감대가 형성되지 않았다는 것이다. 가이드라인은 업계에 방향성을 제시하는 것이므로 현실 사례들이 축적되는 것으로 반영하여 개발되어야 한다. 또한 가이드라인이 규제로 작용하지 않도록 유의해야 한다.

둘째, 정부가 인증이나 도입 의무화를 추진하는 것은 바람직하지 않다. 제로 트러스트가 구현되는 범위, 수준, 형태 등이 매우 다양할 것으로 예상되는데 분야 및 기업의 특성에 맞게 도입할 수 있도록 유연성을 최대한 보장해야 한다. 자동차는 글로벌 산업이므로 국내에서만 인증을 도입한다고 해서 효과를 얻을 수 있는 것이 아니고 자칫 무역규제로 작용할 수도 있기 때문이다.

셋째, 공공 부문에서 선행적으로 도입하여 사례를 제시하는 것이 바람직하다. 예를 들어 신규 도입이 추진되고 있는 스마트시티 등의 클라우드 기반 교통시스템에 대해 어느 부분에 어떤 형태로 제로 트러스트 모델을 적용할 것인지 레퍼런스 모델을 개발하고 적용하여 성공사례를 제시함으로써 관련 기업으로의 확산을 촉진할 수 있다.

“제로 트러스트 적용 확산을 위해서는 민간의 영역도 중요하지만 공공의 영역에서

선행적으로 적용하여 관련 산업 확산 및 보안기술개발 유도가 필요함. 도로교통체계와 자동차 운영과 관련된 부분은 기존에 적용되어 있는 망분리를 제로 트러스트 형태로 전환하는 것은 어렵지만, 신규 도입이 추진되고 있는 스마트시티 등의 클라우드 기반 교통시스템의 경우 기관이 망분리를 선택할 수 있도록 선제적 규제 항목으로 되어 있는 망분리 관련 법규 항목을 사후 규제 항목으로 변경하는 것이 요구됨”(자동차 보안 전문가 3)

“제로 트러스트로 전환하기 위해서는 초기 설계 단계부터 자산을 식별하여 관련 접근 통제 보안기술을 적용하는 것이 필요하지만, 자동차 산업에 특화된 모델을 발굴하기가 어렵기 때문에 초기단계 적용 지원 및 레퍼런스 모델 발굴 정책이 요구됨. 또한, 제로 트러스트 적용 확대를 위해서는 제로트러스터 적용을 위한 자산 식별 방안과 통제방안 등에 대한 기본 가이드라인과 로드맵 제시가 필요함”(자동차 보안 전문가 3)

넷째, 개체 식별과 관련된 법 제도의 정비를 추진해야 한다. 금융권 등에서 사용하는 공동인증서나 금융인증서 같이 인증서 관련 법률에 근거하여 자동차들을 식별하기 위한 인증서를 발급할 수 있어야 한다. “전자서명법”에서는 개체를 사람으로 보고 있기 때문에 이를 임의의 개체로 확장할 수 있어야 한다. 데이터 3법, 즉 ‘개인정보보호법’, ‘신용정보법’, ‘정보통신망법’에서 개체 식별과 관련된 부분도 정비가 필요하다.

“금융권에서 사용하는 공동인증서나 금융인증서 등과 같이 인증서관련 법률을 통해 자동차들을 식별하기 위한 인증서를 발급할 수 있어야 함. 과학기술정보통신부의 ‘전자서명법’에서는 개체를 사람으로 보고 있기 때문에 이를 임의의 개체로 확대할 수 있어야 함. 자동차에 대한 식별정보는 개인의 식별정보와 연결이 되어 위치정보에 대한 노출 등으로 인해 개인정보보호에 대한 법률도 고려되어야 함. 즉, 데이터 3법이라고 하는 “개인정보보호법”, 신용정보법“, ”정보통신망법“에서의 개인정보의 식별에 대한 부분도 고려를 해야 됨”(자동차 보안 전문가 2)

제5절 소결

각 산업별 문헌 조사, 전문가 자문, 연구팀 토의 등의 결과를 종합하여 요약하면 다음과 같다.

<표 4-12> 금융 산업의 보안 위협, 대응수단 및 정책 요약

보안 위협	- (가로채기) 고객정보, 금융정보 유출, 다른 금융 범죄에 활용 - (위조/변조) 불법 금융 거래(자금 이체 등) - (차단) 분산 서비스 거부(Distributed Denial of Service: DDoS) 공격
대응 수단	- (보안 기술) 이상거래 탐지 시스템(Fraud Detection System, FDS) 등 다양한 기술 - (제로 트러스트) 중요 금융거래에 대해 도입 중
보안 규제	- (국내) 「전자금융감독규정」: 제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다. 3. 내부통신망과 연결된 내부 업무용시스템은 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지 5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것 - (해외) 망분리는 권고사항, 강제하거나 의무화하고 있는 국가 없음, 가이드라인 제시
정책 제언	- 망분리 완화가 필요, 핵심 금융정보에 대해서는 망분리 유지 가능 - 자율적 보안체계 강조: 선제적 지침 배포, 사후 발생하는 보안사고에 대한 처벌/징계 - 제로 트러스트 도입을 위해 데이터 중요도 평가, 전환 과정의 문제에 대한 책임 경감
특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 큼(금융 IT 발달), 편차 존재(대기업 vs. 스타트업) - (전산자원 지불 의사) 타 분야 대비 높음(기업 의사결정), 편차 존재(대기업 vs. 스타트업)

자료: 저자 작성.

<표 4-13> 헬스케어 산업의 보안 위협, 대응수단 및 정책 요약

보안 위협	- (가로채기) 개인정보, 검진정보, 의료정보 등의 유출(예. 병원 데이터 제약사 유출) - (위조/변조) 처방전 위조 등(예. 항정신성약약품 처방) - (차단) 의료시스템 작동불능 등(예. 해외 병원의 수술장비 셧다운으로 환자 사망)
-------	---

대응 수단	- (보안 기술) DRM(Digital Rights Management), DLP(Data Loss Prevention) 등 - (제로 트러스트) 헬스케어 적용 사례는 없는 것으로 파악됨								
보안 규제	- (국내) 「전자의무기록의 관리·보존에 필요한 시설과 장비에 관한 기준」: 제7조(의료기관 외의 장소 관리·보존시 추가적인 조치) 전자의무기록 관리자가 의료기관 외의 장소에서 전자의무기록을 관리·보존하는 경우에는 규칙 제16조제1항제3호부터 제7호까지에 따른 시설과 장비에 대하여 별표에 따른 추가적인 조치를 하여야 한다. 〈별표: 의료기관 외의 장소에 전자의무기록 보관시 필요한 추가적인 조치(일부 발췌)〉 <table><tr><th colspan="2">구분</th><th>세부조치 내용</th></tr><tr><td rowspan="2">네트워크 보안에 관한 시설과 장비</td><td>이중화된 네트워크의 구성</td><td> - 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립 </td></tr><tr><td>네트워크 보호시스템 운영</td><td> - 침입차단시스템, 침입탐지시스템 등 인증된 정보보호시스템을 운영하여 내·외부 네트워크를 보호하여야 한다. </td></tr></table> - (해외) 명시적 망분리 규제 없음. 건강정보 보안 표준 설정(HIPPA Security Rule) 등	구분		세부조치 내용	네트워크 보안에 관한 시설과 장비	이중화된 네트워크의 구성	- 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립	네트워크 보호시스템 운영	- 침입차단시스템, 침입탐지시스템 등 인증된 정보보호시스템을 운영하여 내·외부 네트워크를 보호하여야 한다.
구분		세부조치 내용							
네트워크 보안에 관한 시설과 장비	이중화된 네트워크의 구성	- 의료데이터 전송을 위한 이중화된 네트워크를 구성하여야 하며 아래 조건을 충족하여야 한다. · 물리적 또는 그에 준하는(논리적 포함) 둘 이상의 회선 분리 · 둘 이상의 경로를 제공하는 내부망 구성 · 라우터의 이중화 구성 · 장애발생 시에도 지속적인 서비스 제공 대책 수립							
	네트워크 보호시스템 운영	- 침입차단시스템, 침입탐지시스템 등 인증된 정보보호시스템을 운영하여 내·외부 네트워크를 보호하여야 한다.							
정책 제언	- 망분리가 꼭 필요한 영역은 없다는 의견, 일부 의료장비(핵심 수술장비 등) 검토 가능 - 보건의료 데이터 활용 가이드라인 등과 같은 지침 제시가 바람직								
특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 크지 않음(헬스케어 IT 발달 미흡) - (전산자원 지불 의사) 타 분야 대비 높음(의료기관 결정), 편차 존재(대형 vs. 중소병원)								

자료: 저자 작성.

〈표 4-14〉 홈네트워크 산업의 보안 위협, 대응수단 및 정책 요약

보안 위협	- (가로채기) 홈캠 영상 유출 - (위조/변조) 홈캠 임의 촬영, 도어락 임의 개폐 등 - (차단) 원격제어기기, 원격검침기기, 감지기, 전자출입시스템, 차량출입시스템 등 마비
대응 수단	- (보안 기술) 가상사설통신망(VPN), 가상근거리통신망(VLAN), 암호화 등 - (제로 트러스트) 홈네트워크 적용 사례는 없는 것으로 파악됨
보안 규제	- (국내) 「지능형 홈네트워크 설비 설치 및 기술기준」: 14조의2(홈네트워크 보안) ① 단지서버와 세대별 홈게이트웨이 사이의 망은 전송되는 데이터의 노출, 탈취 등을 방지하기 위하여 물리적 방법으로 분리하거나, 소프트웨어를 이용한 가상사설통신망, 가상근거리통신망, 암호화기술 등을 활용하여 논리적 방법으로

	분리하여 구성하여야 한다. - (해외) 국내와 같이 세대 간 분리를 의무화한 사례는 없는 것으로 파악됨
정책 제언	- 동일한 아파트 단지 내 공격 가능성을 고려할 때 제로 트러스트 모델의 도입 필요 - 홈네트워크 시스템의 특성을 파악하고 검증기반 보안 모델이 적절하게 적용될 수 있는지를 검증하는 연구와 시범적용 등이 선행될 필요
특징 또는 시사점	- (가용 전산자원 규모) 타 분야 대비 작음(아파트 관리실이나 가정 내 설치) - (전산자원 지불 의사) 타 분야 대비 낮음(주로 개인 의사결정)

자료: 저자 작성.

<표 4-15> 자동차 산업의 보안 위협, 대응수단 및 정책 요약

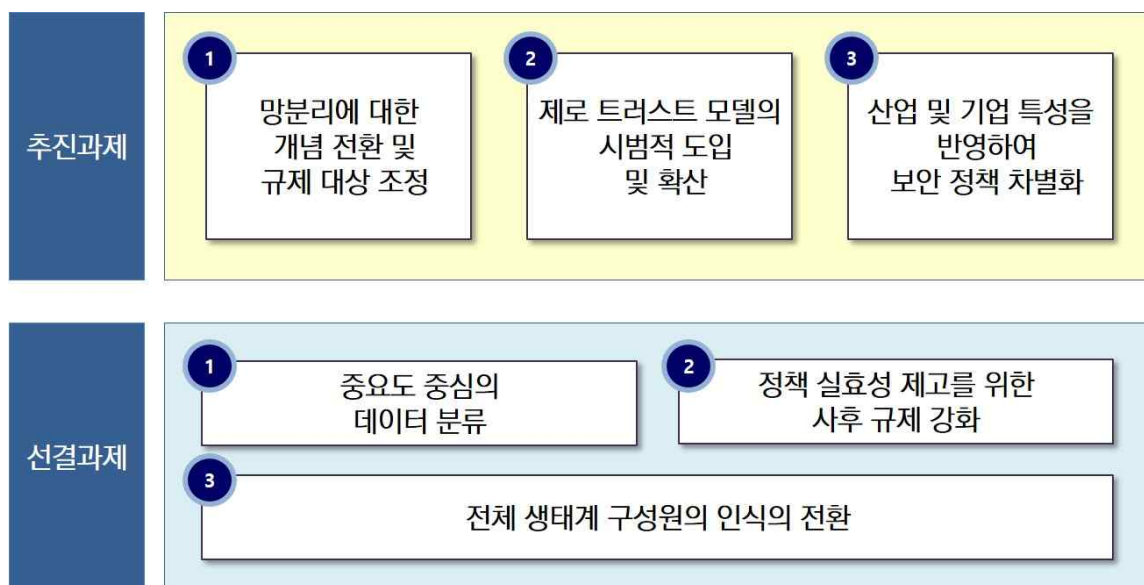
보안 위협	- (가로채기) 차량 위치, 이동 경로 유출 - (위조/변조) 차량 강제 제어(가감속, 조향), 교통신호 강제 제어(예. 영화 “다이하드 4”) - (차단) 교통시스템 마비
대응 수단	- (보안 기술) 이동성, 실시간성으로 최신 보안 기술 활용 불가, 간단한 IDS 활용 수준 - (제로 트러스트) 차량 제어에는 활용 곤란, 인포테인먼트 시스템에는 향후 가능
보안 규제	- (국내) 제조사의 서비스에 대해 「개인정보의 기술적·관리적 보호조치 기준」: 제4조(접근통제) ⑥ 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만명 이상이거나 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억원 이상인 정보통신서비스 제공자 등은 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등을 물리적 또는 논리적으로 망분리 하여야 한다. - (해외) 차량 제어 파트 보호를 위한 구조적 격리(isolation) 권고(망분리 아님)
정책 제언	- 망분리 도입이 어려울 전망이나, 교통신호인프라 등은 망분리 고려 가능 - 글로벌 시장을 고려하여 국내에만 해당되는 보안 규제는 지양할 필요
특징 또는 시사점	- (가용 전산자원 규모) 차량은 작음(모바일 기기), 제조사/교통시스템은 작지 않음 - (전산자원 지불 의사) 차량은 낮음(개인 의사결정), 제조사/교통시스템은 작지 않음

자료: 저자 작성.

| 제5장 | 결론: 초연결 및 디지털 전환 시대의 보안 정책

본 장에서는 미래지향적 보안 정책을 위해 추진되어야 하는 과제와 이를 위해 선결되어야 하는 과제를 제안한다. 본 연구가 지향하는 미래지향적 보안 정책은 연결과 데이터의 공유 및 활용을 통한 미래 신서비스의 구현을 가능하게 하는 정책이고, 데이터 분석을 활용한 새로운 보안 기술을 적용할 수 있는 정책이며, 혁신과 규제 사이의 균형을 유지하는 정책이다. 연결과 데이터의 공유 및 활용을 저해하는 정책은 미래에 지속가능하지 않고, 데이터를 제대로 활용하지 못하는 정책은 효과적일 수 없다. 사람-사람, 사람-기계, 기계-기계 간 연결이 급격하게 확대되고 그 연결의 방식도 다양화되는 초연결 사회에서, 그리고 개체 간 연결과 데이터의 창출, 순환, 분석에 기반한 디지털 전환이 진행되는 상황에서 연결을 차단하는 정책을 계속 유지하기는 어렵다. 또한 기업 내외부를 막론하고 보안 사고가 발생하고 있고 원격근무 확산으로 기업의 내외부 구분이 모호해지는 상황에서는 기업 내부와 외부의 차단만이 효과적이라고 가정하는 것도 비현실적이다.

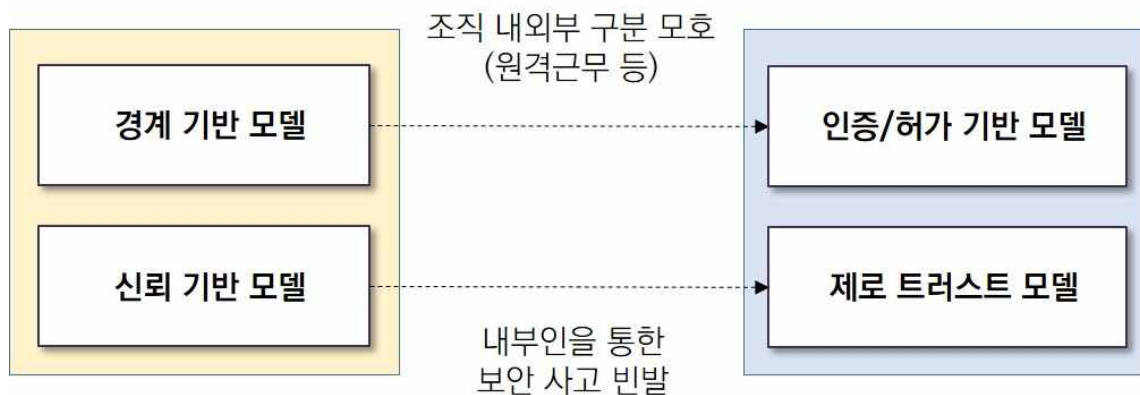
[그림 5-1] 미래지향적 보안 정책을 위한 정책 제안



자료: 저자 작성.

본 연구의 제목에 사용된 “데이터 기반 보안”이라는 표현에서 ‘데이터’는 두 가지 의미를 가진다. 첫째, 보안 대상으로서의 데이터이다. 연구의 주제가 데이터 보안, 즉 개인과 조직의 중요한 자산인 데이터에 대한 보안이라는 것이다. 데이터의 중요도에 따라 규제를 차등화하는 등 데이터 관점에서 보안 정책을 수립해야 한다. 둘째, 보안 수단으로서의 데이터이다. 효과적인 보안을 위해서는 조직 내외부에서 창출되는 다양하고 방대한 데이터를 적극적으로 활용해야 한다는 것이다. 그리고 연구 제목의 “설계와 이행전략”이라는 표현은 단순히 망분리 등 기존 정책의 문제점을 제시하는 것에 그치지 않고 정책 대안을 제안하고 이를 실행할 수 있는 방안을 제시한다는 의미이다. 이하에서는 망분리 규제는 어떻게 변화되어야 하고 제로 트러스트 모델은 어떻게 도입해야 하는지 대안을 제안하고 이를 실행하는 방안도 제시한다.

[그림 5-2] 데이터 기반 보안 정책의 방향성



자료: 저자 작성.

제1절 추진과제

1. 망분리에 대한 개념 전환 및 규제 대상 조정

□ 망분리의 개념을 구조적 망분리를 포함하여 확장

현재 국내에서 사용되고 있는 망분리의 개념은 물리적으로 또는 논리적으로 인터넷 연결을 끊는 것이므로 사실상 망차단(network disconnection or blocking)이라고

할 수 있다. 연결을 차단하여 데이터의 흐름을 막는다는 점에서 보안의 가용성을 저해한다. 망분리 하에서도 어떤 방식으로든 분리된 망 사이에 데이터가 교환될 수밖에 없고 그 과정에서 보안 위협이 발생하므로 보안의 기밀성과 무결성도 높지 않다. 정기적으로 또는 새로운 보안 기술이 개발되거나 보안 위협이 우려될 때 보안 프로그램을 실시간으로 업데이트할 수도 없다.

따라서 망분리의 개념을 현행 물리적·논리적 중심에서 구조적 망분리를 포함하여 확장해야 한다. 제3장에서 살펴본 바와 같이 해외에서 보안 수단의 하나로서 제안하고 있는 망분리는 실제로는 망분할(network segmentation)로서 전체 네트워크를 여러 개의 하위 네트워크로 구분하여 각각의 하위 네트워크에 대해 별도로 보안 관리를 하는 것이다. 제4장의 자동차 분야에서 설명한 구조적인 격리(isolation)도 유사한 취지이다. 망분할, 격리 등의 구조적 망분리는 연결을 허용하면서 보안을 유지하므로 경제성과 보안성을 모두 고려하는 대안이다. 따라서 망분리가 필요한 경우 물리적·논리적 망분리에 한정하지 말고 구조적 망분리도 함께 고려해야 한다.

□ 망분리 규제의 대상을 필수 기능 자산으로 한정

물리적·논리적·구조적 망분리가 필요한 자산을 포지티브 방식으로 지정해야 한다. 기존 문헌에서는 망분리를 단순히 완화되어야 하는 대상으로 파악하고 있지만 분야에 따라서 망분리가 실제로 필요하고 오히려 강화되어야 하는 경우도 존재한다. 망분리가 필요한 대상으로는 필수 기능 자산(mission-critical asset)이 있다. 사회 안전과 국가 안보에 중요한 금융 분야의 중요 개인신용정보, 헬스케어 분야의 핵심 수술장비, 자동차 분야의 교통신호 인프라, 공공 분야의 국가기밀데이터, 기타 핵심 군사시설, 원자력발전소 등은 연결과 공유의 편익보다 보안 위협의 비용이 클 것으로 예상되므로 망분리 규제의 대상으로 고려할 수 있다. 그 방식은 물리적, 논리적, 구조적 망분리 중에서 자산의 중요도와 망분리 적용가능성을 고려하여 선택해야 한다.

망분리 대상 지정과 함께 추진해야 할 것은 망분리의 실효성 제고 방안이다. 망분리 하에서 분리된 망 사이의 데이터 교환에 대한 가이드라인 제시와 관리가 필요하다. 예를 들어, 물리적 망분리의 경우 인가된 사용자 이외의 USB 사용을 금지하는 방안,

논리적 망분리의 경우 망연계 솔루션의 업데이트를 주기적으로 실시하는 방안, 구조적 망분리의 경우 다중요소인증(MFA), 미세 분할(micro-segmentation), 소프트웨어 정의 경계(Software Defined Perimeter, SDP) 등 다양한 수단과 기법을 활용하는 방안을 마련해야 할 것이다.

물리적·논리적·구조적 망분리가 필요한 자산을 포지티브 방식으로 지정한다는 것은 그 이외의 자산에 대해서는 보안 수단의 선택을 기관의 자율에 맡겨야 한다는 것을 의미한다. 본 연구에서 주장하는 것은 망분리 등 경계 기반 모델에서 제로 트러스트 모델로 무조건 전환하지는 것이 아니라 망분리도 제로 트러스트라는 보안 패러다임 안에서 하나의 선택지가 될 수 있다는 것이고, 일방적인 규제 완화가 아니라 규제 강화와 완화를 포함하는 규제 합리화가 바람직하다는 것이다. 즉, 현재 망분리에 지나치게 의존하고 있는 보안 규제를 다양한 보안 수단을 포함하여 확장하는 동시에, 필요한 영역에서는 망분리 규제를 오히려 강화할 필요도 있다.

망분리 규제를 포함한 모든 종류의 규제 설계 시 잊지 말아야 할 사항은 글로벌 경쟁 시대에 글로벌 스탠다드에 맞지 않는 규제가 되지 않도록 해야 한다는 것이다. 자칫 국내 시장을 ‘콜라파고스(Kolapagos = Korea + Galapagos)화’할 우려가 있기 때문이다. 따라서 국내와 해외 규제 수준, 산업 간 규제 수준의 일관성을 유지하기 위해 보안 관련 국제협력 강화, 전 산업의 보안 규제 모니터링 등이 필요하다. 이런 관점에서 한 가지 추가로 제안하면, 현재 지방자치단체가 예산 부족을 이유로 망분리 규제를 준수하지 못하고 있는 상황은 규제의 일관성 차원에서 개선되어야 한다.

2. 제로 트러스트 모델의 시범적 도입 및 확산

망분리 규제의 대상을 필수 기능 자산으로 한정하는 대신 그 대안이라고 할 수 있는 제로 트러스트 모델의 도입을 적극적으로 고려해야 한다. 다만, 제로 트러스트 모델이 국내에서 활발하게 논의되고 있으나 아직 구체적으로 적용된 사례가 많지 않으므로 전면적인 도입보다는 점진적인 도입을 추진하는 것이 바람직하다. 제로 트러스트 모델을 도입하기 위해서는 데이터 등 모든 자산에 대한 중요도 분류, 자산에 접근하려는 모든 주체에 대한 식별 및 인증, 각 자산의 중요도에 따른 주체별 권한 부여가 이루어

져야 한다. 따라서 엄밀한 의미의 제로 트러스트 모델은 아직 본격적으로 구현되지 않았고 구현하기 위한 비용이나 시간도 막대하다. 이는 단순히 재원 투자만으로 가능한 것이 아니라 기업의 업무방식 및 조직 구조, 문화의 상당한 변화를 필요로 한다. 따라서 기존에 존재하는 시스템(legacy system)보다는 신규로 구축되는 시스템에 적용을 시도해 보는 것이 바람직하다. 공공 부문에서 선행적으로 도입하여 사례를 제시하는 것이 바람직하다. 예를 들어 신규 도입이 추진되고 있는 스마트시티 등의 클라우드 기반 교통시스템에 대해 어느 부분에 어떤 형태로 제로 트러스트 모델을 적용할 것인지 레퍼런스 모델을 개발하고 적용하여 성공사례를 제시함으로써 관련 기업으로의 확산을 촉진할 수 있다.

기업이 바람직한 보안 수단 또는 모델을 자율적으로 도입하도록 하는 대표적인 정책 중 하나인 가이드라인 제시를 고려할 수도 있다. 제로 트러스트 같은 최근의 기술 패러다임을 포함하는 보안 가이드라인 관련하여 주의할 점은 아직 실제 구현된 사례가 부족하여 업계의 공감대가 형성되지 않았다는 것이다. 가이드라인은 업계에 방향성을 제시하는 것이므로 현실 사례들이 축적되는 것을 반영하여 개발되어야 한다. 이때 가이드라인이 규제로 작용하지 않도록 유의해야 한다. 또한, 정부가 인증이나 도입 의무화를 추진하는 것은 바람직하지 않다. 제로 트러스트가 구현되는 범위, 수준, 형태 등이 매우 다양할 것으로 예상되므로 분야 및 기업의 특성에 맞게 도입할 수 있도록 유연성을 최대한 보장해야 한다.

새로운 보안 모델로의 전환 과정에서 발생하는 문제에 대한 책임부담을 경감해주는 방안도 고려해야 한다. 업무 수행과정에서 발생된 결과에 책임을 지우는 관행 때문에 기업의 입장에서 신규 시스템의 도입이나 전환을 꺼리게 되기 때문이다. 제로 트러스트 모델은 활용한 사례가 아직 많지 않아 전환 과정에 시행착오가 발생할 수 밖에 없다. 따라서 이러한 정보보안 담당자들의 책임부담이 사라지지 않는 한 새로운 보안 모델로 전환은 적극적으로 이루어지지 않을 것이다. 고의나 중대한 과실이 아닐 경우 발생한 사고에 대해 현재 적용하고 있는 각종 징계조항의 개정을 검토해야 한다. 규제 샌드박스를 활용하여 제로 트러스트 모델을 시범적으로 구축하고 그로부터 발생하는 문제점을 파악한 후 규제나 징계 조항 등을 설계하는 것도 좋은 방법이다.

3. 산업 및 기업 특성을 반영하여 보안 정책 차별화

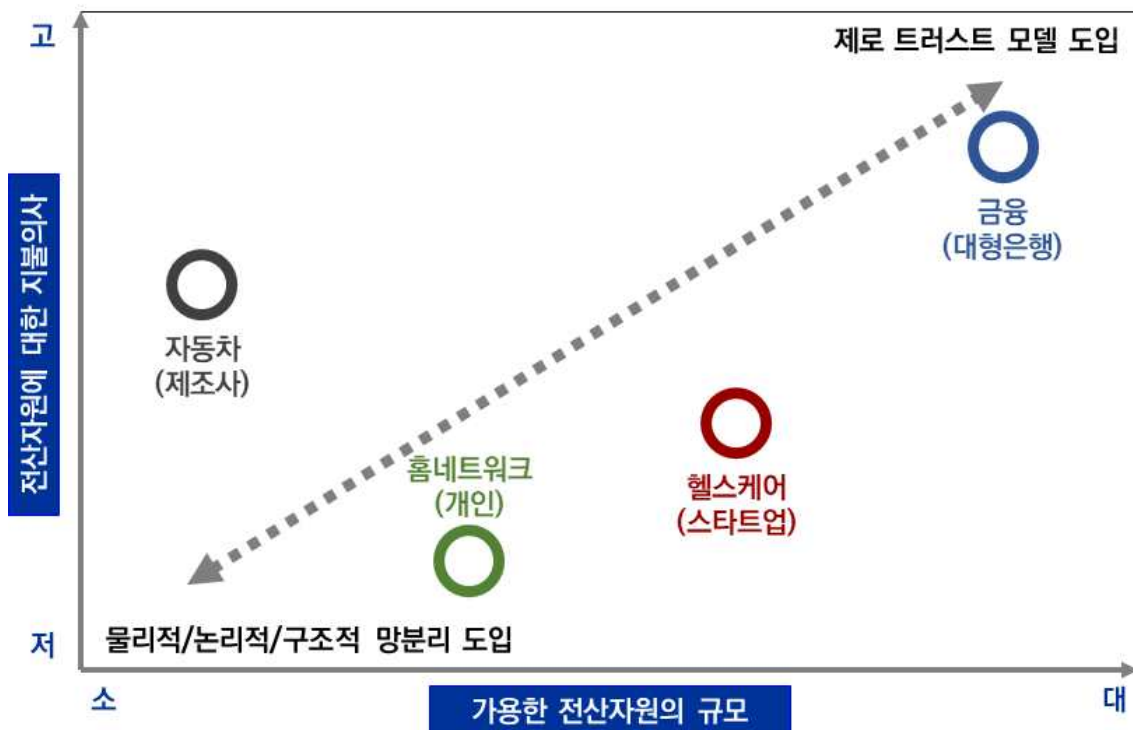
□ 산업별 보안 정책 차별화

보안 정책을 수립할 때 망분리의 개념을 구조적 망분리를 포함하여 확장하고, 망분리 규제의 대상을 필수 기능 자산으로 한정하며, 제로 트러스트 모델을 시범적으로 도입·확산하는 것은 모든 산업에 공통적이지만 각 산업별 특성도 반영해야 한다.

첫째, 가용한 전산자원의 규모가 산업별로 편차가 있다. 일반적으로 산업에서 주로 사용되는 시스템이 고정형일 경우 전산자원의 규모가 늘어날 수 있지만 이동형일 경우 일정 수준 이상 늘어나기 어렵다. 시스템을 운영하는 주체가 기업일 경우에 개인일 경우보다 대규모 전산자원을 운용할 능력을 보유하기 용이하다.

둘째, 전산자원에 대한 지불의사(willingness to pay)도 산업별로 다르다. 시스템을 운영하는 주체가 기업일 경우에 전산자원에 대한 투자를 매출액의 일정 수준까지 집행할 수 있지만, 개인일 경우 전산자원에 대한 투자를 적극적으로 하기 어렵다.

[그림 5-3] 산업별 특성: 전산자원의 가용한 규모 및 지불의사(예시)

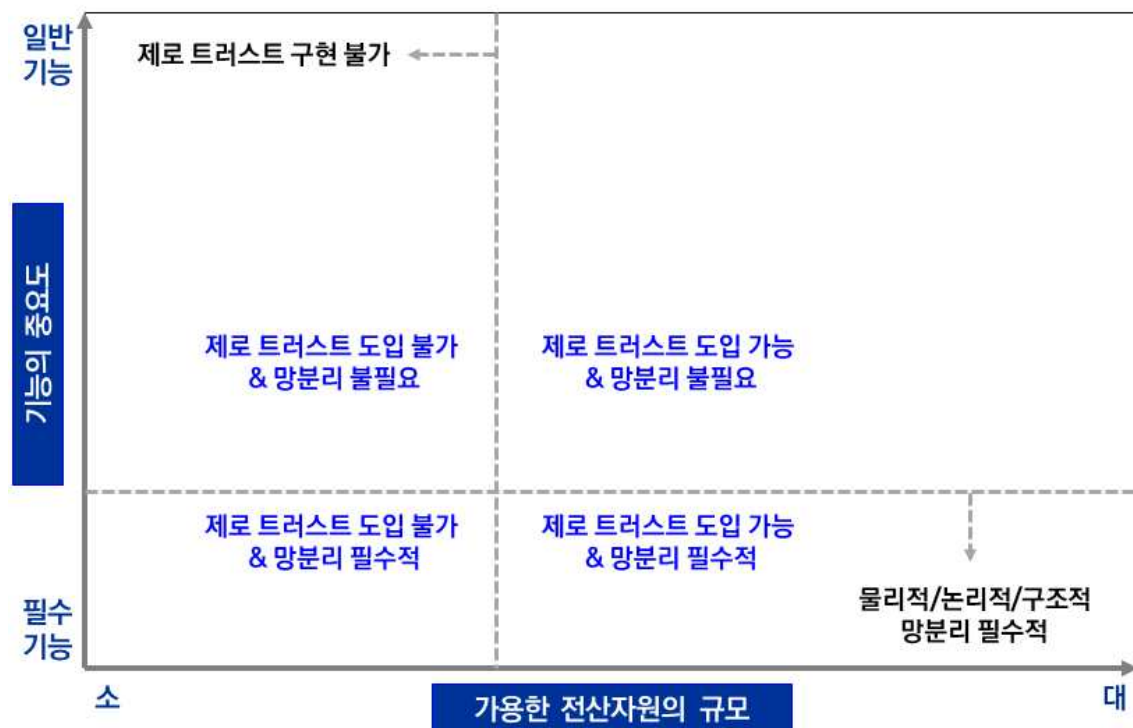


자료: 저자 작성.

[그림 5-3]은 제4장에서 분석한 금융, 헬스케어, 홈네트워크, 자동차 분야를 가용한 전산자원의 규모와 전산자원에 대한 지불의사에 따라 배열한 것이다. 분야별로도 의사결정의 주체가 개인이나 기업이나, 대기업이나 스타트업이나 등에 따라 상황이 달라지기 때문에 일반적으로 말할 수는 없지만 설명을 위해 예시적으로 표현하였다. 이상적으로는 제로 트러스트 모델을 구현하는 것이 바람직하지만 이를 위해 상당한 비용과 시간이 필요하기 때문에 그림에서 우상향에 위치할수록 제로 트러스트 모델의 도입이 용이하고, 좌하향에 위치할수록 도입이 쉽지 않아서 망분리 등 기존 보안 수단을 활용할 수 밖에 없다고 할 수 있다.

물리적·논리적·구조적 망분리를 활용할 것인지, 제로 트러스트 모델을 도입할 것인지를 결정할 때 자산의 중요도도 고려해야 한다. 많은 경우 제로 트러스트 모델을 구현하는 것이 바람직하지만 필수 기능 자산(mission-critical asset)의 경우 물리적·논리적·구조적 망분리가 필수적이기 때문이다. [그림 5-4]는 가용한 전산자원의 규모와 기능의 중요도에 따라 망분리와 제로 트러스트 모델의 도입 가능성을 표현한 것이다.

[그림 5-4] 망분리 및 제로 트러스트의 도입 가능성(예시)



자료: 저자 작성.

□ 기업의 규모 또는 보안 수준에 따른 보안 정책 차별화

보안 규제에 기업 규모별 정책을 적용할 수도 있다. 기업 규모별 정책이란 경제 성장을 목적으로 시장에서의 실패를 보완하거나 기업 환경을 개선하기 위해 외형적 규모 기준에 따라 차별적으로 지원 혹은 규제하는 정부정책을 말한다(박양신·강민지·김영민, 2016). 매출액이나 사용자를 기준으로 하여 일정 수준 이하의 기업에 대해서는 보안 규제의 적용을 제외하거나 유예하는 등 규제를 차등 적용할 수 있다.

기업 규모에 따른 규제 차등화의 논리는 망분리 등의 규제를 준수하는 비용이 규모가 작은 기업에게는 부담이 될 수 있기 때문에 규제 적용의 예외를 두어야 한다는 것이다. 기업 규모에 따라 규제를 차등화하는 것의 법적 근거는 「국민부담 경감을 위한 행정규제 업무처리 지침」에서 찾을 수 있다. 「국민부담 경감을 위한 행정규제 업무처리 지침」은 2016년 7월 제정되었고 소기업이나 소상공인에 대해 전부면제, 일부면제, 규제차등화 등 규제부담 경감방안을 마련해야 한다는 것이다.

〈국민부담 경감을 위한 행정규제 업무처리 지침 (2016.7.19 제정)〉

제5조(소상공인·소기업 규제 경감) ① 중앙행정기관의 장은 제2조에 따른 규제비용 관리의 대상이 되는 규제(규제비용으로 기업에 부담이 되는 규제)를 신설하거나 강화하려는 경우 규제부담의 형평성을 제고하기 위하여 「소상공인 보호 및 지원에 관한 법률」제2조에 따른 소상공인에 대하여 규제 도입 시점부터 3년간 규제적용을 면제하는 방안을 마련하여야 한다.

② 중앙행정기관의 장은 규제비용관리 대상 규제를 신설하거나 강화하려는 경우 「중소기업기본법」제2조에 따른 소기업에 대하여 해당 규제를 일률적으로 적용하는 것이 적절하지 아니하거나 과도한 부담을 주는 경우 규제의 전부 또는 일부의 적용을 면제하거나 유예기간을 설정하는 등 규제비용 부담을 경감하는 방안을 마련하여야 한다.

③ 중앙행정기관의 장은 제1항 및 제2항을 적용하는 것이 적절하지 아니하다고 판단될 경우에는 법 제10조제1항에 따라 위원회에 심사를 요청할 때에 그 판단의 근거를 제시하여야 한다.

기업 규모에 따른 규제 차등화를 실행하기 위해서는 어느 정도의 규모를 기준으로 규제를 차등화할 것인지를 결정해야 한다. 예를 들어, 「중소기업기본법」 제2조와 시행령 제3조에서 정하는 중소기업을 기준으로 활용할 수도 있을 것이다. 하지만 경제 환경의 변화에 따라 어떤 규모의 기업을 정책적으로 지원할 것인가에 대해서는 지속적으로 논란이 제기될 수 있다. 예를 들어 우리나라의 중소기업 범위는 1966년 12월 「중소기업기본법」이 제정된 이후 22번의 개정을 거쳐 현재에 이르고 있다(박양신·강민지·김영민, 2016).

기업 규모에 따른 규제 차등화는 문제점도 안고 있다. 기업 규모와 취급하는 데이터의 규모는 항상 비례하는 것은 아니기 때문에 규모가 작은 기업이라고 하더라도 대형 보안 사고에 노출될 수 있다. 또한 지속적인 정부 지원을 받기 위한 도덕적 해이(moral hazard) 현상이 발생할 수도 있다. 기업 규모가 일정 문턱을 넘어서면 지원이 중단되어 규제의 적용을 받기 때문에 기업이 성장하지 않으려는 피터팬 증후군(Peter Pan Syndrome)이 발생되고 문턱 근처에서 기업규모 분포가 왜곡될 수 있다(박양신·강민지·김영민, 2016).

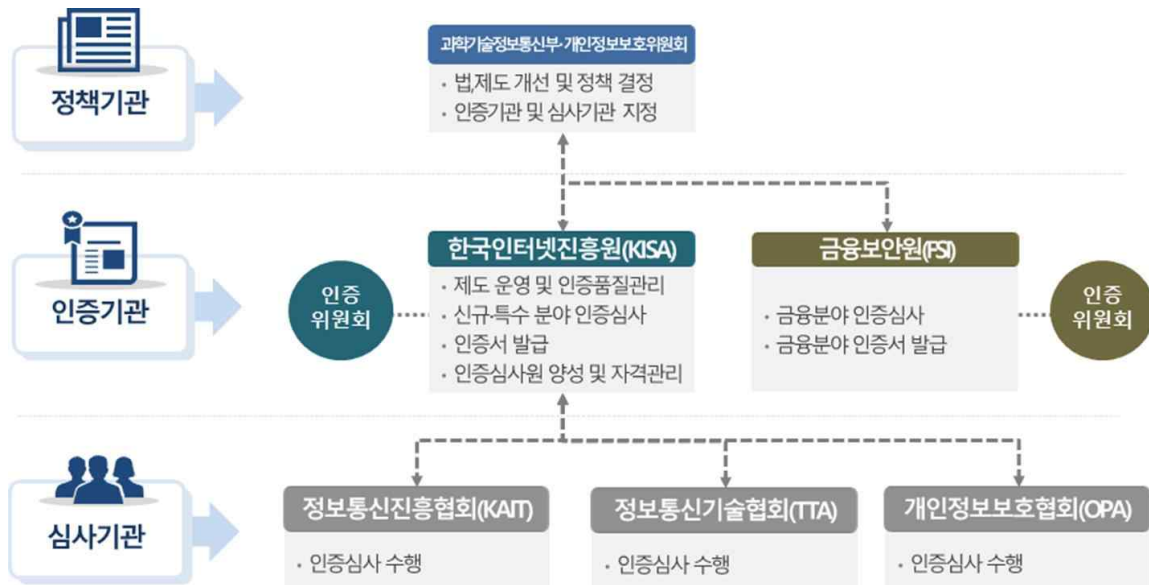
사용자 규모에 따라 보안 규제를 차등 적용하는 방안도 고려할 수 있다. 그 필요성은 규모가 작은 기업에게 규제 준수 비용이 부담이 될 수 있다는 앞의 논리와 동일하다. 하지만 여기서도 사용자 규모와 취급하는 데이터의 규모가 항상 비례하는 것은 아니기 때문에 사용자 규모가 작은 기업이 대형 정보 보안 사고에 노출될 가능성을 염두에 두어야 한다.

보안 수준이 높은 경우에 망분리 등의 규제를 완화해주는 방안도 고려해 볼 수 있다(한국인터넷기업협회, 2022). 개인정보 유출 사고를 예방하고 전자금융 거래의 안전성을 확보하기 위해서는 보안에 대한 많은 투자가 필요하다. 기업의 보안 수준에 따라 규제를 차등화하는 것은 기업이 선진적인 정보 보안 기술에 적극적으로 투자하도록 유도하는 인센티브가 될 수 있다.

기업의 보안 수준은 인증 제도를 통해 평가할 수 있다. 현재 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 제도가 운영되고 있다. 이는 금융회사 및 전자금융업자 등의 기업에서 정보보호 및 개인정보보호 관리체계 활동이 인증기준에 적합한지를 인

터넷진흥원, 금융보안원 등 인증기관이 심사하여 인증을 부여하는 제도이다.⁴⁵⁾ 2018년 11월 「정보보호 및 개인정보보호 관리체계 인증 등에 관한 고시」의 시행으로 정보보호 관리체계(ISMS)와 개인정보보호 관리체계(PIMS) 인증 제도가 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 제도로 통합되었다. 2022년 2월 현재 금융보안원을 통해 정보보호 및 개인정보보호 관리체계 인증(ISMS-P)을 받은 금융기관은 신한은행, 카카오페이 등 22개사이고 정보보호 관리체계(ISMS)를 포함하면 97개사이다(금융보안원, 2022. 3. 23.).

[그림 5-5] 정보보호 및 개인정보보호 관리체계 인증(ISMS-P) 체계



자료: <https://isms.kisa.or.kr/main/ispims/intro/> (검색일 2022. 5. 2.).

<표 5-1> 금융보안원 ISMS-P 인증서 발급 현황

구분	은행	금융투자	보험	금융유관 기관	중소서민	전자금융 (보조)업자	기타	계
ISMS	16	12	7	4	9	19	8	75
ISMS-P	6	6	1	-	6	2	1	22
계	22	18	8	4	15	21	9	97

자료: 금융보안원(2022. 3. 23.), p. 1.

45) <https://isms.kisa.or.kr/main/ispims/intro/>, <https://www.fsec.or.kr/fsec/subIndex/320.do> (검색일 2022. 5. 2.).

글로벌 인증 제도를 활용할 수도 있다. 예를 들어, 결제카드산업 데이터 보안 표준 PCI-DSS(Payment Card Industry Data Security Standard)는 비자, 마스터카드, 아메리칸 익스프레스, 디스커버, JCB 등 5개 글로벌 카드사가 공동 개발한 카드 결제 부문 국제 정보보안표준 인증이다. PCI Security Standards Council⁴⁶⁾에서 12개의 주요 영역에서 400여 개의 항목을 엄격히 심사한다. 최근 국내 기업들의 정보보호 관리체계가 고도화됨에 따라 PCI-DSS 인증을 획득하는 사례가 늘어나고 있다.

46) <https://www.pcisecuritystandards.org/> (검색일 2022. 5. 2.).

제2절 선결과제

이제까지 논의한 데이터 기반 보안 정책이 제대로 이행되기 위해서는 필요한 사항들이 있다. 사전적으로는 중요도 중심의 데이터 분류가 이루어져야 하고, 사후적으로는 사고가 발생했을 때 처벌 수준을 높이는 등 사후규제가 강화되어야 하며, 장기적으로는 전체 생태계 구성원의 인식의 전환이 필요하다.

1. 중요도 중심의 데이터 분류

□ 데이터 분류 시 고려사항

일반적인 데이터 분류는 종류에 따라 수평적으로 묶는 것일 수도 있지만, 보안 목적의 데이터 분류는 중요도 등의 기준에 따른 수직적인 계층화 또는 등급화를 의미한다(4차산업혁명위원회, 2021). 효과적인 데이터 분류를 설계하기 위해서는 기준을 어떻게 선정할 것인지와 이를 실제 상황에서 어떻게 적용할 것인지를 고려해야 한다.

분류 기준은 일반적으로 정보 보안의 3요소인 기밀성(Confidentiality), 무결성(Integrity), 가용성(Availability)을 고려하여 선정한다(4차산업혁명위원회, 2021). 앞서 소개한 바와 같이, 기밀성이란 인가된 사용자만 정보 자산에 접근할 수 있다는 것이고, 무결성은 적절한 권한을 가진 사용자가 인가된 방법으로만 정보를 변경할 수 있도록 하는 것이며, 가용성은 필요한 시점에 정보 자산에 대한 접근이 가능하도록 하는 것이다(양대일, 2021). 즉, 인가되지 않은 사용자가 정보에 접근하거나 변경하고 인가된 사용자가 필요한 시점에 접근이 불가능할 경우에 얼마나 큰 피해가 발생할 것인지를 산정한다.

분류 단계의 수는 많을수록 데이터에 대한 세부적인 관리가 가능해지지만 분류 및 관리 비용도 증가한다. 따라서 국내외의 데이터 분류체계에서는 주로 3~5단계로 구분하고 있다. 실제 상황에서는 누가 데이터를 분류할 것인지에 대한 고려도 필요하다. 데이터 생산자, 데이터 이용자, 데이터 관리자, 또는 기타 데이터 전문가가 데이터 분류를 할 수 있겠지만 특정 개인이 모든 데이터의 내용에 대해 전문성을 갖거나 기밀

성·무결성·가용성이 훼손되었을 때의 피해 정도를 판단하기 어렵다. 데이터가 다루는 분야의 범위가 넓을수록 이 문제는 더욱 어려워진다. 반대로 분류자의 수가 많아질 경우에는 평가의 일관성을 확보하기가 어렵다. 따라서 전문성과 일관성을 고려하여 분류자를 선정하는 것이 데이터 분류의 효과성과 구현가능성을 결정하는 요인이 될 것이다.

□ 해외의 데이터 분류체계

ISO/IEC 27001은 정보보호 인증을 위한 유일한 국제 표준 규격으로서 ISO 회원국에서 표준으로 채택되었고 현재 세계 다수 국가와 기업에서 활용되고 있다(4차산업혁명위원회, 2021). ISO/IEC 27001은 정보를 기밀이 아닌 공개된 정보, 소유권이 있는 정보, 고객 기밀정보, 기업 기밀정보 등 4가지로 분류한다.

<표 5-2> ISO/IEC 27001의 데이터 분류체계

분류 체계	설명	예시
기밀이 아닌 공개된 정보 (Unclassified Public)	- 정보가 공개되어도 회사에 영향이 없음 - 시스템 중단시간으로 인한 가용성의 손실은 허용 가능한 위험으로 고려되어짐	- 제품 브로셔 - 공개적으로 사용가능한 회사 웹사이트를 포함, 공공 영역에서 널리 사용되는 정보 - 판매를 위한 회사의 소프트웨어 샘플 다운로드 - 규제기관에서 요구하는 재무 관련 보고서 - 외부전송을 위한 뉴스레터
소유권이 있는 정보 (Proprietary)	- 정보가 외부 접근으로부터 보호되며 내부 승인에 의해 관리되어야 함 - 인증되지 않은 접근은 회사의 중요한 재정적 손실을 초래, 운영 효율성에 영향을 미치고, 고객의 신뢰에 큰 저하의 요인이 될 수 있음	- 기업 보안 절차에 대한 암호 및 정보 - 클라이언트 정보를 처리하는 데 사용되는 노하우 - 회사의 비즈니스 부분에 사용되는 표준 운영 절차 - 내부적으로 사용되거나 고객에게 판매되는 회사가 개발한 소프트웨어 코드
고객 기밀 정보 (Client Confidential Data)	- 기업이 생산처리를 위해 고객으로부터 받은 정보 - 정보 원본은 클라이언트의 서면 허가 없이는 어떤 방식으로든 변경 불가능	- 클라이언트 미디어 - 클라이언트로부터의 전자적 전송 - 클라이언트를 위해 회사의 생산 활동으로 생성된 제품 정보

기업 기밀 정보 (Company Confidential Data)	• 사람을 고용하기 위해 기업에서 수집한 정보 • 기업 금융의 모든 측면을 관리하는 정보 • 정보에 대한 접근은 기업에서 매우 제한적	• 급여 및 기타 개인 정보 • 내부 회계 정보와 재무 보고서 • 기밀 고객의 비즈니스 정보 및 기밀 계약 정보 • 고객/업체와의 비공식적인 계약
--	--	--

자료: 4차산업혁명위원회(2021), pp. 83~84.

영국 정부는 민감성, 즉 유출될 경우의 피해 수준을 기준으로 정보자산을 공공정보, 기밀정보, 최고 기밀정보 등 3가지 등급으로 분류한다.

〈표 5-3〉 영국 정부의 정보자산 등급 분류

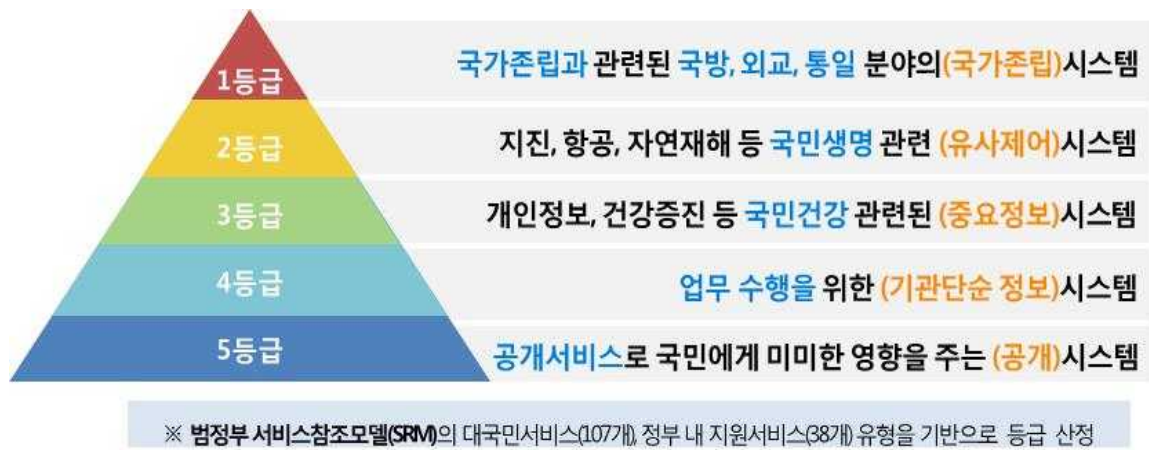
등급 분류	설명
공공정보 (Official)	공공부문의 비즈니스, 운영 및 서비스에 관한 데이터로 민감도와 가치가 다른 광범위한 데이터가 포함됨
기밀정보 (Secret)	민감한 데이터로서 유출될 경우 개인의 생명, 자유 또는 안전에 위협을 가하고 국가의 운영 효율성 또는 보안에 심각한 피해를 초래하는 데이터
최고기밀정보 (Top Secret)	가장 민감한 데이터 자산으로 정부 지원 자산이거나 유출될 경우 인명 손실과 직결, 영국을 직접적으로 위협, 국가 안보에 심각한 손상을 입히고 영국 경제에 장기적인 피해를 입힐 수 있는 데이터

자료: 4차산업혁명위원회(2021), p. 86.

□ 국내의 데이터 분류체계

행정안전부는 2019년 등급별 보안관리 제도를 도입하였는데, 이는 중앙부처와 지방자치단체에서 운영하고 있는 정보시스템들을 취급 정보의 중요도 등에 따라 등급을 분류하고 등급별로 보안관리를 차등 적용하는 것이다(행정안전부 보도자료, 2019. 6. 26.). 이에 따르면 시스템이 관리하는 정보 또는 서비스를 중요도(기밀성, 무결성) 및 가용성(사용자수, 연계기관수 등) 등에 따라 1등급(국가준립과 관련된 국방, 외교, 통일 분야의 시스템)부터 5등급(공개서비스로 국민에게 미미한 영향을 주는 시스템)까지 5개 등급으로 분류한다.

[그림 5-6] 행정안전부의 정보·서비스 등급 분류



자료: 행정안전부 보도자료(2019. 6. 26.), p. 4.

4차산업혁명위원회는 중요도에 따라 데이터를 분류해야 한다고 주장하고, 구체적으로는 특급비밀(특수등급), 비밀정보(1등급), 대외비(2등급), 공개정보(3등급) 등 4단계 분류체계를 제안한다(4차산업혁명위원회, 2021).

<표 5-4> 중요도에 따른 데이터 분류 체계

분류 체계	설명
특급비밀 (특수등급)	조직 내 극소수의 인원에게만 노출되어 있는 정보
비밀정보 (1등급)	① 고객의 개인정보 및 법령을 침해할 수 있는 정보 ② 정보의 접근은 매우 제한적이며, 정보 유출 시 조직에 매우 심각한 위험을 유발할 수 있는 정보
대외비 (2등급)	조직 활동 및 운영을 위한 정보로서 내부승인에 의해 관리되는 정보 (인증되지 않은 접근은 조직의 운영 효율성 및 고객의 신뢰에 큰 저하 요인이 될 수 있음)
공개정보 (3등급)	정보가 공개되어도 조직에 영향이 없는 정보 (모든 사람이 접근 가능)

자료: 4차산업혁명위원회(2021), p. 96.

2. 정책 실효성 제고를 위한 사후 규제 강화

국내외적으로 사전 규제에서 사후 규제로 전환하는 추세이므로 보안 분야에서도 이를 고려할 필요가 있다. 사전 규제(ex-ante regulation)는 문제를 일으킬 위험이 있

는 각종 요인을 찾아내고 그 각각의 대해 위험성을 배제하거나 최소화할 수 있는 방안을 사전에 강제 혹은 자율적으로 준수하게 하는 방식의 규제이고, 사후 규제(ex-post regulation)는 피규제자가 궁극적으로 달성해야 할 목표치를 설정하고 이를 준수하도록 요구하는 것이며 목표를 달성하지 못했을 경우에만 제재조치를 취하는 것이다.

사후 규제가 제대로 작동하기 위해서는 징벌적 손해배상제를 적절히 활용해야 한다. 현재 우리나라의 다수 법률에서, 구체적으로 개인정보와 관련된 개인정보 보호법, 신용정보의 이용 및 보호에 관한 법률, 정보통신망 이용촉진 및 정보보호 등에 관한 법률에서 이미 징벌적 손해배상을 도입하고 있다(김정환, 2019). 정보 보안 분야의 사후 규제가 효과적으로 작동하기 위해서는 향후 징벌적 손해배상제를 손해액에 대한 배상 비율을 높이고, 데이터의 중요도에 따라, 그리고 기업의 고의인가 과실인가에 따라 손해액에 대한 배상 비율을 다르게 하는 등을 보완할 필요가 있다.

<표 5-5> 징벌적 손해배상을 도입하고 있는 개인정보 관련 법률

법률명	징벌적 손해배상 요건	가해자의 주관적 요소	배상액
개인정보 보호법	개인정보의 분실/도난/유출 등	고의/ 중대한 과실	실손해의 3배까지
신용정보의 이용 및 보호에 관한 법률	개인정보의 분실/도난/유출 등	고의/ 중대한 과실	실손해의 3배까지
정보통신망 이용촉진 및 정보보호 등에 관한 법률	개인정보의 분실/도난/유출 등	고의/ 중대한 과실	실손해의 3배까지

자료: 김정환(2019), p. 6에서 일부 발췌.

금융 등의 산업에서 규제 샌드박스 제도의 시행됨에 따라 사후 관리체계 강화의 필요성도 제기되고 있다. 규제 샌드박스란 사업자가 신기술을 활용한 새로운 제품과 서비스를 일정 조건(기간·장소·규모 제한) 하에서 시장에 우선 출시해 시험·검증할 수 있도록 현행 규제의 전부나 일부를 적용하지 않는 것을 말하며 그 과정에서 수집된 데이터를 토대로 합리적으로 규제를 개선하는 제도이다.⁴⁷⁾

47) https://www.better.go.kr/sandbox/info/sandbox_intro.jsp (검색일 2022. 7. 15.)

<표 5-6> 규제 샌드박스의 구분

구분	내용
① 실증특례	■ 신기술을 활용한 사업을 하기 위한 허가 등의 근거 법령에 기준·요건 등이 없거나, 그대로 적용하는 것이 맞지 않거나 또는 다른 법령에 의해 허가 등의 신청이 불가능한 경우, 일정 조건 하에서 시장에서 실증 테스트를 허용함 ■ 이후 실증 결과에 따라 규제 개선의 필요성이 인정될 경우 정부는 관련 법령을 정비함
② 임시허가	■ 신기술로 인한 안전성에 문제가 없는 경우로서 허가 등의 근거가 되는 법령에 기준·요건 등이 없거나 그대로 적용하는 것이 맞지 않을 때 우선 시장 출시가 가능하도록 임시로 허가하고 관계 당국은 관련 규제를 개선함
③ 신속확인	■ 신기술을 활용한 사업을 하려는 기업 등이 규제 유무가 불분명하다고 판단할 경우 신속확인을 신청하면 규제부처가 30일 이내에 규제의 유무를 확인하도록 하여 시장의 불확실성을 최소화함 ■ 특히, 규제부처가 회신하지 않을 경우에는 규제가 없는 것으로 간주함

자료: <https://www.easylaw.go.kr/CSP/CnpClsMain.laf?csmSeq=1345&ccfNo=1&cciNo=1&cnpClsNo=1>
(검색일 2022. 7. 15.)

규제 샌드박스가 실효성을 갖추기 위해서는 합리적인 사후관리 체계를 갖추어야 한다는 주장이 제기된다.⁴⁸⁾ 규제 샌드박스를 통해 신기술 기반의 제품과 서비스를 활성화하는 취지는 좋지만, 사후관리 체계가 부족하다면 국민의 안전이 위협받는 등 다양한 부작용이 발생할 수 있기 때문이다. 규제 샌드박스 참여 기업에 대한 상시·주기적인 모니터링 시스템을 갖추고 업체가 스스로 제품과 서비스를 관리할 수 있도록 책임감을 부여하며, 만약 문제가 생긴다면 과태료·과징금, 더 나아가 징벌적 손해배상 책임까지 물을 수 있어야 한다.

다만, 사전 규제와 사후 규제 중 어떤 것이 맞는가에 대해서는 양자택일의 문제가 아니라는 점에 유의해야 한다. 사후 규제도 보안 사고 발생을 예방하는 효과가 있지만 사전 규제와는 역할은 다를 수 있다. 북한과 대치하고 있는 국가안보 상황, 국가적으로 중대한 사고가 발생했을 때 국민이 정부에게 책임을 묻거나 정부의 적극적인 역할을 기대하는 사회적 분위기를 고려하면 정책 당국 입장에서는 사후 규제가 사전 규제를 완전히 대체한다고 평가하기 어려울 수 있다. 따라서 사전 규제와 사후 규제는 상호 보완적으로 활용되어야 한다.

48) <https://zdnet.co.kr/view/?no=20190612145215> (검색일 2022. 7. 15.)

3. 전체 생태계 구성원의 인식의 전환

정부는 국정과제에서 디지털 혁신금융 생태계를 조성하기 위해 금융보안 규제를 개선하고 사이버보안 역량 강화를 통해 보안 산업을 전략적으로 육성한다는 목표를 제시한 바 있다. 평상시에는 보안에 대한 투자의 중요성을 높게 평가하지 않거나 보안을 전략적인 산업으로 인식하지 않았던 과거에 비해 바람직한 정책 방향이라고 평가할 수 있다.

[국정과제 34] 미래 금융을 위한 디지털 금융혁신

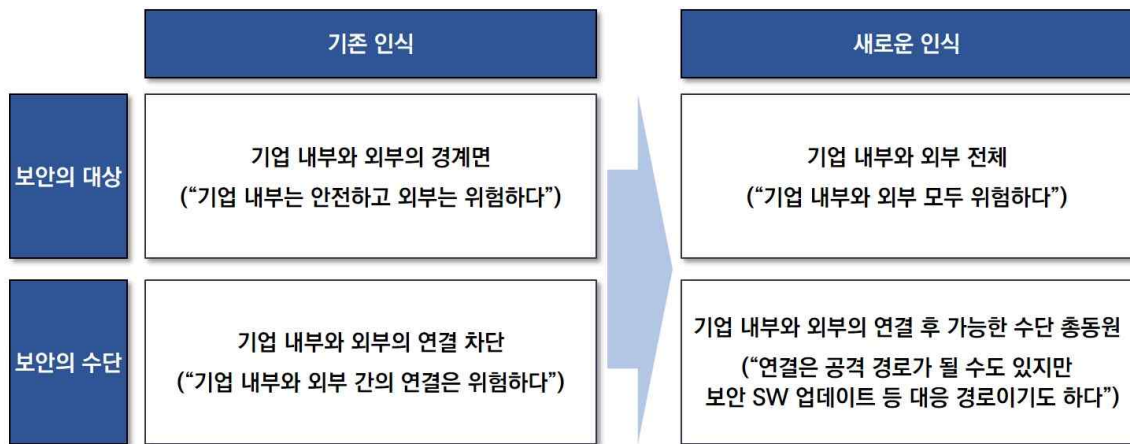
- (디지털 혁신금융 생태계 조성) 디지털 환경 변화에 맞춰 금융분야 데이터 수집·활용 인프라 및 금융보안 규제를 개선

[국정과제 78] 세계 최고의 네트워크 구축 및 디지털 혁신 가속화

- (사이버보안 역량 강화) 보안클러스터 모델의 지역거점 확산으로 기업 성장을 지원하고, 10만 사이버보안 인재 양성(∼'26)

그러나 이같은 정책 방향이 실현되기 위해서는 전체 생태계 구성원의 인식의 전환이 필요하다. 초연결 및 디지털 전환의 시대에 맞게 보안 규제도 변해야 한다는 것이다. 망분리는 보안의 영역을 기업 내부와 외부로 나누고 두 영역 간의 연결을 차단하는 방식이다. 그리고 이는 내부는 안전하고 외부는 위험하다는 가정과 내부와 외부 간의 연결은 위험하다는 가정에 근거하고 있다. 그러나 현실에서 기업 내외부를 막론하고 보안 사고가 발생하고 있고 원격근무 확산으로 기업의 내외부 구분이 모호해지는 상황에서는 기업 내부를 안전하다고 가정하는 것은 적절하지 않다. 또한 데이터 네트워크를 통한 연결은 외부 위협이 침입할 수 있는 경로이기도 하지만 보안 수단이 업데이트 되는 경로이기도 하므로 연결을 차단하는 것만이 해결책이 될 수는 없다. 따라서 보안의 범위를 기업 내부와 외부의 경계면에서 기업 전체로, 보안의 방식을 연결을 차단하는 것에서 기업 내부와 외부의 연결 후 가능한 수단을 총동원하는 것으로 확장하는 인식의 전환이 필요하다.

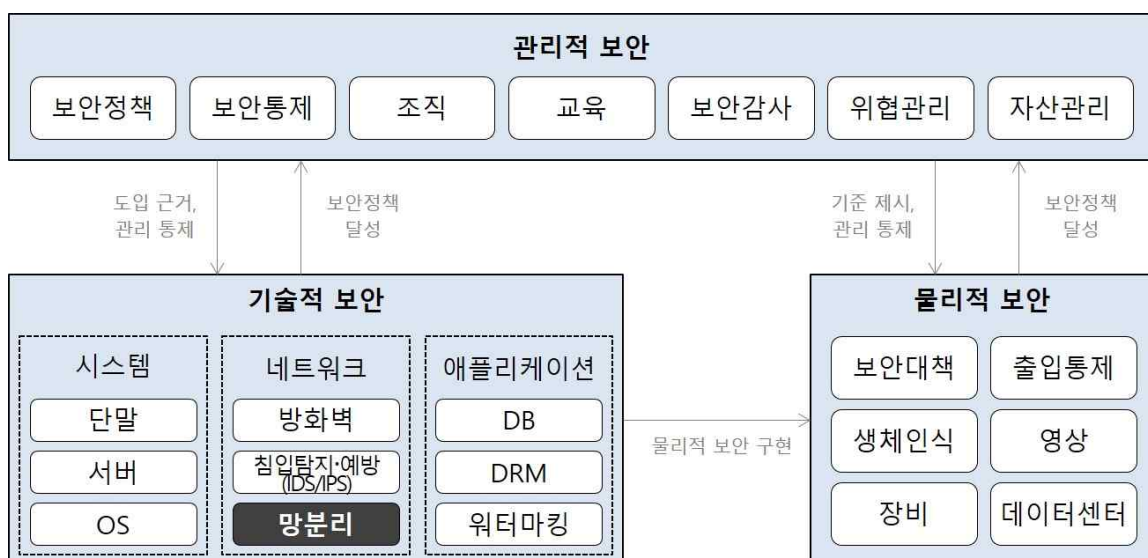
[그림 5-7] 미래지향적인 보안 정책을 위해 필요한 인식의 전환



자료: 저자 작성.

망분리는 기업이 활용할 수 있는 다양한 보안 수단 중 하나에 불과하다. 보안 체계는 관리적 보안, 기술적 보안, 물리적 보안으로 구성되며, 기술적 보안에는 시스템, 네트워크, 애플리케이션에 대한 보안 기술들이 포함된다. 그리고 네트워크 보안 중 하나의 수단이 망분리이다. 망분리에 매몰되지 않고 종합적인 관점에서 보안 정책을 수립해야 한다.

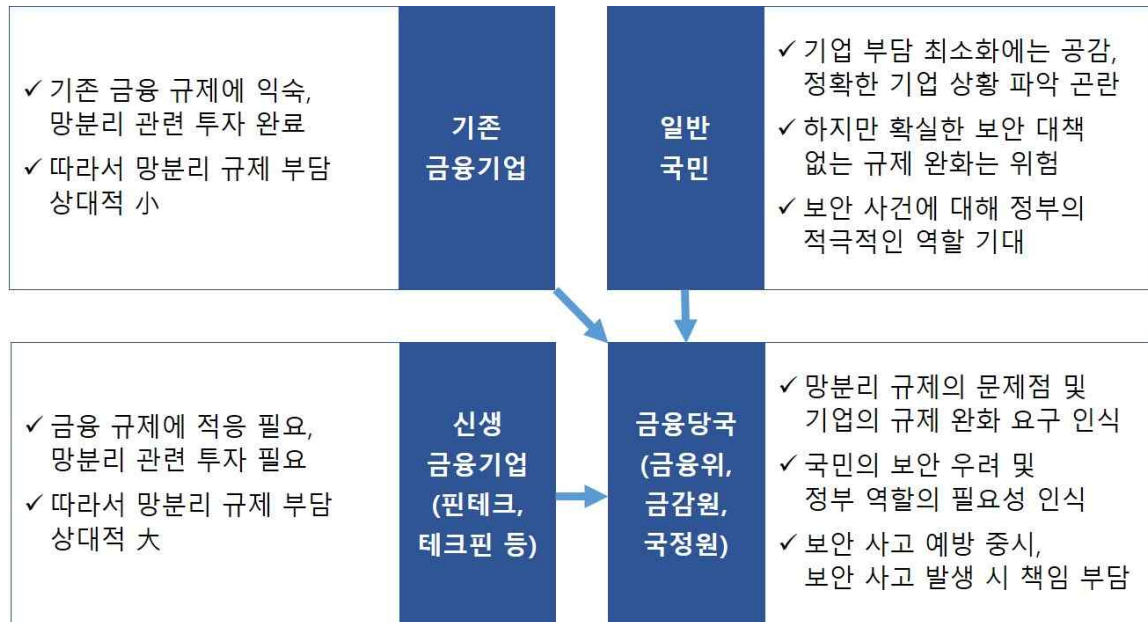
[그림 5-8] 전체 보안 체계에서 망분리의 위치



자료: 강혁(2022), <https://anyflow.net/426> (검색일 2022. 9. 1.) 등을 바탕으로 저자 작성.

보안 정책을 수립할 때 사회적 공감대를 형성하는 것도 중요하다. 업계나 전문가뿐만 아니라 일반 국민까지 포함하는 다양한 관점에 대한 고려가 필요하다.

[그림 5-9] 망분리 관련 이해관계자별 입장(예시)



자료: 저자 작성.

예를 들어, 망분리 규제에 대한 논의를 진행할 때 업계와 전문가의 관점에서는 투자비 증가, 생산성 저하, 인력 유출 등 망분리 규제의 문제점에만 주목하기 쉽다. 하지만 일반 국민 입장에서는 기업의 효율성 제고도 중요하고 동시에 보안성 확보도 필요하다. 따라서 망분리 규제 변화의 필요성에 대한 전 사회적인 공감대를 얻기 위해서는 망분리 규제를 완화하는 것이 보안성을 낮춘다는 일반적인 인식에서 벗어날 필요가 있다. 망분리 규제에 의존하는 기존 보안 정책을 전환하자는 본 연구의 관점은 단순히 규제 완화가 아니라 규제 강화와 완화를 포함하는 규제 합리화가 필요하다는 것이다. 이는 몇몇 산업의 효율성 저하 차원을 넘어 국가의 디지털 전환의 성패를 좌우하는 문제이기 때문이다.

참고문헌

- 4차산업혁명위원회(2019), 「4차 산업혁명 대정부 권고안」.
- 4차산업혁명위원회(2021), 『안전한 데이터 활용을 위한 데이터 위험관리 보고서』.
- 강혁(2022), 「정보보안 분야의 망분리 기술」, STEPI 내부세미나 자료.
- 과학기술정보통신부·개인정보위원회·한국인터넷진흥원(2021. 7), 『정보보호 및 개인정보보호 관리 체계(ISMS-P) 인증제도 안내서』.
- 과학기술정보통신부·한국인터넷진흥원(2020. 12), 『자율주행차 보안모델(요약본)』.
- 과학기술정보통신부·한국인터넷진흥원(2021. 12a), 『디지털 헬스케어 보안모델 PART I: 의료기기』.
- 과학기술정보통신부·한국인터넷진흥원(2021. 12b), 『디지털 헬스케어 보안모델 PART II: 서비스유형별』.
- 과학기술정보통신부·한국인터넷진흥원(2021. 12c), 『자율주행차 보안모델 PART I: 자율주행차 및 서비스』.
- 과학기술정보통신부·한국정보보호산업협회(2020), 『2020 국내 정보보호산업 실태조사』.
- 관계부처 합동(2022. 2. 10.), 「정보보호산업의 전략적 육성 방안」.
- 국가정보원 외(2021), 『2021 국가정보보호백서』.
- 국토교통부·한국교통안전공단(2020. 12), 『자동차 사이버보안 가이드라인』.
- 금융감독원 보도자료(2022. 4. 20.), 「'21년 보이스피싱 피해현황 분석」.
- 금융보안원(2018), 「최근 금융관련 사이버공격 유형 및 대응방안」, 전자금융과 금융보안 제14호.
- 금융보안원(2022. 3. 23.), 「금융보안원 ISMS-P 인증서 발급 현황」.
- 금융위원회(2020. 7), 「4차 산업혁명 시대의 디지털금융 종합혁신방안: 전자금융거래법령 등 개정방향」.
- 금융위원회 보도자료(2022. 4. 15.), 「금융분야 클라우드 및 망분리 규제 개선방안」.
- 금융위원회·금융감독원(2015. 6), 「금융IT부문 자율보안체계 확립 방안」.
- 금융정보화추진협의회(2021), 「2020년도 금융정보화 추진 현황」.
- 김경애(2018. 8. 13.), 「YH데이터베이스, 액티브X 대체하는 이상징후탐지로 보안 업그레이드」, 보안뉴스, <http://m.boannews.com/html/detail.html?idx=72118> (검색일 2022. 7. 30.).

- 김미희(2019. 7. 3.), 「제로 트러스트(Zero Trust) 시대의 도래, 모든 것을 의심하고 조사하라」, 이글루, <https://www.igloo.co.kr/> (검색일 2022. 10. 27.).
- 김보미·오일석(2021. 11), 「김정은 시대 북한의 사이버 위협과 주요국 대응」, 『INSS전략보고』, 국가안보전략연구원.
- 김상현(2019), 『행정에 관한 국민 인식조사』, 한국행정연구원.
- 김인석 외(2015), 『전자금융 보안론』, 아이티포럼.
- 김정환(2019), 『징벌적 손해배상의 적정한 운영방안에 관한 연구』(요약본), 사법정책연구원.
- 김준성(2021), 「AI War: Tesla vs. Non-Tesla」, 메리츠증권.
- 미래창조과학부·방송통신위원회 보도자료(2016. 8. 31.) "인터파크 개인정보 유출 침해사고 조사 결과".
- 박양신·강민지·김영민(2016), 『기업규모별 정책의 현황 및 추진방향』, 산업연구원.
- 보건복지부 데이터·AI팀(2020. 5), 「보건의료 데이터 중심병원 지원사업 공모계획(안)」.
- 삼성SDS 기술사회(2019), 『정보보안』, 제3판, 한울 아카데미.
- 스타트업얼라이언스(2020), 「핀테크 기업의 망분리」, 이슈 미니 써머리 vol 1.
- 아산나눔재단 등(2020), 『2020 스타트업코리아! 온라인 정책 제안 발표회』.
- 양대일(2021), 『정보 보안 개론』, 제4판, 한빛 아카데미.
- 이수환(2021), 「디지털 금융혁신 관련 입법·정책과제 - 금융부문 망분리 규제 개선을 중심으로」, 『NARS 현안분석』 제202호, 국회입법조사처.
- 이용석·이정훈(2019), 「KCMVP(한국형 암호모듈검증제도)의 소개」, 『국방논단』 제1760호, 한국국방연구원.
- 이후기(2022), 「제로 트러스트 보안기술 동향과 적용방안」, 『문화정보 이슈리포트』 제36호, 한국문화정보원.
- 정윤수(2016). 「접근제어를 통한 헬스케어 서비스 환자의 의료 2-way 정보 관리 기법」. 『Journal of Digital Convergence』, 14(7), pp. 185~191.
- 최병삼·양희태·이제영(2017), 「제4차 산업혁명의 도전과 국가전략의 주요 의제」, STEPI Insight 제 215호, 과학기술정책연구원.
- 한국보건산업진흥원(2018), 「헬스케어 분야에서의 블록체인 기술」, 『보건의료 R&D』.
- 한국산업보안연구학회(2022), 『산업보안학』, 제2판, 박영사.
- 한국인터넷기업협회(2022), 『2021 인터넷산업규제 백서』.

- 한국인터넷진흥원(2017), 『홈·가전 IoT 보안가이드』.
- 한국인터넷진흥원(2022), 『2021 글로벌 정보보호 산업시장 동향조사』.
- 한군희(2015), 「APT 공격과 대응 방안 연구」, 『중소기업융합학회 논문지』, 5(1), pp. 25~30.
- 한승우(2015), 「금융권 이상행위탐지기술(FDS) 이용 현황 및 전망」, 『전자금융과 금융보안』, 제1호, pp. 67~98.
- 행정안전부 보도자료(2019. 6. 26.), 「행안부, ‘정보시스템 등급별 보안관리’제도 확산 나선다」.
- SK셀터스(2021), 『2021 IT 정보보호구축 가이드』.
- CISA(2022. 1), “Layering Network Security Through Segmentation.”
- Deloitte(2016), “Asia-Pacific Defense Outlook 2016”.
- Ennis, H. et al.(2019), “National security and technology regulation: Government regulations for emerging technology”, Deloitte Insights.
- Gilman, Evan, and Doub Barth, 『제로 트러스트 네트워크: 안전한 네트워크를 만드는 보안 모델』, evilqcom 역(2022), 에이콘.
- Federal Financial Institutions Examination Council(2016), Information Security, FFIEC Information Technology Examination Handbook.
- ITU(2018), Measuring the Information Society Report 2018: Volume 2.
- ITU(2021), Global Cybersecurity Index 2020: Measuring commitment to cybersecurity.
- Nieves, M., K. Dempsey and V. Y. Pillitteri(2017), "An Introduction to Information Security", NIST.
- NIST(2020. 9), “Security and Privacy Controls for Information Systems and Organizations”, NIST Special Publication.
- NSA(2022. 6), Network Infrastructure Security Guidance.
- NHTSA (2022.9), Cybersecurity Best Practices for the Safety of Modern Vehicles.
- Rose, S. et al.(2020), “Zero Trust Architecture,” Special Publication 800-207, NIST.
- Stallings, W., 『네트워크 보안 에센셜』, 이재광·전태일 역(2017), 진샘미디어.
- White House(2021. 5. 12.), Executive Order on Improving the Nation’s Cybersecurity, <https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/> (검색일 2022. 8. 30.)

White House(2022. 1. 26.), Moving the U.S. Government Towards Zero Trust Cybersecurity Principles.

국가법령정보센터, <https://www.law.go.kr> (검색일 2022. 9. 1.).

국가사이버안보센터, <https://www.ncsc.go.kr:4018/> (검색일 2022. 7. 30.).

네이버 지식백과 IT 용어사전, <https://bit.ly/3r6kbiD> (검색일 2022. 9. 26.)

네이버 지식백과 IT 용어사전, <https://terms.naver.com> (검색일 2022. 7. 30.).

데일리팜(2022. 7. 23.), 「향정 위조처방전에 속은 약국 6곳, 행정처분 없을 듯」,
<http://www.dailypharm.com/Users/News/NewsView.html?ID=290303> (검색일 2022. 9. 22.).

동아사이언스(2020. 9. 18.), 「랜섬웨어 공격으로 독일 병원서 여성 환자 숨져」,
<https://www.dongascience.com/news.php?idx=39930> (검색일 2022. 9. 22.).

디지털데일리(2021. 3. 19.), 「IT 강국의 민낯... 물리보안에 여전히 크게 밀리는 정보보안, 왜?」,
<https://www.ddaily.co.kr/news/article/?no=210943> (검색일 2022. 7. 20.).

보안뉴스(2018. 5. 19.), 「[주말판] 보안의 궁극 망분리, 여태까지 나온 모든 공략법」
<https://www.boannews.com/media/view.asp?idx=69597> (검색일 2022. 7. 20.).

보안뉴스(2022. 7. 4.), 「[긴급] 국내 병원 환자 의료영상 관리 시스템 'PACS' 노린 공격 발견」,
<https://m.boannews.com/html/detail.html?idx=108000> (검색일 2022. 9. 22.).

서울경제(2020. 9. 21.), 「의료 빅데이터 시장 나는데 발목잡는 'EMR 인증제」,
<https://www.sedaily.com/NewsView/1Z7XXQJSXM> (검색일 2022. 9. 27.).

서울신문(2022. 7. 13.), 「서울대병원 개인정보 추가 유출...생년월일·검사결과 줄줄이」,
<https://www.seoul.co.kr/news/newsView.php?id=20220713500188>
(검색일 2022. 9. 22.).

소프트웨어정책연구소, <https://www.spri.kr/posts/view/18165?code=column>
(검색일 2022. 10. 20.).

위키백과, 데이터 유출 방지, <https://bit.ly/3Rfc5il> (검색일 2022. 9. 27.).

위키백과, 접근 제어 목록,
https://ko.wikipedia.org/wiki/%EC%A0%91%EA%B7%BC_%EC%A0%9C%EC%96%B4_%EB%AA%A9%EB%A1%9D (검색일 2022. 9. 27.).

전자의무기록시스템인증, <https://emrcert.mohw.go.kr> (검색일 2022. 9. 22.).

- 정보통신용어사전, <http://terms.tta.or.kr> (검색일 2022. 7. 30.).
- 찾기쉬운 생활법령 정보, <https://www.easylaw.go.kr> (검색일 2022. 9. 1.).
- 청년 의사(2022. 2. 25.), 「내 정보가 제약사에? ‘환자 개인정보 유출’에 머리 숙인 대학병원들」,
<https://www.docdocdoc.co.kr/news/articleView.html?idxno=2020167> (검색일 2022. 9. 22.).
- 청년 의사(2012. 4. 13.), "병의원도 DRM 도입으로 개인정보보호법 해결 가능",
<http://www.docdocdoc.co.kr/news/articleView.html?idxno=112749> (검색일 2022. 9. 28.)
- CCTV NEWS(2022. 8. 24.), 「프랑스 대형 병원, 랜섬웨어 공격 받아 전산 마비돼」,
<https://www.cctvnews.co.kr/news/articleView.html?idxno=233260>
(검색일 2022. 9. 23.).
- ITWorld(2022. 2. 3.), 「헬스케어 산업의 가장 큰 보안 위협은 ‘미패치 IoT 기기」」,
<https://www.itworld.co.kr/news/224024> (검색일 2022. 9. 28.).
- <https://anyflow.net/426> (검색일 2022. 9. 1.)
- <https://aspr.hhs.gov/cip/hph-cybersecurity-framework-implementation-guide/Pages/Introduction.aspx> (검색일 2022. 6. 30.).
- <https://brunch.co.kr/@ka3211/23> (검색일 2022. 10. 20.).
- <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-act> (검색일 2022. 6. 30.).
- [https://en.wikipedia.org/wiki/Air_gap_\(networking\)](https://en.wikipedia.org/wiki/Air_gap_(networking)), 검색일 2022. 6. 30.)
- <https://server-talk.tistory.com/289> (검색일 2022. 10. 20.).
- <https://www.akamai.com/ko/glossary/what-is-zero-day-attack> (검색일 2022. 10. 20.).
- https://www.better.go.kr/sandbox/info/sandbox_intro.jsp (검색일 2022. 7. 15.)
- <https://www.boannews.com/media/view.asp?idx=67036> (검색일 2022. 9. 1.)
- <http://www.cartvnews.com/news/articleView.html?idxno=204588> (검색일 2022. 9. 26.)
- <https://www.ciokorea.com/news/25647> (검색일 2022. 6. 20.)
- <https://www.crowdstrike.com/cybersecurity-101/zero-trust-security/> (검색일 2022. 8. 16.)
- <https://www.datanet.co.kr/news/articleView.html?idxno=144256> (검색일 2022. 11. 5.).

<https://www.easylaw.go.kr/CSP/CnpClsMain.laf?csmSeq=1345&ccfNo=1&cciNo=1&cnpClsNo=1> (검색일 2022. 7. 15.)

<https://www.energy.gov/eere/femp/operational-technology-cybersecurity-energy-systems> (검색일 2022. 10. 19.)

<http://www.engjournal.co.kr/news/articleView.html?idxno=1738> (검색일 2022. 11. 5.).

<https://www.hani.co.kr/arti/international/globaleconomy/678737.html>;
<https://zdnet.co.kr/view/?no=20150217095849> (검색일 2022. 7. 20.).

<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
(검색일 2022. 6. 30.).

<https://www.infusedinnovations.com/blog/secure-intelligent-workplace/pros-and-cons-of-the-zero-trust-model> (검색일 2022. 11. 5.).

<https://www.joongang.co.kr/article/23871180#home> (검색일 2022. 6. 30.).

<https://www.joynews24.com/view/975645> (검색일 2022.11.9.)

<https://www.koit.co.kr/news/articleView.html?idxno=81068> (검색일 2022. 9. 26.)

<https://www.le-lorrain.fr/blog/2015/09/23/la-ligne-magnot/> (검색일 2022. 11. 5.).

<https://www.lgcns.com/blog/cns-tech/security/22605/> (검색일 2022. 6. 30.).

<https://www.microfocus.com/ko-kr/what-is/application-security> (검색일 2022. 10. 20.).

<https://www.mk.co.kr/news/world/view/2022/08/726193/> (검색일 2022. 9. 26.).

<https://www.pcisecuritystandards.org/> (검색일 2022. 5. 2.).

<https://www.sap.com/korea/insights/what-is-cybersecurity.html> (검색일 2022. 10. 20.).

<https://www.youtube.com/watch?v=wPOU1goqfEA> (검색일 2022. 9. 26.)

<https://zdnet.co.kr/view/?no=20190612145215> (검색일 2022. 7. 15.)

<https://zdnet.co.kr/view/?no=20210122194956> (검색일 2022. 6. 30.)

부록 1: 기타 분야의 망분리 규제 현황⁴⁹⁾

망분리 규제는 공공 부문, 개인정보를 다루는 정보통신서비스제공자에게도 적용된다. 이하에서는 각각에 대해 망분리 규제의 내용, 주요 사례 등을 살펴본다.

1. 공공 부문

공공부문의 망분리는 「국가 정보보안 기본지침(2021. 11. 1.)」에 근거를 두고 시행되고 있다.

가. 「국가 정보보안 기본지침」의 법적 성격

「국가정보원법」에 의하면 국가정보원(이하 국정원)은 대통령 소속의 대통령의 지시와 감독을 받는 기관이다. 국정원의 직무로 “국가기관등을 대상으로 하는 사이버공격 및 위협에 대한 예방 및 대응”을 규정하고 있으며(제4조 제1항 4호), 대상이 되는 국가기관등은 다음과 같다.

- 중앙행정기관(대통령 소속기관과 국무총리 소속기관을 포함한다) 및 그 소속기관과 국가인권위원회, 고위공직자범죄수사처 및 「행정기관 소속 위원회의 설치·운영에 관한 법률」에 따른 위원회
- 지방자치단체와 그 소속기관
- 그 밖에 대통령령으로 정하는 공공기관

또한 「전자정부법」은 정보통신망 등의 보안대책 수립·시행과 관련하여 “행정기관의 장⁵⁰⁾은 정보통신망을 이용하여 전자문서를 보관·유통할 때 위조·변조·훼손 또는 유출을 방지하기 위하여 국가정보원장이 안전성을 확인한 보안조치를 하여야 하고, 국가정보원장은 그 이행 여부를 확인할 수 있다”고 규정하고 있다(전자정부법 제56조

49) 부록 1의 내용은 본 연구의 범위에서는 벗어나지만 관심있는 독자들을 위해 전문가 자문 결과를 정리하여 소개한다.

50) 여기서 “행정기관”이란 국회·법원·헌법재판소·중앙선거관리위원회의 행정사무를 처리하는 기관, 중앙행정기관(대통령 소속 기관과 국무총리 소속 기관을 포함한다.이하 같다) 및 그 소속 기관, 지방자치단체를 말한다(전자정부법 제2조제2호)

제3항) . 이에 근거하여 「전자정부법 시행령」은 "행정기관의 장은 정보통신망을 이용하여 전자문서를 보관·유통할 때에는 법 제56조제3항에 따라 국가정보원장이 안전성을 확인한 다음 각 호⁵¹⁾의 보안조치를 하여야 하며" 정보통신망을 이용한 전자문서의 보관·유통 관련 보안조치에 관하여 필요한 사항 및 보안조치의 이행여부 확인에 필요한 사항은 국가정보원장이 따로 지침으로 정할 수 있다(전자정부법 시행령 제69조 및 제70조).

「국가정보원법」과 「전자정부법」 등의 법률에서 정한 업무를 수행하기 위하여 국가정보원장이 정한 지침이 「국가 정보보안 기본지침」(이하 “보안지침”이라 한다)이다. 즉 「국가정보원법」에서 정한 본연의 업무수행 및 「전자정부법」등 각종 법령에서 정보보안을 위해 국가정보원의 업무로 정한 사항을 구체화한 것이 본 보안지침이다.⁵²⁾

나. 보안지침의 적용범위

보안 지침은 “각급기관”의 “정보보안업무”에 적용된다(제3조 본문). 다만, 행정부에 속하지 아니하는 국가기관의 경우 「국가정보원법」, 「전자정부법」, 「정보통신기반보호법」, 「공공기록물 관리에 관한 법률」 등 관계 법률에 따라 위임된 범위에 한한다(제3조 단서).

보안 지침에서 “각급기관”이라 함은 헌법과 법률에 의하여 설치된 국가기관·지방자치단체·교육청 및 그 소속기관, 공공기관, 국·공립학교(「초·중등교육법」 및 「고등교육법」에 따른 국·공립학교를 말한다. 이하 같다) 및 군(軍)기관을 말한다고 규정하고 있다(제2조제2호). 따라서 행정부에 속하는 대부분의 중앙행정기관과 소속기관은 당연히 정보보안에 대하여 본 보안 지침의 적용을 받는다.

또한 “정보보안”의 범위를 ‘각급기관의 기능 유지를 주 목적으로 정보통신망 및 정보시스템을 통해 수집, 가공, 저장, 검색, 송·수신되는 정보의 유출, 위·변조, 훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위’로 규정

51) 1. 국가정보원장이 개발하거나 안전성을 검증한 암호장치와 정보보호시스템의 도입·운영

2. 전자문서가 보관·유통되는 정보통신망에 대한 보안대책의 시행

52) 「국가정보원법」과 「전자정부법」 외에도 「사이버안보 업무규정」(대통령령), 「정보통신기반보호법」 등에서 국가정보원의 업무로 정한 공공분야 보호대책·보호계획 수립지침의 작성 등 정보보안에 대한 기본 업무를 규정하고 있다.

하고 있다(제2조제1호). 즉 정보통신망을 통한 안전한 정보 유통을 위해 필요한 일체의 관리적·물리적·기술적 조치가 모두 본 지침의 적용을 받는다고 볼 수 있다.

다. 망분리 도입 배경과 주요 내용

1) 도입배경

인터넷의 발달 과정에서 해킹 공격에 대한 대처로 정부의 행정망을 중심으로 내부망 보호를 위해 망분리 정책이 진행되었다. 2006년 국가사이버안전전략회의에서 국가기관 업무 전산망을 인터넷으로부터 분리하라는 방침이 최초로 보고되었고, 2007년 국무총리실, 통일부에서 망분리 시범사업을 추진하였으며, 2008년 정부부처 중심 1차 망분리 사업을, 2010년 2차 망분리 사업을 시행하였다(스타트업얼라이언스, 2020).

2) 주요 내용

□ 내부망과 기관 인터넷망의 분리·운영

행정부에 속하는 대부분의 중앙행정기관과 소속기관, 공공기관등은 망분리를 이행하도록 규정하고 있다. 즉 각급기관의 장은 내부망과 기관 인터넷망을 분리·운영하여야 한다(보안지침 제40조 제1항). 여기서 “내부망”이라 함은 각급기관의 장이 기관의 업무 수행을 위하여 인터넷과 별도로 분리하여 구축한 업무 전용(專用) 정보통신망⁵³⁾을 말한다(보안지침 제2조제9호). 또한 “기관 인터넷망”이라 함은 각급기관의 장이 소속 공무원등의 업무 활용 또는 공개서버 운용을 주(主) 목적으로 인터넷과 연동하여 구축한 정보통신망을 말한다(보안지침 제2조제10호).⁵⁴⁾

53) 보안지침 제2조 제8호 : “정보통신망”이라 함은 「사이버안보 업무규정」 제2조제1호에 따른 정보통신망을 말한다.
사이버안보 업무규정 제2조 제1호 : “정보통신망”이란 「전기통신사업법」 제2조제2호에 따른 전기통신설비를 이용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집·가공·저장·검색·송신 또는 수신하는 정보통신체제를 말한다.

54) 한편 “상용 인터넷망”이라 함은 각급기관의 장이 기관 인터넷망과 별개로 소속 공무원등이나 민원인 등의 보편적인 편의성을 위하여 인터넷에 연동하여 구축한 정보통신망을 말한다(보안지침 제2조제11호)

물리적 망분리나 논리적 망분리라는 표현이 없어서 선택할 수 있는 것으로 보이지만 현실적으로는 중앙행정기관은 대부분이 물리적 망분리를 시행하고 있고, 지자체는 예산 문제로 서울시 등 일부 지자체가 추진 중이고, 대부분은 아직 시행하지 못하고 있는 상황이다.

□ 분리·운영시 보안대책

각급기관의 장은 내부망과 기관 인터넷망을 분리·운영하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다(보안지침 제40조제2항).

1. 침입차단·탐지시스템 설치 등 비(非)인가자 침입 차단대책
2. 네트워크 접근관리시스템 설치 등 비(非)인가 장비의 내부망 접속 차단대책
3. 내부망 정보시스템의 인터넷 접속 차단대책
4. 내부망과 기관 인터넷망간 안전한 자료전송 대책
5. 기타 국가정보원장이 배포한 「국가·공공기관 업무전산망 분리 및 자료전송 보안가이드라인」에서 제시하는 보안대책

□ 분리된 내부망과 기관 인터넷망간 자료전송을 위한 점점

각급기관의 장은 분리된 내부망과 기관 인터넷망간 자료전송을 위한 점점이 불가피한 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다(보안지침 제40조제4항).

1. 침입차단·탐지시스템 설치·운영
2. 내부망과 기관 인터넷망간 점점 최소화
3. 내부망과 기관 인터넷망간 일방향 전송장비 등을 이용한 자료전송체계를 구축·운영하고 원본파일은 3개월 이상, 전송기록은 6개월 이상 유지
4. 정기적으로 전송실패 기록을 확인하고 악성코드 유입여부 등 점검
5. 내부망 자료를 기관 인터넷망으로 전송할 경우 부서 분임정보보안담당관 또는 결재권자의 사전 또는 사후 승인절차 마련

3) 망분리 예외

각급기관의 장은 제1항에도 불구하고 예산 부족 등 사유로 부득이한 경우 국가정보 원장과 협의하여 내부망과 기관 인터넷망을 분리하지 아니할 수 있다. 이 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다(보안지침 제40조제5항).

1. 정보시스템 및 개별사용자 PC 영역 등에 대한 접근 통제대책
2. 인터넷 PC의 악성코드 감염 최소화를 위한 인터넷 사용 통제대책
3. 인터넷 PC의 악성코드 감염에 따른 내부망으로의 피해확산 차단대책
4. 사이버공격 탐지·대응 등 안전한 업무환경을 위한 보호대책

라. 논란과 사례

먼저 망분리가 된 공공기관에서도 업무 시 상당한 불편이 뒤따른다. 업무를 하다 보면 인터넷 검색을 통해 자료를 찾게 되는 경우가 많은데, 이 경우 인터넷 망에서 자료를 찾고 내부 결재를 받아 ‘데이터 이동 시스템’을 통해 업무망으로 자료를 송부해야 하므로 매우 불편하다. 업무망에서 작성한 자료를 외부로 자료를 보내는 것도 마찬가지로 매우 불편하다. 출장 중에 업무를 처리하는 것은 더욱 어렵다. 외부에서 업무망에 접근할 수 없다 보니 내부에 있는 다른 직원에게 연락해서 자료를 다운로드 받아서 카톡(국내 상용 메신저)으로 보내달라고 요구하는 일이 다반사다. 오히려 이렇게 외부 업체의 서비스(웹메일, 메신저 등)를 사용하는 것이 오히려 해킹 위협에 노출되고, 정보가 유출되는 경우 추적하기도 쉽지 않다.

망분리의 비용이 상당한 부담이라는 점을 방증하는 정황도 포착된다. 망분리 예외 조항에서도 ‘예산 부족 등 사유로 부득이한 경우’를 들고 있고 행정안전부가 ‘지자체 망분리 사업’을 2020년부터 국비 지원을 포함해 추진했다. 2021년도 지자체 망분리 지원 사업으로 300억 원의 예산 확보를 계획하였으나 국비 확보에 실패하면서 결국 지자체가 자체 예산을 확보해 추진해 달라는 공문을 배포했다.⁵⁵⁾

55) 정보통신신문(2022. 6. 6.), "행안부, 지자체 망분리 국비 지원 '결국 포기'".

2. 개인정보

개인정보 관련 망분리는 「개인정보 보호법 시행령」 및 개인정보보호위원회의 「개인정보의 기술적·관리적 보호조치 기준」⁵⁶⁾에 규정되어 있다.

가. 「개인정보의 기술적·관리적 보호조치 기준」의 법적 성격

개인정보 보호법 제29조는 개인정보처리자의 안전조치의무로서 "개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다"고 규정하고 있다. 이러한 법률에 근거하여 대통령령인 「개인정보 보호법 시행령」 제48조의2 제1항 제2호 다목에서는 정보통신서비스 제공자등이 이용자의 개인정보를 처리하는 경우 취해야 하는 안전성 확보 조치로서 불법적 접근 차단을 위해 "개인정보처리시스템에 접속하는 개인정보취급자의 컴퓨터 등에 대한 외부 인터넷망 차단"을 규정하고 있다. 그리고 시행령 제48조의2 제3항에서는 "제1항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다"고 규정하고 있다. 따라서 이 기준은 개인정보보호위원회 고시이며, 「개인정보 보호법」 제29조 및 같은 법 시행령 제48조의2제3항에 따라 정보통신서비스 제공자등이 이용자의 개인정보를 처리함에 있어서 개인정보의 분실·도난·유출·위조·변조 또는 훼손을 방지하고 개인정보의 안전성 확보를 위하여 필요한 기술적·관리적 보호조치의 최소한의 기준을 정하는 것을 목적으로 한다.

나. 망분리 관련 적용범위

이 보호조치 기준에 의하면 "망분리"라 함은 외부 인터넷망을 통한 불법적인 접근과 내부정보 유출을 차단하기 위해 업무망과 외부 인터넷망을 분리하는 망 차단조치를 의미한다(제2조제5호).

56) [시행 2021. 9. 15.] [개인정보보호위원회고시 제2021-3호, 2021. 9. 15., 일부개정]

이러한 망분리는 모든 개인정보처리자에게 적용되는 것이 아니라 민간영역의 개인정보처리자 중 일정 규모 이상의 정보통신서비스제공자에게 적용된다. 즉 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일평균 100만명 이상이거나 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억 원 이상인 정보통신서비스 제공자등에게 적용된다(제4조제6항).

다. 망분리 도입 배경과 주요 내용

1) 도입 배경

개인정보취급자의 업무용 컴퓨터 등이 정보통신망을 통하여 악성코드에 감염되는 등 불법적인 접근을 차단하고 침해사고를 방지하기 위하여 망분리 제도가 시행되었다.⁵⁷⁾

2020년 8월 이전까지의 민간기업이 적용받는 망분리는 정보통신망 이용촉진 및 정보보호 등에 관한 법률(이하 “정보통신망법”)에 근거하였으나 데이터3법(개인정보 보호법, 정보통신망법, 신용정보법)이 2020년 8월부터 시행되면서 정보통신망법 내의 망분리 관련 조항을 비롯 개인정보에 관한 조항 대부분이 개인정보 보호법으로 이관되었다.

2) 주요 내용

접근통제의 방법으로 일정한 규모의 정보통신서비스제공자로 하여금 망분리 의무를 부과하고 있는데, 물리적 망분리로 제한되지 않고, 논리적으로 망분리도 포함된다(제4조제6항).⁵⁸⁾

규모에 있어서 앞서 언급하였듯이 전년도 말 기준 직전 3개월간 그 개인정보가 저장·관리되고 있는 이용자 수가 일일평균 100만 명 이상이거나 정보통신서비스 부문 전년도(법인인 경우에는 전 사업연도를 말한다) 매출액이 100억 원 이상인 정보통신

57) 개인정보 보호위, 개인정보의 기술적·관리적 보호조치 기준 해설서(2020.12) 77면.

58) 자세한 내용은 “개인정보 보호위, 개인정보의 기술적·관리적 보호조치 기준 해설서(2020.12) 중 “정보통신서비스 제공자등을 위한 망분리 해설”(77-89면)에서 기술하고 있다.

서비스 제공자등에게 적용된다.

이러한 정보통신서비스제공자의 모든 단말에 적용되는 것이 아니라 '개인정보취급자의 단말'에 적용되는 규정이다. 즉 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있거나 개인정보처리시스템에 대한 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 적용된다. 여기서 "다운로드"라 함은 개인정보처리시스템에 직접 접속하여 개인정보취급자의 컴퓨터 등에 개인정보를 엑셀, 워드, 텍스트, 이미지 등의 파일형태로 저장하는 것을 말하며, "파기"라 함은 개인정보처리시스템에 저장된 개인정보 파일, 레코드, 테이블 또는 데이터베이스(DB)를 삭제하는 것을 말한다. 또한 "접근권한 설정"이라 함은 개인정보처리시스템에 접근하는 개인정보취급자에게 다운로드, 파기 등의 접근권한을 설정하는 것을 말한다.⁵⁹⁾ 따라서 개인정보처리시스템에서 단순히 개인정보를 열람, 조회 등만을 할 때는 망분리를 적용하지 않을 수 있다.

라. 논란과 사례

2016년 발생한 인터파크 개인정보 유출 사건은 망분리된 환경에서도 파일 공유 서버의 취약점을 악용해 회원들의 개인정보 2,600만여 건을 탈취한 사건이다(미래창조과학부·방송통신위원회 보도자료, 2016. 8. 31.). 공격자들은 지인을 사칭한 악성코드가 첨부된 이메일을 보내 내부망을 최초로 감염시키고, 내부의 여러 PC에 악성코드 확산과 함께 내부 정보를 수집했다. 그런 다음, 파일 공유 서버를 경유, 개인정보 취급자 PC에 접속해서 제어권을 획득, DB서버에 접속해 회원들의 개인정보를 탈취해 외부로 유출했다.⁶⁰⁾ 이에 대해 방통위는 기술적·관리적 보호조치 의무를 위반한 (주)인터파크에 대해 44억 8천만원의 과징금 및 2,500만원의 과태료와 재발방지 대책을 수립·시행토록 하는 시정명령을 부과했다. 제재 당시 붙임 자료인 (주)인터파크의 기술적·관리적 보호조치 위반사항(요약)에는 처분사유1(최대 접속시간 제한 등)의 법규 위반내용 중 하나로 '(망분리) 보안성이 떨어지는 가상화 방식을 적용하여 운영한 행위'가 적시되어 있다. 논리적 망분리 방식을 사용하는 것 자체가 개인정보보호법(제재

59) 개인정보 보호위, 개인정보의 기술적·관리적 보호조치 기준 해설서, 2020.12, 51-52면

60) 미래창조과학부·방송통신위원회 보도자료(2016. 8. 31.) "인터파크 개인정보 유출 침해사고 조사 결과".

당시 정보통신망법)의 망분리 규제를 위반한 것은 아니지만, 제재에는 논리적 망분리를 사용했기 때문에 적절한 보안을 하지 못했다고 보는 행정당국의 시각이 담겨 있는 것으로 보인다.

부록 2: 금융/헬스케어/홈네트워크/자동차 보안 전문가 서면 질의서

안녕하십니까? 과학기술정책연구원(STEPI)은 「데이터 기반 보안 정책의 설계와 이행전략 연구 – 망분리 규제를 중심으로(연구책임자: 최병삼 연구위원)」라는 연구 과제를 수행 중에 있습니다. 현재 산업별로 데이터 보안 현황과 전망을 살펴보고, 망분리 규제의 대안 수단은 무엇인지 연구하고 있습니다.

본 서면 질의서는 '금융/헬스케어/홈네트워크/자동차' 분야에서의 보안 정책에 대해 전문가분들의 의견을 여쭙고자 합니다. 과제 및 본 서면 질의의 취지에 대해 이해하실 수 있도록 과제 소개자료를 함께 보내드리오니 답변하시기 전에 읽어보 시기를 부탁드립니다.

[데이터 기반 보안 정책 연구] 전문가 자문용 과제 소개자료.pdf

다음 질문들에 대해 자유롭게 의견을 작성해주시고, 가급적 근거나 이유 그리고 관련 자료도 소개해주시면 연구팀에게 큰 도움이 될 것입니다. 분량은 자유롭게 선택하시되 각 질문당 1p 정도로 작성해주시면 좋겠습니다 (총 10장 내외).

질문 요약

보안 위협요소(데이터 가로채기, 위조 삽입 등)

보안 위협요소의 대응수단(망분리, SIEM 등) 및 대응 모델(제로 트러스트 등)

보안 위협요소에 망분리와 다른 보안수단들의 장단점 비교

국내외 금융/헬스케어/홈네트워크/자동차 산업의 망분리 규제 현황과 전망

망분리 규제가 반드시 필요한 부분 or 데이터

영역기반 보안모델(망분리)에서 검증기반 보안모델(제로 트러스트)로 전환 필요성/가능성

검증기반 보안모델(제로 트러스트)로 전환하기 위해 필요한 정책적, 제도적 문제

감사합니다.

Q1. 금융/헬스케어/홈네트워크/자동차 분야의 보안 측면에서 대표적인 위협 요소(가로채기, 변조, 흐름 차단, 위조 삽입 등)는 무엇인가?

Q2. 위의 위협 요소에 대응하기 위한 보안 수단(망분리, SIEM, 블록체인 등)과 보안 모델(제로 트러스트 등)은 어떤 것들이 있는가?

Q3. 위의 각 위협 요소에 대해 망분리와 다른 보안수단들은 효과적으로 대응할 수 있는가? (장단점 비교)

--

Q4. 금융/헬스케어/홈네트워크/자동차 산업에서의 국내·외 망분리 규제 현황과 전망은 어떠한가?

(국내 규제: 과제 소개자료 10~14, 30쪽 참고, 해외 규제: 25~29쪽 참고)

구분	현황과 전망
국내 규제	
해외 규제	

Q5. 금융/헬스케어/홈네트워크/자동차 산업에서 반드시 망분리 규제가 필요한 부분이나 데이터가 있는가? (예를 들어, 원전, 군사시설 등)

Q6. 금융/헬스케어/홈네트워크/자동차 산업에서 '영역 기반 보안 모델(망분리 등)'에서 '제로 트러스트(Zero Trust)*'모델로 전환하는 것이 필요한가, 그리고 가능한가?

* 제로 트러스트 모델: 시스템 내·외부의 구분 없이 적절한 인증절차 없이는 누구도 신뢰할 수 없고 시스템 접속 시 모든 것에 접속 권한을 부여하기 전에 신원 확인을 해야 한다는 보안 모델

Q7. 금융/헬스케어/홈네트워크/자동차 산업에서 '제로 트러스트(Zero Trust)'로 전환하기 위해 어떤 정책이 필요하고 어떤 제도적 문제가 해결되어야 하는가?

♣ 서면 자문에 응해주셔서 대단히 감사합니다. ♣